软件工程课程大作业

智慧企业知识财富库系统

课程大作业完整报告

文档版本 V1.0

课程名称	软件工程课程大作业
项目版本	V2.0
项目组织形式	单人独立项目组
编制人	项目负责人（本人）
编制日期	2026-10-31

目录

第 1 部分　项目开发计划 19
1 项目背景、目标与范围 19
1.1 项目背景 19
1.2 项目目标 19
1.3 成功标准 19
1.4 项目范围 20
1.5 约束与假设 21
2 组织与单人角色映射 21
2.1 组织形式 21
2.2 角色映射 21
2.3 工作量与投入安排 22
2.4 单人协作机制 22
3 工作分解结构（WBS） 23
3.1 WBS 编制原则 23
3.2 WBS 任务表 23
4 模块开发任务与分工 24
5 12 周开发进度计划 25
5.1 总体进度安排 25
5.2 每周执行节奏 26
5.3 进度控制规则 26
6 里程碑计划 27
7 交付物计划 27
8 配置管理计划 28
8.1 配置项 28
8.2 版本与命名规则 28
8.3 分支与提交策略 28
8.4 变更控制 28

8.5 备份与可复现性 29
9 质量保证计划 29
9.1 质量目标 29
9.2 质量活动 29
9.3 测试层次 30
9.4 完成定义（Definition of Done） 30
9.5 缺陷处理原则 30
10 沟通机制 30
10.1 沟通对象与方式 30
10.2 沟通规则 31
11 风险与应对计划 31
11.1 风险监控方式 32
12 验收标准与验收方法 32
12.1 功能验收标准 32
12.2 质量验收标准 33
12.3 验收方法 33
12.4 验收结论规则 33
13 计划收口 34
第 2 部分　软件需求规格说明书 35
1 引言 35
1.1 编写目的 35
1.2 项目背景与建设目标 35
1.3 产品范围 35
1.4 预期读者 36
1.5 术语与缩略语 36
1.6 参考资料 37
1.7 编号规则与优先级 37
2 总体描述 38
2.1 产品视图与系统上下文 38

2.2 用户角色与职责 38
2.3 运行环境 39
2.4 设计与实现约束 39
2.5 假设与依赖 40
2.6 能力边界 40
2.7 功能模块划分 41
3 功能需求 41
3.1 账户与权限 FR-AUTH 41
3.2 知识文档 FR-DOC 43
3.3 检索增强问答 FR-QA 46
3.4 知识关系图 FR-GRAPH 48
3.5 管理功能 FR-ADMIN 50
3.6 运维与系统支撑 FR-OPS 51
4 权限矩阵 52
4.1 权限判定原则 52
4.2 角色与操作权限矩阵 53
4.3 文档密级可见性矩阵 53
4.4 发布状态行为矩阵 54
4.5 权限执行链 54
5 主要用例及事件流 54
5.1 UC-01 登录、失败锁定与进入工作台 54
5.2 UC-02 创建、编辑和发布知识文档 55
5.3 UC-03 检索制度并获取带来源回答 55
5.4 UC-04 机密文档跨部门访问检查 56
5.5 UC-05 管理员治理与审计查询 56
5.6 UC-06 浏览与维护知识关系图 57
6 数据需求 57
6.1 数据原则 57
6.2 核心数据实体 58

6.3 数据关系 58
6.4 文档生命周期与数据联动 58
6.5 数据质量、保留与安全 59
7 非功能需求 59
7.1 性能需求 59
7.2 安全需求 60
7.3 可用性与可靠性需求 60
7.4 易用性需求 61
7.5 兼容性需求 61
7.6 可维护性需求 61
7.7 测试性需求 61
8 接口需求 62
8.1 用户界面需求 62
8.2 REST API 通用约定 63
8.3 API 接口清单 63
8.4 请求与响应示例约束 64
8.5 软件与数据接口 64
8.6 硬件与网络接口 64
9 异常处理 65
9.1 HTTP 状态与错误约定 65
9.2 主要业务异常 65
9.3 事务、审计与日志要求 65
9.4 容错与降级边界 66
10 需求追踪矩阵 66
10.1 业务目标基线 66
10.2 功能需求追踪表 66
10.3 非功能需求追踪 67
11 验收标准 68
11.1 验收前置条件 68

11.2 验收锚点 68
11.3 端到端验收场景 69
11.4 测试基线与质量门禁 69
11.5 阻断性验收条件 70
11.6 验收结论规则 70
附录 A 验收演示路径 70
附录 B 文档边界声明 71
验收签署 71
第 3 部分　软件设计规格说明书 72
1 引言 72
1.1 编写目的 72
1.2 设计范围 72
1.3 适用读者与阅读建议 72
1.4 参考文档 73
1.5 术语与缩略语 73
1.6 设计约束与假设 73
2 设计目标与原则 74
2.1 设计目标 74
2.2 设计原则 74
3 总体架构 75
3.1 运行拓扑 75
3.2 运行时组成 75
3.3 架构特征 76
3.4 UML 设计视图索引 76
3.5 一次请求的典型路径 76
4 前后端分层设计 77
4.1 分层总览 77
4.2 前端分层 77
4.3 后端分层 78

4.4 依赖规则 78
4.5 SPA 与兼容层共存策略 79
5 技术选型与理由 79
5.1 技术栈清单 79
5.2 关键技术选择说明 80
6 模块设计 81
6.1 认证、角色与权限模块 81
6.2 知识文档模块 83
6.3 RAG 问答模块 85
6.4 知识关系图模块 88
6.5 审计模块 89
6.6 管理模块 90
6.7 前端路由与状态设计 91
7 关键流程设计 93
7.1 登录流程 93
7.2 文档创建/编辑流程 93
7.3 RAG 问答流程 94
7.4 图谱同步与过滤流程 94
7.5 审计写入流程 95
8 数据库设计 95
8.1 数据库设计概述 95
8.2 通用约定 95
8.3 users 用户表 96
8.4 categories 分类表 96
8.5 documents 文档表 96
8.6 knowledge_chunks 知识片段表 97
8.7 graph_nodes 与 graph_edges 图谱表 97
8.8 favorites 收藏表 98
8.9 audit_logs 审计表 98

8.10 qa_history 问答历史表 98
8.11 索引与约束汇总 98
8.12 数据关系说明 99
8.13 数据生命周期 99
9 REST API 设计 99
9.1 通用约定 99
9.2 端点总表 100
9.3 认证接口示例 101
9.4 文档接口示例 102
9.5 RAG 接口示例 104
9.6 管理接口筛选 105
9.7 状态码与错误码 105
9.8 错误响应示例 106
10 安全设计 106
10.1 安全边界与威胁模型 106
10.2 会话安全 106
10.3 密码存储 107
10.4 授权与文档密级 107
10.5 检索与图谱的权限过滤 107
10.6 登录防爆破 108
10.7 防开放重定向 108
10.8 注入、XSS 与模板安全 108
10.9 CSRF 与跨域 109
10.10 会话、密钥与部署安全 109
10.11 审计与隐私 109
10.12 安全测试关注点 109
11 异常与降级设计 110
11.1 异常处理原则 110
11.2 异常场景表 110

11.3 大模型降级设计 111
11.4 SPA 与 API 分离状态下的异常 111
11.5 事务与一致性异常 111
12 性能设计 112
12.1 性能目标 112
12.2 后端性能机制 112
12.3 当前性能瓶颈 112
12.4 前端性能机制 112
12.5 性能测试建议 113
12.6 扩展方向（未实现） 113
13 部署设计 113
13.1 部署形态 113
13.2 目录与运行产物 113
13.3 开发环境启动 114
13.4 课程演示/单机运行 114
13.5 访问路径 115
13.6 配置项设计 115
13.7 数据库与文件部署 115
13.8 可选模型服务的部署要求 116
13.9 生产化差距 116
14 可维护性与测试支持 116
14.1 可维护性设计 116
14.2 代码目录与职责 117
14.3 测试策略 117
14.4 测试支持设计 117
14.5 日志与可观测性 118
14.6 已知实现边界与技术债 118
15 需求到设计追踪 118
15.1 需求簇追踪矩阵 118

15.2 用户需求补充映射 123
15.3 设计到测试的反向追踪 123
16 关键设计决策与取舍 124
16.1 设计决策表 124
16.2 为什么不做“看起来更先进”的方案 124
16.3 后续演进优先级建议 125
17 结论与实现边界 125
17.1 设计结论 125
17.2 当前实现能力清单 125
17.3 验收与维护建议 126
第 4 部分　项目测试计划 127
1. 引言 127
1.1 编写目的 127
1.2 项目背景 127
1.3 参考文档 127
1.4 术语与缩略语 127
2. 测试目标、范围与不测项 128
2.1 测试目标 128
2.2 测试范围 128
2.3 不测项与边界说明 129
3. 测试策略 129
3.1 总体策略 129
3.2 自动化策略 129
3.3 人工测试策略 130
3.4 测试轮次 130
4. 测试级别 130
4.1 单元测试关注点 131
4.2 集成测试关注点 131
4.3 系统与验收测试关注点 131

4.4 安全与兼容性测试关注点 131
5. 测试环境与测试数据 132
5.1 硬件与基础软件 132
5.2 部署与访问 132
5.3 测试数据设计 132
5.4 环境配置与隔离要求 132
5.5 环境检查清单 133
6. 进入准则、退出准则与暂停恢复 133
6.1 进入准则 133
6.2 暂停与恢复准则 133
6.3 退出准则 133
7. 测试组织与职责 134
8. 测试进度安排 134
9. 测试用例设计方法 135
10. 缺陷管理与严重级别 135
10.1 缺陷流程 135
10.2 严重级别 135
10.3 优先级 136
11. 测试风险与应对 136
12. 质量度量 137
13. 测试交付物 137
14. 配置管理、需求追踪与审批 138
14.1 配置管理 138
14.2 需求追踪 138
14.3 评审与审批 138
第 5 部分　测试用例说明书 139
1. 文档说明 139
1.1 编写目的 139
1.2 覆盖范围 139

1.3 用例总数 139
2. 测试环境、数据与通用前置条件 140
2.1 环境基线 140
2.2 演示账号 140
2.3 通用前置条件 140
2.4 测试数据建议 140
3. 用例编号、优先级与自动化关联约定 141
3.1 编号规则 141
3.2 优先级定义 141
3.3 类型定义 141
3.4 自动化关联说明 141
4. 详细测试用例 142
4.1 认证与会话 142
4.2 权限、密级与隔离 145
4.3 文档、收藏与检索 148
4.4 RAG 问答与知识片段 150
4.5 知识图谱 153
4.6 管理员与审计 155
4.7 非功能、API 与运维 157
4.8 Vue 3 前端交互 159
5. 测试执行汇总模板 161
5.1 执行轮次汇总 161
5.2 模块执行汇总 161
5.3 自动化执行记录 162
5.4 人工检查记录 162
5.5 执行结论模板 162
6. 缺陷记录模板 163
6.1 缺陷单字段 163
6.2 缺陷记录示例表 163

6.3 缺陷关闭标准 163
7. 需求追踪说明与追踪矩阵 163
7.1 追踪规则 163
7.2 追踪矩阵 164
8. 用例维护与验收说明 164
8.1 用例维护规则 164
8.2 课程验收判定 164
9. 附录：课程验收故事线 165
第 6 部分 项目总结 166
1 项目概况 166
1.1 项目基本信息 166
1.2 项目背景与目标 166
1.3 项目范围与实际边界 167
1.4 组织方式与角色承担 167
2 计划与实际完成对比 167
2.1 总体进度对比 167
2.2 模块完成情况 168
2.3 里程碑对比 169
2.4 偏差分析与处理 169
3 功能与技术成果 170
3.1 功能成果 170
3.2 技术成果 171
3.3 工程化成果 171
4 测试与质量数据 171
4.1 测试策略 171
4.2 测试结果数据 172
4.3 质量覆盖情况 172
4.4 主要缺陷与修复 173
4.5 质量结论 173

5 各阶段复盘 173
5.1 需求阶段复盘 173
5.2 设计阶段复盘 173
5.3 实现阶段复盘 174
5.4 测试阶段复盘 174
6 遇到的问题及解决方案 174
7 项目不足与后续改进 175
7.1 项目不足 175
7.2 后续改进路线 176
8 个人收获 176
8.1 工程能力 176
8.2 项目管理 176
8.3 质量与安全意识 176
8.4 文档与表达 177
8.5 角色切换与自我管理 177
9 最终交付清单 177
10 自评与结论 178
10.1 自评说明 178
10.2 结论 178
第 7 部分　个人项目小结与考核材料 179
0. 个人承担说明与交付总览 179
0.1 单人完成声明 179
0.2 角色与职责矩阵 179
0.3 五部分交付符合性检查 180
0.4 完成情况量化 181
1. 用例图及用例规格说明 182
1.1 用例图 182
1.2 图例与关键元素 183
1.3 用例清单与需求追踪矩阵 183

1.4 用例规格说明 184
1.5 用例与代码对应小结 189
2. 页面原型设计及说明 189
2.1 页面原型总体说明 189
2.2 页面原型逐页说明 191
2.3 页面原型与需求追踪 200
3. 用例实现顺序/时序图及说明 201
3.1 用例实现顺序总览 201
3.2 登录用例时序图 202
3.3 RAG 智能问答时序图 204
3.4 文档发布活动图 206
3.5 文档状态图 207
3.6 时序/活动与代码、测试对应 208
4. 系统/模块类图及说明 209
4.1 领域类图 209
4.2 图例与关键元素 209
4.3 类职责说明 209
4.4 主要关联与多重性 213
4.5 系统/模块类视图 213
4.6 类图与需求/代码对应 215
5. 数据库实体类图及 E-R 图及说明 216
5.1 数据库实体类图（ORM 视角） 216
5.2 E-R 图 217
5.3 表清单与用途 217
5.4 关系与基数说明 218
5.5 数据字典 218
5.6 数据库与代码/API 对应 220
5.7 数据一致性与查询模式 221
5.8 数据库设计需求追踪 221

6. 个人项目小结 222
6.1 项目完成情况自评 222
6.2 主要收获 222
6.3 不足与改进方向 222
6.4 后续计划 223
7. 考核材料与证据路径 223
7.1 个人分工与开发任务 223
7.2 文档任务 224
7.3 完成情况汇总 224
7.4 关键证据清单 225
7.5 提交前检查清单 225
8. 结语 226
第 8 部分 REST API 接口设计说明书 227
1. 概述 227
1.1 设计目标 227
1.2 基础地址与传输 227
1.3 同源、跨域与客户端约定 227
1.4 版本与兼容性 228
1.5 接口分组与端点总览 228
2. 认证方式 229
2.1 会话认证 229
2.2 登录请求与安全约束 229
2.3 认证相关响应 230
3. 统一响应与错误码 230
3.1 成功响应风格 230
3.2 错误结构 230
3.3 错误码表 231
3.4 HTTP 状态码约定 231
3.5 错误示例 231

4. 分页与筛选约定 232
4.1 文档分页 232
4.2 审计分页 232
4.3 非分页列表 233
5. 公共数据结构 233
5.1 UserPayload 233
5.2 DocumentPayload 233
5.3 QAItemPayload 234
5.4 AuditPayload 234
5.5 GraphPayload 234
5.6 PaginationPayload 235
6. 系统、认证与工作台接口 235
6.1 系统接口 235
6.2 认证接口 236
6.3 工作台接口 238
7. 文档接口 239
7.1 权限规则总表 239
7.2 GET /api/documents 239
7.3 GET /api/documents/favorites 241
7.4 GET /api/documents/{id} 241
7.5 POST /api/documents 241
7.6 PUT /api/documents/{id} 242
7.7 DELETE /api/documents/{id} 243
7.8 POST /api/documents/{id}/favorite 243
7.9 收藏接口汇总 243
8. 分类接口 244
8.1 GET /api/categories 244
8.2 POST /api/categories 244
9. 智能问答接口 245

9.1 问答数据流 245
9.2 GET /api/qa 245
9.3 POST /api/qa/ask 246
9.4 GET /api/qa/history/{id} 247
10. 知识图谱接口 248
10.1 图谱权限与裁剪规则 248
10.2 GET /api/graph 248
10.3 GET /api/graph/manage 248
10.4 POST /api/graph/nodes 249
10.5 POST /api/graph/edges 249
11. 管理接口 250
11.1 GET /api/admin/users 250
11.2 GET /api/admin/audits 251
12. 关于与健康接口表 252
12.1 GET /api/about 252
12.2 关于/健康接口速查表 253
12.3 健康检查语义 253
13. 权限矩阵 253
13.1 角色级权限 253
13.2 文档数据级权限 254
13.3 关键权限实现位置 254
14. 调用流程与示例 254
14.1 浏览器会话流程 254
14.2 cURL 示例 255
14.3 PowerShell 示例 255
15. 接口—需求—测试追踪 255
16. 实现边界与维护约定 256
16.1 当前边界 256
16.2 变更维护规则 256

第 1 部分　项目开发计划

1 项目背景、目标与范围

1.1 项目背景

企业在日常经营中会沉淀制度、流程、产品说明、项目经验和常见问题等知识，但这些内容往往分散在文件夹、聊天记录和个人笔记中。即使已经建立文档库，仍常见三个问题：第一，文档缺少统一分类、版本和状态管理，查找成本高；第二，机密文档与普通文档混放，检索和问答容易越过权限边界；第三，传统关键词搜索只能返回文档列表，用户仍需逐篇阅读并自行整理答案。

本项目以课程大作业为背景，设计并实现一个可本地运行、可重复演示的智慧企业知识财富库系统。系统以“可鉴权的知识文档库”为底座，叠加检索增强问答、知识图谱、收藏、审计、用户与分类管理、系统运维等功能，用于展示软件工程全过程中的需求分析、体系结构设计、模块实现、测试验证和交付管理能力。

需要明确的是，本项目没有真实企业用户，也没有在生产环境上线，不使用真实企业资料。系统中的账号、制度正文、部门、图谱节点和问答记录均为虚构演示数据。项目价值在于验证一套完整的技术与工程闭环，而不是证明某个真实组织已经采用该系统。

1.2 项目目标

编号	目标	可检查结果
G1	完成从立项、需求、设计、开发、测试到交付的完整过程	各阶段均有可追溯文档、版本记录和验收证据
G2	形成可运行的业务闭环	用户能够登录、浏览和检索文档、发起问答、查看图谱，并按照角色和密级访问数据
G3	建立清晰的前后端分层架构	Vue 3 + Vite 前端通过 REST API 调用 Flask 3 后端，业务逻辑不散落在页面中
G4	建立可重复的自动化质量基线	pytest 自动化测试共 136 条，编制本计划时的项目快照为全部通过；正式验收以冻结版本的实际执行结果为准
G5	形成完整的课程交付材料	包含 10 张 UML 图、前端页面截图、测试证据、运行说明和课程文档
G6	在单人条件下保持范围、进度和质量可控	WBS、周计划、里程碑、风险清单和验收清单均有明确责任人和检查点

1.3 成功标准

编号	成功标准	度量方式
SC-01	八个业务与管理模块全部可用	按模块验收表逐项演示，不出现阻断

编号	成功标准	度量方式
		性缺陷
SC-02	核心演示链路可完整执行	登录 → 文档检索 → 文档详情 → 检索增强问答 → 知识图谱 → 收藏/审计 → 管理功能
SC-03	权限规则在列表、详情、检索和问答中一致	管理员、同部门用户、异部门用户、作者等场景对照验证
SC-04	自动化测试全部通过	在冻结版本和独立测试数据库中执行 pytest，记录通过数、失败数、错误数与耗时
SC-05	文档、图、截图与代码版本一致	文档中的项目名、版本号、技术栈、模块名和截图均对应 V2.0
SC-06	交付包可复现	按说明安装依赖、初始化数据库、启动前后端并执行测试

1.4 项目范围

1.4.1 范围内

模块	本期范围	关键边界
认证与权限	登录、退出、会话、角色识别、菜单控制、文档密级与部门隔离	采用本地账号体系，不接入企业统一身份认证
知识文档	文档新建、编辑、删除、查看、分类、标签、状态、筛选、分页和检索	以文本型知识文档为主，不扩展为完整办公套件
检索增强问答	文本切分、中文分词、权限内检索、Top-K 片段、来源展示、问答历史	回答必须受当前用户可见范围约束，并明确展示依据
知识图谱	文档、部门、分类、关键词等实体关系同步与可视化	采用轻量关系模型和 ECharts 力导向图，不建设图数据库平台
收藏	文档收藏、取消收藏、个人收藏列表	仅服务当前登录用户
审计	登录、失败登录、文档访问、问答和关键写操作留痕；管理员查询	审计用于课程演示和问题追踪，不等同于合规级审计平台
用户与分类管理	用户查看与管理、分类维护等后台能力	账号数据为虚构演示数据
系统运维	工作台、关于页、健康检查、初始化数据、启动与测试脚本	以单机演示为主，不承诺生产高可用
前端与交互	Vue 3 + Vite 单页应用、路由、API 客户端、统一布局、错误提示和页面截图	覆盖桌面端主要页面，不承诺原生移动端适配
测试与文档	pytest 自动化测试、UML、需求/设计/测试/总结文档、运行说明	以课程验收和可复现性为目标

1.4.2 范围外

不在本期范围	原因
真实企业生产部署、正式运营和高可用集群	课程项目以本地可演示和工程过程验证为目标
对接真实企业 SSO、LDAP、AD 或多租户组织体系	会显著扩大认证与数据隔离范围
大模型训练、微调、向量数据库平台和模型运营	技术风险与资源成本超出课程周期
原生移动端 App、复杂审批流和在线协同编辑	不构成核心验收链路
生产级备份恢复、合规审计、等保测评	需要真实组织和运维环境，课程阶段无法真实完成
真实企业用户访谈和真实业务数据	本项目明确为课程虚构场景

1.5 约束与假设

1. 项目由一人完成，所有角色由本人兼任，进度和质量控制必须依赖时间盒、清单和自检。
2. 项目采用 Vue 3 + Vite、Flask 3 REST API、SQLAlchemy、SQLite、ECharts、jieba 和 pytest，优先保证本机可复现。
3. 外部大模型接口只作为可选增强；即使不配置外部模型，检索、来源展示和本地回答链路仍应可演示。
4. 演示数据必须为虚构内容，文档、截图和答辩材料不得声称系统已在真实企业生产使用。
5. 所有关键交付物以 2026-10-31 的冻结版本为准；编制计划时的 136 条测试结果视为项目快照，最终验收需重新执行。

2 组织与单人角色映射

2.1 组织形式

本项目采用“单人独立项目组”形式。本人既是项目组长，也是全部执行角色的承担者。项目组没有其他成员，不存在代码交接、跨人沟通或多人并行开发；但为了保证软件工程过程完整，仍按照课程要求设置需求、设计、开发、测试、配置管理和交付等角色，并由本人以不同工作视角完成对应职责。

这种组织形式的优势是决策链短、文档与代码一致性强、问题定位成本低；主要风险是时间冲突、个人盲区和自我评审不足。因此，计划通过固定自检清单、阶段性冻结、自动化测试和外部课程反馈降低风险。

2.2 角色映射

角色	承担人	主要职责	主要产物	决策权限
项目组长 / 项目经理	本人	范围、WBS、12 周进度、风险、里程碑和验收统筹	本计划、周检查记录、风险清单、验收记录	范围冻结、优先级和里程碑决策
需求分析	本人	背景梳理、用户需求、系统需求、用例和验收条件	需求说明、用例描述、需求追踪表	需求优先级和范围边界
系统架构与设计	本人	分层架构、数据模型、API、权限模型、RAG 和图谱设计	设计说明、接口清单、ER 图、类图、部署图	技术选型与架构基线
UI/UX 设计	本人	信息架构、页面布局、状态与错误反馈、截图整理	页面原型、交互说明、前端截图	交互一致性和可用性取舍
前端开发	本人	Vue 3 + Vite 页面、路由、状态、ECharts、API 调用	`frontend/` 前端工程	前端组件和交互实现
后端开发	本人	Flask 3 REST API、权限、文档、RAG、图谱、审计、运维	`app/` 后端代码与接口	服务拆分和接口实现
数据与模型	本人	SQLAlchemy 模型、SQLite 表结构、演示	模型、数据库初始化、虚构数据	数据字段与约束

角色	承担人	主要职责	主要产物	决策权限
		数据和索引		
测试	本人	测试设计、pytest 自动化、安全回归、手工验收	测试用例、测试报告、执行记录	缺陷等级和是否放行
配置与发布	本人	版本命名、基线、依赖、启动脚本和交付包	Git 记录、版本标签、启动说明、交付清单	冻结与发布
文档与交付	本人	课程文档、UML、截图、演示脚本和提交材料	文档包、截图集、演示说明	文档定稿与交付核对

2.3 工作量与投入安排

计划投入约 72 人日，按 12 周周期分解。人日用于描述相对工作量，不代表每天只做一个角色；实际执行时按任务优先级切换角色。

工作类别	计划占比	折合人日	主要工作
项目启动与进度管理	7%	5	计划、周检查、风险、里程碑和交付协调
需求分析	11%	8	竞品与场景梳理、用户需求、系统需求、用例和验收条件
系统与界面设计	13%	9	架构、数据、接口、权限、页面与 10 张 UML
前后端实现	56%	40	前端页面、后端 API、认证、文档、RAG、图谱、收藏、审计、管理、运维
测试与质量	7%	5	测试设计、自动化、安全与回归、缺陷复核
文档与交付	7%	5	文档统稿、截图、演示脚本、交付包和验收
合计	**100%**	**72**	覆盖完整软件生命周期

2.4 单人协作机制

场景	具体做法
角色切换	每周开始先以项目经理视角确认任务，再以开发和测试视角执行，周末以评审视角验收
自我评审	需求、设计、代码和文档分别使用独立检查清单，至少间隔一次任务切换后再复核
防止范围膨胀	所有新增想法先登记，只有不破坏 12 周计划和验收标准时才进入本期
防止“只开发不验证”	每个模块完成后立即补接口测试和手工路径，不把测试集中拖到最后一周
防止文档脱节	版本号、模块名、技术栈和截图以冻结代码为准，交付前进行文档与实现对照

3 工作分解结构（WBS）

3.1 WBS 编制原则

WBS 采用“阶段—任务—交付物—验收”的分解方式，编码规则为“一级阶段.二级任务”。最低层任务具备明确输出和检查方式，能够在一周内完成或至少形成可验证的中间结果。WBS 覆盖范围管理、需求、设计、实现、测试和交付，满足课程项目“100% 范围内工作均被分解”的要求。

3.2 WBS 任务表

WBS	任务	主要输出	前置	计划人日	责任人
1.1	制定项目计划与范围基线	项目开发计划、范围表、里程碑	无	2	本人
1.2	周跟踪、风险与变更记录	周检查记录、风险清单、变更台账	1.1	3	本人
2.1	背景、场景与用户需求分析	竞品/场景材料、用户需求、用例草图	1.1	4	本人
2.2	系统需求与验收条件	系统需求、接口需求、验收标准、追踪表	2.1	4	本人
3.1	总体架构、数据模型与 API 设计	分层架构、ER 图、类图、接口清单	2.2	3	本人
3.2	页面信息架构与交互设计	页面清单、导航、状态与错误反馈设计	2.2	2	本人
3.3	UML 建模与渲染	10 张 UML 图及渲染文件	3.1、3.2	4	本人
4.1	前后端工程骨架与配置	Vue/Vite 工程、Flask 应用工厂、依赖与脚本	3.1	3	本人
4.2	认证、会话与权限	登录退出、角色、密级/部门隔离、失败审计	4.1	6	本人
4.3	知识文档模块	文档 CRUD、分类标签、状态、筛选、分页、检索	4.1、4.2	6	本人
4.4	检索增强问答	切分、分词、检索、Top-K、来源、历史、降级	4.2、4.3	7	本人
4.5	知识图谱模块	节点边同步、图谱 API、ECharts 可视化、维护	4.2、4.3	5	本人
4.6	收藏与审计模块	收藏、取消收藏、收藏列表、审计查询	4.2、4.3	4	本人
4.7	用户与分类管理	用户管理、分类维护、角色与状态控制	4.2、4.3	4	本人
4.8	系统运维与前端集成	工作台、关于、健康检查、页面联调、构建与启动	4.2—4.7	5	本人
5.1	测试设计与测试	测试矩阵、夹	2.2、4.1	2	本人

WBS	任务	主要输出	前置	计划人日	责任人
	数据准备	具、虚构数据集、验收用例			
5.2	自动化测试执行与缺陷复核	pytest 测试集、执行输出、缺陷修复记录	4.2—4.8	1	本人
5.3	安全、回归和手工验收	权限矩阵、回归记录、手工验收记录	5.1、5.2	2	本人
6.1	文档统稿与一致性检查	计划、总结、需求、设计、测试等文档	5.3	3	本人
6.2	UML、截图与演示材料整理	10 张 UML、前端截图、演示脚本	3.3、4.8	1	本人
6.3	交付包与最终验收	版本标签、交付清单、验收记录	6.1、6.2	1	本人
合计				**72**	

说明：5.2 的“1 人日”指最终集中执行和复核工作量。各模块的单元/API 测试随 4.x 开发任务持续编写，不重复计入。

4 模块开发任务与分工

本项目全部模块均由本人承担。下表把课程中的模块开发任务完整分配给同一人，并通过“兼任说明”明确其在不同模块中的角色。这样既符合单人项目事实，也避免虚构不存在的团队成员。

模块	主要开发任务	责任人	兼任角色	协作/交接说明
认证与权限	登录、退出、会话、角色菜单、密级与部门隔离、失败审计、登录限制	本人	后端开发、安全设计、测试	无人员交接；先冻结权限规则，再同步实现列表、详情、检索和问答鉴权
知识文档	文档 CRUD、分类、标签、状态、版本、筛选、分页、全文检索、收藏入口	本人	后端开发、前端开发、数据设计、测试	同一人维护 API 契约和页面字段，减少前后端字段漂移
检索增强问答	文本切分、jieba 分词、权限过滤、相关度排序、Top-K、来源展示、历史记录、降级	本人	后端开发、算法设计、前端开发、测试	先设计可解释的检索流程，再实现接口、页面和边界测试
知识图谱	实体与边同步、图谱数据 API、ECharts 力导向图、手工维护、异常清理	本人	后端开发、数据建模、前端可视化、测试	同一人负责同步规则、接口结构和可视化字段
收藏	收藏、取消收藏、唯一性约束、收藏列表、权限校验	本人	后端开发、前端开发、测试	复用文档可见性判定，不单独建立第二套权限规则
审计	登录成功/失败、文档访问、问答、写操作留痕；管理员查询和展示	本人	后端开发、数据设计、安全测试	在关键服务入口统一记录，避免页面遗漏
用户与分类管理	用户列表、角色/状态维护、分类增删改、管理入口控制	本人	后端开发、前端开发、权限测试	管理操作与普通业务共用角色守卫，管理员范围单独测试
系统运维	工作台、关于页、健康检查、初始化、启动/停止/测试脚本、	本人	项目组长、后端开发、前端开发、发布	由项目组长视角定义可复现标准，再由开发角色执行

模块	主要开发任务	责任人	兼任角色	协作/交接说明
	依赖说明			
前端应用与集成	Vue 路由、布局、登录态、API 客户端、表单、错误反馈、图表、页面截图	本人	前端开发、UI/UX、测试	采用统一 API 客户端和路由守卫，页面验收纳入主链路
测试与文档	pytest 用例、权限矩阵、手工验收、UML、课程文档和交付说明	本人	测试、文档、交付	开发完成后立即测试，文档在冻结版本上统一校对

分工结论： 上述模块均 100% 分配给本人。本人既承担项目组长的统筹职责，也承担需求、设计、开发、测试、文档和交付等成员职责。项目不设置第二责任人，不以“后端组”“测试组”等虚构名称掩盖单人事实；风险控制依赖计划、清单、自动化和课程反馈。

5 12 周开发进度计划

5.1 总体进度安排

周次	日期	阶段	主要任务	阶段输出	周末检查点
W1	2026-08-10—08-16	立项与需求启动	明确课程要求、项目定位、系统边界；梳理知识管理场景；建立 WBS 和风险清单	计划初稿、场景清单、范围草案	范围是否覆盖八个模块且没有明显扩张
W2	2026-08-17—08-23	需求基线	完成用户需求和系统需求；确定角色、权限、文档生命周期、问答和验收条件	需求文档、用例清单、验收条件	每条核心需求是否有可验证条件
W3	2026-08-24—08-30	设计基线	三层架构、数据模型、API、权限模型、页面结构、UML 初稿	设计说明、ER/类图/时序图、接口清单	需求能否追踪到设计和接口
W4	2026-08-31—09-06	工程与认证	建立 Vue 3 + Vite 与 Flask 3 工程；配置、数据库、登录、会话、角色守卫	可启动骨架、登录链路、基础测试	前后端能否联通并完成登录
W5	2026-09-07—09-13	文档与权限	文档 CRUD、分类、标签、状态、筛选、分页、密级与部门隔离	文档模块、权限矩阵首版	管理员/同部门/异部门场景是否一致
W6	2026-09-14—09-20	RAG 核心	文本切分、jieba 分词、权限内检索、相关度、来源、历史和无命中处理	问答 API、问答页面、RAG 测试	答案是否只使用可见文档并展示来源
W7	2026-09-21—09-27	图谱与可视化	图谱节点边同步、图谱 API、ECharts 力导向图、管理员维护	图谱页面、同步逻辑、图谱测试	文档变化后图谱是否可重复同步
W8	2026-09-28—10-04	管理、收藏与审计	收藏、审计、用户管理、分类管理、工作台、健康检查	完整业务模块首版	关键操作是否留痕、管理入口是否受控

周次	日期	阶段	主要任务	阶段输出	周末检查点
W9	2026-10-05—10-11	集成与界面完善	前端路由与 API 统一、错误状态、空状态、响应式布局、页面截图初稿	可演示 V2 前端、截图初稿	核心页面能否通过主链路连续操作
W10	2026-10-12—10-18	测试强化	扩展 pytest、权限与安全回归、RAG 边界、接口契约、缺陷修复	自动化测试集、缺陷清单、测试报告初稿	是否达到“全部通过且无阻断缺陷”
W11	2026-10-19—10-25	文档与预验收	文档统稿、10 张 UML 校对、截图更新、启动说明、演示脚本、交付清单	文档评审稿、交付包候选版	文档、图片、代码版本是否一致
W12	2026-10-26—10-31	冻结与最终验收	代码冻结、全新环境复核、136 条测试复跑、演示彩排、最终提交	V2.0 交付包、最终验收记录	是否满足全部验收标准并完成提交

5.2 每周执行节奏

时间	行动	产出
周一	以项目组长视角确认本周目标和范围，更新风险与依赖	本周任务清单
周二至周四	以开发角色完成主任务，当日结束前补最小可验证结果	功能增量、接口或页面
周五	以测试角色补充用例并执行回归，记录缺陷	测试结果和修复清单
周六	以设计/文档角色同步更新说明、图和截图	文档增量、图表更新
周日	以评审角色对照验收条件，决定是否进入下一阶段	周检查记录、下周计划

5.3 进度控制规则

6. **周计划只承诺可验证输出。** 不以“完成开发”作为检查点，而以可启动页面、可调用 API、可执行测试或可审阅文档作为输出。

7. **关键路径优先。** 认证与权限、文档、RAG 属于关键路径；图谱、界面细节和文档美化不得挤占关键路径测试时间。

8. **延期先调范围，不先降质量。** 若任务延期，优先压缩非核心视觉优化，再考虑顺延；不得以减少权限测试或跳过回归换取进度。

9. **每周设置缓冲。** 周末预留半天处理缺陷和文档同步，避免问题堆积到 W12。

10. **版本冻结。** W12 只修复阻断验收的问题，不新增业务模块；任何变更需记录影响并重新回归。

6 里程碑计划

里程碑	计划日期	达成条件	验收证据
M0 项目启动	2026-08-10	项目名称、版本、范围、角色和 12 周计划确认	本计划初稿、范围表
M1 需求基线	2026-08-23	八个模块的角色、主流程和验收条件明确	需求文档、用例、需求追踪表
M2 设计基线	2026-08-30	架构、数据、接口、权限和 10 张 UML 初稿完成	设计说明、UML 源文件与预览图
M3 核心 MVP	2026-09-20	登录、权限、文档和 RAG 主链路可用	可运行系统、核心测试结果
M4 功能完整	2026-10-04	图谱、收藏、审计、用户/分类管理、运维入口完成	模块清单、主链路演示记录
M5 质量基线	2026-10-18	自动化测试全部通过，无阻断级缺陷，权限边界可复核	pytest 输出、缺陷清单、测试报告初稿
M6 文档与预验收	2026-10-25	文档、UML、截图、演示脚本和交付清单齐备	文档评审稿、截图集、交付候选包
M7 最终交付	2026-10-31	冻结版本通过复跑和演示验收，提交材料完整	最终测试记录、验收记录、交付清单

验收提示：136 条自动化测试全部通过是本计划编制时的项目快照。最终验收应在 2026-10-31 冻结版本上重新执行，以实际通过数、失败数、错误数和日志为准；如果后续代码变化导致结果不同，以重跑结果为准并重新评估是否放行。

7 交付物计划

编号	交付物	形式/位置	验收要点
D-01	项目开发计划	`docs/course/01-项目开发计划.md`	含范围、角色、WBS、进度、风险、质量和验收标准
D-02	项目总结	`docs/course/06-项目总结.md`	含计划实际对比、成果、复盘、不足、交付和自评
D-03	需求与设计过程材料	`docs/` 中现有需求、设计、用例和调研文档	与 V2.0 模块、权限和技术栈一致
D-04	UML 图集	`docs/uml/` 源文件与渲染图	10 张图齐全，中文标签可读，和实现一致
D-05	前端页面截图	课程交付图片目录	覆盖登录、工作台、文档、问答、图谱、审计和管理页面
D-06	前端工程	`frontend/`	Vue 3 + Vite 可安装、可构建、可连接后端
D-07	后端工程	`app/`、`run.py` 等	Flask 3 REST API 可启动，数据库可初始化
D-08	自动化测试	`tests/`、运行脚本	pytest 可执行，测试使用隔离数据库，结果可记录
D-09	运行与提交说明	`README.md`、`00-提交说明.md`、启动脚本	新环境可按步骤安装、启动、停止和测试
D-10	演示与验收材料	演示脚本、虚构账号说明、验收记录	主链路可连续演示，演示数据均为虚构
D-11	版本与交付清单	Git 标签、文件列表、校验记录	冻结版本与提交材料一致

8 配置管理计划

8.1 配置项

配置项	管理方式	基线时机
源代码	Git 仓库管理，按功能小步提交	M3、M4、M5、M7
前端构建配置	package.json、Vite 配置和源码一并管理	M4、M7
后端依赖	依赖清单与虚拟环境说明	M3、M7
数据库脚本/初始化数据	随源代码管理；运行时数据库不入库	M3、M7
自动化测试	与对应功能同版本管理	M5、M7
UML 源文件与渲染图	源文件、渲染脚本和图片一并管理	M2、M6
课程文档	按文档编号和版本管理	M6、M7
截图与演示脚本	与冻结前端版本对应	M6、M7

8.2 版本与命名规则

11. 应用版本采用 V 主版本.次版本，本项目最终交付版本为 V2.0。
12. 文档版本采用 V0.x 草稿、V0.9 评审稿、V1.0 定稿；文档内容发生实质变化时递增版本。
13. 文档文件名保持“编号-名称.md”格式，例如 01-项目开发计划.md、06-项目总结.md。
14. Git 提交信息采用“类型: 简短说明”，例如 feat: 完成权限内问答检索、test: 补充文档权限矩阵、docs: 更新项目总结。
15. 里程碑使用标签记录，例如 m3-core-mvp、m5-quality-baseline、v2.0-course-submit。

8.3 分支与提交策略

单人项目仍保留轻量分支纪律：

分支/操作	用途
main	保存可运行、可回归的稳定版本
feature/*	单个模块或较大改动，完成测试后合并
docs/*	文档、UML、截图等非运行时代码改动
小步提交	每次提交只解决一个明确问题，便于定位和回退
合并前检查	至少确认应用可启动、相关测试通过、文档无版本冲突

8.4 变更控制

新增或调整需求时填写变更记录，至少说明变更内容、影响模块、对进度和测试的影响、是否进入本期。W12 冻结后只接受以下变更：

16. 阻断演示或验收的缺陷修复；
17. 与事实不符、可能造成误导的文档更正；
18. 安全检查发现的权限或数据泄露修复；
19. 不改变范围的兼容性修复。

任何冻结后修改都必须重新执行受影响测试，并在项目总结或验收记录中说明。

8.5 备份与可复现性

20. 代码、文档、UML 源文件和截图纳入版本管理；本地数据库、日志和缓存不作为交付成果。
21. 交付前确认项目内虚拟环境、依赖清单、启动脚本和测试命令可用。
22. 数据库可以通过初始化脚本重建，演示账号和业务正文使用虚构数据。
23. 对外提交时排除临时文件、密钥、个人环境配置和运行日志。

9 质量保证计划

9.1 质量目标

质量维度	目标
功能完整性	八个业务与管理模块均具备可演示入口和主要操作
权限正确性	列表、详情、检索、问答和收藏使用一致的可见性判定，不返回越权正文或来源
数据一致性	文档保存后切分索引和图谱同步可重复执行，不产生明显重复或陈旧数据
自动化质量	pytest 共 136 条，编制时全部通过；冻结版本验收时以实际输出为准
缺陷控制	验收前无阻断级缺陷；已知限制在文档中明确说明
可用性	核心页面有加载、空状态和错误反馈，主链路不需要手工改数据库
可复现性	新环境按说明可启动、可停止、可执行测试
文档一致性	技术栈、版本、模块、截图与冻结代码一致，不夸大生产使用情况

9.2 质量活动

活动	执行时点	检查内容	证据
需求检查	M1 前	每项核心需求是否有角色、输入、输出和验收条件	需求追踪表
设计评审	M2 前	架构分层、权限规则、数据关系、API 与 UML 是否一致	设计说明、UML
代码自检	每个功能提交前	命名、错误处理、配置外置、权限校验和重复代码	提交记录、检查清单
接口联调	每个模块完成后	请求参数、响应结构、错误码、登录态和跨域/构建配置	联调记录、自动化 API 测试
自动化回归	每周和里程碑前	核心路径、权限矩阵、RAG、登录安全、数据初始化	pytest 输出
安全复核	M5 前	未登录访问、越权访问、机密检索、登录失败审计、密码存储	安全检查表、测试用例
手工验收	M6/M7	主链路、页面状态、截图、启动停止和演示脚本	验收记录、截图
文档校验	M6/M7	版本、路径、命令、图号、表格、事实边界	文档检查表

9.3 测试层次

测试层次	范围	执行方式
单元/服务测试	文本切分、分词、打分、来源去重、权限辅助、图谱同步等	pytest
API 测试	登录、文档、问答、图谱、收藏、审计、用户与分类、健康检查	pytest 客户端
集成测试	前端 API 客户端与 Flask 接口、数据库初始化和主链路	手工联调 + 自动化
安全测试	角色、密级、部门、作者、未登录、登录限制、失败审计	权限矩阵和专项用例
回归测试	每次修复后重跑相关子集和关键主链路	pytest + 手工冒烟
界面验收	页面布局、空状态、错误提示、图表和截图	浏览器手工检查

9.4 完成定义（Definition of Done）

一个任务只有同时满足以下条件才算完成：

24. 代码或文档产物已写入规定位置；
25. 接口/页面/文档可通过明确步骤验证；
26. 相关测试已执行并记录结果；
27. 权限和数据边界已检查；
28. 文档中的路径、名称、版本与实现一致；
29. 不引入新的阻断级缺陷，已知限制已记录；
30. 变更已提交并可追溯。

9.5 缺陷处理原则

等级	判定	处理要求
阻断	无法启动、无法登录、主链路中断、数据泄露	立即修复，修复后执行完整相关回归
严重	核心模块不可用、权限结果错误、问答越过可见范围	验收前必须修复，并补充回归用例
一般	部分筛选/展示异常、错误提示不清晰、非主链路功能缺陷	评估影响，原则上验收前修复
轻微	文案、样式、非关键体验问题	可进入已知问题清单，不影响放行

10 沟通机制

10.1 沟通对象与方式

沟通对象	沟通内容	频率/时点	方式	输出
自己（项目组长 ↔ 执行角色）	本周目标、优先级、依赖、风险、完成情况	每周一、周五	任务清单和自检记录	周计划、周检查记录
自己（开发 ↔ 测	新增接口、边界条	每个功能完成时	测试用例、缺陷记录	测试结果和修复说明

沟通对象	沟通内容	频率/时点	方式	输出
试）	件、缺陷复现与修复			
自己（设计 ↔ 实现）	API、字段、权限、页面与 UML 一致性	设计变更和联调时	对照表和差异清单	设计更新、接口修订
课程教师/助教	课程要求、交付格式、答疑和反馈	按课程安排	课堂、课程平台或指定渠道	问题结论和调整记录
验收/演示对象	运行方式、演示主链路、范围边界	预验收和最终验收	演示脚本、运行说明	验收记录

10.2 沟通规则

31. 与课程要求相关的问题及时记录，不凭猜测改变交付格式。

32. 任何影响范围、技术栈或验收标准的反馈，都先进入变更记录，再决定是否修改。

33. 演示说明必须明确“课程项目、非生产系统、演示数据虚构”，不把本地演示描述为真实上线。

34. 单人项目也要保留书面记录，避免仅凭记忆安排任务。

35. 发现无法在计划内解决的问题时，优先缩小非核心范围并明确已知限制，而不是隐瞒或夸大完成度。

11 风险与应对计划

编号	风险	概率	影响	预警信号	应对措施	责任人
R-01	单人承担全部角色导致时间冲突	高	高	周任务连续延期、测试被压缩	关键路径优先；每周留缓冲；非核心界面优化可裁剪	本人
R-02	范围膨胀，模块和页面不断追加	高	高	频繁新增需求、WBS 外任务增多	依据范围表冻结；新增项进入候选清单；W12 只修复不扩展	本人
R-03	前后端接口字段或错误格式不一致	中	高	页面空数据、联调反复改字段	先定 API 契约；统一客户端；接口测试固定响应结构	本人
R-04	权限过滤不完整造成机密内容泄露	中	高	问答来源越权、列表与详情结果不一致	共享 `can_view` 规则；检索先过滤；权限矩阵回归	本人
R-05	RAG 中文分词或召回效果不稳定	中	中	关键词无结果、目标文档排序异常	补充领域词；保留可解释打分；用代表性问题和边界测试验证	本人
R-06	图谱与文档数据不同步	中	中	文档已修改但图谱仍旧、重复节点	保存后同步；同步逻辑幂等；提供重同步和管理员维护	本人
R-07	测试污染演示数据库	中	高	测试后数据量异常、审计记	测试使用独立临时数据库；	本人

编号	风险	概率	影响	预警信号	应对措施	责任人
				录增多	夹具隔离；测试前后检查	
R-08	外部大模型不可用或调用失败	中	中	超时、密钥缺失、返回异常	外部模型为可选增强；失败回退本地回答；界面明确模式	本人
R-09	依赖、构建或启动环境不一致	中	高	新环境无法安装、端口冲突、前后端无法联通	固定依赖清单；提供启动/停止脚本；全新环境复核	本人
R-10	UML、截图和文档与最终代码不一致	中	中	图中有旧模块、截图版本混用	M6 统一校对；以冻结版本重拍截图；检查版本号和技术栈	本人
R-11	文档后期集中编写导致遗漏	中	中	W11 文档缺口大、表格与代码不一致	每阶段同步文档；W11 只做统稿和校对	本人
R-12	自动化测试数量增加但维护成本上升	中	中	测试运行慢、重复夹具、失败定位困难	按层次组织测试；复用夹具；只保留有行为价值的用例	本人

11.1 风险监控方式

每周检查一次风险状态，记录“发生/预警/关闭”。触发高影响风险时，优先保证登录、文档、权限、问答和主链路可演示，再处理图谱细节、视觉优化和补充材料。风险关闭必须有证据，例如测试通过、缺陷修复记录或文档更新，而不是口头判断。

12 验收标准与验收方法

12.1 功能验收标准

编号	验收项	通过条件
A-01	启动与初始化	按说明可启动前后端，数据库可初始化，健康检查可返回正常状态
A-02	认证与角色	正确账号可登录，错误账号有明确提示，退出后会话失效，角色菜单符合权限
A-03	文档管理	可新建、编辑、查看、删除文档；分类、标签、状态、筛选、分页和检索可用
A-04	文档权限	管理员、同部门、异部门、作者、未登录场景结果符合权限规则，越权不返回正文
A-05	检索增强问答	可提出问题并获得带来源的回答；无命中时明确说明；问答历史可查看；来源不越权
A-06	知识图谱	页面可显示节点和边，支持拖拽/缩放；文档变更后图谱可同步；管理员可维护

编号	验收项	通过条件
A-07	收藏与审计	收藏可增删且不重复；关键动作包含失败登录记录；管理员可查询审计
A-08	用户与分类管理	管理员可查看和管理用户、维护分类；非管理员不能进入管理操作
A-09	系统运维	工作台、关于页、健康检查、启动/停止/测试脚本可用
A-10	前端页面	登录、工作台、文档、问答、图谱、审计、用户与分类等主要页面可用，截图与版本一致
A-11	自动化测试	冻结版本执行 pytest，136 条用例的最终实际结果全部通过；若有变化以实际日志为准
A-12	交付材料	文档、10 张 UML、截图、运行说明、测试证据和交付清单齐全

12.2 质量验收标准

36. 不存在阻断级缺陷；严重缺陷已修复并有回归证据。
37. 权限、问答来源和审计三类安全相关场景均有专项测试。
38. 测试使用独立数据库，执行后不污染演示数据。
39. 前端可构建，后端可启动，接口路径与文档一致。
40. 文档中的项目版本为 V2.0，技术栈为 Vue 3 + Vite、Flask 3 REST API、SQLAlchemy、SQLite、ECharts、jieba、pytest。
41. 演示数据均为虚构，文档不声称真实企业用户、真实生产上线或真实业务成效。
42. 已知限制明确列出，不用“全部完美”或无法验证的指标替代事实。

12.3 验收方法

步骤	操作	记录
1	冻结代码、文档、UML 和截图版本	版本号、冻结时间、文件清单
2	在独立环境按运行说明安装依赖并初始化	安装和启动日志
3	执行 pytest 全量测试	总数、通过、失败、错误、耗时、关键输出
4	按主链路手工演示	登录、文档、问答、图谱、收藏、审计、管理、健康检查
5	执行权限对照场景	管理员/同部门/异部门/作者/未登录结果
6	检查 10 张 UML 和页面截图	文件齐全、中文可读、版本一致
7	对照验收表逐项签字或打勾	验收通过、有条件通过或不通过

12.4 验收结论规则

- 全部功能项通过、自动化测试全部通过、无阻断/严重缺陷、交付材料齐全：验收通过。
- 非核心功能存在一般问题，但核心链路完整、权限无泄露、测试通过且问题已记录：可有条件通过，并列出后续修复项。

- 出现无法启动、核心链路中断、权限泄露、测试失败或关键交付物缺失：验收不通过，修复后重新执行验收。

13 计划收口

本计划以 2026-10-31 为交付控制点，以 12 周为整体窗口，以八个业务与管理模块、136 条自动化测试、10 张 UML 和前端页面截图为课程交付基线。项目最终是否通过，不取决于计划中写了多少功能，而取决于冻结版本能否按验收表复现、测试结果是否真实、文档是否与实现一致、权限边界是否可靠。

在后续验收中，如实际测试数量、通过结果、页面截图或文档路径发生变化，应更新相应记录并以实际交付物为准。本计划不把课程项目描述为真实企业生产系统，也不将虚构演示数据描述为真实业务数据。

第 2 部分　软件需求规格说明书

1 引言

1.1 编写目的

本文档定义《智慧企业知识财富库系统》V2.0 的软件需求基线，用于：

43. 明确系统的业务目标、功能边界、权限规则和可验收标准；
44. 为架构设计、接口设计、数据库设计、前端实现、后端实现和测试用例设计提供统一依据；
45. 向课程指导教师和验收组说明系统“已实现什么、如何验证、哪些不在本期范围”；
46. 建立业务目标、功能需求、主要用例、自动化测试和最终验收之间的可追踪关系。

本文档既是需求说明，也是验收依据。需求中使用的“必须”表示验收必须满足，“应”表示正常情况下必须满足、例外需有明确说明，“可”表示允许的增强能力。未列入本期范围的能力不得在验收时被解释为已交付。

1.2 项目背景与建设目标

企业内部制度、产品资料、项目经验和安全规范通常分散在邮件、即时通讯、个人网盘及不同部门目录中。员工查找一条规定需要反复询问，新员工上手成本较高；同时，机密材料若仅依赖链接转发或人工提醒，容易出现跨部门越权访问。课程项目需要在一个可运行、可演示、可测试的系统中完整体现需求分析、权限设计、检索问答、知识关联和工程管理过程。

V2.0 的建设目标如下：

目标编号	目标	成功判据
G-01	建立统一的知识文档库	登录用户可在权限范围内浏览、检索、查看和维护制度及业务资料
G-02	实现权限可控的知识访问	角色、部门、密级和发布状态共同约束列表、详情、检索、问答和图谱
G-03	提供可追溯的检索增强问答	回答基于用户有权访问的知识片段，并展示文档来源与相关度
G-04	建立可理解的知识关系	通过文档、部门、分类、关键词节点和关系边呈现知识结构
G-05	形成可治理、可审计的管理闭环	管理员可查看用户、维护分类与图谱、按条件分页查询审计日志
G-06	形成可构建、可启动、可测试的工程交付	前后端可构建运行，健康检查可用，自动化测试基线可重复执行

1.3 产品范围

1.3.1 本期范围

本期交付一个面向企业内部制度与业务资料的 B/S 知识库系统，包含：

范围类别	本期内容
账户与权限	登录、退出、会话、管理员/员工角色、部门归属、三级密级、登录防爆破、安全回跳
知识文档	文档列表、详情、新建、编辑、删除、分类、标签、版本、发布状态、收藏、关键词与正文检索
检索增强问答	权限内知识切分与检索、排序、Top-K 片段、本地摘要式回答、来源展示、问答历史
知识关系图	文档—部门—分类—关键词关系自动同步、ECharts 力导向图、按权限过滤、管理员补充节点和关系
管理功能	管理员用户列表、分类查看与新增、图谱节点/关系新增、审计日志服务端筛选与分页
运维支撑	健康检查、系统元信息、工作台、统一错误处理、启动脚本、pytest 自动化测试

1.3.2 非本期范围

以下能力不作为本期已实现功能或验收前置条件：

不在本期范围的能力	说明
用户自助注册、找回密码、账户增删改与角色变更	本期用户数据由初始化/演示数据提供；管理端用户列表为只读
与 AD/LDAP、OA、HR 等企业身份源对接	不接入真实组织系统，不承诺单点登录
细粒度到单文档、单用户的 ACL 授权	本期采用角色、部门、密级、作者和状态组合规则
附件上传、PDF/Word 自动解析、OCR	本期文档以结构化文本字段录入和展示为主
独立全文搜索引擎、向量数据库、生产级 RAG 平台	本期采用 SQLite + jieba + 片段评分的轻量检索增强方案
分类重命名、合并、删除	本期分类维护范围为分类查询和新增
图谱节点/关系的编辑、批量导入、删除	本期维护范围为节点新增和关系新增，并自动清理文档删除产生的关联
多租户、移动原生应用、在线协同编辑、工作流审批	不属于课程项目范围
高可用集群、多进程共享限流、生产级容灾与容量承诺	本期按单机/局域网课程演示环境设计

1.4 预期读者

读者	关注重点
项目作者	作为设计、编码、测试和交付的一致性依据
课程指导教师	检查需求完整性、软件工程规范性、可实现性与验收证据
验收组	按功能、权限、数据、接口和非功能标准执行验收
测试人员	依据需求编号设计功能、安全、接口和回归测试用例
后续维护者	理解能力边界、权限规则、数据关系与已知限制

1.5 术语与缩略语

术语/缩写	定义
SRS	Software Requirements Specification，软件需求规格说明书
B/S	Browser/Server，浏览器/服务器架构
REST API	基于 HTTP 方法和资源路径的应用程序接口风格
ORM	Object-Relational Mapping，对象关系映射；本项目使用 SQLAlchemy
SPA	Single Page Application，单页应用；本项目前端为 Vue 3
RAG	Retrieval-Augmented Generation，检索增强生成；先检

术语/缩写	定义
	索知识，再形成回答
Chunk / 知识片段	文档正文切分后用于检索和来源展示的文本单元
Top-K	按相关度从高到低保留前 K 个结果，默认 K=5
密级 / 可见性	公开、内部、机密三级访问范围
发布状态	草稿、已发布、已归档三种文档生命周期状态
管理员	角色值为 admin，具备全量业务查看和后台治理权限的用户
员工	角色值为 employee，按部门与密级访问业务的普通用户
作者	创建某篇文档的用户；作者对本人文档具有额外访问和维护权
审计日志	记录登录、退出、登录失败、文档查看/写入和问答等动作的服务端记录
知识关系图	由文档、部门、分类、关键词/概念节点及其关系边组成的可视化图
验收基线	验收时重新执行构建、自动化测试和人工演示所依据的版本与结果

1.6 参考资料

47. 《智慧企业知识财富库系统用户需求说明书》及原系统需求材料；

48. 本项目竞品调研报告、软件设计说明书、测试报告、UML 图和用例描述；

49. Vue 3、Vite、Flask 3、SQLAlchemy、SQLite、ECharts、jieba、pytest 官方技术文档；

50. ISO/IEC/IEEE 29148 软件与系统需求工程相关思想，以及 IEEE 830 需求规格说明书结构实践；

51. 本项目 README、配置说明、接口实现和自动化测试代码。

1.7 编号规则与优先级

1.7.1 需求编号

前缀	含义	示例
G	建设目标	G-01
FR	功能需求	FR-AUTH-001
NFR	非功能需求	NFR-SEC-001
UC	主要用例	UC-01
AC	验收标准	AC-01
AT	验收/测试锚点	AT-AUTH-01

功能模块缩写如下：AUTH 表示账户与权限，DOC 表示知识文档，QA 表示检索增强问答，GRAPH 表示知识关系图，ADMIN 表示管理功能，OPS 表示运维与系统支撑。

1.7.2 优先级

优先级	定义	验收要求
P0	核心阻断需求	未满足则系统不得通过验收；涉及越权、数据泄漏或主流程不可用
P1	重要需求	应在本期交付；若存在缺陷，须评估是否阻断演示

优先级	定义	验收要求
P2	一般增强需求	可在不影响核心验收的前提下记录为改进项

2 总体描述

2.1 产品视图与系统上下文

系统采用前后端分离的 B/S 结构。Vue 3 + Vite 构建的单页应用负责页面路由、表单交互、状态呈现和 ECharts 可视化；Flask 3 提供 REST API，负责会话认证、权限判定、业务规则、数据持久化和审计；SQLAlchemy 负责对象关系映射，默认以 SQLite 文件保存数据；jieba 负责中文分词、关键词提取和检索信号构造；pytest 负责自动化回归。

层次	主要技术	职责
表现层	Vue 3、Vue Router、ECharts、Vite	登录、工作台、文档、问答、图谱、管理页面及交互反馈
接口层	Flask 3 REST API	HTTP 路由、JSON 请求响应、会话、认证、状态码和错误结构
业务层	Flask 服务/蓝图、权限与 RAG/图谱服务	可见性判定、文档检索、片段排序、问答、图谱同步、审计
数据层	SQLAlchemy、SQLite	用户、文档、分类、片段、图谱、收藏、问答历史和审计持久化
质量保障	pytest	权限矩阵、API、RAG、登录安全、系统主路径回归

系统上下文关系如下：

52. 用户通过桌面浏览器访问 Vue 前端；
53. 前端以同源会话 Cookie 调用 /api 下的 REST 接口；
54. 后端先完成身份认证，再按角色、部门、密级、作者和状态执行授权；
55. 授权通过后，后端从 SQLite 读取或写入业务数据，并生成审计记录；
56. 问答模块在授权后的文档片段集合中检索并生成带来源回答；
57. 图谱模块从文档元数据和关键词同步节点/关系，再按当前用户可见范围返回图数据；
58. 管理员通过受保护接口查看用户、维护分类和图谱、筛选分页查看审计日志；
59. 运维人员通过健康检查确认服务和数据库可用性。

2.2 用户角色与职责

角色	系统标识	关键属性	职责与能力
管理员	admin	角色为管理员，通常归属综合部	查看全部文档与图谱；维护文档、分类、图谱；查看用户列表和审计日志；执行全部普通员工功能
员工	employee	角色为员工，必须归属一个部门	查看权限范围内文档；执行搜索、问答、收藏；新建文

角色	系统标识	关键属性	职责与能力
			档；编辑/删除本人文档；查看本人问答历史
文档作者	非独立角色	由文档 author_id 标识	在员工权限基础上，可访问本人草稿/归档文档，可编辑/删除本人文档；对本人机密文档具有作者例外权
匿名访问者	未登录	无有效会话	仅可访问登录页、系统元信息、会话探测和健康检查；不得访问业务数据
运维/验收人员	非业务角色	具备运行环境访问条件	执行启动、健康检查、日志查看、构建、自动化测试和验收操作

角色说明：本期只实现管理员和员工两种角色；“文档作者”是文档级身份，不是第三种系统角色。前端菜单隐藏仅用于改善体验，不能替代服务端授权。

2.3 运行环境

类别	最低/目标环境	说明
客户端操作系统	Windows 10/11 x64	课程演示环境
浏览器	Chrome 或 Edge 近两年版本	需要支持 ES Modules、Fetch、Canvas/SVG 和现代 CSS
前端运行	Node.js 18+（构建时）	安装依赖并执行 Vite 构建；开发时使用 Vite 开发服务器
后端运行	Python 3.12 项目虚拟环境	Flask 3、SQLAlchemy、jieba、pytest 等依赖
数据库	SQLite	默认文件位于 instance/knowledge.db；测试使用隔离数据库
网络	本机或局域网 HTTP	默认后端 127.0.0.1:5000；Vite 开发端口 5173
部署入口	Flask 服务 /ui/	生产构建产物由 Flask 托管；API 前缀为 /api
外部服务	无强制外部依赖	核心检索增强问答可在本地完成；外部增强服务不是验收前置条件

2.4 设计与实现约束

60. **架构约束**：前端必须是 Vue 3 + Vite 单页应用；后端必须提供 Flask 3 REST API；业务数据通过 SQLAlchemy 持久化到 SQLite。

61. **接口约束**：前端业务调用统一位于 /api 前缀；JSON 使用 UTF-8；认证使用服务端会话 Cookie，不采用前端自造权限状态。

62. **权限约束**：所有业务接口必须执行服务端鉴权；列表、详情、检索、问答和图谱必须复用一致的可见性判定规则。

63. **数据约束**：用户名、分类名和收藏关系必须满足唯一性；删除文档必须同步清理知识片段、收藏和文档关联图谱节点/边。

64. **问答约束**：核心验收以本地分词检索与摘要式回答为准；不得在无命中时伪造答案，不得泄露无权限文档标题或正文。

65. **图谱约束**：普通用户只能获得基于其可见文档及其相邻节点/关系形成的图谱；管理员可查看完整图谱并执行受控维护。

66. **部署约束**：本期按单机/单进程演示环境设计；登录限流状态保存在进程内，多进程或多机部署不在此期能力承诺内。

67. **安全约束**：密码不得明文存储或返回；生产部署必须配置独立 SECRET_KEY，公网环境必须在前置代理或部署层启用 HTTPS。

68. **课程交付约束**：单人独立完成，但必须保留需求、设计、实现、测试、验收之间的完整追踪证据。

2.5 假设与依赖

编号	假设/依赖	影响与应对
A-01	用户拥有有效的系统账号，账号已绑定角色和部门	无账号时不能自助注册，需由初始化数据或后续管理能力提供
A-02	浏览器允许同源会话 Cookie	前后端分离开发时通过 Vite 代理保持同源访问体验
A-03	SQLite 文件可读写且 instance 目录可创建	启动时自动建表；数据库异常时健康检查返回 degraded
A-04	文档正文以文本形式录入，标题和正文为必填项	不依赖 OCR 或第三方文档解析服务
A-05	演示数据规模和单用户/小规模访问为主	性能目标按课程演示场景定义，不承诺生产级并发
A-06	jieba 及依赖环境已安装	若分词依赖不可用，问答和检索无法达到验收要求
A-07	课程验收网络可访问本机服务	默认监听 127.0.0.1；局域网演示时可调整绑定地址
A-08	外部大模型能力如启用，仅在配置密钥后生效	不属于核心验收依赖；调用失败应回退本地摘要或明确提示

2.6 能力边界

2.6.1 已纳入 V2.0 验收的能力

能力域	已实现能力基线
身份与访问	登录/退出、会话、管理员/员工角色、部门、三级密级、登录失败限流、失败审计、安全回跳
文档管理	列表、详情、创建、编辑、删除、分类、标签、版本、发布状态、收藏、关键词/正文检索、相关文档
问答	权限内片段检索、jieba 分词、相关度评分、Top-K、同文档片段去重、摘要回答、来源展示、历史记录、无命中提示
知识图谱	文档/部门/分类/关键词节点自动同步、关系边生成、ECharts 力导向展示、权限过滤、管理员新增节点/关系
管理	管理员用户只读列表、分类查询与新增、审计日志服务端筛选和分页、管理员接口隔离
运维	健康检查、元信息、工作台、统一错误结构、前端构建与 Flask 托管、pytest 自动化基线

2.6.2 明确不作为已实现能力的规划项

为避免把规划写成完成事实，以下内容在需求与验收中均标记为非本期或可选增强：

69. 外部大模型生成质量、模型微调、提示词平台和计费管理；
70. 向量数据库、语义向量检索、重排序模型和知识图谱推理；
71. 用户注册、密码重置、用户增删改、角色变更和部门管理后台；
72. 附件上传、多格式解析、OCR、在线预览和版本文件存储；
73. 分类编辑/删除、图谱节点/关系编辑/删除、批量导入；
74. 单点登录、LDAP/AD、组织架构同步；
75. 多进程共享限流、Redis、消息队列、高可用部署和容量承诺；
76. 移动原生应用、离线模式和跨租户隔离。

2.7 功能模块划分

模块	编号前缀	主要职责	核心优先级
账户与权限	FR-AUTH	登录、退出、会话、角色、部门、防爆破、安全回跳、密码保护	P0
知识文档	FR-DOC	文档 CRUD、元数据、状态、检索、筛选、分页、收藏、片段与图谱同步	P0/P1
检索增强问答	FR-QA	问题提交、权限内检索、片段排序、回答、来源、历史、无命中处理	P0/P1
知识关系图	FR-GRAPH	图数据、自动建图、权限过滤、节点与关系维护	P1
管理功能	FR-ADMIN	用户列表、分类维护、审计筛选分页、管理员隔离	P0/P1
运维与支撑	FR-OPS	健康检查、工作台、系统信息、错误处理、构建测试	P1/P2

3 功能需求

本章按模块给出可设计、可实现、可测试的功能需求。每条需求均包含描述、输入、输出、业务规则、优先级和验收标准。接口路径以第 8 章为准；权限规则以第 4 章为准。

3.1 账户与权限 FR-AUTH

FR-AUTH-001 用户登录

属性	内容
描述	用户使用用户名和密码登录系统；认证成功后建立服务端会话并返回用户身份信息。
输入	JSON 或表单字段：username（必填）、password（必填）、remember（可选布尔值）。

属性	内容
输出	成功：HTTP 200，返回 user 对象和“登录成功”消息；失败：HTTP 401，返回统一错误信息；锁定：HTTP 429，返回 retry_after。
业务规则	用户名去除首尾空白后精确匹配；密码使用哈希校验；用户名不存在与密码错误统一提示“用户名或密码错误”，避免账号枚举；成功后清除该来源的失败计数并写入登录审计；失败时写入脱敏后的登录失败审计。
优先级	P0
验收标准	正确账号可进入工作台；错误密码不能建立会话；登录成功和失败均可在审计日志中查询；响应中不出现密码哈希。

FR-AUTH-002 退出与会话管理

属性	内容
描述	已登录用户可主动退出；系统可返回当前会话用户，未登录时返回空用户而不将其视为异常。
输入	退出：已认证的 POST 请求；会话探测：GET /api/auth/session。
输出	退出成功：HTTP 200 并清除会话，随后访问受保护接口返回 401；会话探测：user 为用户对象或 null。
业务规则	退出前写入 logout 审计；退出后旧会话不得继续访问受保护资源；默认会话有效期为 12 小时，Cookie 设置 HttpOnly 和 SameSite=Lax。
优先级	P0
验收标准	退出后再次请求文档、问答或管理接口均被拒绝；刷新页面后前端能正确识别未登录状态并跳转登录页。

FR-AUTH-003 角色与菜单授权

属性	内容
描述	系统根据管理员/员工角色控制菜单展示和服务端操作权限。
输入	当前会话用户、请求资源和方法。
输出	允许：继续执行并返回业务结果；未登录：401；已登录但无角色权限：403。
业务规则	管理员可访问全部业务和管理接口；员工不可访问用户列表、审计日志、分类新增、图谱维护接口；前端可隐藏管理员入口，但服务端必须再次校验；员工编辑/删除文档时还必须满足作者或管理员条件。
优先级	P0
验收标准	员工请求 /api/admin/users 或 /api/admin/audits 返回 403；管理员请求成功；员工不能通过直接构造 URL 绕过页面限制。

FR-AUTH-004 登录防爆破

属性	内容
描述	对同一客户端地址的连续登录失败实施滑动窗口计数和临时锁定。
输入	登录请求的客户端 IP、失败事件时间、配置 LOGIN_MAX_ATTEMPTS 与 LOGIN_WINDOW_SECONDS。
输出	锁定前：登录失败 401；达到阈值后：429，返回剩余等待

属性	内容
	秒数；成功后：失败计数清零。
业务规则	默认阈值为 8 次/300 秒；先判定锁定再校验密码，锁定期间即使密码正确也不得登录；窗口外旧失败事件自动过期；不同 IP 的计数相互独立；失败事件写入审计；本期限流为进程内实现。
优先级	P0
验收标准	连续失败达到阈值后返回 429；锁定期间正确密码仍被拒绝；等待窗口结束可恢复；成功登录后计数清零；多进程共享限流不在本期验收范围。

FR-AUTH-005 密码安全存储

属性	内容
描述	用户密码只保存带盐慢哈希，不保存明文，不通过接口返回。
输入	用户设置密码或演示数据初始化时的密码。
输出	数据库中仅存在 password_hash；认证时进行哈希校验。
业务规则	使用 Werkzeug 提供的带盐慢哈希机制（当前运行环境为 scrypt 系列）；任何管理列表、会话、审计和错误响应不得包含 password_hash；日志不得记录明文密码。
优先级	P0
验收标准	检查数据库和 API 响应均未出现明文密码或哈希原文；错误密码不能通过哈希校验；自动化安全用例覆盖密码存储检查。

FR-AUTH-006 登录后安全回跳

属性	内容
描述	登录后可回到站内原目标页面，但必须拒绝站外和危险回跳地址。
输入	可选 next 参数。
输出	安全站内相对路径；非法值丢弃并回到工作台或默认页。
业务规则	仅接受以单个斜杠开头的站内相对路径；拒绝包含协议、域名、双斜杠、反斜杠、换行、回车或空字符的地址；不得通过回跳泄露登录态。
优先级	P1
验收标准	常见恶意 next 值被拒绝；合法站内路径可正常回跳；未登录访问业务页时能携带安全的目标路径到登录页。

3.2 知识文档 FR-DOC

FR-DOC-001 文档列表与权限过滤

属性	内容
描述	登录用户可分页浏览其权限范围内的已发布文档。
输入	页码 page、每页数量 per_page、可选筛选条件。
输出	items 文档摘要数组、pagination、categories、departments、当前 filters。
业务规则	默认每页 9 条，API 每页上限 50；只展示 published 文档；列表总数和分页必须在权限过滤后计算；管理员可看到全部已发布文档，员工按公开、内部、机密规则过滤；默认按更新时间倒序。

属性	内容
优先级	P0
验收标准	员工列表不出现无权限机密文档；分页总数与该用户可见集合一致；管理员可见全量已发布文档；列表不会因分页或筛选泄露被过滤文档的数量。

FR-DOC-002 关键词检索、筛选与排序

属性	内容
描述	用户可按关键词检索标题、摘要、标签和正文，并按分类、部门、密级和排序方式筛选。
输入	q、category_id、department、visibility、sort、page、per_page。
输出	按相关度或指定排序返回的文档摘要及分页信息。
业务规则	检索前先执行权限过滤；关键词命中标题、标签、摘要和正文时综合评分，标题与标签优先；有 q 时按相关度排序，无 q 时支持最近更新、标题顺序、部门分组；分类、部门、密级条件可组合；不存在或非法参数使用安全默认值。
优先级	P0
验收标准	搜索“年假”能命中相关制度并优先展示；正文中的关键词可被检索；分类、部门、密级筛选结果正确；越权文档不进入候选集。

FR-DOC-003 文档详情与相关推荐

属性	内容
描述	用户可查看有权访问的文档详情，并获得权限范围内的相关文档建议。
输入	文档 ID、当前用户。
输出	document 对象（含正文、分类、作者、版本、密级、状态、标签、字符数、片段数）、related 最多 4 篇、can_edit 布尔值。
业务规则	不存在的文档返回 404；无权限返回 403；草稿和归档文档仅作者或管理员可直接访问；published 文档按密级判定；相关文档按同分类、同部门、标签重叠综合筛选，且必须再次执行可见性过滤；同一用户 2 分钟内重复打开同一文档最多写入一次 view_document 审计。
优先级	P0
验收标准	同部门机密可查看，异部门机密返回 403；作者可查看本人草稿；相关推荐不含越权文档；查看审计可查询且不会因反复刷新无限增长。

FR-DOC-004 新建文档

属性	内容
描述	登录用户可创建知识文档并立即进入可检索、可建图的已发布或草稿状态。
输入	title、content（均为必填）；summary、category_id、department、visibility、status、version、tags（可选）。
输出	HTTP 201；返回完整 document 对象和“文档已创建”消息。
业务规则	标题和正文去空白后必须非空；摘要为空时从正文自动截

属性	内容
	取；分类必须存在；部门必须来自系统部门词表，否则使用当前用户部门；visibility 缺省为 internal，status 缺省为 published，version 缺省为 1.0；tags 可为数组并规范化为逗号分隔文本；创建后重建知识片段、同步图谱并写入 create_document 审计；整个过程在事务保护下完成。
优先级	P0
验收标准	合法文档创建成功并可按权限检索；空标题或空正文返回 400；不存在的分类返回 400；新文档片段和图谱关系自动生成；审计可见创建记录。

FR-DOC-005 编辑文档

属性	内容
描述	文档作者或管理员可修改文档内容和元数据。
输入	文档 ID、与新建基本一致的字段集合。
输出	HTTP 200；返回更新后的 document 对象和“文档已更新”消息。
业务规则	仅作者或管理员可编辑，其他用户返回 403；校验规则同新建；更新后必须重建知识片段并重新同步图谱，避免旧正文继续被问答检索；写入 edit_document 审计；变更提交失败时不得留下半更新状态。
优先级	P0
验收标准	作者可编辑并立即检索到新正文；非作者员工编辑返回 403；分类不存在时拒绝更新；编辑审计可查询；图谱节点标题和关系随更新同步。

FR-DOC-006 删除文档

属性	内容
描述	文档作者或管理员可删除文档。
输入	文档 ID。
输出	HTTP 200 和“文档已删除”消息。
业务规则	仅作者或管理员可删除；删除文档时级联清理知识片段和收藏关系，并清理关联图谱节点及边；写入 delete_document 审计；删除后不得再出现在列表、检索、问答历史和新的图谱查询中（历史问答记录本身按历史口径保留）。
优先级	P0
验收标准	作者删除成功；其他员工删除返回 403；删除后检索不再命中；图谱无残留文档节点；审计保留删除记录。

FR-DOC-007 文档元数据与发布状态

属性	内容
描述	文档支持分类、标签、版本、部门、密级和发布状态等元数据。
输入	category_id、tags、version、department、visibility、status。
输出	文档列表和详情中的标准化标签、密级文案、状态文案和版本号。
业务规则	密级取值仅允许 public、internal、secret；状态取值仅允许 draft、published、archived；标签以逗号分隔并去

属性	内容
	除空项；版本使用字符串表达，默认 1.0；普通用户只能选择系统部门词表中的部门；非法枚举值回退到安全默认值或被拒绝。
优先级	P1
验收标准	三个密级和三个状态在界面与 API 中文案一致；非法值不能写入；标签、版本和分类正确回显；状态对列表、检索、问答和图谱的影响符合第 4 章矩阵。

FR-DOC-008 收藏与取消收藏

属性	内容
描述	用户可收藏或取消收藏其有权查看的文档，并查看个人收藏列表。
输入	文档 ID、当前用户。
输出	is_favorite 布尔值和“已收藏/已取消收藏”消息；收藏列表返回当前用户可见的收藏文档。
业务规则	同一用户与同一文档最多一条收藏记录；操作按切换语义执行；不可收藏无权限文档；收藏列表必须再次过滤权限，避免文档密级变化后泄露；收藏为个人数据，不向其他员工展示。
优先级	P1
验收标准	收藏后出现在“我的收藏”；再次操作取消；重复数据不产生；异部门机密不能收藏；其他用户看不到该用户的收藏。

FR-DOC-009 知识片段与图谱同步

属性	内容
描述	文档创建或更新后，系统自动切分正文、提取关键词并同步知识图谱。
输入	文档标题、正文、摘要、分类、部门、标签。
输出	知识片段记录、关键词、文档节点及部门/分类/关键词关系。
业务规则	默认片段长度 400、重叠 50，可由环境配置调整；切分为幂等重建，编辑后不得保留旧片段；关键词提取使用 jieba；标签为空时可依据正文关键词补全；文档节点标题变化时同步节点名称；文档删除时清理关联节点和边。
优先级	P1
验收标准	新文档可立即检索；编辑正文后旧内容不再命中；删除文档后片段与图谱无孤儿节点；切分参数可通过配置读取。

3.3 检索增强问答 FR-QA

FR-QA-001 提交问题

属性	内容
描述	已登录用户可输入自然语言问题，系统返回基于知识库片段整理的回答。
输入	question（必填，去除首尾空白后的文本）。
输出	HTTP 200；返回 answer、mode、mode_label、history_id、sources、fragments。
业务规则	空问题返回 400 VALIDATION_ERROR；仅允许已登录用户调

属性	内容
	用；问题文本按原样用于检索并保存到本人问答历史；问答动作写入 ask_qa 审计；回答不得使用用户无权访问的文档。
优先级	P0
验收标准	输入“员工年假有几天”等业务问题可得到回答；空问题被拒绝；问答后历史记录增加；普通员工不能通过问答接口获取机密文档内容。

FR-QA-002 权限内知识检索

属性	内容
描述	问答只检索当前用户有权访问的已发布文档片段。
输入	当前用户、问题文本、可见性规则。
输出	候选文档 ID 集合和候选知识片段集合。
业务规则	先通过统一可见性函数筛选文档，再查询片段；普通员工可检索公开、内部以及本部门或本人作者的机密文档；异部门机密及其片段不得进入排序、回答、来源或数量统计；草稿和归档不进入问答检索。
优先级	P0
验收标准	人事账号提问信息部机密内容时无来源且不出现相关标题；信息部账号可检索本部门机密；问答与文档列表使用同一权限判定。

FR-QA-003 片段排序与去重

属性	内容
描述	系统对候选片段进行中文分词、相关度评分、排序和来源去重。
输入	问题、问题分词集合、知识片段的正文、关键词和所属文档标题。
输出	Top-K 命中片段，含 score、chunk_id、document_id、title、department、fragment_no、fragment_total。
业务规则	使用 jieba 分词并结合领域词和汉字二字组提高召回；综合词重叠、关键词、标题命中与短语包含评分；默认 Top-K 为 5；同文档最多保留 2 个片段，避免来源被单篇长文垄断；按分数从高到低返回；分数与片段信息可用于界面显示。
优先级	P1
验收标准	“年假”等业务词可产生非空分词结果并命中目标制度；同一文档最多贡献 2 条来源；结果按相关度降序；Top-K 参数可由配置调整。

FR-QA-004 带来源回答

属性	内容
描述	系统基于命中片段形成回答，并向用户展示可核对的文档来源。
输入	问题、Top-K 命中片段、当前问答模式。
输出	answer 文本；sources 按文档分组的来源列表；fragments 原始片段；mode 为本地检索或增强模式。
业务规则	回答必须限定在命中片段范围内；来源至少包含文档 ID、标题、相关度和部门；无命中时不得生成看似有依据的结论；若启用可选外部增强能力，必须显式标识模式，调用

属性	内容
	失败时回退本地摘要，不得伪装为已成功调用；外部增强能力不属于本期核心验收依赖。
优先级	P0
验收标准	回答页面显示文档标题、相关度和片段依据；提问年假时来源指向相关制度；删除或无权限文档不能成为来源；回答模式与来源可追溯。

FR-QA-005 问答历史

属性	内容
描述	用户可查看本人最近问答记录，管理员可查看指定历史记录详情。
输入	当前用户、历史记录 ID、分页/列表请求。
输出	最近 20 条历史摘要；详情包含问题、回答、模式、时间和来源 JSON。
业务规则	普通用户只能查看本人历史；管理员可查看任意用户历史详情；来源字段必须以可解析 JSON 或空数组返回；历史记录用于追溯，不因原文档被删除而自动篡改；问答历史与审计日志职责分离。
优先级	P1
验收标准	用户只能看到自己的历史列表；直接访问他人历史返回 403；管理员可查看；历史详情能展示来源标题和相关度。

FR-QA-006 无命中与异常降级

属性	内容
描述	当没有可访问知识片段或增强服务不可用时，系统给出明确、可理解的降级结果。
输入	问题、空命中集合或外部增强异常。
输出	本地模式的明确提示、回退摘要或带原因的降级说明；不得返回 500 作为无命中结果。
业务规则	无命中时提示“未在可访问的知识库中检索到相关内容”，并建议换问法或确认权限；本地摘要模式必须明确标识；外部服务失败时回退本地摘要，可附带受控错误说明但不泄露密钥、堆栈或内部路径；问题为空时返回 400。
优先级	P1
验收标准	无命中不出现虚假答案；无权限时提示与权限事实一致；外部增强不可用不影响本地问答主流程；错误响应不含敏感配置。

3.4 知识关系图 FR-GRAPH

FR-GRAPH-001 图谱浏览与权限过滤

属性	内容
描述	登录用户可查看由文档、部门、分类和关键词等节点及关系边构成的知识关系图。
输入	当前用户及可选图谱查询条件。
输出	nodes、links、categories 三类 JSON 数据，供 ECharts 力导向图渲染。
业务规则	普通用户只能看到与其可见文档关联的节点和边；管理员

属性	内容
	可查看完整图谱；图谱返回前须按当前用户可见文档集合过滤；点击文档节点可跳转其详情；不得通过节点名称或边信息泄露无权限文档标题；无数据时返回空结构而不是错误。
优先级	P1
验收标准	图谱正常渲染并可拖拽、缩放；普通员工看不到异部门机密的文档节点；管理员可见完整结构；点击文档节点可进入详情或收到明确提示。

FR-GRAPH-002 自动建图与关系同步

属性	内容
描述	系统根据文档元数据自动生成文档、部门、分类、关键词节点及语义关系。
输入	文档标题、部门、分类、标签、正文关键词。
输出	文档节点、部门节点、分类节点、关键词节点，以及属于、分类为、含有关联边。
业务规则	节点按名称复用；文档节点命名与标题关联；部门、分类与关键词节点按文档元数据生成；标签为空时可从正文提取关键词；同名关系不重复创建；文档更新时同步标题与关系；文档删除时清理相关节点和边，避免孤儿数据。
优先级	P1
验收标准	新建文档后自动出现文档、部门、分类或关键词关系；编辑标题后节点名称同步；删除文档后无孤立文档节点；关系图接口返回结构稳定。

FR-GRAPH-003 管理员维护图谱节点

属性	内容
描述	管理员可新增概念节点并查看近期节点列表。
输入	name（必填）、node_type（可选）、description（可选）。
输出	HTTP 201；返回节点 ID、名称和“节点已添加”；管理页返回最近节点和边。
业务规则	仅管理员可调用；节点名称不能为空；同名节点复用并避免重复；node_type 支持 document、department、project、keyword、concept；本期不提供节点编辑和删除。
优先级	P1
验收标准	管理员可新增节点并立即在管理列表看到；空名称返回 400；员工调用返回 403；重复名称不会产生重复节点记录。

FR-GRAPH-004 管理员维护关系

属性	内容
描述	管理员可在两个节点之间新增关系边。
输入	source_name、target_name（均必填）、relation（可选，默认“关联”）。
输出	HTTP 201 和“关系已添加”消息；管理页可查看近期关系。
业务规则	仅管理员可调用；起点或终点为空返回 400；不存在的节点按概念节点自动创建；同一源、目标、关系组合不重复

属性	内容
	创建；关系名称去除首尾空白后保存；本期不提供关系编辑和删除。
优先级	P1
验收标准	管理员通过页面或接口新增关系后可看到连线；空端点被拒绝；员工无权操作；重复关系不产生重复边。

3.5 管理功能 FR-ADMIN

FR-ADMIN-001 管理员用户列表

属性	内容
描述	管理员可查看用户只读列表及文档贡献统计。
输入	当前管理员会话。
输出	用户数组（ID、用户名、显示名、角色及文案、部门、创建时间、文档数）和管理员/员工汇总。
业务规则	仅管理员可访问；密码哈希不得返回；列表不包含用户编辑、删除、角色变更和部门变更操作；普通员工访问返回 403；统计仅供治理展示，不得替代正式审计。
优先级	P1
验收标准	管理员可看到全部用户及角色、部门、文档数；员工访问被拒绝；响应中无密码字段。

FR-ADMIN-002 分类查看与新增

属性	内容
描述	登录用户可查看分类列表；管理员可新增分类。
输入	查看：无；新增：name（必填）、description（可选）。
输出	分类数组（ID、名称、说明、文档数）；新增成功 HTTP 201。
业务规则	分类名称去空白后不能为空且全局唯一；重复名称返回验证错误；新增分类后可用于文档编辑；本期不提供分类重命名、合并和删除；普通员工可读取分类列表但不能新增。
优先级	P1
验收标准	分类列表含文档数；管理员新增成功并可在文档表单选择；重复或空名称被拒绝；员工新增返回 403。

FR-ADMIN-003 审计日志服务端筛选与分页

属性	内容
描述	管理员可在服务端按动作、用户名和明细关键词筛选审计日志，并按页查看。
输入	action、user、detail、page；每页固定 25 条。
输出	items、pagination（page、pages、total、per_page）、action_stats、可选动作字典。
业务规则	仅管理员可访问；筛选必须在数据库查询层完成，不能只在前端隐藏行；按时间和 ID 倒序；非法动作值不施加动作过滤；用户名筛选支持模糊匹配；明细支持模糊匹配；页码越界时收敛到最后有效页；审计动作至少覆盖 login、login_failed、logout、view_document、create_document、edit_document、delete_document、ask_qa。

属性	内容
优先级	P0
验收标准	登录失败可通过 action 筛选；用户名/明细查询有效；分页总数正确；普通员工无法访问；不会一次性返回全量日志导致页面失控。

FR-ADMIN-004 管理员接口隔离

属性	内容
描述	所有管理能力必须在服务端执行管理员角色校验，前端菜单隐藏只作为辅助。
输入	当前会话、请求路径与方法。
输出	允许：业务数据；未登录：401 AUTH_REQUIRED；无权限：403 FORBIDDEN。
业务规则	管理接口包括用户列表、审计日志、分类新增、图谱管理、节点新增和关系新增；不得通过修改 Vue 路由、请求体或浏览器状态获得管理员能力；管理员身份以服务端会话为准。
优先级	P0
验收标准	未登录和员工请求全部管理接口均被拒绝；管理员请求正常；前端路由守卫绕过不影响服务端结果。

3.6 运维与系统支撑 FR-OPS

FR-OPS-001 健康检查

属性	内容
描述	系统提供无需登录的健康检查接口，用于确认服务与数据库基本可用。
输入	GET /api/health。
输出	JSON：status、database、version。数据库正常时 status 为 ok，异常时 status 为 degraded。
业务规则	健康检查执行数据库 SELECT 1；不得返回密钥、文件路径或内部堆栈；健康检查不能替代完整业务自检；数据库异常时接口应明确反映降级状态。
优先级	P1
验收标准	正常情况下返回 200、status=ok、database=true 和 V2.0 版本；数据库不可用时返回 degraded；接口无需登录即可访问。

FR-OPS-002 工作台与系统信息

属性	内容
描述	登录用户可查看工作台、可见范围统计、近期内容、快捷入口和系统元信息。
输入	当前用户。
输出	文档、收藏、问答、图谱等统计；部门/分类图表数据；近期文档、问答、管理员近期审计；系统版本和技术栈。
业务规则	文档和片段相关统计必须按当前用户可见范围计算；管理员可看到近期审计，普通员工不可看到全局审计；系统元信息不含密钥；统计口径应在界面说明；空数据状态需给出可读提示。
优先级	P2

属性	内容
验收标准	工作台正常加载并展示统计；员工与管理员看到的审计范围不同；文档数不包含无权访问内容；元信息版本为 2.0。

FR-OPS-003 统一错误响应与错误页面

属性	内容
描述	API 与前端对常见错误提供统一、可理解的处理。
输入	未登录、无权限、资源不存在、参数错误、限流或服务器异常。
输出	API JSON 含 error 和 code；页面级错误显示 403、404 或 500 提示；前端通过提示条显示 API 错误。
业务规则	400 用于参数/业务验证失败；401 用于未认证；403 用于无权限；404 用于资源不存在；429 用于登录锁定；500 不得向最终用户展示裸堆栈；错误文案不泄露敏感配置；前端收到 401 时清理会话并引导登录。
优先级	P1
验收标准	常见错误状态码与前端提示一致；未知路径显示 404 而非登录页；越权显示 403；错误响应中不含密码、密钥或完整堆栈。

FR-OPS-004 可构建、可启动与可测试交付

属性	内容
描述	项目提供可重复的前端构建、后端启动和自动化测试入口。
输入	项目依赖、环境变量、启动脚本、pytest 命令。
输出	可访问的 /ui/ 前端、可访问的 /api/ 接口、测试通过报告。
业务规则	Vite 构建产物由 Flask 托管；开发环境通过 Vite 代理 /api；启动脚本应避免重复启动和端口冲突；自动化测试必须使用隔离数据库，不污染演示库；截至 2026-10-31 记录的测试基线为 136 条全部通过，最终以验收时重新执行结果为准。
优先级	P1
验收标准	干净环境按说明安装依赖后可构建和启动；健康检查可用；pytest 可执行；验收时重新执行的测试结果与基线一致或已记录差异。

4 权限矩阵

4.1 权限判定原则

77. **默认拒绝**：未建立有效会话的请求不得访问任何业务数据。

78. **服务端为准**：前端菜单、路由守卫和按钮显示只改善体验，最终授权以 Flask API 的服务端会话和角色判定为准。

79. **最小必要**：用户只能看到完成当前任务所需的数据；无权限文档不得进入列表总数、检索候选、问答来源、图谱节点或统计口径。

80. **统一口径**：文档列表、详情、问答检索、相关推荐、收藏过滤和图谱过滤必须复用一致的可见性规则。

81. **多层约束**：文档访问同时考虑登录状态、角色、部门、密级、作者和发布状态；满足一个条件不代表自动满足全部条件。

82. **管理隔离**：管理员能力通过独立接口和统一管理员校验保护；员工即使知道路径也不能操作。

4.2 角色与操作权限矩阵

说明：“✓”表示允许，“—”表示禁止，“条件”表示需同时满足附加规则。文档作者是文档级身份，不是第三类角色。

操作	匿名	员工（非作者）	作者（非管理员）	管理员
登录、探测会话、查看公开元信息	✓	✓	✓	✓
健康检查	✓	✓	✓	✓
退出登录	—	✓	✓	✓
查看公开文档	—	✓	✓	✓
查看内部文档	—	✓	✓	✓
查看本部门机密文档	—	✓	✓	✓
查看他部门机密文档	—	—	条件：本人为作者	✓
查看本人草稿/归档	—	条件：本人为作者	✓	✓
查看他人草稿/归档	—	—	—	✓
创建文档	—	✓	✓	✓
编辑/删除本人文档	—	条件：本人为作者	✓	✓
编辑/删除他人文档	—	—	—	✓
收藏有权访问的文档	—	✓	✓	✓
文档列表、分类/部门/密级筛选	—	✓	✓	✓
关键词与正文检索	—	✓	✓	✓
检索增强问答	—	✓	✓	✓
查看本人问答历史	—	✓	✓	✓
查看他人问答历史详情	—	—	—	✓
浏览权限过滤后的知识图谱	—	✓	✓	✓
查看完整知识图谱	—	—	—	✓
查看分类列表	—	✓	✓	✓
新增分类	—	—	—	✓
查看用户列表	—	—	—	✓
新增图谱节点/关系	—	—	—	✓
查看审计日志	—	—	—	✓
访问管理路由和 API	—	—	—	✓

4.3 文档密级可见性矩阵

密级	匿名	任意已登录员工	文档所属部门员工	文档作者	管理员
公开 public	—	✓	✓	✓	✓
内部 internal	—	✓	✓	✓	✓
机密 secret	—	—	✓	✓	✓

补充规则：

83. “内部”表示所有已登录员工可见，不等于互联网公开；

84. “机密”至少满足管理员、同部门员工、文档作者三者之一；

85. 作者例外适用于作者本人创建的机密文档，不因作者跨部门而失效；

86. 密级判定通过后，仍须满足发布状态判定；

87. 文档列表、问答和图谱默认只使用 published 文档，因此 unpublished 文档不会因密级规则被误纳入普通检索。

4.4 发布状态行为矩阵

状态	普通列表	搜索/筛选	问答候选	默认图谱	作者/管理员直接查看	作者/管理员编辑
草稿 draft	—	—	—	—	✓	✓
已发布 published	✓（再按密级过滤）	✓（再按密级过滤）	✓（再按密级过滤）	✓（再按密级过滤）	✓	✓
已归档 archived	—	—	—	—	✓	✓

状态说明：本期没有独立审批工作流；发布状态由文档表单管理。普通用户不能通过列表或问答发现草稿和归档文档，但作者/管理员可通过受控详情路径查看。

4.5 权限执行链

一次受保护 API 请求按以下顺序处理：

88. 解析会话，判断是否已登录；未登录返回 401；

89. 判断接口是否要求管理员；不满足返回 403；

90. 读取资源并判断存在性；不存在返回 404；

91. 判断文档密级、部门、作者和状态；不满足返回 403；

92. 在候选数据集合上执行检索、问答、图谱或统计；

93. 写入必要的审计或业务记录；

94. 以统一 JSON 结构返回结果。

该顺序必须在所有相关接口中保持一致，尤其禁止“先检索全库、再由前端隐藏结果”的实现方式。

5 主要用例及事件流

5.1 UC-01 登录、失败锁定与进入工作台

项目	内容
用例编号	UC-01

项目	内容
用例名称	登录、失败锁定与进入工作台
主要参与者	员工、管理员
前置条件	系统已启动；用户拥有有效账号；浏览器可访问前端和 /api
触发条件	用户在登录页提交用户名和密码
主事件流	1. 前端提交登录请求；2. 后端检查该 IP 是否锁定；3. 后端查询用户并校验密码哈希；4. 成功后清除失败计数、建立会话、写入登录审计；5. 前端保存用户状态并跳转工作台；6. 工作台按当前用户可见范围加载统计和近期内容。
备选/异常流	A1：用户名或密码错误，写入 login_failed 审计并提示统一错误；A2：失败达到阈值，返回 429 和剩余等待秒数；A3：已登录用户再次访问登录页，前端跳转工作台；A4：请求的网络或服务器异常，显示可读错误并允许重试。
后置条件	成功时存在有效会话和登录审计；失败时无有效会话，必要时存在失败审计与临时锁定状态。
关联需求	FR-AUTH-001、FR-AUTH-002、FR-AUTH-003、FR-AUTH-004、FR-AUTH-005
验收锚点	AT-AUTH-01 至 AT-AUTH-05

5.2 UC-02 创建、编辑和发布知识文档

项目	内容
用例编号	UC-02
用例名称	创建、编辑和发布知识文档
主要参与者	员工、管理员
前置条件	用户已登录；分类和部门词表已初始化；用户具有文档创建权限
触发条件	用户进入“新建文档”或“编辑文档”页面并提交表单
主事件流	1. 用户填写标题、正文、摘要、分类、部门、密级、状态、版本和标签；2. 前端校验必填项并提交 JSON；3. 后端执行字段、分类和部门校验；4. 保存文档并提交事务；5. 切分正文、提取关键词并重建知识片段；6. 同步文档、部门、分类和关键词图谱；7. 写入 create_document 或 edit_document 审计；8. 返回详情并提示成功。
备选/异常流	A1：标题或正文为空，返回 400；A2：分类不存在，返回 400；A3：非作者员工尝试编辑他人文档，返回 403；A4：片段或图谱同步失败时整体事务回滚，不返回成功；A5：文档不存在，返回 404。
后置条件	文档可被权限内用户检索；其正文、片段、图谱和审计保持同步。
关联需求	FR-DOC-001、FR-DOC-004、FR-DOC-005、FR-DOC-007、FR-DOC-009、FR-GRAPH-002
验收锚点	AT-DOC-01 至 AT-DOC-06、AT-GRAPH-02

5.3 UC-03 检索制度并获取带来源回答

项目	内容
用例编号	UC-03
用例名称	检索制度并获取带来源回答
主要参与者	员工、管理员
前置条件	用户已登录；知识库中存在已发布且用户有权访问的文档；文档已完成片段索引
触发条件	用户在文档页输入关键词，或在问答页提交自然语言问题

项目	内容
主事件流	1. 前端提交问题或检索条件；2. 后端先计算当前用户可见的已发布文档集合；3. 仅在该集合内读取知识片段；4. 使用 jieba 分词、领域词和二字组生成查询信号；5. 对片段评分、排序，限制同文档片段数并取 Top-K；6. 生成基于片段的回答或返回排序后的文档；7. 按文档归并来源，返回标题、相关度、部门和片段；8. 写入 ask_qa 审计并保存问答历史。
备选/异常流	A1：没有可访问命中，返回无命中提示，不生成虚假答案；A2：问题为空，返回 400；A3：外部增强服务不可用，回退本地摘要并明确模式；A4：用户对某些文档无权限，其标题、正文和片段均不进入结果。
后置条件	用户获得可核对来源的回答或明确的无命中结论；本人历史增加一条记录；审计增加 ask_qa 记录。
关联需求	FR-DOC-001、FR-DOC-002、FR-QA-001 至 FR-QA-006
验收锚点	AT-QA-01 至 AT-QA-06

5.4 UC-04 机密文档跨部门访问检查

项目	内容
用例编号	UC-04
用例名称	机密文档跨部门访问检查
主要参与者	员工、管理员
前置条件	存在某部门创建的机密文档；用户已登录
触发条件	用户通过列表、详情 URL、搜索、问答或图谱尝试访问该文档
主事件流	1. 系统获得目标文档和当前用户；2. 判断用户是否为管理员，是则允许；3. 判断文档是否为机密；4. 若为机密，判断用户部门是否等于文档部门，或用户是否为文档作者；5. 满足条件后继续判断发布状态；6. 全部通过后返回数据，否则返回 403。
备选/异常流	A1：文档不存在返回 404；A2：文档处于草稿或归档且用户不是作者/管理员，返回 403；A3：用户通过问答间接访问，无权限文档不得进入候选集；A4：用户通过图谱访问，文档节点及其相邻边不得返回。
后置条件	权限结果一致，不因入口不同产生越权差异；被拒绝的访问不返回正文或标题。
关联需求	FR-AUTH-003、FR-DOC-001、FR-DOC-003、FR-QA-002、FR-GRAPH-001、FR-ADMIN-004
验收锚点	AT-AUTH-03、AT-DOC-07、AT-QA-02、AT-GRAPH-01

5.5 UC-05 管理员治理与审计查询

项目	内容
用例编号	UC-05
用例名称	管理员治理与审计查询
主要参与者	管理员
前置条件	管理员已登录；存在用户、分类和审计数据
触发条件	管理员打开用户、分类或审计管理入口
主事件流	1. 管理员进入治理页面；2. 前端调用受保护管理接口；3. 后端再次校验管理员角色；4. 用户列表返回角色、部门和文档数；5. 分类页返回分类及文档数；6. 管理员可新增分类；7. 审计页按动作、用户名或明细关键词查询，并按 25 条分页；8. 前端展示统计和结果。
备选/异常流	A1：员工或匿名用户访问，返回 403 或 401；A2：分类名称为空或重复，返回验证错误；A3：审计筛选无结果，返

项目	内容
	回空列表和零总数；A4：页码越界，收敛到最后有效页。
后置条件	管理员完成治理或审计查询；普通员工权限不受影响；治理操作产生可追踪结果或明确错误。
关联需求	FR-ADMIN-001 至 FR-ADMIN-004、FR-AUTH-003
验收锚点	AT-ADMIN-01 至 AT-ADMIN-04

5.6 UC-06 浏览与维护知识关系图

项目	内容
用例编号	UC-06
用例名称	浏览与维护知识关系图
主要参与者	员工、管理员
前置条件	用户已登录；系统中存在文档元数据或人工图谱数据
触发条件	用户打开知识关系图页面；管理员打开图谱维护入口
主事件流	1. 前端请求图谱数据；2. 后端根据可见文档生成或过滤节点和关系；3. ECharts 以力导向布局渲染；4. 用户拖拽、缩放、悬停或点击文档节点；5. 点击文档节点进入有权限的详情页；6. 管理员选择维护节点或关系；7. 后端校验名称、类型、端点和关系并保存；8. 管理列表和可视化刷新。
备选/异常流	A1：无可视图谱，显示空状态；A2：点击无权限文档节点不跳转并给出提示；A3：管理员提交空节点名或空端点，返回 400；A4：员工尝试维护，返回 403；A5：同名节点或同组合关系已存在，不产生重复记录。
后置条件	图谱按权限正确展示；管理员维护结果可查询，且不影响无权限用户的数据可见性。
关联需求	FR-GRAPH-001 至 FR-GRAPH-004、FR-DOC-003、FR-ADMIN-004
验收锚点	AT-GRAPH-01 至 AT-GRAPH-04

6 数据需求

6.1 数据原则

95. 业务数据使用 SQLAlchemy 模型映射到 SQLite；默认数据库文件为 instance/knowledge.db。

96. 认证凭据只保存密码哈希，不保存明文密码；敏感配置通过环境变量注入。

97. 文档、知识片段、分类、图谱、收藏、问答历史和审计日志必须保持可追溯关系。

98. 写操作应使用事务；对文档、片段和图谱的联动更新必须保持原子性。

99. 演示数据必须明确为虚构内容，不得写入真实企业机密或个人信息。

100. 自动化测试使用隔离数据库，不读写演示库；最终验收数据以演示库为样本但不以测试数据充当真实业务数据。

6.2 核心数据实体

实体	关键字段	业务约束与说明
用户 User	id、username、password_hash、display_name、role、department、created_at	用户名唯一且索引；角色仅为 admin/employee；部门为受控词表；密码只存哈希
分类 Category	id、name、description	分类名唯一；用于文档归类和图谱概念节点
文档 Document	id、title、content、summary、department、visibility、status、version、tags、category_id、author_id、created_at、updated_at	标题和正文必填；密级三枚举；状态三枚举；删除时级联清理片段和收藏
知识片段 KnowledgeChunk	id、document_id、chunk_index、content、keywords	属于文档；正文按配置切分；编辑时重建，删除时清理
图谱节点 GraphNode	id、name、node_type、description、document_id	名称唯一；node_type 为 document/department/project/keyword/concept；文档节点可关联 document_id
图谱边 GraphEdge	id、source_id、target_id、relation	两端引用图谱节点；同一源、目标、关系不重复；删除节点时清理关联边
收藏 Favorite	id、user_id、document_id、created_at	用户和文档组合唯一；只对有权访问文档展示
问答历史 QAHistory	id、user_id、question、answer、sources、mode、created_at	保存问题和回答；sources 为来源 JSON；普通用户只查看本人，管理员可查看详情
审计日志 AuditLog	id、user_id、action、detail、created_at	user_id 可为空以记录未知账号失败；动作和明细不可由普通用户修改

6.3 数据关系

关系	基数	说明
用户—文档	1:N	一个用户可创建多篇文档；文档作者用于作者例外和编辑/删除权限
分类—文档	1:N	一个分类可包含多篇文档；文档可暂不分类
文档—知识片段	1:N	一篇文档切分为多个可检索片段；片段随文档重建或删除
用户—收藏—文档	M:N	通过 Favorite 建立；同一用户和文档最多一条
用户—问答历史	1:N	每条问答绑定提交用户；用于个人历史追溯
用户—审计日志	1:N	审计可绑定用户；未知用户名登录失败可保留空用户引用
文档—图谱节点	1:0..1（逻辑）	文档节点可关联文档 ID；部门、分类和关键词概念节点可被多篇文档共享
图谱节点—图谱边	1:N（两端）	节点可作为源或目标；删除节点时清理相关边

6.4 文档生命周期与数据联动

阶段	数据动作	可检索性	审计
创建	写入文档、摘要、片段和图谱；提交事务	已发布文档立即可检索；草稿不进入普通检索	create_document
编辑	更新文档、重建片段、同步图谱	新正文立即生效，旧片段不再作为检索依据	edit_document

阶段	数据动作	可检索性	审计
发布	状态改为 published	进入权限内列表、搜索、问答和图谱候选	编辑动作
归档	状态改为 archived	退出普通列表、搜索、问答和图谱候选	编辑动作
收藏	写入或删除 Favorite	不影响文档内容；收藏列表重新校验权限	本期不单独记审计
删除	删除文档、片段、收藏，清理图谱节点/边	不再可检索或展示	delete_document
问答	写入 QAHistory 和 sources	历史保留问题、回答和来源；不改变文档内容	ask_qa
查看	读取详情；2 分钟内同文档去重记录	只对有权用户可见	view_document

6.5 数据质量、保留与安全

101. **完整性**：文档必须具有标题、正文、密级、状态和作者；分类引用必须存在；图谱边端点必须存在。

102. **一致性**：编辑文档后片段与图谱必须同步；删除文档后不得留下可访问的孤儿片段或文档节点。

103. **唯一性**：用户名、分类名、收藏“用户—文档”组合和图谱节点名称必须满足唯一约束。

104. **时效性**：问答历史、审计日志和文档更新时间以本地演示时区展示；时间格式统一到秒，不展示微秒。

105. **保密性**：密码哈希、SECRET_KEY、外部服务密钥不得进入前端、审计或错误响应。

106. **保留策略**：本期未实现自动清理和归档策略；验收演示数据随演示库保留。部署方如需长期使用，应另行制定备份、归档和审计留存制度。

107. **数据规模**：本期按课程演示规模验收，不承诺百万级文档、高并发写入或跨地域复制。

7 非功能需求

本章指标以课程项目的单机/局域网演示环境为口径。性能指标是验收目标，不等同于生产级容量承诺；安全边界、权限一致性和可测试性是本期的硬性要求。

7.1 性能需求

编号	需求	验收口径
NFR-PERF-001	常规列表、详情和工作台页面应在可接受时间内完成首屏加载	本机、单用户、演示数据规模下目标 ≤ 3 秒；验收时记录实际观察结果
NFR-PERF-002	本地检索增强问答应快速返回	演示数据规模下从提交问题到显示回答和来源目标 ≤ 5 秒
NFR-PERF-003	知识图谱应可交互	演示节点规模下完成数据加载和初始力导向布局，用户可拖拽、缩放和点击
NFR-PERF-004	列表和审计必须分页，禁止一次性返	文档 API 每页默认 9、最大 50；审

编号	需求	验收口径
	回无界数据	计日志每页 25；问答历史列表最多返回最近 20 条
NFR-PERF-005	检索与问答候选集应先过滤再计算	代码路径不得先对全库做昂贵打分再将无权限结果显示或隐藏

7.2 安全需求

编号	需求	验收口径
NFR-SEC-001	密码必须带盐慢哈希存储，不得明文保存或返回	检查数据库、API 响应、前端状态和日志；自动化安全用例通过
NFR-SEC-002	会话 Cookie 应设置 HttpOnly 和 SameSite=Lax	检查配置；默认会话有效期 12 小时；生产部署设置独立 SECRET_KEY
NFR-SEC-003	登录必须防爆破并记录失败	默认 8 次失败/300 秒锁定；锁定期间正确密码仍被拒绝；触发 429
NFR-SEC-004	所有业务接口必须执行服务端鉴权	列表、详情、检索、问答、图谱、统计和管理接口均不得仅依赖前端隐藏
NFR-SEC-005	跨入口权限规则一致	同一机密文档在详情、搜索、问答、相关推荐、收藏和图谱中的结果一致
NFR-SEC-006	登录回跳必须防开放重定向	协议、域名、协议相对 URL、反斜杠和控制字符均被拒绝
NFR-SEC-007	输出应防注入和脚本注入	SQLAlchemy 参数化查询；Vue 默认文本转义；不得将用户内容当作可执行脚本；错误不暴露堆栈
NFR-SEC-008	敏感配置不得进入仓库和响应	SECRET_KEY、外部服务密钥通过环境变量注入；健康检查、元信息和错误响应不暴露密钥
NFR-SEC-009	公网部署须启用 HTTPS	本期应用默认本机 HTTP 演示；公网或真实数据部署时必须由前置代理或部署层启用 HTTPS
NFR-SEC-010	限流实现边界必须如实说明	本期为进程内滑动窗口，适合单机/单进程演示；多进程共享限流属于非本期能力

7.3 可用性与可靠性需求

编号	需求	验收口径
NFR-REL-001	服务应提供健康检查	/api/health 可访问，返回 status、database、version；数据库异常显示 degraded
NFR-REL-002	关键写操作应保持事务一致	文档、片段和图谱联动失败时不得返回成功或留下半写入状态
NFR-REL-003	外部增强能力失败不得拖垮核心问答	无外部服务时本地问答仍可用；增强失败回退本地摘要或明确提示
NFR-REL-004	无命中、无权限和空数据应有明确结果	不得把业务性空结果伪装为服务器错误，不得生成虚假来源
NFR-REL-005	前端应处理网络、401、403、404、429 和服务器错误	有提示、可重试或可重新登录；不应出现无反馈白屏
NFR-REL-006	测试应使用隔离数据环境	自动化测试不得污染演示库；可重复执行

7.4 易用性需求

编号	需求	验收口径
NFR-USE-001	主导航应清晰	工作台、知识文档、站内问答、关系图、关于等核心入口可从主界面到达
NFR-USE-002	常用任务应简洁	核心业务一般可在 3 次点击内进入；问答提供示例问题辅助起步
NFR-USE-003	状态和反馈应可理解	加载、空列表、无权限、未找到、锁定、保存成功和删除成功均有中文反馈
NFR-USE-004	表单应明确标识必填项和枚举含义	密级、状态、角色和版本信息使用中文标签；错误提示定位到可修正的问题
NFR-USE-005	桌面布局应适配常见宽度	Chrome/Edge 常见窗口宽度下主要表单和表格可读、可操作

7.5 兼容性需求

编号	需求	验收口径
NFR-COMP-001	客户端兼容主流桌面浏览器	Chrome、Edge 近两年版本可完成登录、文档、问答和图谱主流程
NFR-COMP-002	服务端兼容 Windows 课程演示环境	Windows 10/11 x64 可启动 Flask 服务并访问前端
NFR-COMP-003	前后端开发与生产路径应明确	开发时 Vite 端口 5173 代理 /api 到 5000；构建产物由 Flask 在 /ui/ 托管
NFR-COMP-004	JSON 中文和 UTF-8 应正常	API 中文标签、问答内容、文档标题和来源不乱码
NFR-COMP-005	数据文件路径应可配置	数据库 URL、密钥、切分参数和限流参数可通过环境变量覆盖

7.6 可维护性需求

编号	需求	验收口径
NFR-MNT-001	前后端职责分离	Vue 负责展示和交互；Flask API 负责业务和授权；数据库访问集中在 ORM/服务层
NFR-MNT-002	权限判定集中化	文档可见性复用统一函数，避免各入口复制不同规则
NFR-MNT-003	配置外部化	SECRET_KEY、DATABASE_URL、切分参数、Top-K、登录阈值通过配置注入
NFR-MNT-004	代码结构清晰	路由、模型、服务、组件和样式按职责组织；关键业务有中文说明
NFR-MNT-005	文档与需求可追踪	需求编号、接口、用例、测试和验收锚点相互对应
NFR-MNT-006	具备自动化回归基线	截至 2026-10-31，项目记录 136 条测试全部通过；最终以验收重新执行结果为准

7.7 测试性需求

编号	需求	验收口径
NFR-TEST-001	测试应覆盖权限矩阵	公开、内部、机密、同部门、异部

编号	需求	验收口径
		门、作者、管理员、草稿等边界
NFR-TEST-002	测试应覆盖检索问答主路径	分词、切分、打分、Top-K、来源去重、无命中和权限过滤
NFR-TEST-003	测试应覆盖登录安全	限流阈值、锁定期间正确密码、窗口过期、成功清零、失败审计、密码哈希
NFR-TEST-004	测试应覆盖 API 和主流程	登录/退出、文档 CRUD、收藏、问答来源、图谱、管理员隔离和健康检查
NFR-TEST-005	测试结果应可重复	使用 pytest 和隔离数据库；测试前后演示数据不受影响

8 接口需求

8.1 用户界面需求

页面/路由	页面名称	主要能力	访问控制
/login	登录页	用户名密码登录、演示账号提示、错误显示	匿名可访问；已登录跳转工作台
/dashboard	工作台	可见范围统计、部门/分类图表、近期文档和问答、快捷问题	登录用户
/documents	知识文档	搜索、分类/部门/密级筛选、排序、分页、收藏状态	登录用户
/documents/new	新建文档	填写元数据、正文和标签，创建后同步索引与图谱	登录用户
/documents/{id}	文档详情	正文、元数据、来源标签、相关文档、收藏、编辑入口	有权查看该文档者
/documents/{id}/edit	编辑文档	修改正文和元数据，重建片段与图谱	作者或管理员
/qa	站内问答	示例问题、问题提交、回答、来源、历史列表	登录用户
/graph	知识关系图	力导向图、拖拽缩放、文档节点跳转、管理员维护入口	登录用户；维护仅管理员
/admin/users	用户管理	只读用户列表、角色/部门/文档数	管理员
/admin/audits	审计日志	动作、用户名、明细筛选，服务端分页	管理员
/about	关于系统	版本、技术栈、能力说明和可见范围统计	登录用户
未匹配路径	404 页面	提示页面不存在并返回主导航	公开可显示

界面要求：

108. 前后端调用使用同源 /api；Fetch 请求带 credentials: include，以保持会话 Cookie。

109. 页面加载、空数据、错误和提交中状态必须有视觉反馈。

110. 管理员入口仅对管理员显示，但服务端仍必须校验。

111. 文档列表默认每页 9 条；问答历史列表最多显示最近 20 条。

112. 图谱以 ECharts 力导向布局展示，支持拖拽、缩放、悬停和点击文档节点。

8.2 REST API 通用约定

项目	约定
基础路径	/api
数据格式	请求和响应均为 UTF-8 JSON；部分兼容表单字段
认证	服务端会话 Cookie；前端请求携带 credentials: include
成功状态	查询 200；新建 201；删除/切换等 200
错误结构	至少包含 error 文本；业务错误包含 code；可选 fields 字段级错误
时间格式	yyyy-MM-dd HH:mm:ss 或等价格式；不展示微秒
分页结构	pagination 包含 page、pages、total、per_page
认证错误	401 和 AUTH_REQUIRED；禁止访问为 403 和 FORBIDDEN
验证错误	400 和 VALIDATION_ERROR
资源不存在	404 和 NOT_FOUND

8.3 API 接口清单

方法	路径	权限	功能
GET	/api/meta	公开	返回产品名、版本、技术栈、部门、枚举标签和演示账号
GET	/api/health	公开	健康检查，返回服务状态、数据库状态和版本
GET	/api/auth/session	公开	返回当前会话用户或 null
POST	/api/auth/login	公开	用户名密码登录
GET	/api/auth/me	登录	返回当前用户
POST	/api/auth/logout	登录	退出并写入审计
GET	/api/dashboard	登录	工作台统计、图表、近期内容和快捷问题
GET	/api/documents	登录	文档列表、关键词检索、筛选、排序和分页
GET	/api/documents/favorites	登录	当前用户可见收藏列表
GET	/api/documents/{doc_id}	登录且有权查看	文档详情、相关文档和编辑能力标记
POST	/api/documents	登录	新建文档并同步片段/图谱
PUT	/api/documents/{doc_id}	作者或管理员	更新文档并重建片段/图谱
DELETE	/api/documents/{doc_id}	作者或管理员	删除文档并清理关联数据
POST	/api/documents/{doc_id}/favorite	登录且有权查看	收藏或取消收藏
GET	/api/categories	登录	分类列表及文档数
POST	/api/categories	管理员	新增分类
GET	/api/qa	登录	问答页示例问题、历史和增强模式状态
POST	/api/qa/ask	登录	权限内检索并生成带来源回答
GET	/api/qa/history/{history_id}	本人或管理员	问答历史详情
GET	/api/graph	登录	返回当前用户可见范围内的图谱节点和关系
GET	/api/graph/manage	管理员	返回近期节点、关系和节点类型
POST	/api/graph/nodes	管理员	新增图谱节点
POST	/api/graph/edges	管理员	新增图谱关系
GET	/api/admin/users	管理员	用户只读列表与汇总
GET	/api/admin/audits	管理员	审计筛选、分页和动作统

方法	路径	权限	功能
			计
GET	/api/about	登录	系统元信息与可见范围统计

8.4 请求与响应示例约束

113. 登录请求示例字段：username、password；成功响应包含 user 对象和 message。

114. 文档创建请求字段：title、content、summary、category_id、department、visibility、status、version、tags；成功响应包含 document 和 message。

115. 问答请求字段：question；成功响应包含 answer、mode、mode_label、history_id、sources、fragments。

116. 图谱节点请求字段：name、node_type、description；图谱关系请求字段：source_name、target_name、relation。

117. 审计查询参数：action、user、detail、page；响应包含 items、pagination、action_stats。

118. 错误响应至少包含 error；可选 code 用于程序判断；不得返回密码哈希、SECRET_KEY、外部服务密钥或 Python 堆栈。

8.5 软件与数据接口

接口/组件	类型	说明
Vue 前端 ↔ Flask API	HTTP/JSON	同源会话认证，Vite 开发时通过 /api 代理
Flask ↔ SQLite	SQLAlchemy	默认数据库 instance/knowledge.db；测试使用隔离数据库
Flask ↔ jieba	Python 库	中文分词、关键词提取和检索信号构造
Vue ↔ ECharts	前端库	力导向知识图谱渲染和交互
pytest ↔ Flask	测试框架	使用测试客户端和隔离数据执行自动化回归
外部增强服务	HTTPS/JSON（可选）	仅在显式配置时存在；不属于本期验收前置依赖，失败须降级

8.6 硬件与网络接口

119. 系统不依赖专用硬件；常规 PC 即可运行。

120. 默认后端监听 127.0.0.1:5000，Vite 开发服务监听 5173。

121. 局域网演示时应由运维人员明确绑定地址并限制访问范围。

122. 公网部署时必须增加 HTTPS、访问控制、独立密钥和相应运维措施；本期不对公网暴露作安全承诺。

9 异常处理

9.1 HTTP 状态与错误约定

条件	HTTP 状态	错误标识/表现	客户端处理
未登录访问受保护接口	401	AUTH_REQUIRED	清理会话状态并跳转登录页
用户名或密码错误	401	INVALID_CREDENTIALS	显示统一错误，不透露账号是否存在
登录失败达到阈值	429	返回 error 和 retry_after	显示剩余等待时间，禁用重复提交
已登录但角色或数据权限不足	403	FORBIDDEN	显示无权限提示，不展示资源内容
文档、历史或资源不存在	404	NOT_FOUND	显示不存在提示并提供返回入口
必填项为空、枚举非法、分类不存在、名称重复	400	VALIDATION_ERROR	在表单或提示条显示可修正信息
问答无命中	200	正常回答结构中的无命中提示	显示建议换问法或确认权限
外部增强服务不可用	200 或受控降级结果	本地模式或明确失败说明	保留本地问答结果，不展示密钥或堆栈
数据库不可用	健康检查 degraded；业务请求可能 500	统一错误响应	提示服务异常，运维查看日志
未处理服务器异常	500	通用错误文本	不展示裸堆栈；记录服务端日志并允许重试

9.2 主要业务异常

异常场景	业务处理
登录锁定期间提交正确密码	仍返回 429，不校验通过，不建立会话
登录失败后用户不存在	写入匿名登录失败审计，返回统一凭据错误
编辑或删除他人文档	返回 403，文档内容不变
查看他部门机密文档	返回 403；列表、检索、问答和图谱均不返回该文档
草稿/归档被普通用户访问	返回 403；作者/管理员允许
文档标题或正文为空	拒绝保存并返回 400
分类 ID 不存在	拒绝新建/更新文档并返回 400
分类名重复	拒绝新增分类并返回 400
图谱节点名为空	拒绝新增并返回 400
图谱关系端点为空	拒绝新增并返回 400
删除文档	清理片段、收藏、图谱节点和边；写入审计；失败则事务回滚
问答空问题	返回 400，不写入历史
问答无命中	返回明确无命中回答，不伪造来源
问答历史越权	普通用户访问他人记录返回 403
审计页码越界	自动收敛到最后有效页，返回有效分页信息
前端请求网络失败	显示错误提示，保留当前页面可重试状态

9.3 事务、审计与日志要求

123. 文档保存、片段重建、图谱同步和审计写入应在可回滚的事务边界内完成；任一步骤失败不得返回成功。

124. 审计日志是业务追溯记录，不由普通用户编辑或删除；本期不提供审计修改接口。

125. 登录失败、登录成功、退出、文档查看、文档创建/编辑/删除和问答均应有对应审计动作。

126. 同一用户 2 分钟内重复打开同一文档可去重 view_document 审计，避免刷新导致日志无限膨胀。

127. 服务端异常应记录到运行日志；面向用户的错误响应不得包含堆栈、文件绝对路径、数据库连接字符串和密钥。

128. 前端收到 401 后应清理本地会话状态并引导重新登录；收到 403 不得继续尝试展示缓存中的无权限正文。

9.4 容错与降级边界

129. 无外部大模型配置时，本地检索摘要模式是正常模式，不是系统故障。

130. 外部增强服务失败时，本地检索与摘要仍应可工作；若无法降级，应明确告知失败原因类别，不伪装成功。

131. 图谱无数据时返回空节点/关系集合，页面显示空状态，不返回 500。

132. 健康检查仅证明服务和数据库基本可访问，不证明所有业务功能、权限和问答质量均正常。

133. 登录限流状态在进程重启后清空属于当前单机实现边界，应在部署说明中明确。

10 需求追踪矩阵

10.1 业务目标基线

编号	业务目标
BR-01	将企业制度与业务资料统一沉淀为可分类、可检索、可维护的知识文档
BR-02	通过角色、部门、密级、作者和状态控制知识访问，防止越权
BR-03	在权限范围内提供检索增强问答，并以来源支撑回答
BR-04	通过知识关系图呈现文档、部门、分类和关键词之间的关联
BR-05	提供用户、分类、图谱和审计治理能力，形成可追溯闭环
BR-06	保证系统可构建、可启动、可检查、可重复测试并可按边界验收

10.2 功能需求追踪表

说明：实现状态统一按 V2.0 当前工程记录为“已实现”；验收状态为“待最终验收”，最终以课程验收时重新执行的构建、测试和人工检查为准。

功能需求	业务目标	主要用例	验收锚点	实现状态	验收状态
FR-AUTH-001	BR-02	UC-01	AT-AUTH-01	已实现	待最终验收

功能需求	业务目标	主要用例	验收锚点	实现状态	验收状态
FR-AUTH-002	BR-02	UC-01	AT-AUTH-02	已实现	待最终验收
FR-AUTH-003	BR-02	UC-01、UC-04、UC-05	AT-AUTH-03	已实现	待最终验收
FR-AUTH-004	BR-02	UC-01	AT-AUTH-04	已实现	待最终验收
FR-AUTH-005	BR-02	UC-01	AT-AUTH-05	已实现	待最终验收
FR-AUTH-006	BR-02	UC-01	AT-AUTH-06	已实现	待最终验收
FR-DOC-001	BR-01、BR-02	UC-02、UC-04	AT-DOC-01	已实现	待最终验收
FR-DOC-002	BR-01、BR-03	UC-03	AT-DOC-02	已实现	待最终验收
FR-DOC-003	BR-01、BR-02	UC-02、UC-04	AT-DOC-03	已实现	待最终验收
FR-DOC-004	BR-01	UC-02	AT-DOC-04	已实现	待最终验收
FR-DOC-005	BR-01	UC-02	AT-DOC-05	已实现	待最终验收
FR-DOC-006	BR-01	UC-02	AT-DOC-06	已实现	待最终验收
FR-DOC-007	BR-01、BR-02	UC-02、UC-04	AT-DOC-07	已实现	待最终验收
FR-DOC-008	BR-01、BR-05	UC-03	AT-DOC-08	已实现	待最终验收
FR-DOC-009	BR-01、BR-03、BR-04	UC-02、UC-03	AT-DOC-09	已实现	待最终验收
FR-QA-001	BR-03	UC-03	AT-QA-01	已实现	待最终验收
FR-QA-002	BR-02、BR-03	UC-03、UC-04	AT-QA-02	已实现	待最终验收
FR-QA-003	BR-03	UC-03	AT-QA-03	已实现	待最终验收
FR-QA-004	BR-03	UC-03	AT-QA-04	已实现	待最终验收
FR-QA-005	BR-03、BR-05	UC-03	AT-QA-05	已实现	待最终验收
FR-QA-006	BR-03	UC-03	AT-QA-06	已实现	待最终验收
FR-GRAPH-001	BR-02、BR-04	UC-06	AT-GRAPH-01	已实现	待最终验收
FR-GRAPH-002	BR-01、BR-04	UC-02、UC-06	AT-GRAPH-02	已实现	待最终验收
FR-GRAPH-003	BR-04、BR-05	UC-06	AT-GRAPH-03	已实现	待最终验收
FR-GRAPH-004	BR-04、BR-05	UC-06	AT-GRAPH-04	已实现	待最终验收
FR-ADMIN-001	BR-02、BR-05	UC-05	AT-ADMIN-01	已实现	待最终验收
FR-ADMIN-002	BR-01、BR-05	UC-02、UC-05	AT-ADMIN-02	已实现	待最终验收
FR-ADMIN-003	BR-05	UC-05	AT-ADMIN-03	已实现	待最终验收
FR-ADMIN-004	BR-02、BR-05	UC-04、UC-05	AT-ADMIN-04	已实现	待最终验收
FR-OPS-001	BR-06	UC-06、验收准备	AT-OPS-01	已实现	待最终验收
FR-OPS-002	BR-06	UC-01、验收准备	AT-OPS-02	已实现	待最终验收
FR-OPS-003	BR-06	异常处理	AT-OPS-03	已实现	待最终验收
FR-OPS-004	BR-06	验收准备	AT-OPS-04	已实现	待最终验收

10.3 非功能需求追踪

非功能需求组	关联业务目标	主要验证方式
NFR-PERF-001 至 NFR-PERF-005	BR-01、BR-03、BR-06	演示环境计时、分页边界检查、代码路径检查
NFR-SEC-001 至 NFR-SEC-010	BR-02、BR-05	自动化安全用例、权限矩阵、响应和配置检查
NFR-REL-001 至 NFR-REL-006	BR-06	健康检查、异常注入、构建和测试执行
NFR-USE-001 至 NFR-USE-005	BR-01、BR-03、BR-04	人工界面验收
NFR-COMP-001 至 NFR-COMP-005	BR-06	Chrome/Edge、Windows、JSON 和工作路径检查
NFR-MNT-001 至 NFR-MNT-006	BR-06	结构审查、配置检查、文档与自动化基线
NFR-TEST-001 至 NFR-TEST-005	BR-02、BR-03、BR-06	pytest 回归和隔离数据库检查

11 验收标准

11.1 验收前置条件

134. 项目代码、Vue 前端构建产物和 Flask 服务可在课程演示环境启动；

135. 数据库可初始化，演示账号和演示数据可用；

136. 验收组能够访问 /ui/ 前端和 /api/ 接口；

137. 使用虚构演示数据进行验收，不包含真实企业机密和个人敏感信息；

138. 验收时重新执行自动化测试，并记录版本、命令、通过数、失败数和环境；

139. 截至 2026-10-31 的测试基线为 136 条全部通过；该基线下文仅作为参考，最终以验收时结果为准。

11.2 验收锚点

验收锚点	验收内容	通过标准
AT-AUTH-01	登录成功与失败	正确凭据进入工作台；错误凭据被拒绝且无会话
AT-AUTH-02	退出与会话	退出后受保护接口返回 401；会话探测正确返回 null
AT-AUTH-03	角色授权	员工访问管理接口返回 403；管理员可访问
AT-AUTH-04	登录防爆破	阈值后返回 429；锁定期间正确密码被拒绝；窗口过期恢复
AT-AUTH-05	密码存储	数据库和 API 无明文密码；哈希校验可用
AT-AUTH-06	安全回跳	站内合法路径可用；站外和危险 URL 被拒绝
AT-DOC-01	文档列表	仅展示可见已发布文档；分页总数正确
AT-DOC-02	搜索与筛选	关键词、分类、部门、密级、排序和分页组合有效
AT-DOC-03	详情与相关推荐	详情权限正确；相关推荐不越权
AT-DOC-04	新建文档	必填校验、分类校验、保存、索引和图谱同步成功
AT-DOC-05	编辑文档	作者可更新；他人被拒绝；旧片段失效
AT-DOC-06	删除文档	作者可删除；片段、收藏、图谱清理；审计保留
AT-DOC-07	元数据与状态	三密级、三状态、标签、版本和部门规则生效
AT-DOC-08	收藏	收藏/取消切换、唯一性、权限过滤正确
AT-DOC-09	片段与图谱同步	新建可检索；编辑后重建；删除无孤儿数据
AT-QA-01	问题提交	有效问题返回回答、模式和历史 ID；空问题被拒绝
AT-QA-02	问答权限	异部门机密不进入候选、回答和来源
AT-QA-03	排序与去重	Top-K 生效；同文档最多贡献 2 个片段
AT-QA-04	来源展示	返回文档 ID、标题、部门和相关度；来源可追溯
AT-QA-05	历史	个人历史仅本人可见；管理员可查看详情

验收锚点	验收内容	通过标准
AT-QA-06	无命中与降级	无命中不伪造；外部增强失败可降级
AT-GRAPH-01	图谱浏览	ECharts 图可加载、缩放、拖拽；普通用户按权限过滤
AT-GRAPH-02	自动建图	文档、部门、分类、关键词和关系自动同步
AT-GRAPH-03	节点维护	管理员新增；空名称和员工操作被拒绝；同名不重复
AT-GRAPH-04	关系维护	管理员新增；空端点被拒绝；重复关系不重复创建
AT-ADMIN-01	用户列表	管理员能看到用户及文档数；无密码字段
AT-ADMIN-02	分类维护	分类列表正确；管理员新增；空名/重复名被拒绝
AT-ADMIN-03	审计日志	动作/用户/明细筛选有效；25 条分页总数正确
AT-ADMIN-04	管理隔离	匿名 401、员工 403、管理员可用，服务端生效
AT-OPS-01	健康检查	status、database、version 正确；异常显示 degraded
AT-OPS-02	工作台与元信息	统计按可见范围；版本为 2.0；无敏感配置
AT-OPS-03	错误处理	400/401/403/404/429/500 结构合理，无裸堆栈
AT-OPS-04	构建与测试	前端构建、Flask 启动、pytest 可执行；最终结果记录完整

11.3 端到端验收场景

编号	场景	操作摘要	期望结果
AC-01	登录与工作台	使用管理员登录，打开工作台	进入工作台；显示可见统计、近期文档和管理入口
AC-02	文档检索与查看	搜索“年假”，打开相关制度	目标制度排在合理位置；详情显示密级、部门、分类、标签和正文
AC-03	文档创建与检索	新建一篇已发布文档，搜索其正文关键词	文档可被检索；知识片段和图谱同步生成
AC-04	权限隔离	人事账号访问信息部机密；信息部账号再访问	前者 403，后者成功；列表、问答和图谱均不泄露
AC-05	检索增强问答	提问“员工年假有几天”	返回基于知识的回答；显示文档来源和相关度；历史可查
AC-06	无命中处理	提问知识库中不存在的内容	返回明确无命中提示，不伪造来源
AC-07	知识图谱	打开图谱，拖拽缩放并点击文档节点	图可交互；文档节点跳转正确；普通用户无越权节点
AC-08	管理员治理	查看用户、新增分类、按登录失败筛选审计	管理功能可用；筛选和分页正确；员工无权访问
AC-09	防爆破与回跳	连续错误登录；检查恶意 next 地址	达到阈值返回 429；危险回跳被拒绝
AC-10	健康与构建	访问健康检查；重新构建前端并启动	健康检查正常；/ui/ 可访问；验收测试可执行

11.4 测试基线与质量门禁

项目	基线/要求

项目	基线/要求
自动化测试	截至 2026-10-31 记录 136 条全部通过；最终验收必须重新执行并记录
测试隔离	测试使用隔离数据库，不修改演示库
权限测试	覆盖公开、内部、机密、同部门、异部门、作者、管理员、草稿/归档
问答测试	覆盖分词、切分、评分、Top-K、来源去重、无命中和权限过滤
登录安全测试	覆盖阈值、锁定、窗口过期、成功清零、失败审计和密码哈希
接口测试	覆盖认证、文档 CRUD、收藏、问答、图谱、管理隔离和健康检查
构建与启动	Vite 构建产物可由 Flask 在 /ui/ 提供；API 在 /api 提供
文档完整性	本文档、设计、测试和验收记录相互可追踪

11.5 阻断性验收条件

出现以下任一情况，应判定本轮验收不通过：

140. 未登录或无权限用户能够读取机密文档正文、标题、问答来源或图谱节点；
141. 员工能够通过直接请求管理 API 获得用户、审计、分类新增或图谱维护能力；
142. 密码明文存储、密码哈希被 API 返回，或错误响应泄露 SECRET_KEY；
143. 文档列表、搜索、问答或图谱对同一机密文档产生互相矛盾的权限结果；
144. 前端无法构建、后端无法启动、健康检查不可用，导致主流程无法演示；
145. 新建/编辑文档后索引未同步，使问答继续使用旧正文；
146. 问答无命中时伪造来源，或将无权限文档作为来源；
147. 验收执行时自动化测试存在未说明的失败，且影响 P0 需求。

11.6 验收结论规则

验收结论按“通过 / 有条件通过 / 不通过”记录：

结论	判定条件
通过	P0、P1 需求满足；无阻断性缺陷；验收测试全部通过或差异已获验收组确认
有条件通过	核心主流程可演示，但存在不影响权限安全和非 P0 主流程的已知问题，且有明确修复计划
不通过	存在任一阻断性验收条件，或核心功能无法完成演示

最终结论以课程指导教师和验收组现场检查、重新执行测试和签字结果为准。

附录 A 验收演示路径

建议按以下顺序演示，以在较短时间内覆盖主要能力：

148. 打开 /ui/ 登录页，使用管理员账号登录，进入工作台查看统计和快捷入口；

149. 打开知识文档，搜索“年假”，筛选分类或密级，进入相关制度详情；

150. 新建或编辑一篇文档，展示分类、标签、版本、密级和状态，并确认可立即检索；

151. 打开站内问答，提问“员工年假有几天”，展示回答、来源、相关度和历史；

152. 打开知识关系图，拖拽和缩放，点击文档节点进入详情；

153. 以人事账号打开信息部机密文档，确认 403；改用信息部账号确认同部门机密可访问；

154. 以管理员打开用户列表、分类维护和审计日志，演示登录失败筛选和分页；

155. 连续输错密码触发 429 锁定，再检查审计中的 login_failed 记录；

156. 访问 /api/health 展示健康状态和版本；

157. 重新执行前端构建与 pytest，记录最终验收结果。

附录 B 文档边界声明

158. 本文档描述 V2.0 的软件需求与验收基线，不把未纳入本期的功能写成已实现事实。

159. 当前系统是课程项目，不是生产级企业知识平台；SQLite、单进程限流和本地检索增强方案均有明确适用边界。

160. 外部大模型增强如存在，只是可选配置，不是核心验收依赖；核心问答能力以权限内检索、片段排序、摘要回答和来源展示为准。

161. 管理员用户列表为只读；分类维护为本期查询与新增；图谱维护为本期节点新增与关系新增；分类和图谱的编辑/删除不在本期范围。

162. 文档正文为演示性虚构内容，不代表任何真实企业制度、合同、安全规范或个人信息。

163. 任何新增需求、范围变更或验收口径变化，应通过修订记录更新本文档，并在测试和验收材料中同步追踪。

验收签署

角色	姓名/签字	日期	结论/备注
编制	项目作者（单人独立完成）	2026-10-31	提交评审
评审	课程指导教师/验收组	待验收	待填写
批准	课程验收责任人	待验收	待填写

文档结束：V2.0，2026-10-31。最终完成情况以课程验收结果为准。

第 3 部分　软件设计规格说明书

1 引言

1.1 编写目的

本文档在《系统需求说明书》与《用户需求说明书》的基础上，对 V2.0 系统的总体架构、分层职责、模块边界、关键流程、数据模型、REST API、安全控制、异常降级、性能和部署方式给出可实施、可检查的设计说明。文档重点回答以下问题：

164. 前后端如何分工，Vue 3 单页应用与 Flask 服务端页面如何共存；
165. 认证、角色、部门与文档密级如何共同决定访问范围；
166. 文档保存后如何生成知识片段、关键词与图谱节点；
167. RAG 问答如何做到权限先过滤、检索可解释、来源可追溯、外部模型失败可降级；
168. 数据表、接口、错误码与测试如何形成可追踪的工程闭环。

本文档既可作为开发实现的核对依据，也可作为测试用例设计、答辩演示和后续维护的基线。

1.2 设计范围

设计范围覆盖当前工作区中的可运行系统，包括：

- Vue 3、Vite、Vue Router、原生 CSS 与 ECharts 构成的前端；
- Flask 3 提供、挂载于 `/api` 的 REST API；
- Flask-Login 会话鉴权、SQLAlchemy ORM 与 SQLite 持久化；
- 文档管理、分类、收藏、RAG 问答、知识关系图、审计与只读用户管理；
- 原 Jinja 页面、Bootstrap 页面样式与 Flask 蓝图兼容层；
- 单机启动脚本、前端构建、健康检查、自动化测试与课程演示部署。

本期明确不包含完整向量数据库、生产级模型运维、微服务治理、Redis 共享缓存或限流、消息队列、容器编排、真实 OA/HR/AD/LDAP 接口、在线协同编辑和真实附件解析。代码中的 `uploads/`、文件扩展名白名单和 `documents.filename` 属于附件能力预留，当前新增与编辑文档以文本正文为主，尚不构成完整的上传解析链路。

1.3 适用读者与阅读建议

读者	重点关注章节
指导教师与评审人员	总体架构、关键流程、需求追踪、设计取舍
前端开发人员	前端分层、路由与状态、REST API、异常处理
后端开发人员	模块设计、数据库、权限、事务与降级
测试人员	权限矩阵、错误码、关键流程、测试支持
演示与运维人员	部署设计、配置项、启动脚本、健康检查、已知边界

1.4 参考文档

编号	文档	用途
R1	docs/02-用户需求说明书.md	用户需求与业务目标
R2	docs/03-系统需求说明书.md	SR-* 系统需求条目
R3	docs/uml/	用例、时序、活动、状态、类、ER、部署、构件与架构图
R4	README.md、frontend/package.json、requirements.txt	技术栈、依赖与运行说明
R5	app/、frontend/src/、tests/	当前实现的权威代码事实

1.5 术语与缩略语

术语	说明
SPA	Single Page Application，单页应用；本项目由 Vue 3 实现
REST API	以资源路径、HTTP 方法和状态码组织的 JSON 接口
RAG	Retrieval-Augmented Generation，检索增强生成
Chunk / 知识片段	文档切分后写入 knowledge_chunks 的检索单元
密级	public 公开、internal 内部、secret 机密
文档状态	draft 草稿、published 已发布、archived 已归档
角色	admin 管理员、employee 普通员工
会话	基于 Cookie 的 Flask Session，由 Flask-Login 维护登录态
图谱	以文档、部门、分类、关键词等为节点，以语义关系为边的可视化网络
兼容层	保留原有 Jinja 服务端渲染页面，保证旧入口可继续使用

1.6 设计约束与假设

169. **部署形态**：面向单机或局域网课程演示，默认监听 127.0.0.1:5000。

170. **持久化**：默认使用 SQLite 文件 instance/knowledge.db，通过 SQLAlchemy 访问；可由环境变量 DATABASE_URL 替换连接串，但当前未提供数据库迁移工具。

171. **进程模型**：当前运行方式是 Flask 自带服务器，通常为单进程；登录限流器保存在进程内存中。

172. **前端交付**：开发时 Vite 运行于 5173 并代理 /api；生产构建输出到 frontend/dist，由 Flask 在 /ui/ 提供。

173. **兼容策略**：REST API 与 Jinja 页面共享模型、RAG、图谱和权限判定逻辑，但保留两套控制器入口。

174. **演示数据**：首次建表由 seed_all() 创建演示用户、分类、文档、问答和审计数据；演示账号与内容均为虚构。

175. **外部模型可选**：未配置 `OPENAI_API_KEY` 时仅使用本地检索摘要；配置后才调用 OpenAI 兼容的 Chat Completions 接口。

176. **规模假设**：以课程演示与中小规模知识库为目标，不承诺互联网级并发、海量向量检索或多实例一致性。

2 设计目标与原则

2.1 设计目标

目标	设计落点
权限正确	文档列表、详情、问答、图谱、收藏和历史均以当前用户身份判定；机密文档不进入其他部门用户的检索候选集
前后端清晰	Vue 通过 JSON API 访问后端；Jinja 页面保留为兼容入口；共享业务服务不复制算法
知识可追溯	问答返回文档来源、部门、片段摘要和相关度，并保存到 `qa_history`
结果可解释	本地 RAG 使用分词重叠、关键词、标题、覆盖率和短语命中打分，不伪造大模型调用
失败可降级	没有大模型密钥时使用本地摘要；大模型失败时回退本地摘要并标记为本地模式
可演示、可复现	单机启动、自动建表、种子数据、健康检查、自动化测试与启停脚本齐备
易维护	应用工厂、蓝图、服务层、模型层与前端组件边界明确；配置走环境变量
诚实表达边界	不把预留能力描述为已实现，不在架构中虚构 Redis、向量库或微服务

2.2 设计原则

177. **最小权限原则**：访问控制在后端执行，前端隐藏菜单只承担界面提示，不作为安全边界。

178. **权限先于检索**：问答与图谱先计算当前用户可见文档集合，再在可见范围内读取片段或图结构。

179. **单一事实来源**：角色、密级、状态、动作标签集中定义；文档权限统一使用 `can_view_document()`。

180. **先可用后扩展**：用 SQLite、进程内限流和本地检索满足课程规模，同时通过接口和服务边界保留演进空间。

181. **显式优于隐式**：API 返回稳定字段与错误码；未命中、无权限、未登录分别返回明确结果。

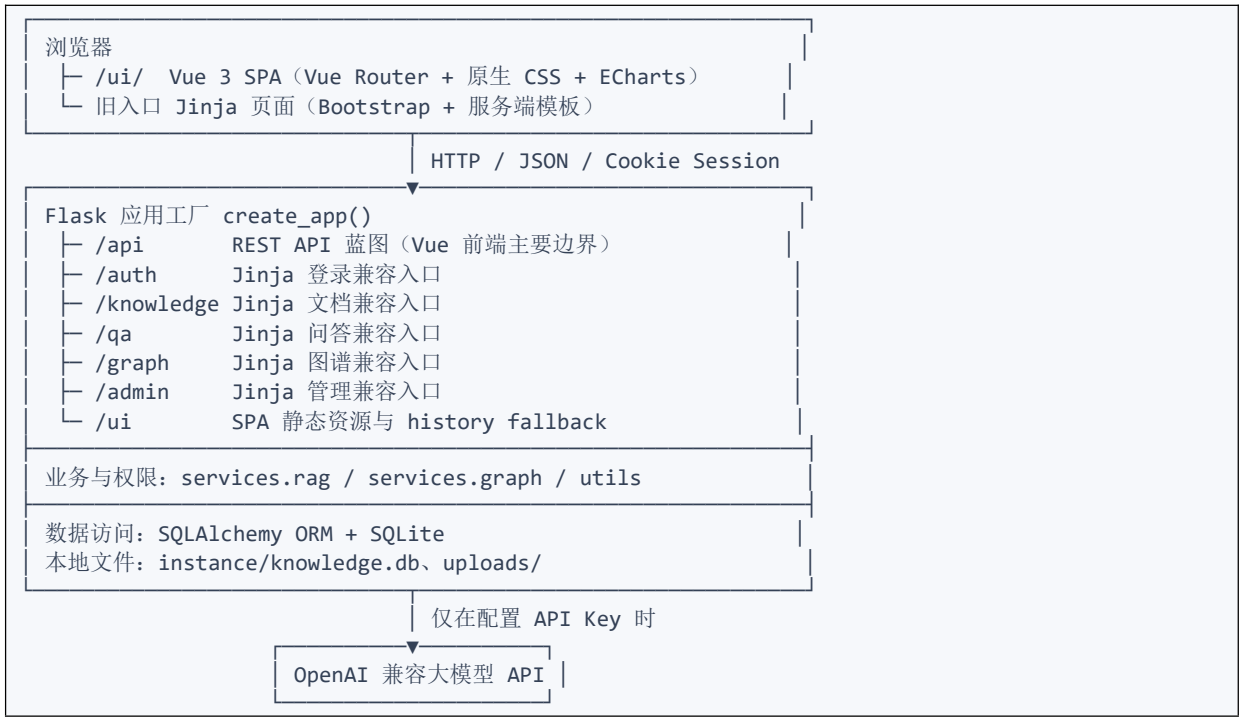
182. **渐进式分离**：V2.0 引入 SPA 与 REST API，但不立即删除旧页面，降低迁移风险。

183. **安全默认值**：密码只保存哈希；生产配置启用 Secure Cookie；会话 Cookie 默认 HttpOnly、SameSite=Lax。

184. **可验证性**：关键规则应有自动化测试，测试使用独立数据库，不污染演示库。

3 总体架构

3.1 运行拓扑



3.2 运行时组成

组成	当前实现	职责
主前端	`frontend/` 下 Vue 3 源码；构建产物位于 `frontend/dist`	页面渲染、路由、交互、图表、调用 REST API
SPA 容器	`app/spa.py`，前缀 `/ui`	返回构建后的 `index.html`、静态资源；前端 history 路由回退
REST API	`app/api.py`，前缀 `/api`	为 Vue 提供 JSON 资源接口、鉴权与错误码
兼容页面	`app/blueprints/*.py` 与 `app/templates/`	保留原有服务端页面、表单提交与旧地址
应用工厂	`app/__init__.py`	加载配置、初始化扩展、注册蓝图、错误页、过滤器与种子数据
业务服务	`app/services/rag.py`、`app/services/graph.py`	文档切分、检索、问答、图谱同步与过滤
数据模型	`app/models.py`	九张核心表的 ORM 映射与关系
扩展	`SQLAlchemy`、`LoginManager`	ORM、会话加载、登录保护
运行脚本	`run.py`、`start.ps1`、`stop.ps1`、`run_tests.ps1`	前台/后台启动、停止、测试
外部服务	OpenAI 兼容 Chat Completions	可选生成式回答，不是系统启动必需依赖

3.3 架构特征

185. **同源部署**：生产演示中 Vue、API、旧页面与静态资源都由同一 Flask 进程提供，浏览器请求天然同源，会话 Cookie 可直接随请求发送。

186. **双控制器、共享领域逻辑**：REST API 与 Jinja 蓝图分别适配 JSON 和 HTML，但二者复用 `models`、`services.rag`、`services.graph` 与 `utils`。

187. **无独立前端服务器依赖**：开发环境需要 Vite；生产运行只需要已构建的 `frontend/dist` 与 Flask。

188. **无跨服务事务**：系统没有微服务，数据库、文件与业务逻辑均在同一进程内；唯一外部写依赖是可选的模型 API，且模型调用不改变核心数据。

189. **有状态会话**：认证状态保存在 Flask Session Cookie 中，服务端通过签名 Cookie 读取当前用户，不采用 JWT。

3.4 UML 设计视图索引

项目现有 10 张 UML 图，分别覆盖需求、交互、状态、结构、数据与部署视图。本文档与这些图共同构成设计基线。

序号	UML 视图	设计用途	源文件	渲染图
01	用例图	参与者与系统功能边界	`../uml/01-用例图.puml`	`../uml/rendered/01-用例图.png`
02	登录时序图	登录、失败审计、限流与会话建立	`../uml/02-登录时序图.puml`	`../uml/rendered/02-登录时序图.png`
03	RAG 问答时序图	权限过滤、检索、生成、历史与审计	`../uml/03-RAG 问答时序图.puml`	`../uml/rendered/03-RAG 问答时序图.png`
04	文档发布活动图	表单校验、保存、切分、建图与审计	`../uml/04-文档发布活动图.puml`	`../uml/rendered/04-文档发布活动图.png`
05	文档状态图	草稿、已发布、已归档与删除边界	`../uml/05-文档状态图.puml`	`../uml/rendered/05-文档状态图.png`
06	类图	领域对象、关系与限流器结构	`../uml/06-类图.puml`	`../uml/rendered/06-类图.png`
07	ER 图	九张核心数据表及关系	`../uml/07-ER 图.puml`	`../uml/rendered/07-ER 图.png`
08	部署图	浏览器、Flask、SQLite、上传目录与可选模型服务	`../uml/08-部署图.puml`	`../uml/rendered/08-部署图.png`
09	构件图	页面、蓝图、服务、模型与数据库依赖	`../uml/09-构件图.puml`	`../uml/rendered/09-构件图.png`
10	三层架构图	UI、业务处理与基础服务层	`../uml/10-三层架构.puml`	`../uml/rendered/10-三层架构.png`

3.5 一次请求的典型路径

以 Vue 文档详情为例：

190. 浏览器访问 `/ui/documents/17`，`app/spa.py` 检测静态文件不存在后返回 `frontend/dist/index.html`。

191. Vue Router 匹配 document-detail，路由守卫先调用 session.bootstrap()。

192. session.bootstrap() 请求 /api/meta 与 /api/auth/session，确认登录态。

193. DocumentDetailView.vue 请求 /api/documents/17。

194. Flask 的 api_login_required 检查会话，document_detail() 读取文档并调用 can_view_document()。

195. 若允许访问，组装文档、相关文档、收藏状态和 can_edit；必要时写入查看审计。

196. 前端使用 Vue 模板插值渲染正文与来源，不把正文或模型回答当作未转义 HTML 注入。

4 前后端分层设计

4.1 分层总览

系统在逻辑上划分为表现层、接口/控制层、业务服务层、数据访问层和基础设施层。V2.0 同时存在 Vue SPA 与 Jinja 兼容页面，因此“表现层”包含两种渲染方式，但二者共享后端业务与数据规则。

层次	主要文件	主要职责	禁止事项
Vue 表现层	frontend/src/views、components、style.css	路由页面、表单、交互、ECharts、可访问性	不自行决定机密文档权限，不伪造后端成功结果
Jinja 兼容表现层	app/templates、app/static	旧页面的服务端渲染、表单、Bootstrap 样式	不在模板中实现检索与权限算法
接口/控制层	app/api.py、app/blueprints/*.py、app/spa.py	JSON 接口、HTML 路由、参数读取、状态码与响应编排	不复制 RAG/图谱核心逻辑
业务服务层	app/services/rag.py、app/services/graph.py、app/utils.py	可见性过滤、切分、评分、回答、图谱同步、登录限流	不依赖具体 Vue 组件或 Jinja 模板
数据访问层	app/models.py、app/extensions.py	表映射、关系、查询、会话	不拼接页面文案或前端路由
基础设施层	config.py、__init__.py、启动脚本、SQLite、可选模型 API	配置、应用生命周期、持久化、日志、部署	不隐藏不可用依赖或越权开放数据

4.2 前端分层

子层	当前设计
入口	main.js 创建 Vue 应用，安装 router，挂载 App.vue
根组件	App.vue 输出 RouterView 与全局 ToastHost
路由	router/index.js 定义懒加载页面、公共页、管理员页和全局守卫
布局	AppShell.vue 提供侧栏、顶部搜索、新建文档入口、角色菜单和退出
页面	views/*.vue 管理各自数据加载、表单状态、错误与交互
复用组件	PageHeader、BaseChart、EmptyState、StatCard、ToastHost、AppIcon
客户端 API	api/client.js 封装 fetch、JSON 序列化、

子层	当前设计
	credentials: include 与 ApiError
全局轻量状态	stores/session.js 管理用户与元信息； stores/toast.js 管理通知
样式	style.css 原生 CSS；未引入 Vue UI 组件库
图表	ECharts 按需注册 Bar、Graph、Pie、Grid、Legend、Tooltip 与 Canvas 渲染器

前端没有使用 Pinia、Vuex 或持久化状态插件。会话信息由一个 reactive 对象维护，页面数据主要保存在各页面的 ref/reactive 中。该设计适合当前页面数量与状态复杂度，降低依赖；若未来出现跨页面草稿、复杂缓存或离线能力，再考虑引入正式状态管理。

4.3 后端分层

197. **应用工厂**：create_app() 负责加载 .env、配置类、扩展、蓝图、错误处理、模板过滤器、数据库目录、上传目录及演示数据。

198. **API 控制器**：app/api.py 以 /api 为前缀返回 JSON；通过 api_login_required、api_admin_required 提供统一的 401/403 响应。

199. **兼容控制器**：auth、main、knowledge、qa、graph、admin 蓝图继续渲染 Jinja 页面，并保留原有表单语义和重定向。

200. **领域服务**：RAG 服务负责文档可见性、切分、评分、检索、回答、来源分组；图谱服务负责节点/边生成、同步、删除与 payload 组装。

201. **模型与扩展**：db 为全局 SQLAlchemy 实例，login_manager 为 Flask-Login 实例；用户加载器通过 db.session.get(User, id) 恢复当前用户。

202. **SPA 服务**：spa 蓝图只处理 /ui，不接管 /api 或旧页面；找不到静态文件时返回 index.html 以支持前端 history 路由。

4.4 依赖规则



允许控制器调用服务、服务调用模型；不允许模型反向依赖控制器，不允许模板直接执行数据库查询。REST API 与 Jinja 控制器可以共享服务函数，但应避免把 HTML 跳转、Flash 消息等页面语义放入共享服务。

4.5 SPA 与兼容层共存策略

入口	路径	渲染方式	状态
Vue 主界面	`/ui/`	静态 `index.html` + Vue 路由	V2.0 主入口
REST API	`/api/*`	JSON	Vue 使用的稳定边界
旧首页与业务页	`/`、`/dashboard`、`/knowledge/*`、`/qa/*`、`/graph/*`、`/admin/*`	Jinja 服务端渲染	兼容保留
健康检查	`/api/health`、`/health`	JSON	新旧入口均可检查
静态资源	`/ui/assets/*`、`/static/*`	Flask `send_from_directory` / 静态目录	分别服务 Vue 与旧页面

兼容层不是第二套数据库或第二套权限规则。文档、问答、图谱和审计继续写入同一数据库；文档可见性继续调用 `can_view_document()`。迁移时的主要风险是两个控制器入口的参数校验和响应格式可能出现差异，因此本次将 REST API 作为主要测试对象，同时对旧页面保留回归测试。

5 技术选型与理由

5.1 技术栈清单

技术	当前版本或约束	设计用途	选择理由	代价与边界
Vue 3	`^3.5.17`	组件化 SPA、响应式页面	组合式 API 清晰，生态成熟，适合课程展示	需要 Node.js 构建；前端状态需自行组织
Vite	`^5.4.11`	开发服务器与生产构建	启动快、配置简单、支持按路由拆分	生产需预先构建 `dist`
Vue Router	`^4.5.1`	History 路由、守卫、懒加载	与 Vue 3 原生配套，支持管理员路由元数据	深层路径依赖 Flask history fallback
原生 CSS	`frontend/src/style.css`	布局、组件视觉、响应式	不增加 UI 框架体积与版本负担，便于课程讲解	样式需要自行维护一致性
ECharts	`^5.6.0`	工作台图表与力导向关系图	图表类型全、交互强、中文资料多	图表库体积较大，需按需注册模块
Flask	`3.0.3`	HTTP 路由、应用工厂、Jinja	轻量、易读、适合 REST 与模板兼容	自带服务器不适合生产高并发
Flask-Login	`0.6.3`	登录态、用户加载、`current_user`	与会话机制集成自然	会话存储与多进程共享不是其职责
Flask-SQLAlchemy	`3.1.1`	ORM 与查询	领域模型清楚，减少手写 SQL	ORM 不替代索引与查询设计
SQLAlchemy	由扩展安装	数据映射、事务、关系	便于从 SQLite 演进到其他关系库	当前仍使用少量 SQLite 特性与文本查询
SQLite	默认 `instance/knowledge.db`	单机持久化	零安装、便于演示和打包	并发写、全文检索与大数据量能力有限
Werkzeug	`3.0.3`	密码哈希、URL 安全辅助	Flask 官方依赖，默认 `scrypt` 哈希	参数轮换与密码升级策略需另行设计
jieba	`0.42.1`	中文分词、关键词提取	本地运行、无需外部服务、可解释	非向量语义检索，同义词召回有限
python-dotenv	`1.0.1`	加载 `.env`	便于配置密钥与模型参数	生产密钥管理仍需外部安全措施

技术	当前版本或约束	设计用途	选择理由	代价与边界
ECharts Canvas	浏览器内置	图形渲染	兼容常见桌面浏览器	节点过多时布局与绘制成本上升
OpenAI 兼容接口	Python 标准库 `urllib` 调用	可选生成式回答	不强制 SDK，兼容 `/chat/completions` 风格接口	外部网络、费用、隐私与可用性风险

5.2 关键技术选择说明

5.2.1 为什么使用 Flask 而非微服务

课程项目功能规模有限，REST API、旧页面、静态文件、业务服务和数据库可在同一 Flask 应用内完成。单进程部署减少网络边界、服务发现、配置分发和分布式追踪成本，也便于在 Windows 本机一键演示。当前没有独立认证服务、文档服务或 RAG 服务，不应在文档中声称已经采用微服务架构。

5.2.2 为什么使用 SQLite

SQLite 文件天然适合课程演示：无需安装数据库服务，便于复制、备份和测试；SQLAlchemy 仍保留切换其他关系库的接口。系统规模较小时，列表、问答和图谱在 Python 层过滤均可接受。若数据量或并发增长，应优先增加数据库索引、全文检索或独立检索服务，而不是直接假设 SQLite 永久适用。

5.2.3 为什么使用关键词检索而非向量数据库

当前 RAG 使用 jieba 分词、关键词、标题、覆盖率和短语命中计算相关度，所有中间结果可解释，且不需要 embedding 模型、向量索引或额外基础设施。对于课程演示中的制度文本，这种轻量方案能够展示“权限过滤—片段检索—来源追溯—可选生成”的完整链路。它不擅长同义词、跨语种和深层语义匹配，这是明确的性能与效果边界。

5.2.4 为什么保留 Jinja 兼容层

V2.0 的目标是完成前后端分离，但项目原有页面、测试、演示脚本和内部链接已存在。通过保留 Jinja 页面，可以降低迁移期间的系统不可用风险，并为新旧实现对照提供依据。兼容层的代价是维护两套控制器；因此本次将共享服务、模型和权限函数集中，避免关键规则分叉。

5.2.5 为什么没有引入 Redis

登录限流当前使用模块级 `RateLimiter` 字典，适合单机、单进程课程环境。引入 Redis 会增加安装、配置、故障模式和演示复杂度，而当前没有多实例部署需求。代码注释已明确：多进程或多机部署必须改用共享存储，但该能力尚未实现，因此本文档不将其列为当前特性。

6 模块设计

6.1 认证、角色与权限模块

6.1.1 模块职责

认证权限模块负责用户名密码登录、会话建立与恢复、退出、角色判断、文档密级判断、管理员保护以及登录失败限流。REST 与 Jinja 共用同一个 `User` 模型和 `can_view_document()` 规则，但分别返回 JSON 错误或 HTML 错误页。

6.1.2 身份模型

属性	设计含义
`username`	登录标识，唯一且建立索引
`password_hash`	仅保存密码哈希，不保存明文
`display_name`	界面展示名称
`role`	`admin` 或 `employee`
`department`	用于机密文档部门隔离
`is_admin`	ORM 属性，判断 `role == "admin"`

角色只分管理员和员工，不在数据库中建立独立角色表、权限表或策略表。部门不是角色，而是用户属性，与文档 `department` 一起参与机密文档判定。

6.1.3 权限矩阵

操作	未登录	普通员工	管理员
查看公共/内部文档	否	是	是
查看同部门机密文档	否	是	是
查看其他部门机密文档	否	否（作者除外）	是
查看已发布文档列表	否	仅可见范围	全部
查看草稿/归档详情	否	仅本人作者	全部
新建文档	否	是	是
编辑/删除文档	否	仅本人作者	任意文档
收藏文档	否	仅可见文档	任意可见文档
查看个人问答历史	否	仅本人	本人或任意
查看图谱	否	可见文档范围	全量文档范围
新增图谱节点/边	否	否	是
查看分类	否	是	是
新增分类	否	否	是
查看用户列表	否	否	是
查看审计日志	否	否	是

6.1.4 文档可见性规则

`can_view_document(user, doc)` 的当前实现为：

```
若 user 为空：拒绝
若 user.is_admin：允许
若 doc.visibility == "secret"：
    允许当且仅当 doc.department == user.department 或 doc.author_id == user.id
```

```
若 doc.visibility == "internal": 允许
若 doc.visibility == "public": 允许
```

“公开”和“内部”都要求用户已经登录。系统的公开不是匿名公开；“public”表示登录用户之间均可访问，“internal”同样对所有登录员工开放，差别主要体现为业务标签和展示分组。若需要更细的部门内网、项目组或岗位级规则，需要扩展模型并修改统一判定函数。

6.1.5 已发布状态与访问状态的组合

列表和 RAG 检索使用 `searchable_documents(user)`：先只取 `status="published"` 的文档，再应用可见性过滤。详情接口在可见性检查之后，额外允许管理员或作者查看非发布文档；其他用户查看草稿或归档时返回 403。因此判断顺序为：

203. 文档是否存在；
204. 当前用户是否满足密级规则；
205. 文档是否已发布，或当前用户是否为作者/管理员。

6.1.6 会话与保护包装

- Flask-Login 使用 `login_user()` 建立会话，使用 `logout_user()` 清除会话；
- 用户加载器从 Session 中的用户 ID 调用 `db.session.get(User, int(user_id))`；
- API 的 `api_login_required` 未登录返回 HTTP 401 与 `AUTH_REQUIRED`；
- API 的 `api_admin_required` 未登录返回 401，已登录但非管理员返回 403 与 `FORBIDDEN`；
- Jinja 页面使用 `@login_required`，未登录由 Flask-Login 跳转登录页；
- 旧页面的管理员保护使用 `admin_required`，普通员工访问返回 403 错误页。

6.1.7 登录限流

`RateLimiter` 以客户端 `remote_addr` 为键维护时间窗口内的失败时间戳。默认阈值为 8 次、窗口 300 秒，可由 `LOGIN_MAX_ATTEMPTS` 与 `LOGIN_WINDOW_SECONDS` 配置。处理顺序是“先检查锁定，再校验密码”，因此锁定期间即使输入正确密码也会被拒绝。登录成功后清空该来源的失败计数。

当前限流器是模块级进程内单例，适用于单机演示；它不跨进程共享，也不在数据库中持久化。重启 Flask 会清空限流状态。多实例部署必须引入共享限流存储，或把限流迁移到网关层。

6.1.8 统计口径

权限不仅影响文档正文，也影响统计数字。当前实现的口径如下：

统计项	口径
工作台可见文档数、部门分布、分类分布	当前用户可见的已发布文档
工作台收藏数、问答总数、近 7 天问答	当前用户个人数据
工作台近期审计	仅管理员返回最近记录

统计项	口径
关于页文档数、Chunk 数	当前用户可见的已发布文档及其片段
关于页问答数	当前用户个人问答数
关于页节点/边数	当前为全库结构概览数字
REST 图谱节点/边	以当前用户可见文档节点为起点进行邻接过滤
分类接口的 `document_count`	当前为全库分类计数，不是按用户权限重算

上述统计口径需要在测试和演示时区分，避免把“全库结构概览”误解为“图谱接口没有权限过滤”。

6.2 知识文档模块

6.2.1 模块职责

文档模块负责列表、筛选、排序、分页、详情、新增、编辑、删除、收藏和分类读取。文档保存后还会触发知识片段重建、图谱同步与审计写入。

6.2.2 查询与筛选

REST 列表接口支持以下查询参数：

参数	默认值	规则
`q`	空	关键词检索标题、摘要、正文、标签
`category_id`	空	按分类 ID 过滤
`department`	空	按文档部门精确过滤
`visibility`	空	按 `public` / `internal` / `secret` 过滤
`sort`	`updated`	`updated`、`title`、`department`
`page`	`1`	最小为 1，超过总页数时夹到最后一页
`per_page`	`9`	最小 1、最大 50

先对 `searchable_documents(current_user)` 结果应用分类、部门和密级过滤，再执行关键词排序或普通排序。因为当前可见文档在 Python 列表中处理，所以过滤、排序和分页是应用层完成，未使用数据库全文索引。

关键词列表排序 `rank_documents()` 的权重为：

命中位置	加分
完整查询串命中标题	+20
完整查询串命中标签	+12
完整查询串命中摘要	+8
完整查询串命中正文	+4
查询词与标题分词重叠	每项 +3
查询词与标签分词重叠	每项 +2
查询词与摘要分词重叠	每项 +1

同分时按 `updated_at` 倒序。由于查询命中为 0 的文档不会进入结果，关键词检索是相关性筛选，而不是简单地把所有文档原顺序返回。

6.2.3 详情与相关阅读

详情接口返回文档正文、摘要、分类、部门、密级、状态、版本、标签、作者、时间、字数、片段数、收藏状态和 can_edit。同时调用 related_documents() 按同分类、同部门、标签重叠计分，取最多 4 篇可见的已发布文档作为相关阅读：

相关度信号	加分
同分类	+5
同部门	+2
共同标签	每个 +3

相关文档候选先取最近更新的 40 篇，再检查权限，避免先返回无权内容再由前端隐藏。

6.2.4 新增与编辑

REST 新增和更新共用 _apply_document_payload()：

206. title 与 content 去空白后必须非空；
207. category_id 必须为数字或空，若提供则分类必须存在；
208. 摘要优先使用请求值，截断到 500 字；为空则从正文自动截取；
209. 部门必须在固定部门列表内，否则保留原部门或回退当前用户部门；
210. 密级只接受 public / internal / secret，未知或空值回退 internal；
211. 状态只接受 draft / published / archived，未知或空值回退 published；
212. 版本为空时回退 1.0；
213. 标签可以传数组或逗号分隔字符串，最终存为逗号拼接文本；
214. 分类为空时允许“未分类”。

PUT /api/documents/<id> 采用全量更新语义：标题和正文必须重新提交，未提交的密级、状态等字段会按默认规则处理。Vue 编辑器会提交完整表单，因此正常使用不受影响；外部调用方必须按全量资源理解该接口。

6.2.5 保存后的派生数据

_finalize_document() 的顺序为：

215. db.session.flush() 获取新文档 ID；
216. rebuild_chunks_for_document() 删除旧片段、重新切分、提取关键词并提交；
217. sync_document_graph() 同步文档节点、部门、分类与关键词关系并提交；
218. 写入 create_document 或 edit_document 审计；
219. 最后再次提交并返回文档。

这种设计保证正常路径下片段和图谱与文档同步更新，但也意味着多个服务函数各自提交事务。当前没有跨步骤的补偿任务：若文档提交成功后图谱或审计阶段抛出异常，可能出现文档、片段、图

谱与审计的短暂不一致。演示规模下可通过重新保存文档触发幂等重建；生产化时应收紧事务边界、增加重试或一致性检查任务。

6.2.6 删除与收藏

- 删除前检查当前用户是管理员或文档作者；
- 调用 `remove_document_graph()` 删除文档节点及所有关联边；
- 由 Document 的 ORM 关系级联删除 `knowledge_chunks` 与 `favorites`；
- 写入 `delete_document` 审计后删除文档；
- 删除为硬删除，不进入回收站。

收藏采用“切换”语义：若当前用户已有收藏则删除，否则新增。数据库对 `(user_id, document_id)` 建立唯一约束，防止重复记录。收藏列表在读取时再次检查文档可见性，因此文档密级变化后，用户不会继续看到无权文档的收藏卡片。

6.2.7 分类

分类字段包括名称和说明。名称全局唯一。REST 接口提供分类读取和管理员新增分类；Jinja 兼容页也提供分类列表和新增表单。当前没有分类编辑、删除或合并 API，分类被文档引用时也不提供级联迁移操作。

6.2.8 附件与上传边界

配置中存在 `UPLOAD_FOLDER`、`MAX_CONTENT_LENGTH=16 MB`、`ALLOWED_EXTENSIONS={txt, md, pdf, docx}` 与 `Document.filename` 字段，但当前 REST 新增/编辑主要接收 `content` 文本，没有实现 PDF/DOCX 解析、文件上传端点或附件下载端点。因此本设计不把“附件管理”列为已完成能力。

6.3 RAG 问答模块

6.3.1 模块职责

RAG 模块负责把文档正文转换为知识片段、为片段提取关键词、按用户权限检索、计算相关度、提供本地摘要或可选大模型回答、返回来源并持久化问答历史。

6.3.2 文档切分

`chunk_text()` 的规则为：

220. 去除首尾空白，空文本返回空片段；
221. 以两个及以上换行符切分段落；
222. 段落合并到不超过 `CHUNK_SIZE`（默认 400）的缓冲区；
223. 单个超长段落按窗口切片；

224. 超长段落的相邻窗口使用 CHUNK_OVERLAP（默认 50）重叠；

225. 所有片段按顺序写入 knowledge_chunks，chunk_index 从 0 开始。

保存文档时会先删除该文档旧片段，再重新生成，因此重复编辑不会累积重复索引。knowledge_chunks.keywords 保存 jieba extract_tags 提取的前 8 个关键词，用逗号分隔。

6.3.3 分词与领域词

检索分词组合三类信号：

226. jieba.lcut() 得到的词典词；

227. 注册到 jieba 的领域补充词，如“年假”“差旅”“密钥轮换”“采购”“知识财富库”等；

228. 当分词结果为空时，使用连续汉字的相邻二字组作为兜底。

单个汉字会被过滤，以减少“的”“了”“是”等噪声。纯单字查询可能没有 token，此时仍可依赖完整短语子串命中。

6.3.4 片段评分

对每个候选片段，先计算：

```
content_hit = |问题词集合 ∩ 片段内容词集合|
kw_hit      = |问题词集合 ∩ 片段关键词集合|
title_hit   = |问题词集合 ∩ 标题词集合|
coverage    = content_hit / |问题词集合|（问题词集合为空时为 0）
```

基础得分为：

```
score = 1.0 × content_hit
      + 1.8 × kw_hit
      + 3.2 × title_hit
      + 2.0 × coverage
```

再叠加短语信号：

条件	加分
完整问题串出现在片段正文	+10
问题长度 ≥ 4 且前半部分出现在正文	+4
完整问题串出现在标题	+6
去掉句末疑问助词后的核心短语出现在正文	+5

评分逻辑的意图是“标题强相关、关键词次之、正文命中为基础、覆盖率奖励多词同时命中、完整短语作为强信号”。它不是 TF-IDF、BM25 或向量相似度，不应在论文或答辩中混淆表述。

6.3.5 权限先过滤

retrieve() 的执行顺序为：

229. 调用 searchable_documents(user) 得到当前用户可见的已发布文档；
230. 提取允许的 document_id 集合；
231. 只查询这些文档的 knowledge_chunks；
232. 对候选片段评分、排序；
233. 同一文档最多保留 2 个片段；
234. 截取 TOP_K（默认 5）个最终片段。

机密文档不会先进入候选再被前端隐藏，因此接口、日志和响应中都不会返回其他部门机密正文。

6.3.6 片段合并与来源

group_hits_by_document() 把片段按文档聚合，文档相关度取该文档命中片段的最高分，片段列表保留原文和 fragment_no/fragment_total。响应包含：

- fragments：按全局得分排序的片段数组；
- sources：按文档聚合的来源数组；
- document_id、title、department、score；
- 每个来源下的片段内容。

6.3.7 回答生成模式

模式	触发条件	回答生成	qa_history.mode
本地检索摘要	未配置 API Key，或无检索命中	拼接命中标题、摘要、来源、部门、相关度	local
大模型生成	配置 API Key 且有命中，调用成功	将命中片段作为上下文，调用 /chat/completions	llm
大模型失败降级	调用异常	返回失败说明并拼接本地摘要	local

本地回答会明确提示“当前为本地检索摘要模式”，不会伪装成大模型输出。系统提示词要求模型“只能依据给定资料回答，资料不足要说明，并指出依据文档标题”，但模型输出仍需用户核对来源。

外部请求使用标准库 urllib.request，向配置的 OPENAI_BASE_URL + /chat/completions 发送 Bearer Token，模型名由 OPENAI_MODEL 配置，temperature=0.2。当前实现调用超时为 60 秒；配置中的 OPENAI_TIMEOUT 尚未接入该调用参数，属于后续维护项。

6.3.8 问答历史

每次问答都写入 qa_history，保存用户、问题、回答、来源 JSON 字符串、模式和创建时间。sources 在数据库中是 TEXT，API 返回时尝试 json.loads()，解析失败则返回空数组。用户只能读取自己的历史，管理员可读取任意历史；越权返回 403。

6.4 知识关系图模块

6.4.1 图谱模型

图谱由 graph_nodes 和 graph_edges 两张表组成。节点名称全局唯一，类型包括：

类型	当前来源
document	文档自动同步，名称格式为 文档:<标题>
department	文档所属部门或种子数据
keyword	文档标签或正文关键词
concept	分类节点、手工概念节点及默认类型
project	种子数据或管理员手工维护

分类在业务上作为“分类节点”使用，但当前代码实际把其 node_type 设为 concept，没有单独的 category 枚举值。文档保存触发 sync_document_graph() 时：

235. 查找或创建文档节点；
236. 创建/复用部门节点，并建立“属于”边；
237. 若文档有分类，创建/复用分类名称的 concept 节点，并建立“分类为”边；
238. 读取文档标签；若没有标签，则从正文提取最多 5 个关键词并回填 doc.tags；
239. 最多取 8 个标签建立 keyword 节点和“含有”边；
240. 对同名节点复用，对同一三元组边通过应用层查询去重。

6.4.2 节点变更与删除

- 文档节点以 document_id 关联文档，标题变化时同步节点名称并清理旧名称冲突节点；
- 删除文档前显式删除其文档节点与所有入边/出边；
- ensure_edge() 在应用层检查 (source, target, relation) 是否已存在，但数据库没有对应唯一约束；
- cleanup_orphan_document_nodes() 可清理 document_id 指向不存在文档的节点，但当前启动流程未自动调用该清理函数；
- 管理端新增边时，如果起点或终点名称不存在，会以 concept 类型自动创建节点。

6.4.3 图谱权限过滤

REST /api/graph 的过滤算法为：

241. 读取完整节点和边；
242. 计算当前用户可见的已发布文档 ID；
243. 只把 document_id 位于可见集合的文档节点作为起始节点；
244. 保留任一端连接可见文档节点的边；
245. 把这些边的另一端部门、分类或关键词节点加入可见集合；
246. 最后只返回两端都在可见集合中的边。

这样不会把其他部门机密文档的标题、部门关系或关键词直接暴露给当前用户。过滤在应用层完成，不是数据库行级安全，也不保证全库图结构统计按用户隔离。

6.4.4 管理端维护

管理员可读取最近 60 个节点和 60 条边，新增节点或新增边。Vue 在 GraphView 中以模态框完成维护，避免单独的管理路由；Jinja 页面仍保留 `/graph/manage`。节点类型由前端提供 5 种选项，但后端新增节点时不会对 `node_type` 做严格白名单校验。

6.4.5 前端可视化

`BaseChart.vue` 按需注册 ECharts 模块，`GraphView.vue` 使用 `graph` 系列的 `force` 布局，支持拖拽、缩放、悬停邻接高亮、点击文档节点跳转详情。节点大小按类型区分，文档节点为 42，其余为 28；节点颜色由图谱服务返回。ECharts 图表在组件卸载时销毁并断开 `ResizeObserver`，降低内存泄漏风险。

6.5 审计模块

6.5.1 审计目标

审计模块用于回答“谁在什么时间对什么对象做了什么”。它覆盖登录、失败登录、退出、文档查看、文档创建、文档编辑、文档删除和智能问答。审计不作为业务数据的备份，也不能替代应用日志；它记录的是面向管理员追查的业务事件。

6.5.2 动作字典

action	中文标签	触发点	关键明细
login	登录	密码校验成功并建立会话后	用户名
login_failed	登录失败	用户不存在或密码错误	输入的用户名（可为空）
logout	退出	已登录用户主动退出	用户名
view_document	查看文档	文档详情成功访问	文档 ID 与标题
create_document	创建文档	文档保存事务完成	文档 ID 与标题
edit_document	编辑文档	编辑保存事务完成	文档 ID 与标题
delete_document	删除文档	删除提交前	文档 ID 与标题
ask_qa	智能问答	问答结果写入后	问题摘要

`audit_detail()` 统一拼接明细格式，例如“查看文档 #17 《员工年休假管理办法》”或“提问：员工年假有几天？”问题文本截断到 80 字，避免审计列表被超长问题撑开。

6.5.3 写入与去重

- 登录失败时即使用户名不存在也写入 `login_failed`，其中 `user_id` 为空；

- 同一用户对同一文档的重复打开，在 2 分钟内最多记录一次查看审计；查询最近 5 条 view_document 明细进行判断；
- 文档增删改在业务操作提交前后写入，明细包含文档 ID 与标题，便于文档删除后仍能追溯；
- 问答在 ask() 保存历史后写入审计；
- 退出先写审计再清除会话，确保退出事件不丢失。

6.5.4 查询与展示

管理员审计接口支持按动作、用户名、明细关键字筛选，固定每页 25 条，按 created_at DESC, id DESC 排序，并返回动作统计。动作筛选只接受动作字典中的值，未知动作被忽略，避免任意字段查询。普通员工访问管理接口返回 403。

审计详情中的用户名通过外连接关联 users 表；若用户不存在或匿名失败登录，展示“匿名/未知”。当前没有日志防篡改、哈希链、归档分区或保留期自动清理机制。

6.6 管理模块

6.6.1 用户管理

当前“用户管理”是只读列表：管理员可查看用户总数、管理员数、员工数，以及每个用户的文档数量。REST 接口为 GET /api/admin/users，Jinja 页面为 /admin/users。系统没有用户新增、编辑、停用、重置密码或角色变更接口；用户由种子数据或数据库级维护产生。

6.6.2 分类管理

管理员可新增分类，分类名称必填且不得重复。REST 为 POST /api/categories，旧页面为 /knowledge/categories 的 POST。当前无分类更新、删除、排序和批量迁移功能。

6.6.3 图谱维护

管理员可新增节点与边，查看最近节点/边列表。REST 为 /api/graph/manage、/api/graph/nodes、/api/graph/edges，旧页面为 /graph/manage。节点名称和边端点不能为空，边关系为空时默认“关联”。

6.6.4 审计管理

管理员可查看筛选后的审计列表、统计和分页。Vue 通过 AuditsView.vue 调用 GET /api/admin/audits，旧页面通过 /admin/audits 服务端渲染。

6.6.5 管理边界

管理功能以“课程演示可操作”为目标，不构建完整后台 RBAC 平台。用户不能在前端自助注册；管理员也不能在界面中创建用户。这样的取舍降低了用户生命周期管理的复杂度，但与生产系统的账号治理能力有明显差距。

6.7 前端路由与状态设计

6.7.1 路由表

路径	路由名	组件	访问条件	说明
/login	login	LoginView.vue	公共	已登录用户进入后跳转工作台
/	—	AppShell.vue	登录后	重定向到 /dashboard
/dashboard	dashboard	DashboardView.vue	登录后	工作台统计、图表、最近文档/问答/审计
/documents	documents	DocumentsView.vue	登录后	文档列表、筛选、分页、收藏视图
/documents/new	document-new	DocumentEditorView.vue	登录后	新建文档
/documents/:id	document-detail	DocumentDetailView.vue	登录后	文档详情、相关阅读、收藏、编辑/删除
/documents/:id/edit	document-edit	DocumentEditorView.vue	登录后，后端再次校验作者/管理员	编辑文档
/qa	qa	QaView.vue	登录后	智能问答与个人历史
/graph	graph	GraphView.vue	登录后	力导向图；管理员可打开维护模态框
/admin/users	users	UsersView.vue	管理员	用户列表
/admin/audits	audits	AuditsView.vue	管理员	审计筛选与分页
/about	about	AboutView.vue	登录后	系统信息与可见范围统计
/:pathMatch(.*)*	not-found	NotFoundView.vue	公共	前端 404

路由组件普遍使用动态 import()，Vite 构建时按页面拆分资源；BaseChart 和 ECharts 相关代码进入独立 chunk，避免所有页面首次加载同一大体积脚本。

6.7.2 路由守卫

router.beforeEach() 每次导航前执行：

247. 调用 session.bootstrap()；首次加载时请求 /api/meta 与 /api/auth/session；
248. 若目标不是公共页且没有用户，跳转 /login?redirect=<当前路径>；
249. 若目标是登录页但已有用户，跳转工作台；
250. 若目标声明 meta.admin 且用户不是管理员，跳转工作台；
251. 导航完成后设置浏览器标题。

前端守卫用于改善体验，不是权限边界；后端仍会对每个业务接口做身份和角色校验。

6.7.3 状态管理

状态	位置	生命周期	说明
当前用户、元信息、加载状态	stores/session.js	应用运行期	reactive 对象；bootstrap() 去重并发初始化
Toast 通知	stores/toast.js	应用运行期	数组状态，定时移除
文档列表筛选与分页	DocumentsView.vue	页面实例	与 URL query 同步，刷新可恢复
文档表单	DocumentEditorView.vue	页面实例	reactive 表单，提交前转换为 API payload
问答对话流	QaView.vue	页面实例	当前会话内消息数组，历史通过 API 读取
图谱数据与维护弹窗	GraphView.vue	页面实例	图谱 payload、管理节点/边表单
工作台、审计、用户、关于数据	各 View 的 ref	页面实例	每次加载重新请求，不做跨页缓存

状态设计避免把敏感文档正文长期放进全局 store。页面卸载后正文引用随组件释放；浏览器历史、URL query 只保存筛选条件，不保存正文。

6.7.4 API 客户端与错误传播

api/client.js 统一执行：

- 基础路径 /api；
- credentials: 'include'，使同源会话 Cookie 随请求发送；
- 有请求体时自动设置 Content-Type: application/json 并 JSON.stringify()；
- 根据 Content-Type 解析 JSON；
- 非 2xx 响应抛出 ApiError，保留 status 与 payload；
- 页面捕获错误后展示内联提示或 Toast。

当前没有全局 401 自动重定向拦截。页面导航依赖路由守卫；业务请求若在登录过期后返回 401，通常在页面内显示后端错误信息，用户可重新进入受保护页面触发守卫。

6.7.5 开发与生产路径

- 开发：npm run dev 启动 Vite，vite.config.js 把 /api 代理到 http://127.0.0.1:5000；
- 生产：npm run build 使用 base: '/ui/' 生成资源；
- Flask 的 /ui 蓝图返回 dist/index.html 与静态文件；
- 对 /ui/documents/17 等深层路径，找不到同名静态文件时回退 index.html，由 Vue Router 处理；
- dist/index.html 不存在时返回 HTTP 503 和构建提示，而不是空白页。

7 关键流程设计

7.1 登录流程

对应 UML：02-登录时序图、源文件。

7.1.1 主流程

252. 用户访问 `/ui/login`，前端读取 `/api/meta` 获取演示账号与系统信息；
253. 用户输入用户名、密码并提交；
254. `POST /api/auth/login` 先检查当前客户端地址是否被限流；
255. 若被锁定，返回 429、错误文字和 `retry_after`；
256. 若未被锁定，按用户名查询用户并调用 `check_password()`；
257. 验证失败：记录失败计数与 `login_failed` 审计，返回 401 和统一错误“用户名或密码错误”；
258. 验证成功：清空限流计数，调用 `login_user()` 建立会话；
259. 写入 `login` 审计；
260. 返回用户信息，前端切换到工作台；
261. 若存在 `redirect` query，前端只在前端路由内替换到站内路径。

7.1.2 异常分支

分支	行为
用户名为空或密码为空	前端本地提示；后端按无效凭据处理
用户不存在	不区分用户名与密码，返回 401，同时写失败审计
密码错误	返回 401，累计失败次数
达到阈值	后续请求优先返回 429，即使密码正确也不校验
会话已存在	登录页守卫直接转向工作台
旧页面登录	`safe_next_url()` 仅允许站内相对路径，拒绝 `http://`、`//host`、反斜杠、换行与空字符

7.2 文档创建/编辑流程

对应 UML：04-文档发布活动图、05-文档状态图。

262. 用户打开新建或编辑页面；
263. 新建时请求分类列表；编辑时先请求文档详情并检查 `can_edit`；
264. 用户填写标题、正文、摘要、分类、部门、密级、状态、版本和标签；
265. 前端做必填校验并转换标签数组；
266. API 再次校验标题和正文，不信任前端；
267. 校验分类存在、部门合法、密级和状态属于白名单；
268. 新建文档时写入作者 ID；编辑时校验当前用户为作者或管理员；

269. flush() 后重建知识片段；

270. 同步图谱节点与边；

271. 写审计并返回文档；

272. Vue 跳转详情页；旧页面通过重定向进入详情页并显示 Flash 消息。

7.2.1 状态流转

当前状态	操作	目标状态	约束
无	新建并选择 draft	草稿	作者或管理员可见
无	新建并选择 published	已发布	进入列表与 RAG 检索
草稿	编辑为 published	已发布	作者或管理员
已发布	编辑为 draft	草稿	立即退出普通用户的列表与检索
已发布/草稿	编辑为 archived	已归档	普通用户不再从列表/检索访问
任意	删除	记录删除	硬删除，图谱边同步清理

状态是由编辑表单显式选择的字段，不是审批工作流。系统没有发布审批人、定时发布、版本快照或回滚功能；“版本”目前只是文本字段，不会自动递增或保存历史版本。

7.3 RAG 问答流程

对应 UML：03-RAG 问答时序图。

273. 用户在 QaView 输入问题或点击示例问题；

274. 前端 POST /api/qa/ask；

275. API 校验问题非空；

276. ask() 调用 retrieve()；

277. retrieve() 先计算当前用户可见的已发布文档 ID；

278. 只查询这些文档的 knowledge_chunks；

279. jieba 分词并计算每个片段得分；

280. 排序后同一文档最多保留 2 个片段，截取 Top-K；

281. 若配置 API Key 且有命中，构造上下文调用大模型；

282. 若无 Key、无命中或调用失败，生成本地摘要；

283. 写入 qa_history，保存问题、回答、来源、模式；

284. 写入 ask_qa 审计；

285. 返回回答、模式、来源分组与原始片段；

286. 前端显示回答、来源折叠卡片和相关度；历史详情从 /api/qa/history/<id> 读取。

7.4 图谱同步与过滤流程

287. 文档保存成功后，sync_document_graph(doc) 被调用；

以 doc.id 查找现有文档节点，没有则创建；

标题改变时更新节点名称；

复用/创建部门节点，建立“属于”边；

有分类时复用/创建分类概念节点，建立“分类为”边；

读取标签；无标签时从正文提取关键词并回填文档标签；

为最多 8 个标签复用/创建关键词节点，建立“含有”边；

图数据接口读取完整图后，以当前用户可见文档节点为起点过滤；

返回节点、边、类型分类与样式信息给 ECharts；

用户点击文档节点时，前端按 document_id 进入文档详情，后端再次校验权限。

7.5 审计写入流程

审计写入不是一个独立异步服务，而是业务控制器在关键节点同步写入 audit_logs 并随业务提交。登录和多文档保存流程中存在多个提交点；设计上以“关键事件尽量不丢失”为目标，以同步简单性换取分布式事务的缺失。管理员查询审计时按动作、用户和明细筛选并分页，动作统计从全量 audit_logs 聚合。

8 数据库设计

8.1 数据库设计概述

数据库由 SQLAlchemy ORM 映射到 SQLite。核心表共 9 张：users、categories、documents、knowledge_chunks、graph_nodes、graph_edges、favorites、audit_logs、qa_history。所有主键为 SQLite 自增整数，时间字段使用 Python 本地时间 datetime.now() 写入无时区 DATETIME，展示格式统一为 YYYY-MM-DD HH:MM:SS。

数据库表在启动或种子初始化时通过 db.create_all() 创建，没有 Alembic 等迁移脚本；字段变更需要开发者在现有库上手工处理。ER 图见 07-ER 图。

8.2 通用约定

约定	说明
命名	表名和字段名使用小写蛇形命名
主键	id INTEGER PRIMARY KEY 自增
空值	除显式 nullable=False 外，多数可选字段允许 NULL；创建 API 通常写入空字符串默认值
枚举	角色、密级、状态、模式以字符串存储，当前由应用层字典校验，不使用数据库 CHECK 约束
时间	created_at、updated_at 默认本地时间；updated_at 在文档更新时自动刷新
布尔	SQLite 中以整数/布尔映射；实际业务主要用属性判断
删除	ORM 关系负责部分级联；图谱删除由服务显式清理；无软

约定	说明
	删除字段
外键	ORM 模型声明外键；SQLite 连接未显式执行 PRAGMA foreign_keys=ON，删除一致性主要依赖 ORM 和显式清理

8.3 users 用户表

字段	类型/长度	可空	默认/约束	说明
id	INTEGER	否	主键	用户 ID
username	VARCHAR(64)	否	唯一、索引	登录名
password_hash	VARCHAR(255)	否	—	Werkzeug 密码哈希
display_name	VARCHAR(64)	否	—	展示名
role	VARCHAR(20)	否	employee	admin / employee
department	VARCHAR(64)	否	综合部	部门名称
created_at	DATETIME	是	当前本地时间	创建时间

关系：一个用户可创建多篇文档、拥有多条收藏、产生多条审计和问答历史。用户名唯一索引是登录查询的主要索引。

8.4 categories 分类表

字段	类型/长度	可空	默认/约束	说明
id	INTEGER	否	主键	分类 ID
name	VARCHAR(64)	否	唯一	分类名称
description	VARCHAR(255)	是	空字符串	分类说明

关系：一个分类可关联多篇文档；文档的 category_id 可为空。分类删除没有专门接口，若直接删除会留下引用问题，需人工先处理文档引用。

8.5 documents 文档表

字段	类型/长度	可空	默认/约束	说明
id	INTEGER	否	主键	文档 ID
title	VARCHAR(200)	否	—	标题
content	TEXT	否	空字符串	正文
summary	VARCHAR(500)	是	空字符串	摘要
department	VARCHAR(64)	否	综合部	所属部门，用于机密隔离
visibility	VARCHAR(20)	否	internal	public / internal / secret
status	VARCHAR(20)	否	published	draft / published / archived
version	VARCHAR(20)	是	1.0	文本版本号
filename	VARCHAR(255)	是	空字符串	附件预留字段，当前未启用上传链路
tags	VARCHAR(255)	是	空字符串	逗号分隔标签
category_id	INTEGER	是	外键 categories.id	分类
author_id	INTEGER	是	外键 users.id	作者
created_at	DATETIME	是	当前本地时间	创建时间
updated_at	DATETIME	是	当前时间，更新时刷新	更新时间

关系：文档属于一个分类和一个作者；拥有多个知识片段、收藏、图谱文档节点。文档标题和正文是必填字段，摘要超长由应用截断。

8.6 knowledge_chunks 知识片段表

字段	类型/长度	可空	默认/约束	说明
id	INTEGER	否	主键	片段 ID
document_id	INTEGER	否	外键 documents.id，索引	所属文档
chunk_index	INTEGER	否	0	文档内序号
content	TEXT	否	—	片段正文
keywords	VARCHAR(500)	是	空字符串	逗号分隔关键词

关系：多个片段属于一篇文档，Document 关系配置 cascade="all, delete-orphan"。当前没有对 (document_id, chunk_index) 建唯一约束，重复重建时先删除旧记录，因此正常情况下索引有序且不重复。

8.7 graph_nodes 与 graph_edges 图谱表

8.7.1 graph_nodes

字段	类型/长度	可空	默认/约束	说明
id	INTEGER	否	主键	节点 ID
name	VARCHAR(100)	否	唯一	节点显示名称
node_type	VARCHAR(40)	否	concept	文档/部门/关键词/概念/项目
description	VARCHAR(255)	是	空字符串	说明
document_id	INTEGER	是	外键 documents.id	文档节点关联；非文档节点为空

8.7.2 graph_edges

字段	类型/长度	可空	默认/约束	说明
id	INTEGER	否	主键	边 ID
source_id	INTEGER	否	外键 graph_nodes.id	起点
target_id	INTEGER	否	外键 graph_nodes.id	终点
relation	VARCHAR(64)	否	关联	关系名称，如属于、分类为、含有

关系：节点分别通过 out_edges 与 in_edges 关联边，删除节点时 ORM cascade 删除相关边；服务层在删除文档节点时还会显式删除入边/出边。(source_id, target_id, relation) 当前没有数据库唯一约束，去重由 ensure_edge() 应用层完成。

8.8 favorites 收藏表

字段	类型/长度	可空	默认/约束	说明
id	INTEGER	否	主键	收藏 ID
user_id	INTEGER	否	外键 users.id	收藏用户
document_id	INTEGER	否	外键 documents.id	收藏文档
created_at	DATETIME	是	当前本地时间	收藏时间

唯一约束 uq_user_doc_fav：(user_id, document_id)。该约束保证一个用户不会重复收藏同一文档；收藏/取消收藏通过存在性查询切换。

8.9 audit_logs 审计表

字段	类型/长度	可空	默认/约束	说明
id	INTEGER	否	主键	审计 ID
user_id	INTEGER	是	外键 users.id	操作者；失败登录可能为空
action	VARCHAR(64)	否	—	动作代码
detail	VARCHAR(500)	是	空字符串	业务明细
created_at	DATETIME	是	当前本地时间	发生时间

关系：审计属于可选用户。当前没有时间、动作、用户的复合索引；审计列表按时间倒序查询，在演示数据量下可接受，数据量增长后应增加 (created_at, id) 或 (action, created_at) 索引。

8.10 qa_history 问答历史表

字段	类型/长度	可空	默认/约束	说明
id	INTEGER	否	主键	历史 ID
user_id	INTEGER	是	外键 users.id	提问用户
question	TEXT	否	—	问题原文
answer	TEXT	否	—	回答原文
sources	TEXT	是	空字符串	JSON 字符串形式来源列表
mode	VARCHAR(20)	是	local	local / llm
created_at	DATETIME	是	当前本地时间	提问时间

关系：一个用户可拥有多条问答历史。来源以 JSON 文本保存，未建立单独来源表；这简化了演示，但不便于按文档统计问答引用次数。

8.11 索引与约束汇总

表	主键	唯一/唯一索引	普通索引	外键
users	id	username	username	—
categories	id	name	—	—
documents	id	—	—	category_id、author_id
knowledge_chunks	id	—	document_id	document_id
graph_nodes	id	name	—	document_id
graph_edges	id	—	—	source_id、target_id
favorites	id	(user_id,	—	user_id、

表	主键	唯一/唯一索引	普通索引	外键
		document_id)		document_id
audit_logs	id	—	—	user_id
qa_history	id	—	—	user_id

8.12 数据关系说明

```
users 1 ── * documents
categories 1 ── * documents
documents 1 ── * knowledge_chunks
documents 1 ── * favorites
users 1 ── * favorites
users 1 ── * audit_logs
users 1 ── * qa_history
graph_nodes 1 ── * graph_edges（source）
graph_nodes 1 ── * graph_edges（target）
documents 0..1 ── 0..1 graph_nodes（document_id，逻辑关联）
```

graph_nodes.document_id 是普通外键，不是数据库强制的一对一约束；服务层通过“先按 document_id 查找”通常保证一个文档节点，但理论上仍可能出现多个节点。节点名称全局唯一，因此同名部门、关键词和概念会复用同一节点，这是图谱聚合的设计选择，也意味着不同业务语义同名时不能共存。

8.13 数据生命周期

297. 首次启动执行 db.create_all() 并通过 seed_all() 创建演示数据；
298. 新增文档先保存主记录，再生成片段、图谱与审计；
299. 编辑文档重建片段并同步图谱；
300. 删除文档删除主记录、片段、收藏、文档图谱节点及边；
301. 问答与审计持续追加，不自动归档；
302. 当前没有数据库备份、恢复、迁移或定期清理任务；演示环境通过复制 SQLite 文件实现最基础的备份。

9 REST API 设计

9.1 通用约定

项目	约定
基础路径	/api；/api 与 /api/ 等价
数据格式	请求和响应以 application/json 为主；表单请求也可通过 request.form 被 _json_body() 接收
字符编码	UTF-8；Flask JSON 设置 ensure_ascii=False，中文直接输出
命名	字段使用 snake_case，如 display_name、document_id、per_page
认证	浏览器同源 Session Cookie；Vue fetch 使用

项目	约定
	credentials: 'include'
时间	字符串格式 YYYY-MM-DD HH:MM:SS
成功	查询 200，创建 201，删除/切换等返回 200 与提示信息
错误	主要返回 {"error": "...", "code": "..."}；限流响应额外返回 retry_after
分页	文档使用 page、per_page；审计固定每页 25 条
权限	业务接口默认要求登录；管理接口要求 admin；资源接口还会做资源级检查

9.2 端点总表

#	方法与路径	认证	功能	成功	主要失败
1	GET /api、GET /api/	公共	API 元信息与 health 路径	200	—
2	GET /api/health	公共	数据库连通性健康检查	200	数据库异常时 status=degraded
3	GET /api/meta	公共	应用名、版本、技术栈、演示账号、部门、标签字典	200	—
4	POST /api/auth/login	公共	用户名密码登录	200	401 无效凭据、429 锁定
5	GET /api/auth/session	公共	查询当前会话；匿名返回 user: null	200	—
6	GET /api/auth/me	登录	查询当前用户	200	401
7	POST /api/auth/logout	登录	写退出审计并清除会话	200	401
8	GET /api/dashboard	登录	工作台统计、图表、最近文档/问答/审计、快捷问题	200	401
9	GET /api/documents	登录	可见文档列表、筛选、排序、分页	200	401
10	GET /api/documents/favorites	登录	当前用户可见收藏列表	200	401
11	GET /api/documents/<id>	登录	文档详情、相关阅读、收藏与编辑能力	200	401、403、404
12	POST /api/documents	登录	新建文档并切分、建图、审计	201	400、401
13	PUT /api/documents/<id>	登录	全量更新文档并重建派生数据	200	400、401、403、404
14	DELETE /api/documents/<id>	登录	删除文档及图谱、写入审计	200	401、403、404
15	POST /api/documents/<id>/favorite	登录	收藏/取消收藏切换	200	401、403、404
16	GET /api/categories	登录	分类列表与全库文档计数	200	401
17	POST /api/categories	管理员	新增分类	201	400、401、403
18	GET /api/qa	登录	建议问题、快捷问题、模型开关、最近 20 条个人历	200	401

#	方法与路径	认证	功能	成功	主要失败
			史		
19	POST /api/qa/ask	登录	权限内 RAG 问答、保存历史与审计	200	400、401
20	GET /api/qa/history/<id>	登录	问答历史详情与来源	200	401、403、404
21	GET /api/graph	登录	当前用户可见范围的图谱数据	200	401
22	GET /api/graph/manage	管理员	最近 60 节点、60 边、节点类型	200	401、403
23	POST /api/graph/nodes	管理员	新增或复用概念节点	201	400、401、403
24	POST /api/graph/edges	管理员	新增或复用节点并建立关系	201	400、401、403
25	GET /api/admin/users	管理员	用户列表、角色统计、文档计数	200	401、403
26	GET /api/admin/audits	管理员	审计筛选、分页、动作统计	200	401、403
27	GET /api/about	登录	系统信息、可见范围统计、个人问答数	200	401

说明：端点 11 的详情接口对可见但未发布的文档再检查作者或管理员身份；端点 19 不返回未命中片段的机密正文；端点 21 的图谱过滤发生在读取完整图之后，是应用层过滤。

9.3 认证接口示例

9.3.1 登录请求

```
POST /api/auth/login
Content-Type: application/json

{
  "username": "admin",
  "password": "admin123",
  "remember": false
}
```

成功响应：

```
{
  "user": {
    "id": 1,
    "username": "admin",
    "display_name": "系统管理员",
    "role": "admin",
    "role_label": "管理员",
    "department": "综合部",
    "is_admin": true,
    "created_at": "2026-10-31 10:00:00"
  },
  "message": "登录成功"
}
```

失败响应：

```
{
  "error": "用户名或密码错误",
  "code": "INVALID_CREDENTIALS"
}
```

锁定响应：

```
{
  "error": "登录失败次数过多，请 300 秒后再试",
  "retry_after": 300
}
```

9.3.2 会话查询

`GET /api/auth/session` 无论是否登录都返回 200：

```
{
  "user": null
}
```

或返回当前用户对象。前端通过该接口判断路由是否需要登录，而不是把 401 当作启动错误。

9.4 文档接口示例

9.4.1 列表请求

```
GET /api/documents?q=年假&category_id=1&department=人事部
&visibility=internal&sort=updated&page=1&per_page=9
```

响应结构：

```
{
  "items": [
    {
      "id": 12,
      "title": "员工年休假管理办法",
      "summary": "正式员工年休假天数、申请节点、跨年延期……",
      "department": "人事部",
      "visibility": "internal",
      "visibility_label": "内部",
      "status": "published",
      "status_label": "已发布",
      "version": "1.0",
      "tags": ["年假", "休假", "人事"],
      "category_id": 1,
      "category": "制度规范",
      "author_id": 2,
      "author": "人事专员",
      "created_at": "2026-10-20 09:00:00",
      "updated_at": "2026-10-25 14:30:00",
      "char_count": 860,
      "chunk_count": 3,
      "is_favorite": true
    }
  ],
  "categories": [
```

```
    {"id": 1, "name": "制度规范", "description": "公司制度"}
  ],
  "pagination": {"page": 1, "pages": 1, "total": 1, "per_page": 9},
  "filters": {
    "q": "年假",
    "category_id": 1,
    "department": "人事部",
    "visibility": "internal",
    "sort": "updated"
  },
  "departments": ["综合部", "人事部", "财务部"]
}
```

items 只包含当前用户可见且已发布的文档。categories 是分类字典；其 document_count 字段在分类接口中显示全库计数，不可等同于当前用户可见文档数。

9.4.2 新建请求

```
POST /api/documents
Content-Type: application/json

{
  "title": "API 自动化测试文档",
  "content": "第一段正文。\n\n 第二段正文。",
  "summary": "测试摘要",
  "category_id": 1,
  "department": "综合部",
  "visibility": "internal",
  "status": "published",
  "version": "1.0",
  "tags": ["API", "测试"]
}
```

成功返回 201：

```
{
  "document": {
    "id": 21,
    "title": "API 自动化测试文档",
    "summary": "测试摘要",
    "department": "综合部",
    "visibility": "internal",
    "status": "published",
    "tags": ["API", "测试"],
    "chunk_count": 1,
    "content": "第一段正文。\n\n 第二段正文。"
  },
  "message": "文档已创建"
}
```

9.4.3 更新和删除

PUT /api/documents/<id> 需要再次提交标题和正文，并通常提交完整元数据。成功返回 200 与 document、message。删除成功返回：

```
{
  "message": "文档已删除"
}
```

9.4.4 收藏切换

```
POST /api/documents/12/favorite
```

响应：

```
{
  "is_favorite": true,
  "message": "已收藏"
}
```

再次调用返回 `is_favorite: false` 与“已取消收藏”。

9.5 RAG 接口示例

请求：

```
POST /api/qa/ask
Content-Type: application/json

{
  "question": "员工年假有几天？"
}
```

响应：

```
{
  "answer": "根据企业知识库检索，针对「员工年假有几天？」整理如下：……",
  "mode": "local",
  "mode_label": "本地检索",
  "history_id": 31,
  "sources": [
    {
      "document_id": 12,
      "title": "员工年休假管理办法",
      "department": "人事部",
      "score": 18.6,
      "fragments": [
        {
          "score": 18.6,
          "chunk_id": 42,
          "document_id": 12,
          "title": "员工年休假管理办法",
          "content": "连续工作满 1 年不满 10 年的，年休假 5 天……",
          "department": "人事部",
          "fragment_no": 1,
          "fragment_total": 2
        }
      ]
    }
  ],
  "fragments": [
    {
      "score": 18.6,
      "chunk_id": 42,
      "document_id": 12,
      "title": "员工年休假管理办法",
      "content": "连续工作满 1 年不满 10 年的，年休假 5 天……",
      "department": "人事部",
```

```
      "fragment_no": 1,
      "fragment_total": 2
    }
  ]
}
```

实际响应中 fragments 与 sources 同时返回：fragments 是全局片段列表，sources 是按文档聚合后的来源列表。未命中时 answer 为“未在可访问的知识库中检索到相关内容”，mode 仍为 local。

9.6 管理接口筛选

审计接口参数：

参数	类型	说明
action	string	仅接受动作字典中的键
user	string	用户名模糊匹配
detail	string	审计明细模糊匹配
page	int	默认 1，超过总页数时夹到最后一页

响应包含 items、pagination、action_stats 和可选的动作字典。分页固定 per_page=25，不是客户端可任意放大。

9.7 状态码与错误码

HTTP	code	场景	前端处理
200	—	查询、更新、删除、切换、登录成功	使用响应数据
201	—	新建文档、分类、图谱节点/边成功	显示成功提示并刷新
400	VALIDATION_ERROR	必填字段缺失、分类不存在、名称为空/重复、端点为空	展示 error 与可选 fields
401	AUTH_REQUIRED	未登录访问受保护接口	提示登录；页面可跳转登录
401	INVALID_CREDENTIALS	用户名或密码错误	登录页内联提示
403	FORBIDDEN	角色不足、文档/历史无权、未发布文档	展示无权提示，不显示正文
404	NOT_FOUND	文档、问答记录不存在	展示不存在提示或返回列表
405	—	HTTP 方法不支持	由 Flask 返回方法不允许
429	—	登录失败次数达到阈值	展示重试秒数
500	—	未捕获的服务端异常	前端使用通用“请求失败（500）”
503	—	Vue 构建产物不存在时访问 /ui	显示前端尚未构建提示

API 中显式定义的业务错误码只有 AUTH_REQUIRED、INVALID_CREDENTIALS、FORBIDDEN、NOT_FOUND、VALIDATION_ERROR。当前没有全局 INTERNAL_ERROR JSON 包装；生产化时可统一异常处理器，避免返回 HTML 默认错误页。

9.8 错误响应示例

```
{
  "error": "只能编辑自己创建的文档",
  "code": "FORBIDDEN"
}
```

```
{
  "error": "标题与正文不能为空",
  "code": "VALIDATION_ERROR"
}
```

```
{
  "error": "文档不存在",
  "code": "NOT_FOUND"
}
```

10 安全设计

10.1 安全边界与威胁模型

本系统的安全目标依次是：防止未登录访问、防止跨部门读取机密文档、防止问答和关系图绕过文档权限、防止密码明文存储、降低登录爆破风险，并避免因开放跳转或模板注入导致客户端风险。系统主要面向课程演示与受控局域网环境，不宣称达到生产级安全合规要求。

主要信任边界如下：

```
不可信输入：浏览器参数、表单、JSON、导入的演示数据、外部模型回答
可信边界：Flask 服务端身份与权限判定、SQLAlchemy 参数化查询
外部依赖：OpenAI 兼容模型 API（可选、不可信返回）
```

10.2 会话安全

控制项	当前设计
会话技术	Flask 签名 Session Cookie + Flask-Login
会话密钥	SECRET_KEY 从环境变量读取；开发默认值仅用于本地演示
HttpOnly	SESSION_COOKIE_HTTPONLY=True，脚本不能直接读取 Cookie
SameSite	SESSION_COOKIE_SAMESITE="Lax"
Secure	生产配置 SESSION_COOKIE_SECURE 默认启用；开发默认不强制 HTTPS
有效期	PERMANENT_SESSION_LIFETIME 默认 43200 秒（12 小时）
用户恢复	Session 中用户 ID 经 user_loader 从数据库重新加载
退出	logout_user() 清除登录态，并写退出审计

生产部署必须替换默认 SECRET_KEY，并在 HTTPS 下启用 Secure Cookie。由于当前没有 Refresh Token、JWT 黑名单或服务端会话表，会话撤销依赖 Cookie 清除和密钥管理；多实例部署也不共享 Session，需另行规划。

10.3 密码存储

用户密码通过 generate_password_hash() 写入 password_hash，通过 check_password_hash() 校验。Werkzeug 3.0.3 默认使用带盐的 scrypt 方案。代码不会把明文密码写入数据库，演示账号密码只出现在种子定义与公开演示元信息中，属于课程展示便利，不应作为生产账号策略。

密码策略当前没有最小长度、复杂度、失败次数冻结账户、密码过期或历史密码校验。生产化时应补充口令强度策略、密码重置流程和哈希参数升级机制。

10.4 授权与文档密级

权限判定采用“身份 + 角色 + 部门 + 文档属性”的组合：

- 未登录用户不能访问业务 API 和页面；
- 普通员工可以访问所有 public / internal 文档；
- secret 文档只允许管理员、同部门员工或文档作者访问；
- 草稿/归档只在详情处对作者或管理员开放，普通列表和 RAG 只取已发布文档；
- 编辑、删除只允许作者本人或管理员；
- 收藏切换先校验文档可见性；
- 问答历史只允许本人或管理员；
- 管理接口通过 api_admin_required 或 admin_required 再次检查角色。

前端菜单隐藏和路由 meta.admin 只影响界面体验，不构成授权。任何用户都可以直接构造 HTTP 请求，因此所有敏感操作必须在后端重复判定。

10.5 检索与图谱的权限过滤

这是系统最关键的防泄漏设计：

303. **先计算文档集**：searchable_documents(current_user) 只返回已发布且 can_view_document 为真的文档；
304. **再查询片段**：RAG 只对允许的 document_id 查询 knowledge_chunks；
305. **再评分排序**：禁止把无权片段送入评分、模型上下文或响应；
306. **图谱从文档节点出发**：只把有权限文档节点作为起点，再纳入直接相连的部门、分类、关键词节点；
307. **前端不作为安全边界**：即使前端隐藏来源，后端也不会返回无权内容。

该规则由 tests/test_security.py、tests/test_rag.py 与 tests/test_api.py 覆盖，包括“其他部门机密不可检索”“同部门可见”“作者可见”“管理员可见”等场景。

10.6 登录防爆破

登录限流采用按 IP 的滑动窗口：

- 默认 300 秒窗口、8 次失败；
- 达到阈值后返回 429，并给出 retry_after；
- 锁定判断先于密码校验；
- 登录成功清除当前来源计数；
- 失败登录写审计，便于管理员发现异常。

限制与风险：

308. 进程内字典不跨进程共享，多进程会形成各进程独立阈值；

309. 只按 remote_addr 计数，部署在反向代理后必须正确配置可信代理头，否则所有用户可能共享代理 IP；

310. 没有验证码、账户冻结或全局 IP 黑名单；

311. 当前无 Redis，不能宣称支持分布式限流。

10.7 防开放重定向

旧登录页支持 next 参数，safe_next_url() 的安全规则为：

312. 空值返回 None；

313. 必须以单个 / 开头；

314. 拒绝 // 开头的协议相对 URL；

315. 拒绝反斜杠、换行、回车和空字符；

316. 通过 urlparse() 再拒绝带 scheme 或 netloc 的地址；

317. 拒绝路径再次以 // 开头。

Vue 登录页的 redirect 只提交给 router.replace()，并检查以 / 开头；后端认证接口不直接执行浏览器跳转，因此不会形成服务端开放重定向。前端仍不应把任意外部 URL 当作路由目标。

10.8 注入、XSS 与模板安全

风险	当前措施	剩余风险
SQL 注入	SQLAlchemy ORM 参数绑定；仅健康检查使用固定 SELECT 1	手写 SQL 扩展时仍需使用绑定参数
Jinja XSS	Jinja 默认自动转义；页面不直接输出未转义用户 HTML	具体模板若使用 safe 需单独审查
Vue XSS	正文和模型回答使用模板插值，按文本渲染	ECharts tooltip 对节点名进行 HTML 字符串拼接，生产需转义
路径穿越	SPA 只通过 send_from_directory	上传目录尚未提供下载接口

风险	当前措施	剩余风险
	返回 dist 内文件	
外部模型注入	系统提示词限定“仅依据资料回答”，来源随回答返回	模型回答仍可能被恶意文档诱导，需人工核对
CSRF	同源 SPA、SameSite=Lax、JSON 请求	当前没有独立 CSRF Token；生产需补充

10.9 CSRF 与跨域

Vue 使用 credentials: 'include' 发送会话 Cookie。开发时 Vite 代理使 /api 与前端同源；生产时 Flask 同时提供 /ui 与 /api，也是同源。系统没有配置 Flask-CORS，不主动允许跨域携带 Cookie。

SameSite=Lax 能降低多数跨站 POST 请求携带 Cookie 的风险，但不能替代 CSRF Token。当前 API 没有 Flask-WTF 或自定义 CSRF 校验；如果未来把前端与 API 分域部署，或引入第三方页面调用，应在所有状态变更接口增加 CSRF 防护、严格 Origin 校验和显式 CORS 白名单。

10.10 会话、密钥与部署安全

318. 生产环境通过 .env 或系统环境变量提供 SECRET_KEY、DATABASE_URL、模型密钥；
319. 不把 .env、数据库文件、日志或上传文件提交到公共仓库；
320. 生产配置启用 Secure Cookie，演示 HTTP 环境不要误开；
321. 反向代理应终止 HTTPS，限制请求体大小，并设置安全响应头；
322. MAX_CONTENT_LENGTH 为 16 MB，可降低超大请求的风险，但当前并没有完整附件端点；
323. 公开 /api/meta 会返回演示账号名称和密码，这是课程演示功能，生产部署应移除或加环境开关。

10.11 审计与隐私

审计包含用户名、文档标题、问题摘要等业务信息。管理员可以查看审计，普通用户不能访问审计列表。问答历史与审计均未实现自动脱敏、加密存储和保留期删除。对于真实企业数据，应评估个人信息、机密标题和模型上下文外发的隐私影响。

10.12 安全测试关注点

- 未登录访问 /api/documents、/api/qa、/api/graph 返回 401；
- 普通员工访问 /api/admin/* 返回 403；
- 其他部门机密文档的列表、详情、RAG 和图谱均不可见；
- 作者可查看自己的草稿，非作者不可查看；
- 连续失败达到阈值后，正确密码仍被 429 拒绝；

- 失败登录写入审计，且用户名不存在时也留痕；
- `safe_next_url()` 拒绝 `//evil.example`、`https://evil.example`、反斜杠、换行；
- 密码字段不是明文，哈希可由 `check_password_hash()` 校验；
- 访问不存在的文档返回 404，不泄露标题或正文。

11 异常与降级设计

11.1 异常处理原则

324. **输入错误尽早返回**：空标题、空正文、空问题、非法分类在控制器层直接返回 400/JSON 或表单提示；
325. **权限错误不降级为成功**：无权限返回 403，不能返回空列表假装成功；
326. **资源不存在返回 404**：避免用 500 暴露内部异常；
327. **外部依赖失败可降级**：大模型不可用时回退本地摘要；
328. **页面与 API 分开处理**：Jinja 使用 Flash + 错误模板；REST 使用 JSON 错误码；
329. **异常信息不无限扩散**：生产模式不应把堆栈返回给用户。

11.2 异常场景表

场景	检测点	当前行为	恢复方式
登录用户名/密码错误	`check_password()`	401 + 统一提示 + 失败审计	重试；次数过多等待窗口
登录被限流	`is_locked_from_request()`	429 + `retry_after`	等待窗口结束或重启演示进程
未登录访问 API	`api_login_required`	401 + `AUTH_REQUIRED`	登录后重试
非管理员访问管理 API	`api_admin_required`	403 + `FORBIDDEN`	使用管理员账号
无权读取机密文档	`can_view_document()`	403，不返回正文	申请同部门权限或联系管理员
文档不存在	`db.session.get()`	404 + `NOT_FOUND`	返回列表
标题/正文为空	`_apply_document_payload()`	400 + `VALIDATION_ERROR`	补齐字段
分类重复	查询唯一名称	400 + 分类名称已存在	使用现有分类
问答无命中	`retrieve()`	本地回答说明未检索到内容	换问法或补充文档
未配置模型 Key	`call_llm_answer()`	本地摘要，`mode=local`	无需处理
模型调用失败	`except Exception`	回答中附失败说明并回退本地摘要，`mode=local`	检查网络/密钥/模型地址
来源 JSON 损坏	`json.loads()`	API 返回空来源列表，页面仍可看回答	修复历史数据
数据库不可用	`/api/health`、`/health`	返回 `status=degraded`、`database=false`	检查文件权限与连接串
Vue dist 不存在	`/ui` 检查 `index.html`	503 + 构建提示	在 `frontend` 执行构建
未知前端路径	SPA fallback	返回 `index.html`，由 Vue 404 视图处理	返回有效页面
Flask 未捕获异常	Flask 默认处理	生产返回通用 500/HTML；前端显示请求失败	查看服务端日志

11.3 大模型降级设计

外部模型是可选增强，不是系统主路径。降级逻辑必须满足：

- 没有 `OPENAI_API_KEY`：不发起外部请求；
- 没有命中片段：不调用模型，直接返回本地无结果说明；
- 调用超时、网络错误、返回结构异常：捕获异常，生成“失败说明 + 本地摘要”；
- 模式标记为 `local`，前端显示“本地检索摘要模式”；
- 不把失败回答标记为 `llm`；
- 不因模型失败回滚已完成的文档检索或问答历史。

当前实现会把异常文本拼入回答，这在课程演示中便于排错，但生产环境可能泄露内部网络地址或服务端信息。正式部署应将详细异常写入服务端日志，只向用户返回通用降级提示。

11.4 SPA 与 API 分离状态下的异常

Vue 客户端用 `ApiError` 统一承载 HTTP 状态和 JSON payload。页面处理策略为：

场景	页面表现
列表加载失败	内联错误面板或 Toast
409/400 保存失败	表单错误提示，不跳转
403 详情	错误提示，不显示正文
401 会话过期	页面显示登录提示；重新导航触发路由守卫
404	返回文档列表或显示不存在
图表无数据	空状态，不显示空 canvas 假象

前端没有全局自动刷新 token，因为系统不使用 JWT/Refresh Token；会话过期需要用户重新登录。

11.5 事务与一致性异常

当前文档保存链路包含多次 `commit()`，不是严格的单一原子事务。异常恢复策略为：

330. 若主文档未提交，数据库回滚后无残留；
331. 若主文档已提交但片段/图谱阶段失败，重新保存同一文档可触发片段重建和图谱同步；
332. 若审计写入失败，业务数据可能已写入，需通过应用日志和服务端检查补齐；
333. 删除文档前先清理图谱，若数据库失败，需要人工检查 `graph_nodes` 与 `graph_edges` 是否残留；
334. `cleanup_orphan_document_nodes()` 已存在但未自动执行，可作为人工维护工具。

生产化建议将“文档主记录、片段、图谱、审计”放入同一事务或引入补偿任务，但本次不虚构已实现的分布式事务。

12 性能设计

12.1 性能目标

系统主要面向课程演示与中小规模知识库，目标不是互联网级高并发。可接受的目标为：

场景	目标	依据
登录、工作台首屏	本机演示下快速返回	数据量小，查询简单
文档列表	演示规模下 ≤ 3 秒	Python 过滤与分页；单页最多 50
文档详情	演示规模下 ≤ 3 秒	单文档 + 相关文档 + 片段计数
本地 RAG	演示规模下 ≤ 5 秒	jieba 首次加载较慢，后续缓存分词词典
关系图	首次可交互，允许布局抖动	ECharts force 布局
单页数据量	文档默认 9，最大 50；审计固定 25	控制 DOM 与响应体

12.2 后端性能机制

335. **索引**：用户名唯一索引、分类名称唯一、图谱节点名称唯一、收藏联合唯一、Chunk 文档索引；

336. **限制结果**：文档 `per_page` 上限 50；问答 Top-K 默认 5；同文档最多 2 个片段；审计每页 25；

337. **权限过滤前置**：问答只查询可见文档的片段，避免无关片段进入评分；

338. **不加载全量历史**：问答页只取最近 20 条，详情单独请求；

339. **ECharts 前端渲染**：关系图不在后端计算布局；

340. **健康检查轻量**：执行固定 `SELECT 1`，只判断连接是否可用。

12.3 当前性能瓶颈

环节	现状	影响
文档列表	先加载所有已发布可见文档，再在 Python 过滤/排序/分页	数据量增大后内存与排序成本上升
关键词检索	列表层逐文档分词与字符串匹配	文档多时 CPU 消耗增加
RAG 检索	对可见文档的全部片段加载并逐个评分	片段数大时耗时明显
图谱过滤	先读取全图，再在 Python 过滤	节点/边多时首屏和内存成本较高
审计查询	只有主键和用户外键，时间与动作无复合索引	大数据量分页需要优化
jieba 初始化	首次分词需加载词典、注册领域词	首个问答/检索请求延迟较高
ECharts	力导向布局与大量节点交互	节点过多时掉帧；当前未设置节点上限
文档保存	同步重建片段、图谱和审计	保存响应受分词与图同步耗时影响

12.4 前端性能机制

- 路由级动态 `import()`，按页面拆分；
- ECharts 按需注册图表与组件，避免引入完整包的所有能力；

- `BaseChart` 使用 `ResizeObserver` 自适应容器，卸载时 `dispose()`；
- 文档列表每页 9 条，避免一次渲染大量卡片；
- 页面对请求状态设置加载/错误状态，避免重复提交；
- 图形交互使用 Canvas 渲染，适合较多节点；
- 长文本详情只在当前页面展示，不进入全局状态。

12.5 性能测试建议

测试	方法	关注指标
登录响应	连续发起登录与失败登录	平均耗时、429 触发
文档列表	分页 1/10/100，关键词查询	返回时间、内存、页数夹取
本地 RAG	10～50 个问题、不同命中数	Top-K、来源准确性、响应时间
同文档去重	构造长文档多片段	每篇最多 2 片段
图谱渲染	100/500/1000 节点	首屏、拖拽、缩放流畅度
保存同步	长文本新建/编辑	切分数量、图谱边变化、耗时

12.6 扩展方向（未实现）

如未来数据规模增长，可考虑：为文档状态、部门、密级和审计时间增加索引；引入 SQLite FTS5 或独立全文检索；将评分迁移到数据库或检索服务；为图谱接口增加服务端分页/子图查询；增加缓存或任务队列。上述均为演进方向，不是当前已实现能力。

13 部署设计

13.1 部署形态

V2.0 采用单机部署：一个 Flask 进程同时提供 Vue 构建后的静态 SPA、REST API、旧 Jinja 页面和 SQLite 数据库文件。该形态适合课程演示、单机开发和局域网功能验证，不采用容器编排、反向代理集群或独立前端服务器。

```
客户端浏览器
   │ HTTP :5000
   ▼
Flask 应用（单进程）
   ├─ /ui/*        frontend/dist
   ├─ /api/*       REST API
   ├─ 旧页面        Jinja 模板
   ├─ SQLAlchemy   instance/knowledge.db
   └─ uploads/     预留文件目录
```

13.2 目录与运行产物

路径	作用
`run.py`	前台启动入口，默认 `127.0.0.1:5000`
`start.ps1`	后台启动；检查虚拟环境、必要时构建前端、写入 PID 和

路径	作用
	日志
stop.ps1	停止后台进程
run_tests.ps1	运行 pytest
frontend/	Vue 源码、依赖与 Vite 配置
frontend/dist/	生产静态构建产物，由 Flask /ui 提供服务
app/	Flask 应用、模板、静态资源、模型与服务
instance/	SQLite 数据库、PID、启动输出与错误日志
uploads/	文件上传预留目录
docs/	需求、设计、UML、用例、测试与项目管理文档
tests/	自动化测试与公共夹具

13.3 开发环境启动

后端：

```
python -m venv .venv
.\.venv\Scripts\python.exe -m pip install -r requirements-dev.txt
.\.venv\Scripts\python.exe run.py
```

前端：

```
cd frontend
npm install
npm run dev
```

开发时访问 Vite 的 http://127.0.0.1:5173，/api 请求代理到 http://127.0.0.1:5000。也可以直接访问 Flask 的旧页面进行兼容验证。

13.4 课程演示/单机运行

```
.\start.ps1
# 或指定端口与绑定地址
.\start.ps1 -Port 5000 -BindHost 127.0.0.1
```

start.ps1 的关键行为：

341. 检查 .venv\Scripts\python.exe；
342. 若 frontend/dist/index.html 不存在且系统有 npm.cmd，自动执行 npm install 与 npm run build；
343. 检查端口占用与已有 PID；
344. 生成仅供启动使用的 instance/_boot_server.py，设置 debug=False、use_reloader=False；
345. 以隐藏窗口后台启动 Flask；
346. 将进程 ID 写入 instance/server.pid；
347. 标准输出和标准错误分别写入 instance/server.out.log、instance/server.err.log；

348. 默认入口提示为 http://127.0.0.1:5000/ui/。

停止：

```
.\stop.ps1
```

该启动方式是“课程演示单机服务”，不是生产级进程管理器。当前依赖中没有安装 Gunicorn、Waitress、Nginx 或容器运行时，因此不能声称已经具备生产 WSGI 部署。

13.5 访问路径

路径	部署结果
/ui/	Vue 应用入口；dist/index.html
/ui/documents/17	SPA history fallback，由 Vue Router 处理
/api/*	JSON REST API
/、/dashboard、/knowledge/* 等	旧 Jinja 页面
/static/*	旧页面使用的 Flask 静态文件
/api/health	API 健康检查
/health	旧入口健康检查

13.6 配置项设计

配置	默认值/来源	作用	备注
FLASK_ENV / APP_ENV	default	选择默认/测试/生产配置	testing、production
SECRET_KEY	开发默认值	签名 Session	生产必须改为随机强密钥
DATABASE_URL	sqlite:///instance/knowledge.db	数据库连接串	支持由环境覆盖
UPLOAD_FOLDER	<project>/uploads	上传预留目录	当前无完整上传链路
MAX_CONTENT_LENGTH	16 MB	请求体上限	固定配置
OPENAI_API_KEY	空	是否启用大模型	空则本地摘要
OPENAI_BASE_URL	https://api.openai.com/v1	兼容接口基址	可指向兼容服务
OPENAI_MODEL	gpt-4o-mini	模型名	由兼容服务支持
OPENAI_TIMEOUT	30	预留超时配置	当前 RAG 调用实际使用 60 秒
CHUNK_SIZE	400	切分窗口	影响片段数量
CHUNK_OVERLAP	50	超长段落重叠	降低边界截断
TOP_K	5	最终片段数	每篇文档最多 2 个
SESSION_LIFETIME	43200 秒	会话有效期	由 PERMANENT_SESSION_LIFETIME 使用
SESSION_COOKIE_SECURE	生产默认 1	Secure Cookie	开发 HTTP 不应误开
LOGIN_MAX_ATTEMPTS	8	登录失败阈值	进程内限流
LOGIN_WINDOW_SECONDS	300	失败计数窗口	进程内限流
AUTO_SEED	默认 1，生产配置 0	是否自动灌演示数据	当前 create_app() 仍直接调用 seed_all()，该开关尚未在调用链中生效

13.7 数据库与文件部署

- 首次启动 seed_all() 调用 db.create_all()，创建表并补充种子数据；
- SQLite 文件位于 instance/knowledge.db，需确保进程对目录有读写权限；
- 演示数据可以通过复制数据库文件带走，但复制前应停止写入；

- `uploads/` 当前为预留目录，不是完整附件存储；
- 若需要迁移到其他主机，应同时复制数据库和应用配置，避免只复制代码导致密钥变化、会话失效；
- 当前没有自动备份、恢复、迁移或数据库压缩任务。

13.8 可选模型服务的部署要求

只有在设置 `OPENAI_API_KEY` 后才需要外部网络。调用地址由 `OPENAI_BASE_URL` 决定，运行时向 `${BASE_URL}/chat/completions` 发送 POST。部署时需考虑：

349. 出口网络和 DNS 是否可达；
350. API Key 不写入源码或前端；
351. 调用失败是否允许回退本地摘要；
352. 数据是否允许发送到第三方模型服务；
353. 超时、限流和费用是否可接受。

未配置密钥时，系统不需要任何外部 AI 服务即可完成登录、文档管理、本地检索、问答、图谱和审计。

13.9 生产化差距

差距	当前状态	生产化建议
WSGI 服务器	使用 Flask 自带服务器	使用成熟 WSGI 服务器或容器平台
反向代理与 HTTPS	未内置	Nginx/Ingress 终止 TLS，配置安全头
多进程 Session	Cookie 可工作，但限流不共享	使用共享 Session/限流存储
数据库	SQLite 单文件	按规模评估 PostgreSQL 等
迁移	`create_all`	引入版本化迁移工具
可观测性	文件日志 + health	指标、追踪、集中日志与告警
备份	手工复制	定时备份、恢复演练与保留策略
附件	目录与字段预留	上传校验、杀毒、解析、权限下载

14 可维护性与测试支持

14.1 可维护性设计

354. **应用工厂**：`create_app(config_class)` 可注入测试、生产或默认配置，便于测试隔离与部署差异；
355. **蓝图划分**：认证、主页面、文档、问答、图谱、管理、SPA 各自有明确前缀；
356. **共享服务**：RAG 与图谱逻辑集中在 `services`，REST 和 Jinja 共用，减少规则漂移；
357. **集中字典**：部门、角色、密级、状态、动作、模式等标签集中在 `utils.py`；

358. **配置外置**：密钥、数据库、模型、切分参数走配置类与环境变量；

359. **组件化前端**：页面、布局、图表、空状态、Toast 分离，路由懒加载；

360. **文档与测试同步**：需求编号、接口路径、UML 文件和测试文件可相互追踪。

14.2 代码目录与职责

目录/文件	维护职责
app/__init__.py	应用生命周期、扩展、蓝图、错误处理、种子调用
app/config.py	默认/测试/生产配置
app/models.py	九张表及关系
app/api.py	Vue 使用的 REST 接口与 JSON 负载
app/blueprints/	旧页面控制器
app/services/rag.py	切分、分词、评分、检索、问答
app/services/graph.py	图谱同步、去重边、过滤 payload
app/utils.py	密级、角色、审计文案、限流、安全跳转、管理员装饰器
frontend/src	Vue 页面、组件、API 客户端、路由、轻量状态
tests/	API、登录安全、RAG、权限、系统回归
docs/	需求、设计、UML、用例、测试、项目管理

14.3 测试策略

当前测试以 pytest 为主，测试数据库使用独立内存 SQLite 或临时文件，避免触碰 instance/knowledge.db。tests/conftest.py 提供会话级 app、事务回滚、管理员客户端、全新临时库等夹具。

测试文件	覆盖重点
tests/test_api.py	Vue REST API 契约、登录/退出、文档 CRUD、收藏、搜索、问答、图谱、管理员接口
tests/test_login_security.py	限流窗口、锁定与恢复、成功清零、失败审计、密码哈希、审计文案
tests/test_rag.py	切分、重叠、关键词、评分权重、权限内检索、每文档最多两片段、Top-K、来源分组
tests/test_security.py	密级矩阵、草稿排除、统计口径、开放重定向、分页与审计筛选
tests/test_system.py	建库、种子数据、页面路由、旧系统冒烟与回归

截至本文档编写时，测试目录中共有 120 个 test_ 测试函数（API 12、登录安全 19、RAG 32、安全 34、系统 23）。文档不把“存在测试函数”表述为“测试已通过”；实际结果应以执行 run_tests.ps1 或 pytest 的输出为准。

14.4 测试支持设计

系统为测试提供以下便利：

- TestingConfig 使用内存 SQLite，关闭 CSRF 副作用并保留登录保护；
- fresh_app 夹具可创建临时数据库并执行完整种子流程；
- 测试客户端可直接登录、调用 REST 与旧页面；

- 种子用户覆盖管理员与多个部门，便于验证密级隔离；
- 服务函数可单独测试切分、评分、权限和来源合并；
- health 接口可快速判断数据库连接。

14.5 日志与可观测性

- Flask 应用日志写入标准输出/错误，`start.ps1` 重定向到 `instance/server.out.log` 与 `instance/server.err.log`；
- `/api/health` 与 `/health` 提供数据库连通性；
- 启动脚本记录 PID，便于停止和排障；
- 审计日志记录业务事件，不替代系统运行日志；
- 当前未集成指标、分布式追踪、错误聚合或告警。

14.6 已知实现边界与技术债

项目	当前事实	影响与建议
AUTO_SEED	配置存在，但 create_app() 未按开关短路	生产需先修正调用逻辑，再依赖该开关
数据库迁移	仅 create_all()	字段升级需手工迁移，建议引入 Alembic
保存事务	片段/图谱/审计多次提交	异常时可能短暂不一致，建议统一事务或补偿
图谱边唯一性	仅应用层去重	并发下可能重复，建议唯一约束
图谱统计	部分统计为全库口径	需在 UI 标注范围或改为权限内统计
分类管理	无更新/删除接口	完整分类治理需补齐
附件	目录/字段/扩展名预留	未实现上传解析，不应在答辩中宣称完成
模型异常	失败详情拼入回答	可能泄露内部信息，生产应改为通用提示
模型超时	OPENAI_TIMEOUT 未接入	实际 urlopen 使用 60 秒
CSRF	无独立 Token	SameSite Lax 仅为基础缓解
全局错误	API 无统一 500 JSON 包装	前端可能只能显示通用错误
ECharts tooltip	HTML 字符串拼接节点名	生产需转义节点名或使用安全 formatter
全文检索	无 FTS/向量索引	规模增大后性能与召回受限

15 需求到设计追踪

15.1 需求簇追踪矩阵

需求簇	设计章节	主要实现	REST/页面入口	数据表	测试/UML
SR-AUTH-001	§6.1、§7.1、	app/api.py、app/blueprints/auth.py、extensions.py	/api/auth/login、/api/auth/session、/api/auth/logout、/auth/*	users、audit_logs	test_api.py、UML 02

需求簇	设计章节	主要实现	REST/页面入口	数据表	测试/UML
～003 登录、会话、退出	§10.2				
SR-AUTH-004 角色菜单	§6.1、§6.7	utils.py、router/index.js、AppShell.vue	meta.admin、/api/meta、/api/auth/me	users	test_api.py、test_security.py
SR-AUTH-005～006 文档权限与403	§6.1、§10.4、§10.5	services/rag.py:can_view_document、API 守卫	/api/documents/*、/knowledge/*	documents	test_security.py、test_api.py、UML 01
SR-AUTH-007 关键动作审计	§6.5、§7.1、§10.11	AuditLog、各控制器	/api/admin/audits、/admin/audits	audit_logs	test_login_security.py、test_security.py
SR-AUTH-008 密码哈希	§10.3	User.set_password/check_password	登录流程	users.password_hash	test_login_security.py
SR-AUTH-009 登录防爆破	§6.1.7、§10.6	RateLimiter、configure_login_limits	/api/auth/login、/auth/login	进程内存，无表	test_login_security.py
SR-DOC-001	§6.1.4、§6.2.	searchable_documents()	GET /api/documents、/knowledge/	documents	test_security.py、test_api.py

需求簇	设计章节	主要实现	REST/页面入口	数据表	测试/UML
可见已发布列表	2				
SR-DOC-002 关键词检索	§6.2.2、§6.3.4	rank_documents()、_tokenize()	GET /api/documents?q=	documents	test_security.py、test_rag.py
SR-DOC-003 分类/部门/密级筛选	§6.2.2	API 查询参数过滤	GET /api/documents	documents、categories	test_api.py
SR-DOC-004 文档详情	§6.2.3	_doc_payload()、related_documents()	GET /api/documents/<id>	documents、knowledge_chunks	test_api.py、UML 05
SR-DOC-005 新建编辑删除	§6.2.4～6.2.6、§7.2	_apply_document_payload()、_finalize_document()	POST/PUT/DELETE /api/documents	documents	test_api.py、UML 04/05
SR-DOC-006 保存后切分	§6.2.5、§6.3.2	rebuild_chunks_for_document()	文档保存内部	knowledge_chunks	test_rag.py
SR-DOC-007 保存	§6.2.5、§6.4.1	sync_document_graph()	文档保存内部	graph_nodes、graph_edges	test_system.py、UML 06/10

需求簇	设计章节	主要实现	REST/页面入口	数据表	测试/UML
后同步图谱					
SR-DOC-008 分类维护	§6.2.7、§6.6.2	Category、分类接口	GET/POST /api/categories	categories	test_api.py
SR-DOC-009 分页	§6.2.2、§12.2	page、per_page、总页数夹取	GET /api/documents	documents	test_security.py、test_api.py
SR-QA-001～002 问答、分词、Top-K	§6.3、§7.3	ask()、retrieve()、score_chunk()	POST /api/qa/ask、/qa/	knowledge_chunks、qa_history	test_rag.py、test_api.py、UML 03
SR-QA-003～004 本地/模型模式	§6.3.7	build_local_answer()、call_llm_answer()	POST /api/qa/ask、GET /api/qa	qa_history.mode	test_rag.py、test_api.py
SR-QA-005 来源展示	§6.3.6、§6.7	group_hits_by_document()、QaView	/api/qa/ask、/api/qa/history/<id>	qa_history.sources	test_rag.py、test_api.py
SR-QA-006 历史持久化	§6.3.8	QAHistory	GET /api/qa、/qa/history/<id>	qa_history	test_api.py
SR-QA-007	§6.1.3、	qa_history_detail()	GET /api/qa/history/<id>	qa_history	test_api.py、test_system.py

需求簇	设计章节	主要实现	REST/页面入口	数据表	测试/UML
历史越权拒绝	§6.3.8				
SR-QA-008 问答权限过滤	§6.3.5、§10.5	allowed_ids + KnowledgeChunk 查询	POST /api/qa/ask	documents、knowledge_chunks	test_rag.py、test_security.py、UML 03
SR-QA-009 示例问题	§6.7	QUICK_QUESTIONS、SUGGESTED_QUESTIONS	GET /api/qa、GET /api/dashboard	无表	test_api.py
SR-KG-001～005 图谱	§6.4、§7.4	services/graph.py	GET /api/graph、GET/POST /api/graph/*	graph_nodes、graph_edges	test_api.py、test_system.py、UML 08/09
SR-FAV-001～003 收藏	§6.2.6	Favorite、toggle_favorite()	POST /api/documents/<id>/favorite、GET /api/documents/favorites	favorites	test_api.py、test_system.py
SR-AUD-001～002 审计	§6.5、§7.5	AuditLog、admin_audits()	GET /api/admin/audits、/admin/audits	audit_logs	test_login_security.py、test_security.py
SR-OPS-001 工作台	§6.1.8、§6.7	dashboard()	GET /api/dashboard、/dashboard	多表聚合	test_api.py、test_system.py
SR-OPS-002 健康检查	§11.2、§14.5	health()	GET /api/health、/health	—	test_system.py
SR-	§6.1.	about()	GET /api/about、	多表聚合	test_api.py、

需求簇	设计章节	主要实现	REST/页面入口	数据表	测试/UML
OPS-003 关于页	8、§6.7		/about		test_system.py
SR-OPS-004 启停与测试	§13、§14	start.ps1、stop.ps1、run_tests.ps1	命令行	—	项目管理/测试文档
SR-OPS-005 首页登录入口	§6.7、§13.5	Jinja 首页、Vue 登录页	/、/ui/login	—	test_system.py

15.2 用户需求补充映射

用户需求	相关系统需求	设计落点
UR-AUTH-01～07	SR-AUTH-001～009	§6.1、§10.2～10.7
UR-DOC-01～06	SR-DOC-001～009	§6.2、§7.2、§8.5～8.6
UR-QA-01～04	SR-QA-001～009	§6.3、§7.3、§10.5
UR-KG-01～02	SR-KG-001～005	§6.4、§7.4、§8.7
UR-FAV-01	SR-FAV-001～003	§6.2.6、§8.8
UR-AUD-01	SR-AUD-001～002	§6.5、§7.5、§8.9

15.3 设计到测试的反向追踪

设计点	关键断言/验证
can_view_document()	公开/内部/机密、跨部门、作者、管理员、匿名矩阵
searchable_documents()	排除草稿、排除其他部门机密、管理员全量
retrieve()	不返回无权机密片段；同文档最多 2 片段；Top-K 生效
score_chunk()	标题、关键词、正文、覆盖率与完整短语权重
safe_next_url()	拒绝外站、协议相对、反斜杠、换行、空字符
RateLimiter	阈值、窗口过期、成功清零、锁定期间正确密码仍拒绝
审计	登录失败、成功登录、文档动作和提问均有记录
REST API	未登录 401、非管理员 403、验证错误 400、资源不存在 404
SPA 构建	/ui 能返回 index.html，深层路径回退，资源缺失返回 503
数据层	收藏唯一约束、Chunk 重建幂等、图谱删除无残留

16 关键设计决策与取舍

16.1 设计决策表

编号	决策	选择	理由	代价/限制
D1	前端形态	Vue 3 SPA + Jinja 兼容层	满足前后端分离，同时降低旧页面迁移风险	两套控制器需同步维护
D2	API 边界	Flask `/api` JSON	与 Vue 解耦，便于测试和后续替换客户端	需要统一错误码与序列化
D3	持久化	SQLAlchemy + SQLite	零安装、易演示、模型清晰	并发和大数据量能力有限
D4	认证	Session + Flask-Login	同源部署简单，服务端可撤销会话	多实例 Session 共享未实现
D5	密码	Werkzeug scrypt 哈希	官方依赖、带盐慢哈希	无密码策略与升级流程
D6	限流	进程内滑动窗口	无额外基础设施，适合单机演示	不跨进程、不持久化
D7	检索	jieba 词项、关键词、标题与覆盖率打分	可解释、无向量服务、演示完整链路	语义召回有限
D8	片段策略	默认 400 字窗、50 字重叠、每文最多 2 片段	平衡上下文覆盖与来源多样性	长文可能丢失远距离上下文
D9	生成	本地摘要默认，OpenAI 兼容接口可选	离线可用，外部失败可降级	外部接口需网络、费用和隐私评估
D10	图谱	文档/部门/分类/关键词关系 + ECharts force	直观展示知识关联，易于同步	全图过滤在应用层，规模受限
D11	权限	角色 + 部门 + 文档密级	与需求直接对应，规则简单	缺乏项目组、岗位级细粒度策略
D12	前端状态	reactive store + 页面局部状态	不引入额外状态库，降低复杂度	跨页面共享与缓存能力有限
D13	数据同步	文档保存同步切分/建图	保存后立即可检索、可看图	写请求较慢，异常一致性需补偿
D14	部署	单 Flask 进程 + 静态 SPA	一键演示、同源 Cookie、路径简单	不是生产高可用架构

16.2 为什么不做“看起来更先进”的方案

课程答辩中容易把“可扩展方向”误写成“已实现能力”。本项目的设计原则是：

- 没有向量索引，就不声称使用向量数据库；
- 没有 Redis，就不声称支持分布式缓存或共享限流；
- 没有拆分服务，就不声称采用微服务；
- 没有附件解析端点，就不声称支持 PDF/DOCX 导入；
- 没有迁移工具，就不声称支持无缝数据库升级；
- 没有实际压测数据，就不承诺生产并发指标。

这种“诚实设计”有利于评审人员区分“当前实现”“课程预留”和“未来演进”，也便于后续开发者从代码中验证每条设计说明。

16.3 后续演进优先级建议

361. **先修正配置一致性**：让 AUTO_SEED 真正控制种子灌入，接入 OPENAI_TIMEOUT，将模型异常转为安全提示；
362. **改进事务边界**：统一文档、片段、图谱与审计提交，或增加一致性修复任务；
363. **补齐数据库索引与迁移**：为状态/部门/密级、审计时间和图边增加索引，引入迁移；
364. **增强检索**：在保持当前可解释基线的前提下，评估 BM25、FTS5 或向量检索；
365. **完善权限策略**：项目组、岗位、文档共享与撤销机制；
366. **补充安全**：CSRF Token、Origin 校验、安全响应头、密码策略与生产密钥管理；
367. **完善管理能力**：分类编辑/删除、用户生命周期、附件上传与解析；
368. **增加可观测性**：结构化日志、指标、错误追踪、备份与恢复演练。

17 结论与实现边界

17.1 设计结论

本文档给出的 V2.0 设计已经覆盖当前系统的主链路：

- Vue 3 SPA 通过 Vue Router 组织页面，通过 REST API 与 Flask 交互，生产构建由 /ui/ 提供；
- Flask 应用工厂、REST 蓝图、兼容蓝图、共享服务与 SQLAlchemy 模型形成清晰分层；
- Session + Flask-Login 鉴权、角色和部门密级规则在服务端执行；
- 文档保存触发片段切分、关键词提取、图谱同步和审计；
- RAG 采用权限先过滤、jieba 分词、可解释评分、每文最多两片段和 Top-K；
- 无模型密钥时使用本地摘要，配置兼容接口后可生成回答，失败时回退；
- 图谱包含文档、部门、分类/概念、关键词等节点，并按用户可见文档过滤；
- 九张核心表、REST 端点、错误码、测试夹具与 10 张 UML 图形成需求—设计—实现—测试的追踪链路。

17.2 当前实现能力清单

能力	状态
Vue 3 SPA 主界面	已实现
Vite 构建与 /ui/ 托管	已实现
Flask REST API	已实现
原 Jinja 页面兼容层	已实现
Session + Flask-Login	已实现
SQLAlchemy + SQLite	已实现
文档 CRUD、分类、筛选、分页、收藏	已实现
文档密级与部门隔离	已实现
登录失败限流与审计	已实现（单进程）

能力	状态
文档切分与 jieba 关键词	已实现
权限内 RAG 检索、来源、历史	已实现
可选 OpenAI 兼容生成与失败回退	已实现
图谱自动同步、权限过滤、ECharts 展示	已实现
管理员用户列表、审计、分类新增、图谱维护	已实现
健康检查、启动/停止/测试脚本	已实现
向量数据库	未实现，不在当前技术栈
Redis/共享限流	未实现，不在当前技术栈
微服务/消息队列	未实现，不在当前技术栈
完整附件上传与 PDF/DOCX 解析	未实现，仅预留目录和字段
数据库迁移、生产级备份	未实现
CSRF Token 与全局 API 500 JSON 包装	未实现，当前依赖 SameSite 和页面错误处理

17.3 验收与维护建议

设计与实现的一致性检查应至少包括：

369. 新端点是否在 `/api` 下并遵循统一 JSON 错误结构；
370. 新查询是否先应用 `can_view_document()` 或明确的权限条件；
371. 文档写操作是否同步片段、图谱与审计；
372. 前端路由是否同时在 Vue Router 和后端 SPA fallback 下可达；
373. 新增配置是否有默认值、环境变量入口和文档说明；
374. 新增业务规则是否有对应测试与需求追踪；
375. 不把未来规划写入“已实现”栏。

文档结束（V2.0 • 2026-10-31）

第 4 部分　项目测试计划

1. 引言

1.1 编写目的

本计划用于指导 V2.0《智慧企业知识财富库系统》的课程大作业测试活动，明确测试目标、范围、策略、级别、环境、数据、进度、职责、准入准出条件、缺陷规则、风险和质量度量，使测试工作可计划、可执行、可追踪、可复核。

本计划的直接读者包括：项目负责人、开发人员、测试执行人员、课程指导教师及验收人员。由于本项目为单人项目，计划中的开发、测试、运维等角色由同一人兼任，但必须按角色分别留下记录，避免“自己开发、自己测试、无证据”的问题。

1.2 项目背景

系统面向企业内部知识管理场景，以可鉴权的知识文档库为基础，提供文档 CRUD、收藏、检索、带来源的 RAG 问答、知识图谱、管理员用户与审计查询等能力。V2.0 采用前后端分离架构：Flask 提供 REST API，Vue 3 SPA 提供交互界面，SQLite 保存业务数据，pytest 承担自动化回归。

系统重点风险不是“页面能否打开”，而是：三级密级与部门隔离是否一致、RAG 问答是否只使用当前用户可见内容、登录防爆破是否有效、审计日志是否完整且可追溯、前后端 API 契约是否稳定、测试是否污染演示数据库。

1.3 参考文档

编号	文档	用途
REF-01	《用户需求说明书》	确认用户角色、业务目标与验收场景
REF-02	《系统需求说明书》	提取功能需求、非功能需求与需求编号
REF-03	《软件设计说明书》	确认模块边界、数据模型、接口与关键设计
REF-04	项目 README 与运行说明	确认技术栈、启动方式、演示账号和测试命令
REF-05	tests 目录及 pytest 配置	确认自动化基线、夹具和测试隔离方式
REF-06	《测试报告》	汇总最终执行结果、缺陷和结论

1.4 术语与缩略语

术语	说明
REST API	基于 HTTP 的资源接口，本项目以 JSON 为主要交换格式
SPA	单页应用，V2.0 前端采用 Vue 3 + Vue Router + Vite

术语	说明
RAG	检索增强生成，先检索权限内知识片段，再生成或拼接带来源回答
Chunk	文档切分后的知识片段，是检索、问答与来源展示的基本单元
三级密级	公开、内部、机密三个可见性等级
部门隔离	机密文档仅同部门用户、作者本人和管理员可访问
防爆破	按 IP 和时间窗口限制连续登录失败，超过阈值后临时锁定
审计	记录登录、登录失败、浏览、问答、写操作等关键行为
跨库隔离	自动化测试使用独立 SQLite 测试库，不读写演示数据库
P0/P1/P2/P3	缺陷或测试优先级，P0 最高

2. 测试目标、范围与不测项

2.1 测试目标

376. 验证 V2.0 Flask REST API 与 Vue 3 SPA 的核心业务链路能够完整运行。

377. 验证登录、角色、三级密级、部门隔离和作者例外规则在列表、详情、检索、问答、统计等入口保持一致。

378. 验证文档 CRUD、收藏、分类、检索、RAG 来源、图谱、管理员用户、审计分页、健康检查等功能符合需求。

379. 验证登录防爆破、安全跳转、密码存储、未授权访问、跨库隔离等安全控制有效。

380. 验证自动化测试可重复执行且不污染 instance 下的演示数据库；计划/交付基线为 136 条，以最终执行记录为准。

381. 验证 Vue 页面在主流浏览器中的关键交互、错误提示、空状态和响应式布局可用。

382. 形成可追踪的用例、执行记录、缺陷记录和测试报告，支撑课程验收与答辩演示。

2.2 测试范围

模块	主要测试内容	主要风险
认证与会话	登录、退出、当前用户、未登录拦截、会话保持、安全 next 跳转	未授权访问、开放重定向、会话残留
登录防爆破	失败阈值、锁定时间窗、窗口过期、成功清零、Retry-After	账号被暴力尝试、误锁定
权限与隔离	公开/内部/机密、同部门、作者例外、管理员、草稿可见性、统计口径	机密内容越权或通过统计泄露
文档管理	新建、详情、修改、删除、标签、分类、版本、发布状态	数据不一致、索引未更新
收藏	收藏、取消收藏、收藏列表、重复操作	重复数据、越权查看
检索	标题/摘要/正文搜索、分类/部门/密级筛选、分页	结果泄漏、排序异常、翻页参数丢失
RAG 问答	切分、分词、打分、Top-K、来源去重、无命中降级、历史	非权限内容进入来源、回答不可追溯
知识图谱	节点/边结构、可见范围、自动同步、管理员维护	图谱泄露、脏节点、删除后残留

模块	主要测试内容	主要风险
管理员功能	用户列表、分类维护、审计查询、权限限制	普通用户越权
审计	登录、失败登录、浏览、问答、写操作、筛选、分页、时间口径	日志缺失、时间错乱、分页失效
非线性功能	健康检查、建库与种子、API 契约、错误页、性能烟测、兼容性	部署失败、前后端错位、恢复困难
前端交互	登录、导航、查询、编辑、问答、图谱、后台表格、响应式	页面状态错误、操作反馈缺失

2.3 不测项与边界说明

不测项	原因与边界
真实大模型的回答质量、稳定性和计费	课程环境不强制依赖外部模型；重点验证本地检索与降级链路，外部模型仅做接口级检查
千人以上并发压测和容量规划	本系统定位单机/局域网演示，性能只做烟测，不作生产容量承诺
多进程、多机部署下的共享限流	当前防爆破为进程内实现，多实例共享限流不在本期范围
跨浏览器像素级视觉回归	只检查 Chrome、Edge 主流版本的布局与关键交互，不做像素比对
移动端原生应用、离线同步	系统为 Web SPA，不提供原生客户端与离线能力
第三方支付、邮件、短信、SSO	系统未集成这些外部能力
生产级安全认证、渗透测试和灾备演练	课程项目执行基础安全检查，不替代正式安全测评
SQLite 高并发、海量数据性能	仅验证演示规模下的可用性，明确其为演示型数据库
instance/knowledge.db 的人为删除恢复	只验证全新库自动建表和种子流程，不负责生产数据备份恢复

3. 测试策略

3.1 总体策略

采用“风险优先、接口为主、分层验证、自动化回归、人工补充体验”的策略。测试顺序不按页面菜单机械排列，而按风险从高到低推进：

383. 先验证认证、会话和未授权访问边界；
384. 再验证三级密级、部门隔离、作者例外和跨库隔离；
385. 验证文档 CRUD 与索引/图谱同步；
386. 验证检索、RAG 来源、Top-K、去重和降级；
387. 验证管理员、审计分页和时间口径；
388. 验证 SPA 关键交互、错误状态、兼容性与性能烟测；
389. 最后执行课程验收故事线和全量回归。

3.2 自动化策略

后端以 pytest 为主要验证手段，测试文件与重点如下：

测试文件	重点
tests/test_system.py	系统冒烟、主路径、路由、错误页、建库、时间口径、演示故事线
tests/test_security.py	权限矩阵、检索范围、统计口径、审计筛选与分页、文本截断
tests/test_rag.py	切分、分词、打分、Top-K、来源分组、去重与降级
tests/test_login_security.py	防爆破阈值、窗口、锁定、失败审计、密码哈希、行为文案
tests/test_api.py	V2.0 REST API 契约、登录退出、文档 CRUD、收藏、问答、图谱、管理员接口

自动化执行原则：

- 每个测试使用独立测试应用、内存 SQLite 或临时文件 SQLite；
- 用例之间通过事务回滚或独立夹具隔离，不共享可变业务数据；
- 不得读写 instance/knowledge.db；
- 使用 fresh_app 等夹具验证全新库建表和种子流程；
- 参数化用例可让自动化执行数大于抽象测试场景数，故“136 条”以 pytest 收集/执行记录为准；
- 前端未建立独立组件测试框架时，关键页面以人工 UI 清单补充，接口契约由 test_api.py 保障。

3.3 人工测试策略

人工检查重点覆盖自动化难以稳定判断的内容：页面布局、导航可达性、表单提示、空状态、确认对话框、图谱拖拽缩放、表格横向滚动、键盘基本操作、不同浏览器渲染。所有人工检查必须有截图、浏览器版本和结论，不能只写“已看”。

3.4 测试轮次

轮次	目的	触发条件	输出
冒烟轮	确认 V2.0 可启动、可登录、可访问核心 API	版本冻结后	冒烟记录、阻断问题
首轮全量	执行功能、安全、接口、非功能用例	冒烟通过	首轮执行记录、缺陷台账
缺陷回归	验证修复不引入新问题	开发提交修复	回归记录、缺陷状态
验收轮	按课程故事线和准出条件复验	修复完成、环境确认	验收记录、测试报告
最终基线	保留可重复执行的最终证据	提交前	pytest 日志、前端构建日志、截图

4. 测试级别

测试级别	测试对象	重点与方法	主要证据
单元测试	RAG 切分/分词/打分、登录限流器、工具函数、文本截	等价类、边界值、错误猜测、断言函数级输入输出	test_rag.py、test_login_security.py

测试级别	测试对象	重点与方法	主要证据
	断		中的单元级用例
集成测试	REST API、SQLAlchemy、SQLite、认证装饰器、服务层	使用 Flask test client，验证接口+数据库+权限的组合	test_api.py、test_security.py
系统测试	登录→工作台→文档→问答→图谱→审计的完整链路	端到端场景、故事线、状态转换、异常路径	test_system.py、人工 UI 检查
验收测试	课程验收场景与需求基线	按角色执行演示脚本，核对可见性与来源	验收记录、截图、最终测试报告
安全测试	认证、权限、开放重定向、防爆破、密码存储、跨库隔离	权限矩阵、负向输入、边界阈值、日志核验	test_security.py、test_login_security.py、安全缺陷记录
兼容性测试	Vue SPA、浏览器、屏幕宽度、构建产物	Chrome/Edge 同版本对照、响应式人工检查	浏览器版本表、截图、npm build 日志

4.1 单元测试关注点

- 空文本、短文本、长段落、空行、超长无标点段落的切分边界；
- 中文领域词“年假”等分词结果；
- 标题、关键词、正文、精确短语的权重关系；
- Top-K、单文档来源上限、去重和排序；
- 登录失败阈值、窗口过期、成功清零、不同 key 独立计数；
- 密码哈希、文本截断和标签映射。

4.2 集成测试关注点

- API 状态码、JSON 字段、错误 code 和前端可消费性；
- 文档保存后知识片段、图谱节点/边是否同步；
- 同一份可见性判定是否被列表、详情、搜索、问答共同复用；
- 普通用户和管理员的接口权限差异；
- 审计记录是否与业务动作一致；
- 测试库与演示库是否物理隔离。

4.3 系统与验收测试关注点

使用 admin、hr、it 等演示账号执行完整故事线：管理员总览 → 搜索“年假” → 查看文档 → 问答“员工年假有几天” → 查看来源 → 图谱 → 审计；再用 hr/it 对比机密文档访问结果。验收时特别核对“来源是否可追溯”和“机密内容是否不进入普通用户结果”。

4.4 安全与兼容性测试关注点

安全测试采用权限矩阵和负向用例，不以正向成功代替安全验证。兼容性测试覆盖当前主流 Chrome 与 Edge，检查布局、导航、表单、图表和错误提示；不承诺所有历史浏览器。性能只做关键页面和 API 烟测，发现明显阻塞、超时或 N+1 类问题时记录缺陷。

5. 测试环境与测试数据

5.1 硬件与基础软件

项目	测试基线
操作系统	Windows 10/11 x64
CPU/内存	4 核 / 8 GB 及以上；课程演示最低 2 核 / 4 GB
Python	3.12，项目虚拟环境 .venv
后端框架	Flask 3.x、Flask-SQLAlchemy、Flask-Login
前端	Vue 3.5、Vue Router 4、Vite 5、ECharts
数据库	SQLite，测试使用临时/内存库
自动化	pytest 8.x，执行脚本 run_tests.ps1
浏览器	Chrome、Edge 当前稳定版
网络	后端测试不依赖外网；默认不配置 OPENAI_API_KEY

5.2 部署与访问

组件	地址/启动方式	说明
Flask API	http://127.0.0.1:5000/api	提供 REST 接口与健康检查
Vue 开发服务	http://127.0.0.1:5173	Vite 开发模式，供 UI 检查
Vue 构建产物	frontend/dist	构建后由 Web 服务或静态服务承载
测试命令	.\run_tests.ps1	透传 pytest 参数，执行后端自动化测试
前端构建	npm run build	在 frontend 目录执行，检查构建是否成功

5.3 测试数据设计

数据类别	设计方式	使用原则
演示账号	admin、hr、it、finance、product 等种子账号	只使用公开演示密码；不得写入真实个人信息
组织数据	综合部、人事部、财务部、信息部、产品部	覆盖同部门、异部门、管理员三类权限
密级数据	公开、内部、机密；含作者与异部门场景	机密数据必须有明确归属部门和作者
文档数据	制度文本、产品 FAQ、项目模板；含长文、空行、特殊字符	覆盖检索、切分、问答与边界
草稿数据	未发布状态文档	验证非作者/非管理员不可见，检索不返回
图谱数据	文档、部门、分类、关键词、项目、概念节点	验证节点类型、可见范围和删除清理
审计数据	登录、失败登录、浏览、问答、写操作	验证筛选、分页、时间顺序与详情
测试专用数据	独立测试库、临时文档、临时分类	用完回滚或删除，不进入演示库

5.4 环境配置与隔离要求

- 测试配置必须显式使用 TestingConfig 或等价测试配置；

- 测试开始前确认数据库 URI 指向内存库或临时文件，而不是 instance/knowledge.db；
- 测试结束核对演示数据库未被修改，必要时记录文件大小/关键表行数；
- 不把真实 API Key、生产密码、个人数据放入测试夹具或截图；
- 时间相关用例应允许合理的执行时间误差，但必须验证顺序和无微秒展示口径；
- 前端人工检查应固定浏览器版本、分辨率、缩放比例和后端提交版本。

5.5 环境检查清单

检查项	通过标准
Python 与依赖	虚拟环境可创建，requirements-dev 安装成功
后端启动	/api/health 返回成功且数据库可用
前端依赖	npm install 成功，npm run build 无错误
演示账号	admin 可登录，hr/it 可完成权限对照
测试隔离	pytest 前后 instance/knowledge.db 不变
浏览器	Chrome/Edge 可访问 SPA，控制台无阻断性错误
日志与截图	测试记录可定位版本、时间、环境、执行人

6. 进入准则、退出准则与暂停恢复

6.1 进入准则

编号	进入条件
EN-01	V2.0 代码、依赖和数据库初始化脚本已提交到测试基线
EN-02	后端可启动，健康检查可用；前端可启动或已生成可访问 dist
EN-03	需求、接口和演示账号信息有可查版本，关键变更已同步测试
EN-04	测试环境使用独立测试库，演示库备份/保护措施明确
EN-05	自动化测试能够被收集执行，失败信息可定位
EN-06	无阻断级环境问题；如有，已记录并获准带风险进入

6.2 暂停与恢复准则

出现以下情况时暂停测试：服务无法启动、数据库初始化失败、核心账号不可登录、测试会写入演示库、关键权限规则无法判定、前端构建阻断。暂停原因、时间、影响范围和恢复条件必须写入执行记录。修复后先执行冒烟和相关回归，再恢复全量。

6.3 退出准则

编号	退出条件	目标
EX-01	计划内用例执行率达到 100%，经批准豁免的除外	100%
EX-02	P0/P1 缺陷全部关闭；P2 无未接受的阻断性缺陷	0 个未关闭 P0/P1
EX-03	认证、权限、密级、RAG 来源、审计	100%

编号	退出条件	目标
	等高优先级场景全部通过	
EX-04	自动化基线执行通过；若数量变化，以最终 pytest 收集与执行记录为准	136 条计划/交付基线
EX-05	测试前后演示库未被污染，跨库隔离证据齐全	通过
EX-06	前端关键页面人工检查完成，无阻断交互问题	通过
EX-07	缺陷台账、执行汇总、测试报告和需求追踪完成	齐备
EX-08	课程验收故事线可完整演示，已知限制已记录	通过

准出口径说明：通过率按“通过数 ÷ 已执行数”计算，执行率按“已执行数 ÷ 计划数”计算。因环境原因被批准豁免的用例，不计入失败，但必须记录豁免理由、影响和批准人。

7. 测试组织与职责

本项目为单人项目，不设置独立测试部门。为避免职责混同，同一人按阶段承担不同角色，并通过测试基线、脚本、截图和缺陷记录实现可复核。

角色	兼任人员	主要职责	输出
项目负责人	项目负责人本人	批准计划、协调范围、确认风险与准出	计划、审批记录
测试负责人	项目负责人本人	制定策略、分配用例、跟踪进度、汇总结果	测试计划、执行汇总
测试设计/执行	项目负责人本人	设计用例、准备数据、执行自动化和人工检查	用例、日志、截图
开发/修复	项目负责人本人	修复缺陷、提交变更说明、配合回归	修复记录、提交记录
配置/环境管理	项目负责人本人	管理版本、依赖、环境变量和测试数据	环境记录、基线说明
验收/复核	课程指导教师或同学	按验收标准抽查、复核证据	验收意见

单人项目的补偿控制：所有关键结论至少保留一种客观证据；安全问题必须同时有负向用例和日志/数据库证据；修复后必须执行相关自动化回归；不得仅凭页面截图判定权限正确。

8. 测试进度安排

阶段	计划日期	主要工作	里程碑/输出
计划与范围确认	2026-10-20	确认 V2.0 范围、风险、环境和交付要求	测试计划初稿
用例设计	2026-10-21 至 10-22	按模块设计功能、安全、接口和 UI 用例	测试用例说明书
环境与冒烟	2026-10-23	安装依赖、启动前后端、确认测试库隔离	冒烟记录
首轮执行	2026-10-24 至 10-26	执行自动化与人工 UI 检查，登记缺陷	执行汇总、缺陷台账
修复与回归	2026-10-27	修复问题，执行相关回归与	回归记录

阶段	计划日期	主要工作	里程碑/输出
		全量复核	
验收准备	2026-10-28	按故事线验收，核对需求追踪与证据	验收记录
最终基线与报告	2026-10-31	复跑自动化、整理截图和报告	最终测试报告、提交包

上述日期为课程提交计划。如课程验收日期调整，测试活动按阶段顺序平移，但进入、暂停、退出准则不得降低。

9. 测试用例设计方法

方法	使用场景	示例
等价类划分	用户名、密码、密级、部门、状态、动作筛选	合法/非法登录；公开/内部/机密可见性
边界值分析	失败次数、时间窗口、分页页码、文本长度、Top-K	第 8 次失败锁定、超出页码钳制、超长问题截断
判定表	密级 × 部门 × 作者 × 角色	管理员、同部门、作者、异部门对机密文档的决定
状态转换	登录锁定、草稿/发布、文档编辑/删除、收藏切换	失败计数→锁定→过期解锁→成功清零
场景法	登录→文档→问答→图谱→审计	课程验收故事线与 SPA 导航
错误猜测	空字段、非法 JSON、越权 ID、异常 next、重复收藏	未登录访问、开放重定向、重复收藏、404
配对组合	浏览器 × 页面 × 数据状态	Chrome/Edge 下的空列表、错误、长表格
权限矩阵法	角色、部门、密级、资源状态的正交组合	列表、详情、搜索、问答、统计范围一致性

测试用例应做到“前置条件可搭建、步骤可复现、预期可判定、证据可保存”。对随机性、时间、中文分词和第三方模型相关结果，避免模糊断言，优先断言权限边界、结构字段、排序关系、来源标题和明确降级状态。

10. 缺陷管理与严重级别

10.1 缺陷流程

新建 → 复核/分级 → 指派 → 修复 → 待回归 → 回归通过关闭；若暂不修复，进入延期/接受风险状态，必须记录理由、影响范围、责任人和评审结论。缺陷记录必须包含环境、版本、复现步骤、实际结果、预期结果、证据和关联用例。

10.2 严重级别

级别	名称	判定标准	示例
S1	阻断	系统不可用、数据丢失、核	任意人可读机密；测试写入

级别	名称	判定标准	示例
		心安全边界被绕过、测试污染演示库	生产库；无法登录
S2	严重	核心功能不可用或关键结果错误，无合理绕行	RAG 来源越权；文档保存后不可检索；审计缺失关键动作
S3	一般	非核心功能错误或体验明显受损，有绕行方式	筛选参数丢失；分页边界异常；错误提示不准确
S4	轻微	文案、样式、轻微体验问题	标签大小不一致；非关键空状态文案不当

10.3 优先级

优先级	处理原则
P0	立即停止测试并处理，修复后再进入
P1	当前轮次必须修复，准出前关闭
P2	计划内修复；若延期需接受风险并记录影响
P3	可排入后续版本，不阻断课程验收

严重级别描述“影响有多大”，优先级描述“何时修”。S1 通常对应 P0/P1，避免用 P3 掩盖安全问题。

11. 测试风险与应对

风险	可能性	影响	应对措施
单人项目遗漏测试场景	中	中高	使用模块化用例清单、权限矩阵和自动化回归，按清单逐项签字
测试误写演示数据库	中	高	强制 TestingConfig、临时库、夹具回滚；执行前后核对数据
权限规则只在列表验证，详情/问答遗漏	中	高	对同一资源执行列表、详情、搜索、问答、统计多入口对照
RAG 结果受分词和语料影响	高	中	固定领域词、断言来源与排序关系，不只断言自然语言答案逐字一致
时间窗口/时区导致偶发失败	中	中	使用可控时钟或宽容阈值；断言顺序、格式和无微秒口径
前后端 API 契约漂移	中	高	以 test_api.py 固定字段/状态码；前端构建和人工联调同时执行
外部大模型不可用或超时	中	中	默认本地模式；验证降级提示与来源仍可用，不依赖外网结果
浏览器/屏幕差异	中	低中	固定 Chrome/Edge 版本，检查关键断点；不追求像素级一致
SQLite 并发限制	中	中	明确演示规模；避免并发写压测；记录已知限制
课程时间不足	中	中高	优先完成高风险权限、来源、审计和主路径；低风险

风险	可能性	影响	应对措施
			项明确延期

12. 质量度量

度量项	目标/口径	数据来源	最终值
测试用例执行率	100%，豁免除外	执行汇总	待验收填写
自动化基线通过率	计划/交付基线 136 条，以最终 pytest 记录为准；目标 100%	pytest 日志	待验收填写
高优先级用例通过率	P0/P1 场景 100%	执行汇总	待验收填写
需求模块覆盖率	认证、权限、文档、问答、图谱、管理、审计、非功能均有用例	需求追踪表	100%
P0/P1 缺陷关闭率	100%	缺陷台账	待验收填写
测试数据隔离	演示库执行前后无变化	文件/表行数核对	待验收填写
API 契约一致性	关键接口状态码、JSON 字段和错误 code 符合前端约定	API 测试与人工检查	待验收填写
关键页面可用性	登录、工作台、文档、问答、图谱、后台主操作可完成	浏览器截图	待验收填写
性能烟测	演示数据规模下关键页面/API 无明显超时或阻断	浏览器与接口记录	建议 ≤ 2 s，具体以环境记录为准
缺陷回归通过率	已修复缺陷回归 100% 通过	回归记录	待验收填写

度量结果必须区分“计划值”“实际值”和“取数时间”。不得用自动化用例数量代替需求覆盖率，也不得用页面可打开代替权限正确。

13. 测试交付物

编号	交付物	内容	责任人	时机
DEL-01	项目测试计划	本文件	项目负责人	测试启动前
DEL-02	测试用例说明书	模块化用例、执行汇总模板、缺陷模板、需求追踪	项目负责人	用例设计完成
DEL-03	自动化测试基线	tests 目录与 pytest 配置	项目负责人	每轮回归
DEL-04	测试执行记录	自动化日志、浏览器截图、接口结果	项目负责人	每轮执行后
DEL-05	缺陷台账	缺陷编号、级别、状态、修复和回归证据	项目负责人	持续维护
DEL-06	需求追踪矩阵	需求—用例—自动化—结果对应	项目负责人	验收前
DEL-07	测试报告	范围、环境、结果、缺陷、风险和结论	项目负责人	提交前
DEL-08	演示与运行证据	启动截图、验收故事线截图、健康检查结果	项目负责人	答辩前

14. 配置管理、需求追踪与审批

14.1 配置管理

- 被测版本、前端版本、依赖锁文件和测试代码必须来自同一提交基线；
- 测试前记录 Git 提交或等价版本标识；测试后如代码变化，相关用例必须重新执行；
- 测试数据与测试代码分离，临时数据不得提交到演示数据库；
- 测试日志、截图和缺陷记录以日期+版本+环境命名，防止证据混用；
- 已豁免用例必须保留原因和风险接受记录。

14.2 需求追踪

需求追踪按“需求编号 → 测试用例编号 → 自动化文件/测试函数 → 执行结果 → 缺陷”链条维护。至少覆盖认证、权限、文档、检索、问答、图谱、管理员、审计、健康检查、跨库隔离、时间口径和前端交互。具体用例与需求映射见《05-测试用例说明书》的需求追踪章节。

14.3 评审与审批

活动	参与者	结论标准
计划评审	项目负责人、指导教师或同学	范围清楚、风险有应对、准出可判定
用例评审	项目负责人、开发/验收人员	步骤可复现、预期明确、覆盖高风险场景
执行复核	项目负责人、验收人员	日志/截图与结论一致，测试库未污染
准出审批	指导教师或课程验收人	满足退出准则或批准带风险提交

计划批准：项目负责人（签名：_____）

验收复核：指导教师/复核人（签名：_____）

批准日期：2026-10-31

文档结束

第 5 部分　测试用例说明书

1. 文档说明

1.1 编写目的

本文档把 V2.0 的功能需求、非功能需求和安全要求转化为可执行的测试用例，供项目负责人自测、课程验收和后续回归使用。每条用例均包含编号、模块、测试项、前置条件、步骤、预期结果、优先级、类型和自动化关联。

1.2 覆盖范围

模块	覆盖能力	用例编号
认证与会话	登录、退出、当前用户、未认证拦截、防爆破、安全跳转、密码哈希	AUTH-001 至 AUTH-010
权限与隔离	公开/内部/机密、同部门、作者、管理员、草稿、统计口径、跨库隔离	PERM-001 至 PERM-009
文档与收藏	检索、详情、CRUD、索引同步、收藏、筛选分页、输入校验	DOC-001 至 DOC-009
RAG 问答	切分、分词、打分、Top-K、来源、去重、降级、历史、审计	RAG-001 至 RAG-012
知识图谱	结构、可见范围、自动同步、删除清理、管理员维护、前端交互	GRAPH-001 至 GRAPH-008
管理员与审计	用户、分类、审计筛选分页、失败登录、行为详情、时间口径	ADMIN-001 至 ADMIN-008
非功能与 API	健康检查、建库种子、测试隔离、REST 契约、构建、性能、兼容、启停	NFR-001 至 NFR-009
Vue 前端	登录、会话、工作台、文档、问答、图谱、后台、错误与响应式	UI-001 至 UI-008

1.3 用例总数

模块	用例数	P0	P1	P2	P3
认证与会话	10	8	2	0	0
权限与隔离	9	6	3	0	0
文档与收藏	9	1	7	1	0
RAG 问答	12	5	6	1	0
知识图谱	8	2	5	1	0
管理员与审计	8	1	4	3	0
非功能与 API	9	2	3	4	0
Vue 前端	8	2	4	2	0
合计	**73**	**27**	**34**	**12**	**0**

上表用于执行汇总时的计划基数。若后续变更用例，应同步更新执行汇总和需求追踪。

2. 测试环境、数据与通用前置条件

2.1 环境基线

项目	基线
操作系统	Windows 10/11 x64
Python	3.12，项目 .venv
后端	Flask REST API + SQLAlchemy + Flask-Login
数据库	SQLite；自动化使用内存库或临时文件库
前端	Vue 3.5 + Vue Router 4 + Vite 5 + ECharts
测试框架	pytest 8.x，run_tests.psl 为执行入口
浏览器	Chrome、Edge 当前稳定版
分辨率	建议 1920×1080；响应式另测 1366×768 和窄屏
外部模型	默认不配置 OPENAI_API_KEY，按本地检索/摘要模式验证

2.2 演示账号

账号	密码	部门/角色	典型用途
admin	admin123	综合部/管理员	全量可见、管理员功能、审计
hr	hr123	人事部/普通用户	人事文档、异部门机密拒绝
it	it123	信息部/普通用户	同部门机密放行
finance	fin123	财务部/普通用户	财务文档和检索
product	prod123	产品部/普通用户	产品 FAQ 和问答

演示密码只用于课程演示，禁止在真实环境复用。测试记录中不得出现真实个人密码或 API Key。

2.3 通用前置条件

编号	前置条件
PRE-01	后端已按测试配置启动，健康检查可用
PRE-02	前端可启动或 dist 可访问，浏览器控制台无阻断错误
PRE-03	测试数据库为独立内存库或临时文件库，不是 instance/knowledge.db
PRE-04	演示账号和种子文档已初始化，权限数据完整
PRE-05	执行人已记录版本、日期、环境、浏览器与数据库标识
PRE-06	涉及写操作的用例使用测试库或可回滚事务，执行后清理临时数据

2.4 测试数据建议

数据	建议值
业务文档检索词	年假、差旅住宿、采购审批、API 密钥、产品密码
新建文档	标题“测试文档-日期-序号”，正文含两段以上，标签为测试标签
分类	测试分类-日期-序号
图谱节点	测试节点-日期-序号，类型为 concept
问题输入	空问题、正常问题、超长问题、无命中问题
异常输入	未登录、非法 ID、非法密级、空标题、空正文、外部 next

3. 用例编号、优先级与自动化关联约定

3.1 编号规则

- AUTH：认证、会话、防爆破与安全登录；
- PERM：角色、密级、部门、作者、草稿与统计隔离；
- DOC：文档 CRUD、收藏、检索和分页；
- RAG：知识片段、检索排序、问答、来源、降级和历史；
- GRAPH：图谱数据和维护；
- ADMIN：用户、分类、审计；
- NFR：健康检查、API、建库、隔离、构建、性能、兼容和运维；
- UI：Vue SPA 人工交互。

3.2 优先级定义

优先级	定义	准出要求
P0	核心安全边界、核心主路径、数据隔离；失败会阻断验收	必须 100% 通过
P1	重要业务功能或关键接口；失败影响主要演示	必须通过，或经批准豁免
P2	一般功能、体验、边界情况；有合理绕行	计划内执行，可评估延期
P3	轻微体验或可选检查	记录结果，不阻断验收

3.3 类型定义

类型	含义
功能	业务功能是否正确
接口	REST 状态码、JSON 字段和错误契约
安全	认证、授权、防爆破、跳转、密码和隔离
集成	接口、数据库、服务层与权限的组合
可靠性	建库、隔离、错误恢复、降级
性能	演示规模下的响应烟测
兼容性	浏览器、屏幕宽度和构建产物
易用性	提示、空状态、导航、可理解性
UI	页面交互和视觉可用性

3.4 自动化关联说明

- test_system.py：系统冒烟、主路径、路由、建库、时间口径和故事线；
- test_security.py：权限矩阵、检索范围、统计口径、审计筛选分页和文本截断；
- test_rag.py：切分、分词、打分、Top-K、来源分组与降级；

- test_login_security.py：失败阈值、锁定窗口、失败审计、密码哈希和行为文案；
- test_api.py：V2.0 REST API 契约；
- “人工 UI 检查”：在 Chrome/Edge 中按步骤操作并截图；
- “人工 API 检查”：在自动化未覆盖或需核对数据库副作用时执行；
- 表格中的自动化函数名为代表性关联，不表示只执行该函数即可覆盖整条业务用例。

4. 详细测试用例

4.1 认证与会话

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
AUTH-001	认证与会话	管理员正常登录并建立会话	后端可用；admin 账号存在；无登录会话	1. 调用 POST /api/auth/login，提交 admin/admin123。 2. 调用 GET /api/auth/me。 3. 在前端登录页重复操作并观察跳转。	登录返回 200 且用户信息含 is_admin=true；后续 me 返回同一用户；前端进入工作台，刷新后会话保持。	P0	功能/接口	test_api.py::test_api_login_logout_flow；test_system.py::test_03_login_success_dashboard；人工 UI 检查
AUTH-002	认证与会话	错误密码登录失败且不建立会话	admin 账号存在；无登录会话	1. 使用 admin 和错误密码提交登录。 2. 查询当前会话。 3. 检查页面提示和审计日志。	返回 401；不建立有效会话；当前用户接口仍为未认证；页面显示明确失败提示；失败行为被审计。	P0	功能/安全	test_api.py::test_api_login_logout_flow；test_system.py::test_02_login_fail；人工 UI 检查
AUTH-003	认证与会话	未认证访问受保护 AP	无登录会话	1. 直接访问 GET /api/dashboard。 2. 访问其他需登录接口。 3. 检查响应体和前端处理。	返回 401；JSON code 为 AUTH_REQUIRED；不返回业务数据；前端清除会话并跳转登录或提	P0	接口/安全	test_api.py::test_api_requires_authentication；人工 UI 检查

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
		I 返回统一错误			示重新登录。			
AUTH-004	认证与会话	退出登录清除会话	admin 已登录	1. 调用 POST /api/auth/logout。 2. 再调用 /api/auth/me 和受保护接口。 3. 刷新页面。	退出返回 200；当前用户接口返回 401；受保护数据不可访问；刷新后仍为未登录状态。	P0	功能/安全	test_api.py::test_api_login_logout_flow；人工 UI 检查
AUTH-005	认证与会话	连续失败达到阈值后触发防爆破锁定	独立测试库或可重置限流状态；阈值配置已知	1. 使用同一 IP 连续提交错误密码至阈值。 2. 第阈值+1 次继续提交。 3. 检查状态码、Retry-After 和审计。	达到阈值后的请求返回 429；Retry-After 为正数；响应提示稍后重试；失败尝试均能被追溯。	P0	安全	test_login_security.py::test_repeated_failures_lock_the_ip； test_login_security.py::test_retry_after_positive_when_locked
AUTH-006	认证与会话	锁定期间正确密码仍拒绝，窗口过期后恢复	已触发锁定；可控制时间或等待窗口	1. 锁定期间使用正确密码登录。 2. 检查状态码。 3. 等待或模拟窗口过期后重试。	锁定期间即使密码正确仍返回 429；窗口过期后可正常登录；过期不会残留永久锁定。	P0	安全	test_login_security.py::test_correct_password_still_blocked_while_locked； test_login_security.py::test_lock_expires_outside_window
AUTH-	认证	成功	有少	1. 制造少量失败。	成功登录后失败计数清	P1	安全	test_login_security.py::test_success_clears_counter；

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
007	与会话	登录清零当前计数	量失败记录但未锁定	2. 使用正确密码登录成功。 3. 再次制造失败并观察阈值计数。	零；随后失败从 1 重新计数；不会因旧失败提前锁定。			test_login_security.py::test_successful_login_resets_counter
AUTH-008	认证与会话	登录成功和失败均写入审计，未知用户也留痕	admin 可登录；审计可查询	1. 记录管理员登录成功。 2. 使用不存在的用户名和错误密码登录。 3. 管理员查询审计日志。	成功登录有 login 记录；未知用户失败有 login_failed 记录；详情含用户名/来源等信息但不含明文密码。	P1	安全/集成	test_login_security.py::test_failed_login_is_recorded; test_login_security.py::test_unknown_user_failure_is_recorded
AUTH-009	认证与会话	密码以安全哈希存储	数据库可只读检查；已有演示账号	1. 读取用户表密码字段。 2. 与明文密码比对。 3. 使用正确和错误密码验证认证。	密码字段不是明文，具备密码哈希格式；正确密码可认证，错误密码不可认证；页面和日志不泄露哈希。	P0	安全	test_login_security.py::test_password_is_hashed_not_stored
AUTH-010	认证与会话	登录 next 跳转只允许站内安全	登录页可访问；准备站内和外	1. 使用站内路径 next 登录。 2. 使用 http、//、反斜杠、javascript、编码绕过等 next 值登录。 3. 观察最终跳转。	站内路径可跳转；外部和协议相对地址被拒绝或回落安全页；不发生开放重定向；前端不直接执行 next。	P0	安全	test_system.py::test_16_open_redirect_blocked; test_system.py::test_17_safe_next_allows_internal_path; test_security.py::test_rejects_unsafe; test_security.py::test_allows_internal

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
		路径	部next值					

4.2 权限、密级与隔离

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
PERM-001	权限隔离	公开和内部文档对已登录用户可见	hr已登录；存在公开、内部文档	1. 获取文档列表和详情。 2. 搜索对应标题。 3. 检查是否可读正文。	公开和内部文档在列表、详情和搜索中可见；正文可读；不能据此访问机密文档。	P1	功能/安全	test_security.py::test_public_internal_visible_to_any_logged_in_user
PERM-002	权限隔离	同部门机密文档可见	it已登录；存在信息部机密文档	1. 以 it 查询文档列表。 2. 打开信息部机密文档详情。 3. 搜索并问答相关内容。	it 可看到同部门机密文档；详情返回 200 且正文可见；搜索和问答在权限范围内可命中。	P0	功能/安全	test_system.py::test_07_secret_allowed_for_it; test_security.py::test_secret_allowed_for_same_department
PERM-003	权限隔离	机密文档作者本人可见	存在作者为当前普通用户的机密文	1. 以作者身份打开详情。 2. 检查列表和检索结果。 3. 读取正文。	作者本人可访问自己创建的机密文档；详情返回 200；列表和检索不因跨部门而误拒绝。	P0	功能/安全	test_security.py::test_secret_allowed_for_author

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
			档；作者已登录					
PERM-004	权限隔离	异部门机密文档不可见且详情拒绝	hr已登录；存在信息部机密文档	1. 查询文档列表并记录可见ID。 2. 直接访问该机密文档详情ID。 3. 搜索该文档标题。	文档ID不出现在hr列表；直接访问详情返回403而不是200或404泄露；搜索不返回该文档。	P0	安全	test_system.py::test_06_secret_denied_for_hr; test_api.py::test_api_secret_document_permission; test_security.py::test_secret_denied_for_other_department
PERM-005	权限隔离	管理员可访问全部密级文档	admin已登录；存在公开、内部、机密和草稿	1. 查看列表并统计密级。 2. 打开异部门机密文档。 3. 执行检索和问答。	管理员可见全部文档；异部门机密详情返回200；管理员检索可包含机密，但仅限其授权范围。	P1	功能/安全	test_security.py::test_admin_sees_everything; test_rag.py::test_admin_can_retrieve_secret
PERM-006	权限隔离	文档搜索排除异部门机密和未发布草	hr已登录；存在异部门机密草稿和已	1. 搜索异部门机密标题。 2. 搜索草稿标题。 3. 搜索公开对照标题。 4. 查看返回总数和条目。	机密和草稿均不出现在非授权用户搜索结果；公开对照可命中；总数与实际可见结果一致。	P0	安全/功能	test_security.py::test_excludes_other_department_secret; test_security.py::test_excludes_drafts; test_system.py::test_04_search_leave_policy

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
		稿	发布对照文档					
PERM-007	权限隔离	RAG 问答不引用异部门机密来源	hr 已登录；异部门机密内容含独特关键词	1. 用独特关键词提问。 2. 查看回答、sources 和 fragments。 3. 用管理员执行对照。	hr 的回答和来源不出现异部门机密；管理员对照可检索到该内容；越权内容不进入来源标题、摘要或片段。	P0	安全/集成	test_rag.py::test_never_returns_secret_from_other_department; test_rag.py::test_admin_can_retrieve_secret; test_api.py::test_api_qa_returns_traceable_sources
PERM-008	权限隔离	统计数字跟随当前用户可见范围	hr 和 admin 均可登录；存在机密文档	1. hr 打开关于页或工作台统计。 2. 记录文档数与片段数。 3. admin 查看同一统计。	hr 的文档数和片段数小于管理员或至少不包含不可见机密规模；页面标明统计口径；不能通过数字推断机密数量。	P1	安全/功能	test_security.py::test_hr_sees_fewer_documents_than_admin; test_security.py::test_chunk_count_matches_visible_documents
PERM-009	权限隔离	普通用户不可访问管理员接口和页面	hr 已登录	1. 调用 GET /api/admin/users 和 /api/admin/audits。 2. 在前端直接输入后台路由。 3. 检查响应和菜单。	API 返回 403 且 code 为 FORBIDDEN；前端不显示管理员菜单；直接访问后台页面被拒绝或重定向到无权提示。	P0	安全/接口	test_api.py::test_api_admin_endpoints_and_permission; test_system.py::test_18_non_admin_gets_403_on_admin

4.3 文档、收藏与检索

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
DOC-001	文档管理	标题和正文关键词检索	admin 已登录；种子文档已初始化	1. 搜索“年假”。 2. 搜索正文独有词。 3. 检查结果标题、摘要和总数。	搜索“年假”可命中《员工年休假管理办法》；正文独有词可命中对应文档；摘要与文档一致；无结果时显示空状态而非报错。	P0	功能	test_system.py::test_04_search_leave_policy；test_api.py::test_api_document_search_and_detail
DOC-002	文档管理	文档筛选、排序与分页	已有足够文档覆盖部门和密级	1. 按部门、密级、分类筛选。 2. 设置 page 和 per_page。 3. 比较第一页与第二页。 4. 输入超范围页码。	筛选条件生效且可组合；分页总数正确；第一二页不重复；超范围页码被钳制到有效页；翻页时保留当前筛选。	P1	功能/接口	test_security.py::test_page_is_capped；test_security.py::test_second_page_differs_from_first；test_security.py::test_out_of_range_page_is_clamped；人工 API 检查
DOC-003	文档管理	查看文档详情字段和权限状态	已登录；存在可读文档	1. 打开文档详情或调用 GET /api/documents/id。 2. 检查标题、正文、分类、部门、密级、标签、状态、作者。 3. 检查编辑按钮。	详情字段完整、标签中文正确、正文可见；管理员或有权限作者显示可编辑；无权限用户得到 403。	P1	功能/接口	test_api.py::test_api_document_search_and_detail；test_system.py::test_12_doc_list_cards_and_chinese_labels；人工 UI 检查
DOC-004	文档管理	新建文档并同步片段与图谱	admin 已登录；使用测试库	1. 提交包含标题、正文、摘要、部门、密级、状态、标签的文档。 2. 查询数据库和文档详情。 3. 搜索正文关键词。 4. 查看图谱。	接口返回 201；文档可查询；正文被切分为至少一个片段；索引可立即检索；图谱节点和边同步；审计有创建记录。	P1	功能/集成	test_api.py::test_api_document_crud_and_favorite；test_system.py::test_09_create_document_and_index
DOC-005	文档管	编辑文	存在可	1. 修改标题、正文、标签、密级和状态。	修改返回 200 且详情为新值；知识片段	P1	功能/	test_api.py::test_api_document_crud_and_favorite；test_rag.py::test_rebuild_is_idempotent；人工

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
	理	档后重建索引和摘要	编辑测试文档	2. 保存。 3. 检索旧关键词和新关键词。 4. 查看图谱。	按新正文重建；旧独有关键词不再命中或不再作为主要来源；图谱同步更新；审计有编辑记录。		集成	API 检查
DOC-006	文档管理	删除文档并清理关联数据	存在无其他依赖的测试文档及片段、收藏、图谱	1. 调用 DELETE /api/documents/id。 2. 查询文档、片段、收藏、图谱。 3. 再次访问详情。	删除返回 200；文档记录不存在；片段、收藏和自动图谱节点/边被清理或按设计保留无悬空引用；再次访问返回 404。	P1	功能/集成	test_api.py::test_api_document_crud_and_favorite；人工 API 检查数据库副作用
DOC-007	文档管理	收藏与取消收藏切换	普通用户已登录；存在可读文档	1. 收藏文档。 2. 再次调用收藏接口。 3. 打开收藏列表。 4. 取消收藏。	首次收藏成功且 is_favorite=true；重复操作不产生重复记录；收藏列表出现该文档；取消后列表移除。	P1	功能/接口	test_api.py::test_api_document_crud_and_favorite；人工 UI 检查
DOC-008	文档管理	收藏列表仅展示当前用户收藏	用户 A、B 均存在且各自收藏不	1. A 登录后收藏文档甲。 2. B 登录后收藏文档乙。 3. 分别请求收藏列表。	A 只看到甲，B 只看到乙；不能通过参数查看他人收藏；收藏列表仍遵守文档可见性。	P1	功能/安全	人工 API 检查；人工 UI 检查

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
			同文档					
DOC-009	文档管理	文档输入校验和不存在资源处理	admin 已登录；使用测试库	1. 提交空标题或空正文。 2. 提交非法密级或非法状态。 3. 请求不存在的文档 ID。 4. 提交超长标签。	校验失败返回 400 且字段提示明确；不产生半成品数据；不存在 ID 返回 404 和 NOT_FOUND；错误响应为 JSON。	P2	功能/接口	人工 API 检查；test_api.py 契约用例作为回归底线

4.4 RAG 问答与知识片段

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
RAG-001	RAG 问答	空文本和短文本切分	可调用切分服务	1. 输入空字符串。 2. 输入短于切分阈值的文本。 3. 检查片段数与内容。	空文本返回空片段；短文本返回单个片段且内容不丢失；不抛异常。	P1	单元	test_rag.py::test_empty_input； test_rag.py::test_short_text_single_chunk
RAG-002	RAG 问答	多段落按上限合并	准备多个短段落和空行	1. 按段落切分并合并。 2. 检查片段长度和段落边界。 3. 输入含空行文本。	短段落尽量合并至上限；不跨越超限；空段落被丢弃；片段文本可读且可追溯。	P1	单元	test_rag.py::test_paragraphs_merge_up_to_limit； test_rag.py::test_blank_paragraphs_dropped
RAG-003	RAG 问答	超长段落窗口化与重	准备超长无标点段落	1. 执行切分。 2. 检查片段长度、数量和重叠内容。 3. 使用长标点段落复验。	超长段落被窗口化而非截断丢失；相邻片段有设计内重叠；每	P1	单元	test_rag.py::test_long_paragraph_is_windowed； test_rag.py::test_overlap_creates_shared_content

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
		叠			个片段不超过上限；无死循环。			
RAG-004	RAG问答	中文分词与领域词“年假”召回	领域词典已加载；含年假文档存在	1. 对“员工年假有几天”分词。 2. 检查返回格式。 3. 对空问题和普通文本复验。	“年假”不被过滤为空；返回逗号分隔关键词；空文本返回空结果；业务问句可参与检索。	P0	单元/功能	test_rag.py::test_returns_comma_separated; test_rag.py::test_empty_text; test_system.py::test_05_rag_answer
RAG-005	RAG问答	标题、关键词、正文和精确短语权重	构造标题命中、关键词命中、正文命中和无重叠样本	1. 分别计算四类得分。 2. 比较排序。 3. 加入精确短语样本。	关键词权重高于标题权重，标题权重高于正文；精确短语有额外加分；无重叠得分为0；目标文档排序正确。	P0	单元	test_rag.py::test_title_weight_exceeds_body_weight; test_rag.py::test_keyword_weight_exceeds_title_weight; test_rag.py::test_exact_phrase_in_body_is_strongest_signal; test_rag.py::test_no_overlap_scores_zero
RAG-006	RAG问答	文档片段重建幂等	文档已有旧片段；可调用重建	1. 连续两次重建同一文档片段。 2. 比较片段数和旧片段。 3. 检查检索结果。	重复重建不产生翻倍脏片段；片段数与内容稳定；检索无重复来源；索引与正文一致。	P1	集成	test_rag.py::test_rebuild_is_idempotent
RAG-007	RAG问答	Top-K、单文档来源	存在多文档命中和单文档多片段命中	1. 提交普通问题。 2. 记录返回数量和分数。 3. 检查同文档来源数量和分组。	返回数不超过Top-K；同一文档最多贡献2条片段；结	P1	单元/集成	test_rag.py::test_max_two_hits_per_document; test_rag.py::test_hits_are_sorted_by_score; test_rag.py::test_top_k_respected; test_rag.py::test_group_score_is_best_fragment_score

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
		上限与排序			果按分数降序；同文档分组分数取最佳片段。			
RAG-008	RAG 问答	问答返回回答、来源标题和片段	admin 已登录；问答服务可用	1. 提问“员工年假有几天？” 2. 检查 answer、sources、fragments。 3. 点击前端来源。	返回 200；answer 非空；sources 含真实标题；fragments 可关联片段；前端可打开来源详情，回答不脱离知识库。	P0	功能/接口	test_system.py::test_05_rag_answer；test_api.py::test_api_qa_returns_traceable_sources；人工 UI 检查
RAG-009	RAG 问答	无命中时诚实降级	已登录；输入知识库不存在的独特字符串	1. 提交无命中问题。 2. 检查回答文案、sources 和 mode。 3. 检查历史。	明确提示未检索到相关内容；不伪造来源；不把本地拼接伪装成大模型回答；历史可记录或按设计处理。	P0	功能/可靠性	test_rag.py::test_no_hits_gives_honest_fallback；test_rag.py::test_states_local_mode
RAG-010	RAG 问答	外部模型不可用时回退本地摘要	不配置 API Key 或模拟外部调用失败	1. 正常提问。 2. 检查 mode 和回答。 3. 配置失败/超时场景复验。	外部模型不可用不影响基本问答；回退本地摘要并标明模式；来源仍可追溯；不返回空页面或 500。	P0	可靠性	test_rag.py::test_states_local_mode；人工模拟外部失败
RAG-011	RAG 问	问答历	用户已登录并	1. 提交问题。 2. 获取 history_id。	历史含问题、回答、	P1	功能/	test_api.py::test_api_history_detail_uses_json_sources；人工 UI 检查

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
	答	史保存与详情读取	至少提问一次	3. 调用 GET /api/qa/history/id。 4. 刷新问答页。	模式和时间；sources 为可解析列表而非字符串；刷新后可见历史；用户不能读取他人历史。		接口	
RAG-012	RAG 问答	问题超长截断与审计展示	可构造超长问题	1. 提交超长问题或查看审计记录。 2. 检查历史问题。 3. 检查审计 detail。	超长问题在审计/列表展示中按规则截断并带省略号；短问题不截断；完整历史仍可追踪到合理范围；不造成页面溢出。	P2	功能/集成	test_login_security.py::test_question_is_truncated; test_login_security.py::test_short_question_has_no_ellipsis

4.5 知识图谱

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
GRAPH-001	知识图谱	图谱 JSON 节点和边结构	admin 已登录；种子图谱存在	1. 请求 GET /api/graph。 2. 检查 nodes、links、categories。 3. 校验节点 ID 和边端点。	返回 200；nodes 非空；links 非空；category 属于 document、department、project、keyword、concept；边端点均能对应节点。	P1	功能/接口	test_system.py::test_08_graph_data; test_api.py::test_api_graph_payload_is_visible_scope
GRAPH-002	知识图谱	图谱按当	hr 和 admin 均	1. hr 请求图谱。 2. admin 请求图谱。	hr 不出现不可见机密文档节点及不应暴露的	P0	安全/接	test_api.py::test_api_graph_payload_is_visible_scope; 人工 API 检查

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
		前用户可见范围返回	可登录；有机密文档图谱	3. 对比文档节点和关联边。	关联；admin 可见范围更广；图谱不通过名称或边泄露机密。		口	
GRAPH-003	知识图谱	新建和编辑文档自动同步图谱	admin 已登录；使用测试库	1. 新建带部门、分类、关键词的文档。 2. 查看图谱。 3. 修改部门/标签后再次查看。	自动生成文档、部门、分类或关键词节点及边；修改后关联更新且无重复边；可见范围正确。	P1	集成	test_system.py::test_09_create_document_and_index；人工 API 检查图谱同步
GRAPH-004	知识图谱	删除文档后清理图谱关联	存在测试文档图谱	1. 删除测试文档。 2. 查询图谱数据。 3. 检查节点和边。	文档节点和关联边移除；不出现悬空边；共享部门/关键词节点按设计保留但不指向已删文档；查询不报错。	P1	集成	人工 API 检查数据库副作用
GRAPH-005	知识图谱	管理员新增概念节点	admin 已登录；图谱管理可用	1. 提交节点名称、类型 concept、描述。 2. 刷新图谱。 3. 重复提交同名节点。	新增成功；图谱出现节点和分类；重复名称按设计复用或返回明确提示，不产生不受控重复。	P1	功能/接口	人工 API 检查
GRAPH-006	知识图谱	管理员新增节点关系	已存在两个可用节点	1. 提交 source_name、target_name、relation。 2. 查询图谱边。 3. 提交不存在的端点。	合法关系创建成功并可检索；边方向正确；不存在端点返回可理解错误；不产生悬空边。	P1	功能/接口	人工 API 检查
GRAPH-007	知识图谱	普通用户不可	hr 已登录	1. 调用节点/边创建接口。 2. 访问图谱管理页面。 3. 检查前端	创建接口返回 403；管理页面不可进入或无维护表单；普通用户只可	P0	安全	人工 API 检查；人工 UI 检查

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
		维护图谱		按钮。	浏览可见图谱。			
GRAPH-008	知识图谱	图谱前端拖拽、缩放、筛选和图例	admin 或 hr 已登录；图谱有节点	1. 打开图谱页。 2. 拖拽节点、缩放、查看图例。 3. 切换分类筛选。 4. 在窄屏检查布局。	节点可拖拽和缩放；图例与节点类型一致；筛选后显示对应子图；长名称不溢出；无控制台错误。	P2	UI/兼容性	人工 UI 检查

4.6 管理员与审计

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
ADMIN-001	管理员功能	管理员用户列表与汇总	admin 已登录；种子账号存在	1. 请求 GET /api/admin/users。 2. 检查 summary 和用户字段。 3. 用普通用户复验。	管理员返回 200；summary.total 与实际用户数一致；字段含用户名、角色、部门等；普通用户不可访问。	P1	功能/接口	test_api.py::test_api_admin_endpoints_and_permission
ADMIN-002	管理员功能	审计日志列表可查询	admin 已登录；存在审计记录	1. 请求 GET /api/admin/audits。 2. 检查分页和条目字段。 3. 打开审计页面。	返回 200；分页总数大于 0；条目含动作、用户、时间、详情；页面表格可显示。	P1	功能/接口	test_api.py::test_api_admin_endpoints_and_permission；人工 UI 检查
ADMIN-003	管理员功能	审计按动作、用户	存在 login、login_failed、view、ask 等记录	1. 按 action 筛选。 2. 按 user 筛选。 3. 按 detail 子串筛选。 4. 输入未知 action。	筛选结果只含匹配记录；用户和详情筛选可组合；未知 action 被忽略或	P2	功能/接口	test_security.py::test_action_filter_narrows_results； test_security.py::test_user_filter_narrows_results； test_security.py::test_detail_filter_uses_substring； test_security.py::test_unknown_action_is_ignored

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
		和详情筛选			回落为全部；不返回他人无权数据。			
ADMIN-004	管理员功能	审计分页、页大小和筛选保持	审计记录多于单页容量	1. 请求第一页和第二页。 2. 设置筛选后翻页。 3. 请求超大页码和超大 per_page。	第二页与第一页不同；翻页保留筛选；页码越界被钳制；per_page 有上限；分页链接不丢参数。	P2	功能/接口	test_security.py::test_page_is_capped; test_security.py::test_pagination_preserves_active_filters; test_security.py::test_out_of_range_page_is_clamped
ADMIN-005	管理员功能	登录失败进入审计且可筛选	已有失败登录记录	1. 制造一次已知用户名失败。 2. 制造一次未知用户名失败。 3. 在审计页筛选 login_failed。	两类失败均出现；记录含动作和用户/详情；可直接定位失败原因类别；不记录明文密码。	P0	安全/集成	test_login_security.py::test_failed_login_is_recorded; test_login_security.py::test_unknown_user_failure_is_recorded
ADMIN-006	管理员功能	审计动作标签和详情完整性	存在登录、浏览、问答、写操作	1. 查看各动作中文标签。 2. 打开文档相关记录。 3. 检查详情中 ID、标题或问题摘要。	动作标签可读且格式统一；文档记录含 ID 和标题；问答记录含问题摘要；关键操作有详情，不出现空白。	P1	功能	test_login_security.py::test_successful_login_action_label_exists; test_login_security.py::test_document_actions_include_id_and_title
ADMIN-007	管理员功能	审计时间顺序和无微秒展示	存在新旧审计记录	1. 查看审计列表顺序。 2. 新建一条审计记录后刷新。 3. 检查时间格式和系统时钟。	新记录排在合理位置；列表按时间稳定排序；展示时间不含微秒；时间与本地系统时钟口径一致。	P1	功能/集成	test_system.py::test_ll_datetime_filter_no_micros; test_system.py::test_now_naive_matches_system_clock; test_system.py::test_new_audit_row_is_newer_than_seeded_rows; test_system.py::test_audit_rows_render_chronologically
ADMIN-008	管理员功	分类创建	admin 已登录；使用测试库	1. 创建“API 测试分类”。 2. 查询分类列表。	创建返回 201；分类列表出现新分	P2	功能/接	test_api.py::test_api_admin_can_create_category；人工 UI 检查

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
	能	与列表同步		3. 在文档编辑页选择该分类。	类；文档编辑页可选择；普通用户创建被拒绝或被限制为只读。		口	

4.7 非功能、API 与运维

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
NFR-001	健康检查	健康检查返回应用、版本和数据库状态	后端已启动；数据库可连接	1. 请求 GET /api/health。 2. 检查 JSON 字段。 3. 停止数据库或模拟异常后复验。	正常时返回 200，含应用标识、版本和数据库状态；数据库异常时返回非健康状态；健康检查不需要登录。	P0	可靠性/接口	test_system.py::test_01_health；人工 API 检查
NFR-002	建库与恢复	全新数据库自动建表并灌入种子	使用临时空数据库路径；不触碰演示库	1. 以全新库配置启动应用。 2. 调用建库/初始化流程。 3. 登录并查看文档、用户、图谱。	自动建表成功；演示账号、文档、图谱种子存在；admin 可登录；空库启动无异常。	P1	可靠性/集成	test_system.py::test_19_fresh_database_builds_and_seeds；tests/conftest.py 的 fresh_app 夹具
NFR-003	测试隔离	自动化测试不读演示数据库	已记录 instance/knowledge.db 的关键表行数或哈希	1. 执行全量 pytest。 2. 比较执行前后演示库。 3. 检查测试日志中数据库 URI。	演示库文件内容和关键表行数不变；测试只使用内存/临时库；测试失败也不会污染演示数据。	P0	安全/可靠性	tests/conftest.py 夹具；人工核对执行前后数据库
NFR-004	API 契约	REST API 状态码、JSON 和错误 code 一致	后端可用；已登录和未登录状态均可准备	1. 调用成功、401、403、404、400 场景。 2. 检查 Content-Type 和 JSON 字段。 3. 用 Vue	成功返回约定 JSON；401 为 AUTH_REQUIRED；403 为 FORBIDDEN；404 为 NOT_FOUND；校验失败为 VALIDATION_ERROR；前端不需要猜测	P1	接口	test_api.py 全部用例；人工 API 检查

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
				前端消费接口。	HTML。			
NFR-005	前端构建	Vue 3 SPA 可构建并加载静态资源	frontend 依赖已安装	1. 在 frontend 执行 npm run build。 2. 检查 dist 目录和资源。 3. 用静态服务或后端承载访问。	构建退出码为 0；dist 存在 index.html 和带指纹资源；页面可加载；控制台无模块解析错误。	P1	兼容性/集成	人工构建检查
NFR-006	性能烟测	演示规模下关键页面和 API 无明显超时	演示数据已初始化；浏览器缓存清理	1. 记录登录、工作台、文档列表、问答、图谱、审计的响应时间。 2. 连续操作 3 次取合理观察值。 3. 检查是否有明显卡顿。	关键页面和 API 在演示环境可接受，建议 ≤ 2 s；无请求超时、无限 loading 或浏览器卡死；异常需记录环境与数据规模。	P2	性能	人工 UI 与网络面板检查
NFR-007	错误处理	404、尾斜杠和错误页行为正确	前后端可用	1. 访问未知 API 和未知 SPA 路由。 2. 访问 /qa 与 /qa/ 等尾斜杠路径。 3. 检查页面和状态码。	未知 API 返回 JSON 404；未知 SPA 路由显示 404 页面而非登录页；尾斜杠按设计可访问或重定向；错误页不泄露堆栈。	P2	功能/接口	test_system.py::test_14_trailing_slash_ok; test_system.py::test_15_unknown_path_is_404_not_login; 人工 UI 检查
NFR-008	兼容性	Chrome 和 Edge 关键页面一致可用	安装当前稳定版 Chrome、Edge	1. 分别登录并访问主要页面。 2. 检查布局、图表、表单、表格和弹窗。 3. 记录浏览器版本和差异。	两种浏览器均可完成核心操作；无阻断性脚本错误；布局差异在可接受范围；问题有截图和版本记录。	P2	兼容性	人工浏览器检查
NFR-009	运维脚本	启停脚本可启动和释放	端口空闲；脚本和虚拟环境可用	1. 执行 start.psl 或 start.bat。	服务可按脚本启动；端口和日志正常；停止后进程退出、端口释	P2	可靠性/运	人工脚本检查

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
		服务		2. 访问健康检查和登录页。 3. 执行 stop.ps1，确认端口释放。 4. 再次启动。	放；再次启动成功；不误删业务数据。		维	

4.8 Vue 3 前端交互

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
UI-001	前端交互	登录页表单、错误提示和跳转	前端和后端已启动；admin 账号存在	1. 空用户名或空密码提交。 2. 输入错误密码提交。 3. 输入正确账号提交。	空字段有前端校验；错误密码显示可理解提示且不清空所有输入；成功后进入工作台；锁定状态显示稍后重试提示。	P0	UI/易用性	人工 UI 检查；后端由 AUTH-001 至 AUTH-006 覆盖
UI-002	前端交互	路由守卫、会话失效和角色菜单	普通用户、管理员账号可用	1. 未登录直接打开受保护路由。 2. 登录普通用户查看菜单。 3. 手动输入管理员路由。 4. 模拟会话失效。	未登录跳转登录并保留安全回跳；普通用户不显示管理员菜单；直接访问后台得到无权提示；会话失效时清理状态并重新登录。	P0	UI/安全	人工 UI 检查；后端由 PERM-009 覆盖
UI-003	前端交互	工作台统计、图表和快捷问题	admin 或 hr 已登录；统计数据可用	1. 打开工作台。 2. 检查统计卡、部门图表和快捷问题。 3. 点击快捷问题。 4. 切换到普通用户对照。	统计与当前用户可见范围一致；图表有标题/图例且无空白；快捷问题可带入问答页；普通用户统计数据不泄露机密规模。	P1	UI/功能	人工 UI 检查；后端由 PERM-008 覆盖

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
UI-004	前端交互	文档列表、搜索、筛选、分页和空状态	已登录；文档数据存在	1. 搜索“年假”。 2. 切换部门/密级/分类筛选。 3. 翻页、清空筛选。 4. 搜索不存在关键词。 5. 调整窄屏宽度。	搜索与筛选组合生效；分页状态正确；清空后恢复；空结果显示空状态而非崩溃；窄屏表格/卡片可读。	P1	UI/功能	人工 UI 检查；后端由 DOC-001、DOC-002 覆盖
UI-005	前端交互	文档详情、编辑、收藏和删除确认	已登录且有可编辑或可读文档	1. 打开文档详情。 2. 收藏并刷新。 3. 进入编辑页，提交空标题和正常修改。 4. 删除文档并取消一次、确认一次。	详情字段展示正确；收藏状态跨刷新保持；空标题有提示；保存成功有 toast 并更新列表；删除有确认且取消不删除。	P1	UI/功能	人工 UI 检查；后端由 DOC-003 至 DOC-007 覆盖
UI-006	前端交互	RAG 问答、来源、历史和无结果状态	已登录；问答接口可用	1. 输入“员工年假有几天？”并发送。 2. 查看回答和来源。 3. 点击来源打开详情。 4. 提交无命中问题。 5. 刷新并打开历史。	发送中有 loading 且防重复提交；回答与来源对应；来源可点击；无命中显示诚实提示；历史可查看且不串用户。	P1	UI/功能	人工 UI 检查；后端由 RAG-008 至 RAG-011 覆盖
UI-007	前端交互	图谱浏览与管理员维护	admin 已登录；图谱数据存在	1. 打开图谱页。 2. 拖拽、缩放、切换图例筛选。 3. 管理员新增概念节点和关系。 4. 普通用户重新进入。	图谱渲染正常；拖拽缩放可用；筛选生效；管理员可新增并反馈成功；普通用户看不到维护入口。	P2	UI/功能	人工 UI 检查；后端由 GRAPH-001 至 GRAPH-007 覆盖

编号	模块	测试项	前置条件	步骤	预期结果	优先级	类型	自动化关联
UI-008	前端交互	后台用户/审计表格、响应式和基本可访问性	admin 已登录；审计记录充足	1. 打开用户和审计页面。 2. 使用筛选和分页。 3. 缩小到 1366×768 和窄屏。 4. 使用 Tab 键、Esc 和回车操作关键控件。	表格可读，长内容不撑破布局；筛选分页可用；侧栏在窄屏可收起；焦点可见；按钮有可理解文本；弹窗可用 Esc 关闭。	P2	UI/兼容性/易用性	人工 UI 检查；后端由 ADMIN-001 至 ADMIN-008 覆盖

5. 测试执行汇总模板

5.1 执行轮次汇总

字段	填写内容
轮次编号	TR-____
被测版本	V2.0，提交号：_____
前端版本	V2.0，构建号/时间：_____
执行日期	2026-__-__
执行人	_____
环境	Windows 10/11，Python 3.12，Chrome/Edge 版本：_____
数据库	独立测试库/临时库标识：_____
计划用例数	73
已执行数	____
通过数	____
失败数	____
阻塞数	____
豁免数	____
执行率	已执行数 ÷ 73
通过率	通过数 ÷ 已执行数
自动化基线	计划/交付基线 136 条，实际收集/执行：____ 条，通过：____ 条
关联缺陷	DEF-____、DEF-____
结论	通过 / 有条件通过 / 不通过
复核人/日期	_____

5.2 模块执行汇总

模块	计划	已执行	通过	失败	阻塞	豁免	通过率	备注
认证与会话	10							
权限与隔离	9							
文档与收	9							

模块	计划	已执行	通过	失败	阻塞	豁免	通过率	备注
藏								
RAG 问答	12							
知识图谱	8							
管理员与审计	8							
非功能与 API	9							
Vue 前端	8							
合计	**73**							

5.3 自动化执行记录

项目	填写内容
执行命令	.\run_tests.psl 或 pytest tests
执行时间	_____
收集用例数	____
通过数	____
失败数	____
跳过数	____
耗时	____
失败用例	文件::函数::参数
日志路径	_____
演示库隔离核对	通过 / 不通过，证据：_____
结论	通过 / 不通过

5.4 人工检查记录

用例	浏览器/版本	分辨率	操作摘要	结果	截图路径	备注
UI-____	Chrome/Edge ____	1920×1080		通过/失败		
NFR-____	Chrome/Edge ____	1366×768		通过/失败		
其他						

5.5 执行结论模板

- 本轮计划执行 73 条模块化用例，实际执行 ____ 条，通过 ____ 条，失败 ____ 条，阻塞 ____ 条。
- 自动化基线计划/交付 136 条，实际收集 ____ 条，通过 ____ 条，失败 ____ 条，以后附 pytest 日志为准。
- P0/P1 未关闭缺陷：____ 个；是否满足准出：是/否。
- 演示库隔离：通过/不通过；证据：_____。
- 前端关键页面：通过/不通过；截图：_____。
- 总体结论：通过/有条件通过/不通过。有条件通过时必须列出残留风险和批准人。

6. 缺陷记录模板

6.1 缺陷单字段

字段	填写要求
缺陷编号	DEF-YYYYMMDD-序号
标题	用“模块+条件+错误现象”描述，避免只写“有问题”
关联用例	例如 PERM-004、RAG-009
发现版本	V2.0，提交号：_____
环境	操作系统、Python、浏览器、数据库类型
严重级别	S1/S2/S3/S4
优先级	P0/P1/P2/P3
发现人/日期	_____
前置条件	账号、角色、部门、数据、密级
复现步骤	编号列出，最少包含一次失败路径
实际结果	客观现象、状态码、错误字段
预期结果	对应需求或用例的明确结果
证据	日志、截图、响应体、数据库查询
状态	新建/处理中/待回归/已关闭/延期/不接受
修复人/版本	_____
修复说明	根因与修改范围
回归结果	通过/失败，回归用例和日期
风险与影响	对验收、安全和数据的影响

6.2 缺陷记录示例表

缺陷编号	标题	关联用例	严重级别	优先级	状态	实际结果	预期结果	证据	回归结果
DEF-_____	模块+条件+现象		S_	P_	新建				待回归

6.3 缺陷关闭标准

缺陷关闭必须同时满足：修复代码已进入测试基线；原复现步骤不再出现；相关负向用例通过；必要时完成权限矩阵回归；修复未引入新的 P0/P1 问题；证据已附在缺陷记录中。仅凭开发口头说明或单张截图不得关闭安全类缺陷。

7. 需求追踪说明与追踪矩阵

7.1 追踪规则

需求追踪按“需求编号 → 用例编号 → 自动化关联 → 执行结果 → 缺陷编号”维护。每个需求至少有一条正向用例；安全、权限、隔离类需求同时要有负向用例。需求变更后，测试负责人必须检查用例是否失效、自动化是否需更新、执行汇总是否需重跑。

7.2 追踪矩阵

需求域	代表性需求	对应用例	自动化证据	验收关注点
认证与会话	SR-AUTH-001 至 SR-AUTH-008	AUTH-001 至 AUTH-010	test_api.py、test_system.py、test_login_security.py	登录、退出、未认证、防爆破、安全跳转、密码哈希
角色与权限	SR-AUTH-005、SR-AUTH-006 及角色需求	PERM-001 至 PERM-009	test_security.py、test_system.py、test_api.py	管理员、普通用户、后台入口
三级密级与部门隔离	SR-AUTH-005、SR-AUTH-006	PERM-001 至 PERM-007	test_security.py、test_system.py、test_rag.py	同部门、异部门、作者、草稿、来源
文档管理	SR-DOC-001 至 SR-DOC-006	DOC-001 至 DOC-009	test_api.py、test_system.py	CRUD、详情、索引、收藏、筛选分页
检索与问答	SR-QA-001 至 SR-QA-008	DOC-001、RAG-001 至 RAG-012	test_rag.py、test_system.py、test_api.py	分词、排序、Top-K、来源、降级、历史
知识图谱	SR-KG-001 至 SR-KG-004	GRAPH-001 至 GRAPH-008	test_system.py、test_api.py、人工 UI	结构、可见范围、同步、维护
管理员功能	SR-ADMIN 相关	ADMIN-001、ADMIN-008	test_api.py、人工 UI	用户、分类、权限
审计	SR-AUD-001 至 SR-AUD-004	ADMIN-002 至 ADMIN-007、AUTH-008	test_security.py、test_login_security.py、test_system.py	失败登录、筛选、分页、时间、详情
健康与运维	SR-OPS-001、SR-OPS-002	NFR-001、NFR-002、NFR-009	test_system.py、人工脚本检查	健康检查、全新库、启停
非功能与接口	NFR 易用/安全/可靠/性能/可维护	NFR-001 至 NFR-009	pytest、npm build、人工浏览器	API 契约、测试隔离、构建、兼容、性能
前端交互	用户需求中的演示场景	UI-001 至 UI-008	人工 UI 检查	登录、文档、问答、图谱、后台、响应式

表中的需求编号以现行需求和报告口径为准。如需求编号调整，应保持“需求内容—用例—自动化—结果”的对应关系不变，并在修订记录中说明。

8. 用例维护与验收说明

8.1 用例维护规则

390. 新增功能必须新增或修改用例，不能只更新实现；
391. 安全边界变化必须同时更新正向和负向用例；
392. 自动化函数改名、删除或拆分时，必须更新关联列；
393. 删除用例需说明理由，不能为“让结果变绿”而删除；
394. 用例通过后仍需保留执行日期、版本和证据路径。

8.2 课程验收判定

- P0 用例必须 100% 通过；
- P1 用例原则上全部通过，未通过时必须有明确残留风险和批准；

- 认证、权限、密级、RAG 来源、测试库隔离不得带安全问题通过；
- 自动化基线 136 条以最终 pytest 日志为准，不得只引用历史截图；
- 人工 UI 用例至少覆盖 Chrome 或 Edge 一种主流浏览器，关键场景建议两者对照；
- 最终结论以《测试报告》和验收当日执行记录为准。

9. 附录：课程验收故事线

步骤	操作	账号	预期证据
1	打开登录页，演示错误密码和正确登录	admin	错误提示、工作台截图、会话保持
2	查看工作台统计、部门图表和快捷问题	admin	统计跟随可见范围、图表正常
3	搜索“年假”并打开文档	admin	命中年休假办法、详情字段完整
4	提问“员工年假有几天”并点击来源	admin	回答、来源标题、片段可追溯
5	打开知识图谱，拖拽和筛选	admin	节点、边、图例和管理入口
6	查看用户列表和审计日志，筛选失败登录	admin	用户汇总、登录失败记录、分页
7	使用 hr 打开信息部机密文档	hr	列表不出现或详情 403
8	使用 it 打开同部门机密文档	it	200 且正文可见
9	连续输错密码触发锁定	hr	429 提示、Retry-After、审计
10	查看关于页统计并核对权限口径	hr	统计不泄露不可见机密规模
11	返回 admin，查看最终自动化日志和测试库隔离证据	admin	136 条基线执行记录、演示库无变化

验收结论：在满足《项目测试计划》退出准则后，方可将本系统判定为“通过课程验收”。若存在未关闭的 P0/P1 缺陷、测试库污染或机密来源越权，必须判定为不通过并重新回归。

文档结束

第 6 部分　项目总结

1 项目概况

1.1 项目基本信息

《智慧企业知识财富库系统》是一个面向课程实践的本地 Web 应用。项目以知识文档管理为基础，叠加认证与权限、检索增强问答、知识图谱、收藏、审计、用户与分类管理、系统运维等功能。最终版本为 V2.0，完成日期为 2026-10-31。

维度	内容
项目定位	软件工程课程大作业，可用于本地运行、演示和测试
用户角色	管理员、普通员工；演示账号均为虚构
核心业务对象	知识文档、分类、标签、部门、密级、问答片段、图谱节点与边、收藏、审计记录
前端	Vue 3 + Vite、Vue Router、ECharts
后端	Flask 3 REST API、SQLAlchemy
数据库	SQLite
文本处理	jieba 中文分词、文本切分与相关度排序
测试	pytest，当前测试集共 136 条，编制文档时全部通过
建模与交付	10 张 UML 图、前端页面截图、课程文档、运行与提交说明

1.2 项目背景与目标

课程项目需要一个既能体现完整软件工程过程、又能形成可运行成果的题目。知识管理系统具备文档、权限、检索、问答、图谱和审计等多个典型模块，既能覆盖需求分析与系统设计，也能体现前后端分离、数据建模、算法服务和安全测试。因此选择“智慧企业知识财富库系统”作为课程题目。

项目目标包括：

395. 完成从立项、需求、设计、开发、测试到交付的完整闭环；
396. 实现可鉴权的知识文档库，确保不同角色和部门只能访问授权内容；
397. 在文档基础上实现检索增强问答，做到回答有依据、来源可追溯；
398. 通过知识图谱展示文档、部门、分类和关键词之间的关系；
399. 用收藏、审计、用户与分类管理、系统运维补齐业务和工程支撑；
400. 通过 pytest 自动化测试和过程文档证明结果可重复、可核查；
401. 在单人条件下完成全部角色职责，并保持范围、进度和质量可控。

1.3 项目范围与实际边界

本期交付覆盖八个业务与管理模块：认证与权限、知识文档、检索增强问答、知识图谱、收藏、审计、用户与分类管理、系统运维。前端页面、后端接口、数据库模型、测试、10 张 UML 图、前端页面截图和课程文档也属于实际交付范围。

项目没有真实企业用户，也没有在生产环境上线。所有演示制度、账号、部门和图谱数据均为虚构。外部大模型调用只作为可选增强，未配置时系统仍应提供检索、片段来源和本地回答链路。项目没有实现真实企业 SSO、多租户、原生移动端、在线协同编辑、生产级高可用和图数据库平台。

1.4 组织方式与角色承担

本项目只有一个执行人。本人同时承担以下职责：

角色	本人实际完成的工作
项目组长 / 项目经理	制定计划、WBS、周进度、里程碑、风险清单和验收标准
需求分析	梳理场景、角色、文档权限、问答流程和验收条件
系统设计	设计三层架构、数据模型、权限模型、REST API、RAG 和图谱方案
UI/UX 设计	设计导航、页面结构、状态反馈和主要操作路径
前端开发	完成 Vue 3 + Vite 页面、路由、API 客户端和 ECharts 展示
后端开发	完成 Flask 3 API、业务逻辑、数据库访问、权限与审计
数据设计	设计 SQLAlchemy 模型、SQLite 表结构、约束和虚构演示数据
测试	设计测试矩阵，编写和执行 pytest，开展手工回归和验收
文档与交付	编写课程文档、维护 UML、截图、运行说明和交付清单

单人组织缩短了沟通链路，也让需求、设计、代码和文档更容易保持一致。但其代价是所有问题都需要本人发现和解决，缺少真正的多人评审。因此项目采用“角色切换 + 自检清单 + 测试回归 + 里程碑冻结”的方式模拟质量控制，而不是虚构其他团队成员。

2 计划与实际完成对比

2.1 总体进度对比

计划窗口为 2026-08-10 至 2026-11-01，共 12 周；计划交付控制点为 2026-10-31。实际于 2026-10-31 完成交付，整体处于计划的 12 周窗口内。下表按阶段对比计划输出与实际结果；由于项目为单人执行，阶段存在交叉和迭代，表中“实际结果”以最终交付状态为准，重点描述是否完成以及产生的影响。

阶段	计划完成内容	实际结果	是否达成	偏差与说明
立项与范围	明确课程要求、项目定位、范围和 12 周计划	完成课程项目定位、八个模块范围、范围外清单和进度安排	达成	范围保持稳定，未增加真实生产目标
需求分析	角色、场景、功能需求、验收条件	完成管理员/员工角色、文档权限、问答、图谱和验收要求	达成	后期将权限与问答边界进一步细化

阶段	计划完成内容	实际结果	是否达成	偏差与说明
系统设计	架构、数据、接口、页面和 UML	完成三层架构、数据关系、REST API、权限模型、RAG 与图谱设计	达成	10 张 UML 图最终统一校对
工程骨架	前后端工程、配置、数据库和启动方式	建立 Vue 3 + Vite 与 Flask 3 工程，完成配置、初始化与运行脚本	达成	V2 前端改造增加联调和构建工作量
认证权限	登录退出、角色、密级、部门隔离和失败审计	完成登录会话、角色菜单、文档可见性、失败登录留痕与安全处理	达成	权限矩阵在测试阶段继续补充
知识文档	CRUD、分类标签、状态、筛选、分页、检索	完成文档管理、列表筛选、详情、检索、分类和状态能力	达成	与权限、切分、图谱同步联动
检索问答	分词、检索、Top-K、来源、历史与降级	完成权限内检索、jieba 分词、来源展示、问答历史和本地回答路径	达成	问答边界与无命中场景进行了多轮修正
知识图谱	数据同步、API、ECharts 和维护	完成节点边同步、图谱数据接口、力导向可视化和管理员维护	达成	重点解决重复同步和数据陈旧问题
收藏审计管理	收藏、审计、用户、分类、工作台和健康检查	完成收藏、审计查询、用户/分类管理、工作台、关于和健康检查	达成	管理功能按角色收口
前端集成	页面导航、状态、错误反馈和截图	完成主要 Vue 页面、路由、API 客户端、图表和截图整理	达成	作为 V2.0 的重点实际工作
测试验证	自动化测试、安全与回归、无阻断缺陷	136 条自动化测试编制时全部通过，完成手工主链路验收	达成	最终以冻结版本实测输出为准
文档交付	计划、总结、UML、截图和交付清单	完成课程文档、10 张 UML、说明材料和交付清单	达成	文档与实现按 V2.0 统一校对

2.2 模块完成情况

模块	计划目标	实际完成	结论
认证与权限	登录、退出、角色与密级隔离	已实现会话登录、角色菜单、管理员/同部门/异部门/作者可见性规则和越权拒绝	完成
知识文档	文档全生命周期管理	已实现新建、编辑、查看、删除、分类、标签、状态、筛选、分页和检索	完成
检索增强问答	权限内检索并展示来源	已实现切分、jieba 分词、相关度排序、Top-K、来源、历史和降级	完成
知识图谱	关系同步与可视化	已实现实体关系同步、JSON 数据接口、ECharts 力导向图和后台维护	完成
收藏	收藏与取消收藏	已实现收藏、取消收藏、个人收藏列表和唯一约束	完成
审计	关键动作留痕与查询	已实现登录、失败登录、文档访问、问答和写操作记录；管理员可查询	完成

模块	计划目标	实际完成	结论
用户与分类管理	管理员维护基础数据	已实现用户查看与管理、分类维护及管理入口控制	完成
系统运维	工作台、关于、健康检查和脚本	已实现工作台、关于页、健康检查、初始化、启动/停止和测试脚本	完成
前端应用	Vue 3 + Vite 主要页面	已实现登录、工作台、文档列表/详情/编辑、问答、图谱、审计、用户、关于和错误页面	完成
测试与文档	自动化测试、UML、截图和文档	已形成 pytest 测试集、10 张 UML、页面截图、课程文档和交付说明	完成

2.3 里程碑对比

里程碑	计划日期	实际状态	达成说明
M0 项目启动	2026-08-10	达成	建立项目定位、范围、组织方式和 12 周计划
M1 需求基线	2026-08-23	达成	完成角色、模块、权限和验收条件
M2 设计基线	2026-08-30	达成	完成架构、数据、接口和 10 张 UML 设计材料
M3 核心 MVP	2026-09-20	达成	登录、权限、文档和检索问答主链路可运行
M4 功能完整	2026-10-04	达成	图谱、收藏、审计、管理、运维和前端页面形成完整闭环
M5 质量基线	2026-10-18	达成	自动化测试与安全回归通过，主要缺陷关闭
M6 文档与预验收	2026-10-25	达成	文档、UML、截图、演示脚本和交付清单齐备
M7 最终交付	2026-10-31	达成	V2.0 冻结并完成课程交付材料整理

2.4 偏差分析与处理

本项目的主要偏差不是业务模块缺失，而是 V2.0 前端技术升级带来的集成工作量增加。前端采用 Vue 3 + Vite 后，需要重新组织页面路由、登录态传递、API 客户端、错误处理、图表加载和构建流程；相较服务端模板方式，前后端联调和页面状态验证需要更多时间。

处理方式如下：

402. 优先保证八个业务模块和核心演示链路，减少与验收无关的装饰性页面；

403. 先固定 API 请求/响应结构和错误处理方式，再并行完善页面；

404. 将前端页面检查与后端接口测试放在同一里程碑，避免最后集中返工；

405. 把 V2.0 技术栈和页面截图纳入文档基线，确保交付材料与实现一致；

406. 对不能在本期完成的生产级能力明确列入范围外和后续改进，不用“已完成上线”掩盖项目边界。

3 功能与技术成果

3.1 功能成果

3.1.1 认证与权限

系统支持本地账号登录、退出和会话维持，区分管理员与普通员工角色。文档按照公开、内部、机密等可见性规则控制访问；管理员可访问全部文档，机密文档仅允许同部门用户或文档作者访问。无权限访问返回拒绝结果，不在详情、列表、检索或问答来源中泄露正文。关键登录失败也会进入审计，便于发现异常尝试。

权限设计的重点不是只在详情页做判断，而是让文档列表、详情、检索、问答、收藏和统计使用同一套可见性规则。这样能够降低“列表不可见但问答能搜到”的不一致风险。

3.1.2 知识文档

文档模块支持新建、查看、编辑、删除、分类、标签、状态、密级、部门和版本等字段，并提供关键词检索、分类筛选、部门筛选、密级筛选和分页。文档保存后会触发知识片段切分和图谱同步，使后续问答与图谱使用最新内容。文档正文、摘要和元数据在页面中统一展示，便于课程演示和复查。

3.1.3 检索增强问答

问答流程包括问题接收、中文分词、权限范围内的候选文档筛选、知识片段检索、相关度排序、Top-K 选择、来源组装和回答生成。回答页面展示来源文档、部门、片段摘要和相关度，用户能够判断答案依据。系统还保存问答历史，支持查看本人历史记录。无命中时明确说明没有检索到合适依据；未配置外部模型时采用本地回答链路，不把本地结果伪称为大模型生成。

权限先于检索是本项目最重要的设计约束之一。系统先根据当前用户确定可见文档，再在对应片段中检索，避免机密片段进入候选集、日志展示或来源列表。

3.1.4 知识图谱

知识图谱模块将文档、部门、分类和关键词等实体组织为节点与边，通过接口提供给前端，并使用 ECharts 力导向图展示。文档变更后可再次同步关系，管理员可以通过维护入口补充自动同步不足的节点或关系。该模块主要用于表达知识之间的关联，而不是替代图数据库或复杂图计算平台。

3.1.5 收藏、审计与管理

收藏模块支持收藏、取消收藏和个人收藏列表，并通过唯一约束避免重复收藏。审计模块记录登录成功、登录失败、文档访问、问答和关键管理操作，管理员可按条件查询。用户与分类管理模块提

供用户查看、用户状态/角色相关维护和分类维护能力，管理入口只对管理员开放。系统运维模块提供工作台、关于页、健康检查、初始化数据、启动/停止和测试脚本，使项目能够在本地复现。

3.2 技术成果

层次	技术实现	设计价值
表现层	Vue 3 + Vite、Vue Router、统一 API 客户端、ECharts	前后端职责分离，页面状态和接口错误集中处理
接口层	Flask 3 REST API	前端通过稳定接口访问业务能力，便于测试
业务层	认证、文档、问答、图谱、收藏、审计、管理、运维服务	路由只负责编排，权限和核心规则集中复用
数据层	SQLAlchemy + SQLite	模型清晰，便于本地初始化和课程演示
文本处理	jieba、切分、相关度评分、Top-K	在没有复杂向量平台的前提下提供可解释检索
测试层	pytest、测试夹具、临时数据库	支持重复执行，避免污染演示数据
文档与图	Markdown、PlantUML、10 张 UML、页面截图	形成可审阅的设计和交付证据

项目没有把业务逻辑写入页面模板或前端组件，而是通过后端 API 统一完成鉴权、权限过滤、数据访问和审计。这一结构使权限规则能够被自动化测试直接覆盖，也减少了前端绕过业务规则的空间。

3.3 工程化成果

407. 使用应用工厂、分层路由和服务模块组织 Flask 后端，配置项支持不同运行环境。

408. 使用统一 API 客户端处理前端请求和错误，使认证失效、无权限和服务异常有一致表现。

409. 使用 SQLAlchemy 建立用户、文档、知识片段、图谱、收藏、审计和问答历史等模型。

410. 使用独立临时数据库执行测试，避免测试修改演示数据库。

411. 使用虚构种子数据保证首次启动后即可演示，同时避免真实企业信息。

412. 提供启动、停止、测试和依赖安装说明，降低复查环境搭建成本。

413. 完成 10 张 UML 图和前端页面截图，覆盖用例、时序、活动、状态、类、ER、部署、构件和三层架构等视角。

4 测试与质量数据

4.1 测试策略

测试采用“自动化为主、手工验收补充”的方式。自动化测试重点覆盖可重复验证的业务规则和边界条件；手工验收重点检查页面布局、主链路连续性、错误提示和截图一致性。

测试层次	主要内容	目的

测试层次	主要内容	目的
单元/服务测试	文本切分、jieba 分词、相关度、Top-K、来源去重、图谱同步	验证核心算法和服务的确定性
API 测试	登录、文档、问答、图谱、收藏、审计、用户与分类、健康检查	验证接口契约和状态码
权限安全测试	管理员、同部门、异部门、作者、未登录	防止越权和机密泄露
登录安全测试	失败次数、窗口、锁定、成功清零、失败审计、密码存储	防止暴力尝试并保留证据
集成/回归测试	新建文档后可检索、问答来源、图谱同步、主链路	验证模块联动
手工验收	页面、图表、空状态、错误页、截图、启动停止	验证用户可见结果

当前自动化测试集共 136 条，分布在 `test_api.py`、`test_login_security.py`、`test_rag.py`、`test_security.py` 和 `test_system.py` 五个测试文件中。测试使用临时数据库和夹具，不读写演示数据库。

4.2 测试结果数据

指标	数值	说明
自动化测试总数	136	文档编制时项目测试集
通过数	136	文档编制时快照
失败数	0	文档编制时快照
错误数	0	文档编制时快照
通过率	100%	以通过数/总数计算
阻断级已知缺陷	0	编制时交付判断
严重级已知缺陷	0	编制时交付判断
测试数据库	独立临时数据库	避免污染演示数据

> 数据边界：上述数字是本文编制时对项目状态的记录，不是永久保证。正式验收应在代码、依赖和测试文件冻结后重新执行 pytest，以最终日志中的实际总数、通过数、失败数、错误数和耗时为准。若实际结果发生变化，应更新总结和测试记录，不应沿用旧数字掩盖差异。

4.3 质量覆盖情况

质量维度	已验证内容	结果判断
功能完整性	八个模块均有 API、页面或运行入口	满足课程交付
权限一致性	文档详情、列表、检索、问答、收藏使用可见性规则	重点通过
问答可追溯	来源、部门、片段摘要和相关度展示	满足演示
数据联动	文档保存后切分、检索、图谱同步	满足演示
登录安全	失败限制、锁定、失败审计、密码非明文	通过
管理权限	管理员入口和普通用户隔离	通过
测试隔离	临时数据库、夹具初始化	通过
可复现性	安装、启动、停止、测试和初始化说明	满足本地复查
文档一致性	10 张 UML、截图、版本和技术栈	完成统一校对
生产级质量	高并发、持久化限流、备份恢复、真实用户验收	不在本期范围

4.4 主要缺陷与修复

问题	影响	解决方式	结果
权限判断分散可能导致列表、详情和问答结果不一致	越权泄露风险	统一文档可见性判定，检索前先限定可见文档	已修正并纳入权限回归
测试直接使用演示数据库会污染数据	测试结果不稳定，演示数据被改写	使用独立临时数据库和测试夹具	已隔离
中文业务词分词不准确导致检索失效	关键词搜索或评分异常	使用 jieba 并补充领域词、边界测试	已改善
图谱同步重复或文档变更后关系陈旧	可视化与实际文档不一致	同步逻辑幂等处理，保存后触发并支持维护/重同步	已修正
前后端字段或错误格式不一致	页面空数据或错误提示混乱	固定 API 契约，统一客户端和错误处理	已修正
登录缺少失败限流和失败留痕	暴力尝试难以发现	增加失败计数、锁定窗口和失败审计	已修正
UML 中文渲染异常	图中标签不可读	统一字体和渲染流程，逐图检查	已修正
单人物色缺少外部评审	设计与实现盲区	使用检查清单、里程碑冻结和自动化回归补强	部分缓解

4.5 质量结论

在项目编制时快照下，136 条自动化测试全部通过，核心业务链路可运行，权限、问答、图谱、收藏、审计、管理和运维均有可验证成果。项目没有声称覆盖率、并发能力或真实用户满意度等未采集指标；这些缺口已在不足与后续改进中明确列出。

5 各阶段复盘

5.1 需求阶段复盘

复盘项	评价
有效做法	先确定八个模块和范围外清单，再写功能和验收条件；把权限、问答来源和虚构数据边界提前写入需求
主要不足	没有真实企业用户参与，场景主要来自课程目标和合理推演；部分交互细节直到前端联调才完全明确
改进方向	增加低保真原型和角色走查，在编码前用具体页面流程验证需求

需求阶段最有价值的决定是明确“先权限、后检索”和“演示数据全部虚构”。前者为后续问答安全提供了硬边界，后者避免课程项目被误解为真实企业案例。需要承认的是，课程项目没有真实用户访谈和真实业务样本，需求覆盖度不能等同于生产系统。

5.2 设计阶段复盘

复盘项	评价
有效做法	采用前后端分离与分层服务；先定义角色、权限和数据关系；用 UML 补充静态与动态视角
主要不足	V2 前端技术栈调整后，部分接口字段和页面状态设计需要二次对齐；单人评审容易漏掉边界
改进方向	采用接口契约优先和页面状态表，在开发前固定请求、响

复盘项	评价
	应、空状态和错误状态

设计阶段形成了 10 张 UML 图，包括用例、登录时序、问答时序、文档发布活动、文档状态、类图、ER 图、部署图、构件图和三层架构图。这些图不只是交付材料，也帮助检查模块边界和调用顺序。问题在于图形设计与实际 V2 前端联调之间存在时间差，后续应把 API 契约和页面状态纳入设计基线。

5.3 实现阶段复盘

复盘项	评价
有效做法	按认证、文档、RAG、图谱、管理逐步增量实现；共享权限和 API 客户端；每个模块完成后立即验证
主要不足	单人开发容易优先完成“能运行”，后补异常边界；前端构建与后端联调占用较多时间
改进方向	继续使用小步提交和接口测试；为前端增加端到端自动化；把异常路径纳入开发完成定义

实现阶段的难点集中在权限一致性、RAG 检索可解释性和图谱同步。通过把文档可见性提取为共享规则、在检索前过滤文档、对图谱同步做幂等处理，系统才形成稳定的业务闭环。Vue 3 + Vite 前端使页面组织和交互更清晰，但也暴露出接口契约、登录态和构建配置必须提前设计的问题。

5.4 测试阶段复盘

复盘项	评价
有效做法	使用临时数据库；覆盖权限矩阵和问答边界；测试与演示数据分离；在里程碑前执行全量回归
主要不足	没有统计代码覆盖率；缺少浏览器端端到端自动化；没有生产级性能和并发测试
改进方向	增加覆盖率、E2E、性能基线和持续集成结果归档

测试阶段确认了自动化测试对单人项目的重要性。由于没有独立测试人员，权限和问答等高风险区域必须通过可重复用例来补偿人工检查的不足。136 条用例覆盖了 API、安全、RAG、登录和系统主链路，但课程项目没有采集未实现的覆盖率数据，因此不能把“测试通过”扩大解释为所有代码路径均已覆盖。

6 遇到的问题及解决方案

编号	问题	根因分析	解决方案	经验
P-01	单人承担全部角色，时间与精力冲突	没有多人并行和外部评审	用 WBS、周计划、里程碑和 Definition of Done 拆分工作；关键路径优先	单人项目更需要书面计划
P-02	权限规则容易在不同入口重复实现	列表、详情、问答、收藏都有可见性判断	建立共享可见性规则；检索前先过滤；用权限矩阵回归	安全规则必须集中
P-03	问答可能越过文档权限	检索候选集未先按用户过滤	先确定可见文档，再检索片段；来源也走	问答不是权限例外

编号	问题	根因分析	解决方案	经验
			同一规则	
P-04	业务词分词效果不足	通用词典对课程业务词覆盖有限	使用 jieba 领域补充词和边界测试，保持打分可解释	检索效果要用真实问题集验证
P-05	文档变更后图谱不同步	图谱与文档分属不同数据路径	文档保存触发同步；同步幂等；提供维护与重同步	关系数据要有重建机制
P-06	测试污染演示库	测试直接使用运行数据库	测试使用临时数据库和独立夹具	测试隔离是质量基础设施
P-07	前后端联调字段漂移	页面和接口由同一人先后实现，缺少契约检查	固定 API 结构，使用统一客户端，补充 API 测试	单人也要做接口契约管理
P-08	登录失败难以追踪	只记录成功登录，缺少失败审计	记录失败登录并加入计数窗口和锁定处理	安全事件要可观察
P-09	UML 中文标签显示异常	渲染字体和工具配置不一致	固定中文字体与渲染流程，逐图校对	图也是交付质量的一部分
P-10	文档容易落后于代码	文档集中到最后阶段编写	每阶段同步增量，W11—W12 统一校对版本、路径和截图	文档要进入里程碑

7 项目不足与后续改进

7.1 项目不足

414. **没有真实用户和真实生产上线。** 项目是课程设计，需求和场景主要基于课程目标与合理推演，不能证明真实企业采用或产生实际业务收益。

415. **没有生产级部署与高可用。** SQLite 和本地运行方式适合演示，不适合高并发、多实例和长期生产运维。

416. **登录限流和会话能力仍偏演示。** 单机限流、进程内状态和多实例共享等问题没有在本期解决。

417. **RAG 评估不充分。** 已实现检索、排序、来源和历史，但缺少大规模问题集、召回率/精确率评估、重排模型和系统化幻觉评估。

418. **知识图谱能力有限。** 采用轻量关系模型和 ECharts，不具备图数据库查询、复杂推理和大规模图谱分析能力。

419. **测试覆盖仍有缺口。** 136 条用例全部通过是重要成果，但没有采集代码覆盖率，也缺少浏览器端端到端自动化和生产级压力测试。

420. **单人评审的客观性有限。** 虽然使用清单、自动化测试和文档复核，但没有真正的多人代码审查和用户验收。

421. **前端体验和可访问性仍有提升空间。** 主要面向桌面演示，移动端适配、键盘操作、无障碍语义和跨浏览器细节未做系统验证。

422. **文档和实现的一致性依赖人工校对。** 虽然完成了统一校对，但缺少自动检查文档链接、接口字段和截图版本的机制。

7.2 后续改进路线

优先级	改进项	具体动作	预期价值
P0	可观测性和质量门禁	接入持续集成、覆盖率统计、前端 E2E 和统一测试报告	让每次变更都有客观回归证据
P0	权限安全加固	补充细粒度权限、审计异常检测、共享限流存储和会话策略	降低越权和暴力尝试风险
P1	数据层演进	从 SQLite 迁移到 PostgreSQL，引入迁移工具和连接池	支持更大规模和更可靠的部署
P1	RAG 评估与优化	建立问题集、召回评估、重排和模型输出评价	从“可演示”走向“可度量”
P1	图谱能力增强	引入图数据库或更完整的实体/关系查询能力	支持复杂关系分析和探索
P2	用户体验完善	移动端适配、无障碍、表单校验、操作引导和多语言	提升可用性与可访问性
P2	生产运维	备份恢复、监控告警、密钥管理、容器化与灰度发布	为真实部署做准备，但不在课程范围内宣称已完成

改进项中，P0 针对当前质量证据的缺口，P1 面向技术和业务深化，P2 属于产品化方向。继续演进时应先明确真实用户和合规要求，再决定是否引入多租户、企业身份认证和外部模型服务。

8 个人收获

8.1 工程能力

通过独立完成项目，我系统实践了需求分析、架构设计、前后端开发、数据库建模、测试设计和文档交付。尤其是 Vue 3 + Vite 与 Flask 3 REST API 的联调，让我认识到接口契约、错误处理、路由守卫和构建配置不是附属工作，而是系统能否稳定演示的一部分。

8.2 项目管理

单人项目没有天然的团队分工，必须自己建立范围、WBS、里程碑和检查点。最大体会是：计划不是把任务列出来，而是明确每个阶段的输出、验收条件和延期处理方式。关键路径优先、每周缓冲、冻结后只修复不扩展，是控制单人项目节奏的有效方法。

8.3 质量与安全意识

权限、问答来源、审计和测试隔离让我认识到，安全边界必须通过共享规则和自动化用例来保证。只在某个页面加判断并不可靠；权限规则一旦分散，就很容易在问答、图谱或统计入口出现遗漏。136 条测试用例的价值不只是数量，而是把高风险规则固化为可重复检查。

8.4 文档与表达

项目还让我练习了把设计意图写成可检查文档、把过程数据写成可核验表格、把不足和边界写清楚。课程文档不能只描述“做了什么”，还要说明为什么这样做、如何验证、哪些没做以及后续如何改进。

8.5 角色切换与自我管理

本人同时承担项目组长和全部成员职责，需要不断在管理者、开发者、测试者和文档编写者之间切换。这个过程提升了任务拆解、优先级判断、风险识别和自我检查能力，也让我更清楚多人项目中沟通、评审和交接为什么重要。

9 最终交付清单

序号	交付物	位置/形式	状态
1	项目源代码	项目根目录、`app/`、`frontend/`	完成
2	后端应用	Flask 3 REST API、SQLAlchemy 模型、SQLite 配置	完成
3	前端应用	Vue 3 + Vite 页面、路由、API 客户端、ECharts	完成
4	自动化测试	`tests/` 下 pytest 测试集，共 136 条编制时快照	完成
5	项目开发计划	`docs/course/01-项目开发计划.md`	完成
6	项目总结	`docs/course/06-项目总结.md`	完成
7	需求与设计文档	`docs/` 中相关过程文档	完成
8	UML 图集	10 张 UML 源文件及渲染图	完成
9	前端页面截图	课程交付截图集	完成
10	运行与提交说明	`README.md`、`00-提交说明.md`、启动/停止/测试脚本	完成
11	演示材料	虚构账号说明、演示主链路和验收记录	完成
12	版本与交付清单	V2.0 冻结文件、文档和交付核对记录	完成

交付边界： 上述交付物用于课程项目展示和本地复查，不代表真实企业系统上线。所有演示账号、制度正文、部门、图谱和业务数据均为虚构；如实际验收时测试数量或文件路径发生变化，应以冻结版本的实际结果和文件清单为准。

10 自评与结论

10.1 自评说明

以下评分是本人对课程项目完成度的个人自评，不代表教师或课程组的最终成绩。评分重点考察计划执行、功能闭环、工程质量、文档完整性和事实边界。

评价维度	自评分（100）	自评依据
项目管理	88	完成范围、WBS、12 周计划、里程碑、风险和验收管理；单人评审客观性有限
需求分析	88	八个模块、角色、权限和验收条件较完整；缺少真实用户访谈
系统设计	90	架构、数据、API、权限、RAG、图谱和 10 张 UML 较完整
功能实现	90	核心业务链路完整，前后端可联动，演示数据为虚构
前端与体验	86	主要页面和 ECharts 功能完成；移动端与无障碍验证不足
测试质量	91	136 条测试编制时全部通过，覆盖高风险边界；缺少覆盖率和 E2E
文档与交付	90	文档、图、截图、说明和清单较完整；部分一致性依赖人工校对
安全与边界	92	权限先于检索、失败审计和测试隔离明确；未达生产级
工程可复现性	89	本地启动、停止、测试和初始化可复现；未完成生产部署
综合自评	**90**	课程项目整体完成度高，实际生产化和规模化验证仍有明显改进空间

10.2 结论

《智慧企业知识财富库系统》V2.0 已完成课程设定的主要目标：形成可运行的前后端应用，覆盖认证与权限、知识文档、检索增强问答、知识图谱、收藏、审计、用户与分类管理、系统运维八个模块；完成 10 张 UML 图、前端页面截图和课程文档；测试集编制时共 136 条，全部通过。

项目由本人一人完成，并同时承担项目组长、需求、设计、开发、测试、文档和交付职责。能够交付的主要原因不是资源充足，而是较早冻结范围、按关键路径推进、把权限和问答来源作为高风险边界、持续补充自动化测试，并在最后阶段以冻结版本统一校对文档与材料。

同时，项目仍属于课程设计而非真实企业生产系统。没有真实用户、真实业务数据和生产上线，也没有完成高并发、覆盖率、端到端自动化、生产级备份和长期运维验证。后续如继续演进，应优先补齐质量门禁、权限加固、数据库迁移和 RAG 评估，再讨论真实部署和业务推广。

总体而言，本项目完成了“可运行、可演示、可测试、可追溯、边界清楚”的课程交付目标，也让我完整经历了一次从项目计划到最终验收的软件工程实践。

第 7 部分　个人项目小结与考核材料

0. 个人承担说明与交付总览

0.1 单人完成声明

本项目为 **2026-10-31 提交的 V2.0 版本**，由本人 **1 人独立完成**。项目没有第二成员，因此不存在“组长只做协调、成员分别做模块”的分工。本人同时承担：

- 项目组长：范围冻结、计划编排、里程碑检查、风险控制、交付统稿；
- 需求负责人：竞品调研、用户需求、系统需求、验收标准；
- 架构与建模负责人：前后端分层、数据库设计、UML 全套图；
- 前端负责人：Vue 3 + Vite 页面、路由、会话、交互与 ECharts 图表；
- 后端负责人：Flask 3 REST API、Flask-Login 会话、SQLAlchemy 模型、权限与审计；
- RAG/图谱负责人：jieba 分词、知识片段切分、检索打分、来源合并、图谱同步；
- 测试负责人：权限矩阵、API 契约、RAG 算法、登录安全、系统回归；
- 文档与运维负责人：Markdown 文档、截图、PlantUML 本地渲染、启停脚本与健康检查。

因此，本文中的“个人分工”不是团队分工表，而是 **同一名项目成员在不同工程角色下的职责矩阵**；“完成情况”以工作区中可核对的代码、文档、图片和脚本为准。

模块负责人矩阵（全部由本人担任）

模块	模块负责人	主要交付
认证与安全	本人	登录/退出、会话、密码哈希、登录限流、失败审计
知识文档	本人	列表/检索/详情/新建/编辑/删除、片段与图谱同步
收藏与分类	本人	个人收藏切换、收藏列表、分类列表与管理员新增
智能问答（RAG）	本人	权限过滤、jieba 检索、Top-K、来源、历史、模式降级
知识图谱	本人	自动同步、权限裁剪、ECharts 可视化、管理员维护
用户与审计管理	本人	用户目录、审计筛选与分页
关于与健康检查	本人	关于页统计、`/api/about`、`/api/health`、兼容 `/health`
前端壳层与交互	本人	Vue 路由、AppShell、全局样式、错误/空状态、图表组件
文档与工程化	本人	需求/设计/测试/项目文档、UML、截图、启停与测试脚本

0.2 角色与职责矩阵

工程角色	本人承担的具体职责	主要产出	状态
项目组长	确定 V2.0 范围，安排需求、设计、开发、测试、文	`docs/06-项目管理.md`、`README.md`、本文	完成

工程角色	本人承担的具体职责	主要产出	状态
	档里程碑，检查交付完整性		
需求分析	整理业务痛点、用户角色、功能需求、非功能需求、需求追踪	docs/01-竞品调研报告.md、docs/02-用户需求说明书.md、docs/03-系统需求说明书.md	完成
系统设计	设计表现层、REST API 层、服务层、ORM 层、SQLite 存储层	docs/04-软件设计说明书.md、docs/uml/	完成
UML 建模	绘制用例图、登录时序图、RAG 时序图、活动图、状态图、类图、E-R 图、部署图、构件图、三层架构图	docs/uml/*.puml、docs/uml/rendered/*.png、*.svg	完成
Vue 前端	登录、工作台、文档列表/详情/编辑、问答、图谱、用户、审计、关于共 10 类页面	frontend/src/views/、frontend/src/components/	完成
Flask 后端	API 蓝图、认证会话、文档 CRUD、收藏、分类、问答、图谱、管理、关于、健康检查	app/api.py、app/models.py、app/services/	完成
数据治理	密级可见性、部门隔离、状态控制、收藏唯一约束、审计留痕、来源可追溯	app/services/rag.py、app/models.py、app/utils.py	完成
测试与质量	API 契约、权限矩阵、RAG 算法、登录防爆破、失败审计、系统回归	tests/test_*.py、run_tests.ps1、docs/05-测试报告.md	完成
工程化	Vite 代理、后台启停、UML 本地渲染、环境变量配置、健康检查	frontend/vite.config.js、start.ps1、stop.ps1、scripts/	完成

0.3 五部分交付符合性检查

学校要求	本文对应位置	图引用	代码/需求证据	完成情况
1. 用例图及用例规格说明	第 1 章	docs/uml/rendered/01-用例图.png	docs/uml/01-用例图.puml、app/api.py、frontend/src/router/index.js	已覆盖
2. 页面原型设计及说明	第 2 章	docs/screenshots/01-login.png 至 docs/screenshots/10-about.png	frontend/src/views/*.vue、frontend/src/components/AppShell.vue	页面已实现；截图按交付清单归档
3. 用例实现顺序/时序图及说明	第 3 章	02-登录时序图.png、03-RAG 问答时序图.png、04-文档发布活动图.png、05-文档状态图.png	frontend/src/api/client.js、app/api.py、app/services/rag.py	已覆盖
4. 系统/模块类图及说明	第 4 章	06-类图.png，辅以 09-构件图.png、10-三层架构.png	app/models.py、app/services/、frontend/src/	已覆盖
5. 数据库实体类图及 E-R 图及说明	第 5 章	06-类图.png（ORM 视角）、07-ER 图.png（关系视角）	app/models.py、instance/knowledge.db 的 SQLAlchemy 映射	已覆盖
个人分工、开发/文档任务、完成情况、小结、证据	第 0、6、7 章	本文表格与证据索引	工作区全部交付物	已完成

0.4 完成情况量化

统计口径：截至 2026-10-31，按当前共享工作区文件统计；不包含 node_modules、构建产物和第三方依赖。

指标	数量	说明
UML 源文件	10	用例、时序、活动、状态、类、ER、部署、构件、三层架构
UML 渲染图	10 组 PNG + SVG	docs/uml/rendered/
前端页面	10 类业务页面，另有 404 页	登录、工作台、文档列表/详情/编辑、问答、图谱、用户、审计、关于
REST API 端点	27 个主要方法/路径组合	另有 /api/ 根路径别名与兼容 /health
后端与前端源文件	43 个	app/**/*.py 与 frontend/src/**/*.vue,*.js
源代码行数	约 6387 行	不含依赖与构建产物，用于说明独立完成规模
自动化测试函数	120 个	5 个 tests/test_*.py 文件；参数化后实际执行用例更多
数据库表	9 张	users、categories、documents、knowledge_chunks、graph_nodes、graph_edges、favorites、audit_logs、qa_history
页面截图引用	10 张	按 01-login.png 至 10-about.png 的交付命名组织

1. 用例图及用例规格说明

1.1 用例图

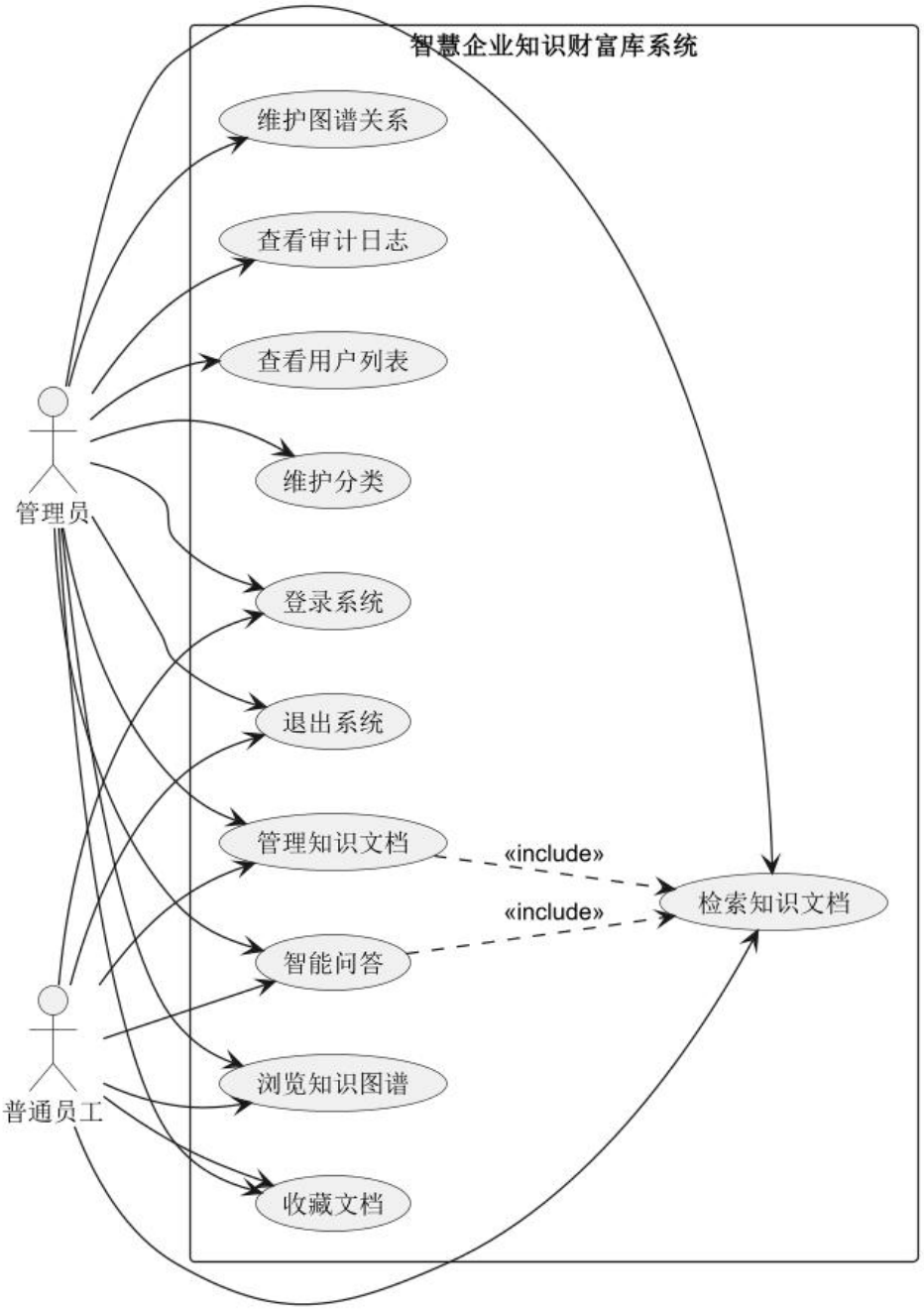


图 1-1 智慧企业知识财富库系统用例图

图 1-1 说明：系统参与者分为“普通员工”和“管理员”。普通员工可登录、退出、管理知识文档、检索文档、智能问答、浏览图谱和收藏文档；管理员在此基础上增加维护分类、维护图谱关系、查看审计日志、查看用户列表等治理能力。“管理知识文档”和“智能问答”均包含“检索知识文档”能力。

图源：`docs/uml/01-用例图.puml`

渲染图：`docs/uml/rendered/01-用例图.png`

1.2 图例与关键元素

图元素	含义	本项目对应
火柴人	系统外部参与者	普通员工、管理员；管理员是普通员工能力的超集
矩形边框	系统边界	V2.0 Vue 3 SPA + Flask REST API 系统
椭圆	用例/业务目标	登录、检索、问答、图谱、审计等
实线	参与者与用例的关联	谁能发起该用例
虚线箭头 <<include>>	被包含的必需子流程	管理文档、智能问答均必须调用检索能力
用例粒度	以用户可感知目标划分	“管理知识文档”内部再细分增删改查，规格说明中展开

关键解释：

423. **普通员工不是“只读用户”**。当前实现允许已登录员工新建文档；编辑、删除仅限本人文档，管理员可编辑/删除全部文档。

424. **管理员权限不是独立业务系统**。管理员仍复用普通员工的文档、问答、图谱能力，只是额外拥有分类维护、图谱维护、用户查看和审计查看入口。

425. **检索是共享能力**。文档列表检索和 RAG 问答共享同一套“可访问文档”判定，但用途不同：前者返回文档卡片，后者返回知识片段和答案来源。

426. **机密隔离是跨用例约束**。无论列表、详情、问答还是图谱，均先按当前用户权限过滤；权限规则在 `app/services/rag.py` 的 `can_view_document()` 与 `searchable_documents()` 中集中实现。

1.3 用例清单与需求追踪矩阵

编号/用例	参与者与权限	需求编号	主要页面/API	代码与验证证据
UC-01 登录系统	普通员工、管理员；公开接口，失败限流	UR-AUTH-01/05/06/07；SR-AUTH-001/002/007/008/009	/login；POST /api/auth/login	app/api.py、app/blueprints/auth.py、LoginView.vue；tests/test_api.py、test_login_security.py
UC-02 退出系统	普通员工、管理员；必须已登录	UR-AUTH-02；SR-AUTH-003	顶部退出；POST /api/auth/logout	app/api.py、AppShell.vue；tests/test_api.py
UC-03 管理知识文档	普通员工、管理员；新建已登录，编辑/删除仅作者或管理员	UR-DOC-01/03/04/05；SR-DOC-001/004/005/006/007	/documents、new/edit；文档 CRUD API	app/api.py、DocumentEditorView.vue；tests/test_api.py、test_security.py
UC-04 检索知识文档	普通员工、管理员；仅已发布且可见文档	UR-DOC-02；SR-DOC-001/002/003/009；SR-QA-008	/documents?q=...；GET /api/documents	app/api.py、app/services/rag.py；tests/test_api.py、test_security.py
UC-05 智能问答	普通员工、管理员；仅检索可见片段	UR-QA-01/02/03/04；SR-QA-001～009	/qa；GET /api/qa、POST /api/qa/ask	app/services/rag.py、QaView.vue；tests/test_api.py、test_rag.py

编号/用例	参与者与权限	需求编号	主要页面/API	代码与验证证据
UC-06 浏览知识关系图	普通员工、管理员；从可见文档节点裁剪	UR-KG-01；SR-KG-001/002/003/005	/graph；GET /api/graph	app/services/graph.py、GraphView.vue；tests/test_api.py、test_security.py
UC-07 收藏文档	普通员工、管理员；仅限通过密级判定的文档	UR-FAV-01；SR-FAV-001/002/003	列表/详情收藏按钮；收藏 API	app/api.py、app/models.py；tests/test_api.py
UC-08 维护分类	管理员新增；所有登录用户可读列表	UR-DOC-06；SR-DOC-008	文档表单分类；GET/POST /api/categories	app/api.py、app/models.py；tests/test_api.py、test_security.py
UC-09 维护图谱关系	管理员	UR-KG-02；SR-KG-004	图谱维护弹窗；图谱管理 API	app/api.py、app/services/graph.py；tests/test_api.py
UC-10 查看审计日志	管理员	UR-AUD-01；SR-AUD-001/002	/admin/audits；GET /api/admin/audits	app/api.py、AuditsView.vue；tests/test_api.py、test_login_security.py
UC-11 查看用户列表	管理员	UR-AUTH-03；SR-AUTH-004	/admin/users；GET /api/admin/users	app/api.py、UsersView.vue；tests/test_api.py、test_security.py

1.4 用例规格说明

UC-01 登录系统

项目	规格
用例编号/名称	UC-01 登录系统
参与者	普通员工、管理员
目标	以用户名和密码建立服务端会话，并进入工作台
前置条件	系统可访问；用户拥有系统账号
触发事件	用户在登录页提交用户名、密码
主成功场景	1. 前端 POST /api/auth/login 提交 JSON；2. 服务端检查来源 IP 是否处于锁定窗口；3. 查询用户并用带盐哈希校验密码；4. 成功则清零失败计数、写入 login 审计、建立 Flask-Login 会话；5. 返回用户资料；6. 前端跳转工作台。
异常/分支	用户名或密码错误：记录失败计数与 login_failed 审计，返回 401；窗口内失败达到阈值：后续请求返回 429 和 retry_after；请求体缺少字段按错误凭据处理。
后置条件	成功：会话存在、审计落库；失败：无会话，失败事件进入限流器和审计。
权限/数据规则	登录接口公开；密码不落明文；会话 Cookie 为 HttpOnly、SameSite=Lax。
需求追踪	UR-AUTH-01/05/06/07；SR-AUTH-001/002/007/008/009
实现位置	app/api.py::login、app/blueprints/auth.py::login_limiter、app/utils.py::RateLimiter、frontend/src/stores/session.js
验证证据	tests/test_api.py::test_api_login_logout_flow、tests/test_login_security.py

UC-02 退出系统

项目	规格
用例编号/名称	UC-02 退出系统
参与者	普通员工、管理员
目标	终止当前会话并留下退出审计
前置条件	当前用户已登录
触发事件	点击顶部退出入口，或调用退出 API
主成功场景	1. 前端 `POST /api/auth/logout`；2. 服务端写入 `logout` 审计；3. 调用 `logout_user()` 清除会话；4. 返回“已退出登录”；5. 前端清理用户状态并跳转登录页。
异常/分支	未登录调用返回 401 `AUTH_REQUIRED`；网络异常时前端保留提示。
后置条件	会话失效，审计中包含退出记录。
权限/数据规则	必须已登录；只能退出当前会话。
需求追踪	UR-AUTH-02；SR-AUTH-003
实现位置	`app/api.py::logout`、`frontend/src/components/AppShell.vue`
验证证据	`tests/test_api.py::test_api_login_logout_flow`

UC-03 管理知识文档

项目	规格
用例编号/名称	UC-03 管理知识文档
参与者	普通员工、管理员
目标	创建、查看、编辑、删除知识文档，并自动建立检索片段与图谱关系
前置条件	已登录；编辑/删除时当前用户是作者或管理员
触发事件	点击“新建文档”“编辑”“删除”或保存表单
主成功场景	1. 用户填写标题、正文、摘要、分类、部门、密级、状态、版本、标签；2. 前端调用 `POST /api/documents` 或 `PUT /api/documents/{id}`；3. 服务端校验标题与正文；4. 写入/更新 `documents`；5. 重建 `knowledge_chunks`；6. 同步图谱节点与边；7. 写入审计并返回文档详情。
异常/分支	标题或正文为空：400 `VALIDATION_ERROR`；分类不存在：400；非作者且非管理员编辑/删除：403；文档不存在：404；草稿/归档仅作者和管理员可见详情。
后置条件	文档、知识片段、图谱和审计保持一致。
权限/数据规则	列表只返回当前用户可见的已发布文档；密级规则见 UC-04；部门为空时使用当前账号部门；密级/状态非法值回退为 `internal/published`。
需求追踪	UR-DOC-01/03/04/05；SR-DOC-001/004/005/006/007
实现位置	`app/api.py::_apply_document_payload`、`create_document`、`update_document`、`delete_document`；`app/services/rag.py::rebuild_chunks_for_document`；`app/services/graph.py::sync_document_graph`
验证证据	`tests/test_api.py::test_api_document_crud_and_favorite`、`tests/test_security.py`

UC-04 检索知识文档

项目	规格
用例编号/名称	UC-04 检索知识文档
参与者	普通员工、管理员
目标	在权限范围内按关键词、分类、部门、密级检索并分页浏览文档
前置条件	已登录；存在可访问的已发布文档

项目	规格
触发事件	在文档列表输入关键词或选择筛选条件
主成功场景	1. 前端 `GET /api/documents` 携带 `q/category_id/department/visibility/sort/page/per_page`；2. 服务端先取当前用户可见的已发布文档；3. 按分类、部门、密级过滤；4. 有关键词时用 jieba 分词与标题/标签/摘要/正文加权排序；5. 返回分页文档、分类、部门、筛选回显。
异常/分支	`page` 超出总页数时钳制到最后一页；`per_page` 限制在 1～50；无结果返回空 `items` 且 `pages=1`；未登录 401。
后置条件	不修改业务数据；查看详情时可能写入查看审计。
权限/数据规则	`secret` 仅管理员、同部门用户或作者可见；`public/internal` 对已登录用户可见；列表排除草稿和归档。
需求追踪	UR-DOC-01/02；SR-DOC-001/002/003/009；SR-QA-008
实现位置	`app/api.py::list_documents`、`app/services/rag.py::searchable_documents`、`rank_documents`、`frontend/src/views/DocumentsView.vue`
验证证据	`tests/test_api.py::test_api_document_search_and_detail`、`tests/test_security.py`

UC-05 智能问答

项目	规格
用例编号/名称	UC-05 智能问答
参与者	普通员工、管理员
目标	基于当前用户有权访问的知识片段生成回答，并展示可追溯来源
前置条件	已登录；文档已发布且已生成知识片段
触发事件	用户输入问题或点击示例问题
主成功场景	1. 前端 `POST /api/qa/ask`；2. 服务端先调用 `searchable_documents(user)` 过滤权限；3. 加载可见文档的 `knowledge_chunks`；4. jieba 分词、评分、取 Top-K（同一文档最多 2 个片段）；5. 无 Key 时生成本地摘要，有 Key 时调用兼容 Chat Completions 的大模型；6. 保存 `qa_history`；7. 写入 `ask_qa` 审计；8. 返回答案、模式、来源和片段。
异常/分支	问题为空：400；无命中：回答明确提示未检索到相关内容；大模型调用失败：回退为本地检索摘要并标记 `local`；历史越权：403。
后置条件	问答历史和审计落库；返回结果带来源文档标题、部门、相关度和片段。
权限/数据规则	问答与列表共用权限过滤；不得返回无权文档的片段正文；普通用户只看本人历史，管理员可看任意历史。
需求追踪	UR-QA-01/02/03/04；SR-QA-001～009
实现位置	`app/api.py::qa_page、ask_question、qa_history_detail`；`app/services/rag.py::retrieve、group_hits_by_document、ask、call_llm_answer`；`frontend/src/views/QaView.vue`
验证证据	`tests/test_api.py::test_api_qa_returns_traceable_sources`、`tests/test_rag.py`

UC-06 浏览知识关系图

项目	规格
用例编号/名称	UC-06 浏览知识关系图
参与者	普通员工、管理员
目标	以力导向图查看文档、部门、关键词、分类/概念之间的连接
前置条件	已登录；图谱中存在与可见文档关联的节点
触发事件	打开 `/graph` 或点击刷新
主成功场景	1. 前端 `GET /api/graph`；2. 服务端生成全量图谱载荷；3. 只保留当前用户可见文档节点；4. 加入与这些文档直接相连的部门/关键词/概念节

项目	规格
	点；5. 返回裁剪后的 nodes/links/categories；6. 前端 ECharts 渲染并支持拖拽、缩放、悬停、点击文档节点跳转。
异常/分支	无可视图谱返回空节点；未登录 401；管理员可打开“维护图谱”弹窗。
后置条件	只读浏览不改变数据；管理员新增节点/边后写入数据库。
权限/数据规则	普通用户看不到仅由隐藏文档连接的节点；节点类型包括 document/department/project/keyword/concept。
需求追踪	UR-KG-01；SR-KG-001/002/003/005
实现位置	app/api.py::_visible_graph_payload、graph_view；app/services/graph.py::graph_payload；frontend/src/views/GraphView.vue
验证证据	tests/test_api.py::test_api_graph_payload_is_visible_scope、tests/test_security.py

UC-07 收藏文档

项目	规格
用例编号/名称	UC-07 收藏文档
参与者	普通员工、管理员
目标	将当前可见文档加入个人收藏，或取消收藏
前置条件	已登录；目标文档存在且当前用户可查看
触发事件	点击列表卡片或详情页收藏按钮
主成功场景	1. 前端 POST /api/documents/{id}/favorite；2. 服务端校验文档存在与可见性；3. 已存在则删除收藏，否则新增收藏；4. 返回 is_favorite 状态和提示。
异常/分支	文档不存在：404；无权查看：403；唯一约束 (user_id, document_id) 防止重复收藏。
后置条件	收藏状态与文档列表/详情同步；收藏列表仅返回当前用户且仍可见的文档。
权限/数据规则	收藏按用户隔离；管理员也不能代替其他用户收藏。
需求追踪	UR-FAV-01；SR-FAV-001/002/003
实现位置	app/api.py::favorite_documents、toggle_favorite；app/models.py::Favorite
验证证据	tests/test_api.py::test_api_document_crud_and_favorite

UC-08 维护分类

项目	规格
用例编号/名称	UC-08 维护分类
参与者	管理员；普通员工只读分类列表
目标	为文档建立统一分类及说明
前置条件	新增分类时当前用户为管理员
触发事件	管理员提交分类名称和说明
主成功场景	1. 前端 POST /api/categories；2. 校验名称非空且不重复；3. 写入 categories；4. 返回新分类 id/name；5. 文档编辑页刷新分类下拉。
异常/分支	名称为空或重复：400；非管理员：403；分类列表未登录：401。
后置条件	分类可供文档引用；当前 API 未暴露删除分类，文档分类通过 category_id 可为空表示未分类。
权限/数据规则	GET /api/categories 所有登录用户可读；POST /api/categories 仅管理员。
需求追踪	UR-DOC-06；SR-DOC-008
实现位置	app/api.py::categories、create_category；app/models.py::Category
验证证据	tests/test_api.py、tests/test_security.py

UC-09 维护图谱关系

项目	规格
用例编号/名称	UC-09 维护图谱关系
参与者	管理员
目标	手工补充概念节点和节点间语义关系，弥补自动同步不足
前置条件	当前用户为管理员
触发事件	图谱页点击“维护图谱”，提交新增节点或关系
主成功场景	1. `GET /api/graph/manage` 获取最近节点、边和节点类型；2. `POST /api/graph/nodes` 新增/复用节点；3. `POST /api/graph/edges` 新增关系，必要时自动创建起点/终点概念节点；4. 提交事务后返回成功消息。
异常/分支	节点名为空：400；起点或终点名称为空：400；非管理员：403；同名节点按名称复用。
后置条件	新节点/边进入图谱；管理员管理面板显示最近 60 个节点和边。
权限/数据规则	管理面板与写操作均要求管理员；普通用户只能浏览权限裁剪后的图谱。
需求追踪	UR-KG-02；SR-KG-004
实现位置	`app/api.py::graph_manage`、`add_graph_node`、`add_graph_edge`；`app/services/graph.py::get_or_create_node`、`ensure_edge`
验证证据	`tests/test_api.py`、`tests/test_security.py`

UC-10 查看审计日志

项目	规格
用例编号/名称	UC-10 查看审计日志
参与者	管理员
目标	按动作、用户、明细检索关键操作记录，支持审计追溯
前置条件	当前用户为管理员；已有审计数据
触发事件	打开 `/admin/audits` 或设置筛选条件
主成功场景	1. `GET /api/admin/audits`；2. 按 `action/user/detail/page` 过滤；3. 按时间倒序分页（每页 25 条）；4. 返回日志、分页、动作统计和动作选项。
异常/分支	非管理员：403；未登录：401；无效动作被忽略；页码超出时钳制到最后一页。
后置条件	只读；不修改审计记录。
权限/数据规则	仅管理员；审计类型包括 login、login_failed、logout、view_document、create_document、edit_document、delete_document、ask_qa。
需求追踪	UR-AUD-01；SR-AUD-001/002；SR-AUTH-007
实现位置	`app/api.py::admin_audits`、`_audit_payload`；`frontend/src/views/AuditsView.vue`
验证证据	`tests/test_api.py`、`tests/test_login_security.py`

UC-11 查看用户列表

项目	规格
用例编号/名称	UC-11 查看用户列表
参与者	管理员

项目	规格
目标	查看账号、角色、部门和文档贡献数量
前置条件	当前用户为管理员
触发事件	打开 `/admin/users`
主成功场景	1. `GET /api/admin/users`；2. 服务端查询用户及按作者统计的文档数；3. 返回用户列表与管理员/员工汇总；4. 前端支持本地关键字过滤。
异常/分支	非管理员：403；未登录：401。
后置条件	只读；不修改账号。当前版本账号由种子数据维护，不提供用户新增/删除 API。
权限/数据规则	仅管理员；密码哈希不进入响应；用户资料字段包含 id、username、display_name、role、department、is_admin、created_at。
需求追踪	UR-AUTH-03；SR-AUTH-004
实现位置	`app/api.py::admin_users`；`frontend/src/views/UsersView.vue`
验证证据	`tests/test_api.py`、`tests/test_security.py`

1.5 用例与代码对应小结

分层	主要职责	证据
Vue 路由与页面	把用户操作映射到 REST API，展示错误和状态	`frontend/src/router/index.js`、`frontend/src/views/`
REST API 蓝图	统一 `/api` 前缀、JSON 返回、会话与管理员校验	`app/api.py`
服务层	RAG 检索问答、图谱同步与权限过滤	`app/services/rag.py`、`app/services/graph.py`
ORM 模型	用户、文档、片段、图谱、收藏、审计、问答历史	`app/models.py`
安全工具	密码哈希、限流、安全回跳、审计文案	`app/utils.py`、`app/blueprints/auth.py`

2. 页面原型设计及说明

2.1 页面原型总体说明

V2.0 前端为 Vue 3 + Vite 单页应用，统一采用左侧导航 + 顶部身份区 + 主内容区的桌面端工作台布局。登录页采用独立的左右分栏品牌页，不进入工作台壳层；其余业务页在 `AppShell` 内切换。

截图基线目录：`docs/screenshots/`。本文按以下预期文件名引用：

`01-login.png`、`02-dashboard.png`、`03-documents.png`、`04-document-detail.png`、`05-document-editor.png`、`06-qa.png`、`07-graph.png`、`08-users.png`、`09-audits.png`、`10-about.png`。

如最终交付批次对文件名做了中文名、日期后缀或大小写调整，以同目录下对应页面的通配文件为准（例如 `docs/screenshots/*login*.png`、`docs/screenshots/*问答*.png`），页面语义和本文章节顺序不变。

全局图例：

图例/元素	含义
深蓝/蓝紫主按钮	当前页面主要动作，如登录、保存、发起问答
灰色描边按钮	次要动作，如刷新、返回、取消
红色描边/红色徽标	高风险或机密状态，如删除、机密、管理员
绿色/蓝色/灰色状态胶囊	公开/内部/机密、已发布/草稿/已归档等状态
左侧导航	工作台、知识文档、智能问答、知识关系图、管理员菜单、关于系统
顶部身份区	当前用户、部门、角色、退出
空状态/骨架屏	加载或检索无结果时的可理解反馈
响应式断点	主要面向桌面浏览器；窄屏时布局收敛，详细限制见页面说明

页面与权限：

页面	路由	可见角色	主要 API
登录	`/login`	匿名	`GET /api/meta`、`POST /api/auth/login`、`GET /api/auth/session`
工作台	`/dashboard`	已登录	`GET /api/dashboard`
知识文档列表	`/documents`	已登录	`GET /api/documents`、`POST /api/documents/{id}/favorite`
文档详情	`/documents/:id`	有文档查看权限的已登录用户	`GET /api/documents/{id}`、收藏、删除
文档编辑	`/documents/new`、`/documents/:id/edit`	已登录；编辑需作者或管理员	`GET /api/categories`、`POST /api/documents`、`PUT /api/documents/{id}`
智能问答	`/qa`	已登录	`GET /api/qa`、`POST /api/qa/ask`、`GET /api/qa/history/{id}`
知识关系图	`/graph`	已登录；维护弹窗仅管理员	`GET /api/graph`、`GET /api/graph/manage`、`POST /api/graph/nodes`、`POST /api/graph/edges`
用户管理	`/admin/users`	管理员	`GET /api/admin/users`
审计日志	`/admin/audits`	管理员	`GET /api/admin/audits`
关于系统	`/about`	已登录	`GET /api/about`

2.2 页面原型逐页说明

2.2.1 登录页

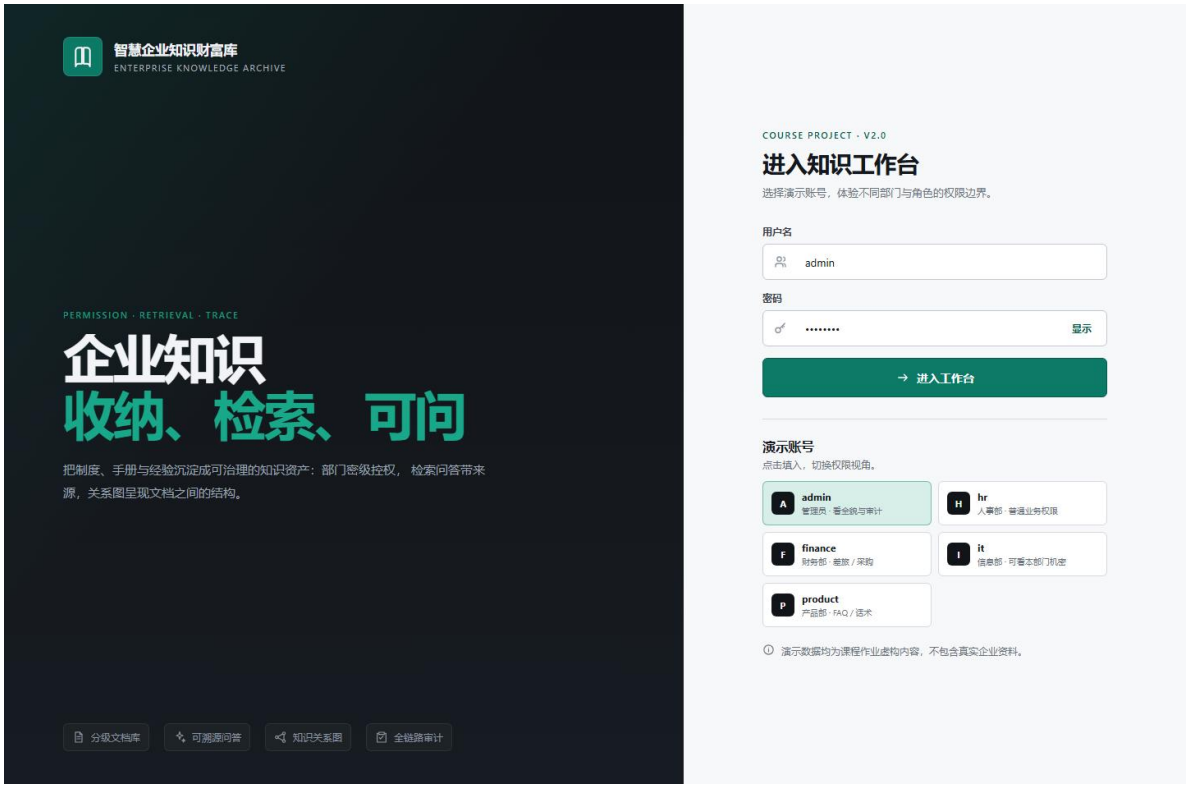


图 2-1 登录页原型

项目	说明
对应文件	`docs/screenshots/01-login.png`；实现：`frontend/src/views/LoginView.vue`
页面目标	在未登录状态说明系统价值，并提供账号密码登录与演示账号入口
主要区域	左侧品牌/价值说明/问答与机密隔离示意；右侧登录表单；用户名、密码、显示/隐藏、登录按钮、错误提示、演示账号快捷填充
关键交互	输入或选择演示账号；提交时校验非空；登录成功后跳转 `redirect` 或 `/dashboard`；失败显示统一错误；锁定显示剩余秒数
数据/API	`GET /api/meta` 获取版本与演示账号；`GET /api/auth/session` 判断已登录；`POST /api/auth/login` 建立会话
权限/异常	公开页；401 提示“用户名或密码错误”；429 提示稍后再试；已登录访问登录页会被路由守卫送回工作台
需求/代码映射	UR-AUTH-01/05/06/07；SR-AUTH-001/002/007/008/009；`LoginView.vue`、`stores/session.js`、`router/index.js`

2.2.2 工作台



图 2-2 工作台原型

项目	说明
对应文件	`docs/screenshots/02-dashboard.png`；实现：`frontend/src/views/DashboardView.vue`
页面目标	登录后提供当前权限范围内的业务概览和快捷入口
主要区域	问候与当前身份、四个统计卡（可见文档、我的收藏、本周问答、图谱节点）、部门知识分布、知识分类构成、最近更新、快捷提问、最近问答、管理员近期审计动态
关键交互	刷新统计；点击统计/最近文档进入详情；点击快捷问题跳转问答页并带入 `q`；管理员点击审计中心进入审计页
数据/API	`GET /api/dashboard`；ECharts 渲染 `charts.departments` 与 `charts.categories`；最近文档 6 篇、最近问答 6 条、审计动态仅管理员返回 8 条
权限/异常	仅已登录；文档、收藏、问答与图表按当前用户可见范围统计；图谱节点/边为全量结构统计；普通员工不显示审计区块
需求/代码映射	SR-OPS-001；`DashboardView.vue`、`BaseChart.vue`、`app/api.py::dashboard`

2.2.3 知识文档列表

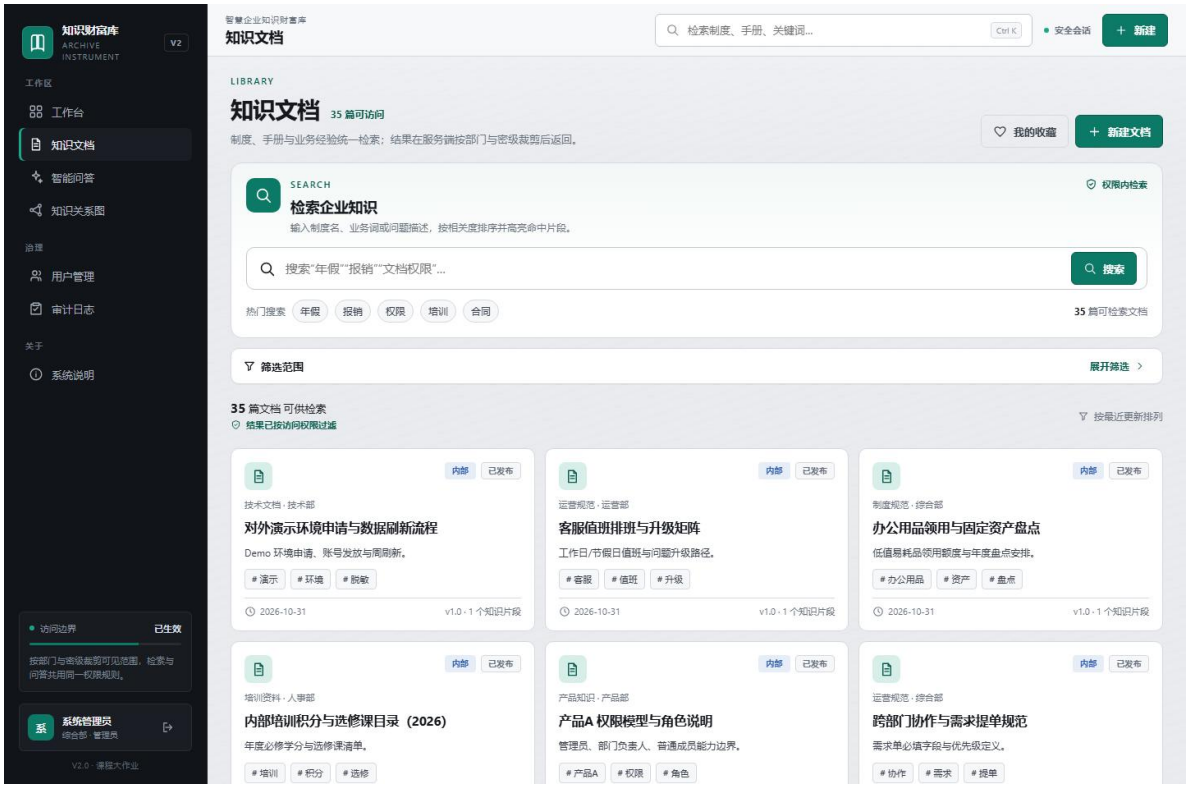


图 2-3 知识文档列表原型

项目	说明
对应文件	`docs/screenshots/03-documents.png`；实现：`frontend/src/views/DocumentsView.vue`
页面目标	在权限范围内检索、筛选、分页浏览文档，并快速收藏或新建
主要区域	页面标题与“新建文档”入口；关键词、分类、部门、密级、排序筛选区；结果总数；文档卡片网格；状态/密级徽标；标签；知识片段数；收藏按钮；分页
关键交互	提交筛选；重置筛选；查看收藏集合；卡片进入详情；收藏/取消收藏即时更新；分页保持查询参数
数据/API	`GET /api/documents`（`q/category_id/department/visibility/sort/page/per_page`）；`POST /api/documents/{id}/favorite`
权限/异常	仅返回已发布且当前用户可见文档；无结果展示空状态；未登录由路由守卫重定向登录；收藏失败显示提示
需求/代码映射	UR-DOC-01/02；SR-DOC-001/002/003/009；`DocumentsView.vue`、`app/api.py::list_documents`

2.2.4 文档详情

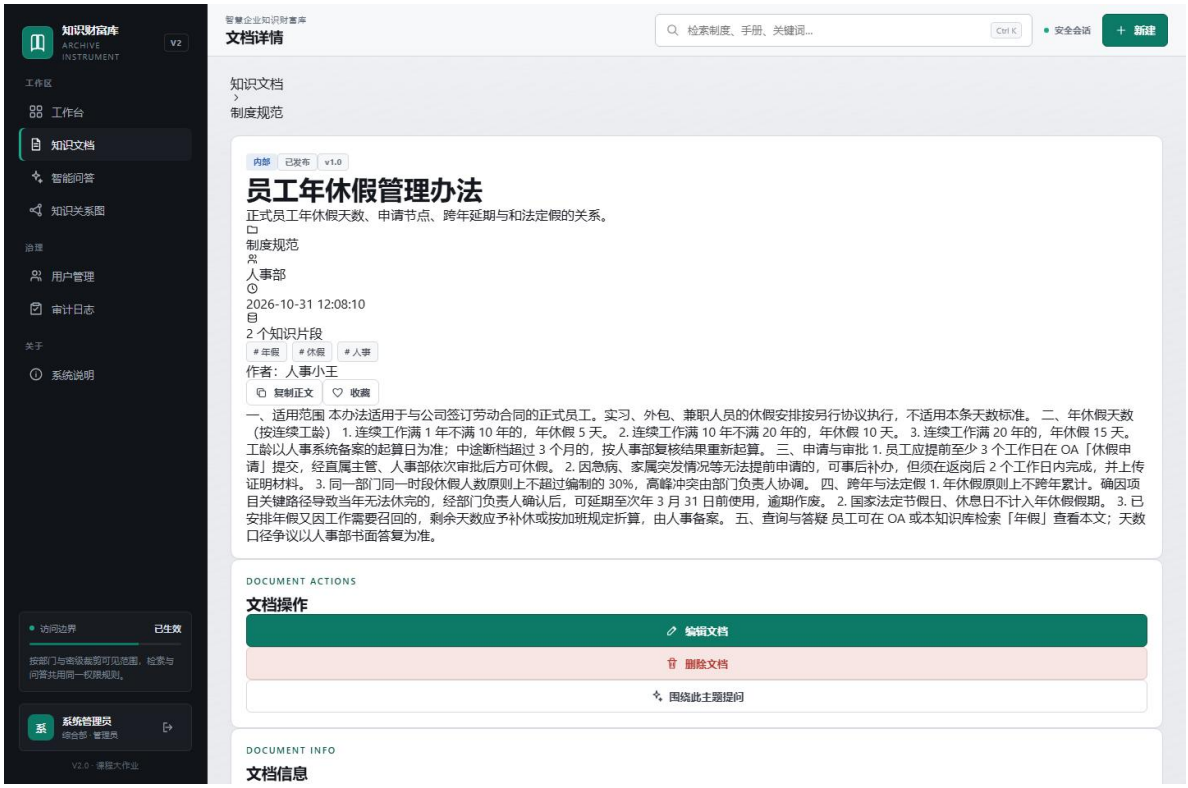


图 2-4 文档详情原型

项目	说明
对应文件	`docs/screenshots/04-document-detail.png`；实现：`frontend/src/views/DocumentDetailView.vue`
页面目标	阅读文档正文并核对元数据、来源、操作权限和相关阅读
主要区域	面包屑；密级/状态/版本徽标；标题、摘要、分类、部门、更新时间、片段数、标签；作者与复制/收藏按钮；正文；文档操作；文档信息；相关文档
关键交互	复制正文；收藏/取消收藏；作者/管理员显示编辑和删除；围绕主题提问；相关文档跳转
数据/API	`GET /api/documents/{id}` 返回 `document/content/related/can_edit`；收藏与删除接口；首次查看写入 `view_document` 审计（2 分钟去重）
权限/异常	无权查看 403；草稿/归档仅作者或管理员可打开；404 显示返回列表入口；删除需二次确认且不可恢复
需求/代码映射	UR-DOC-03/04/05；SR-DOC-001/004/005；`DocumentDetailView.vue`、`app/api.py::document_detail`

2.2.5 文档编辑页

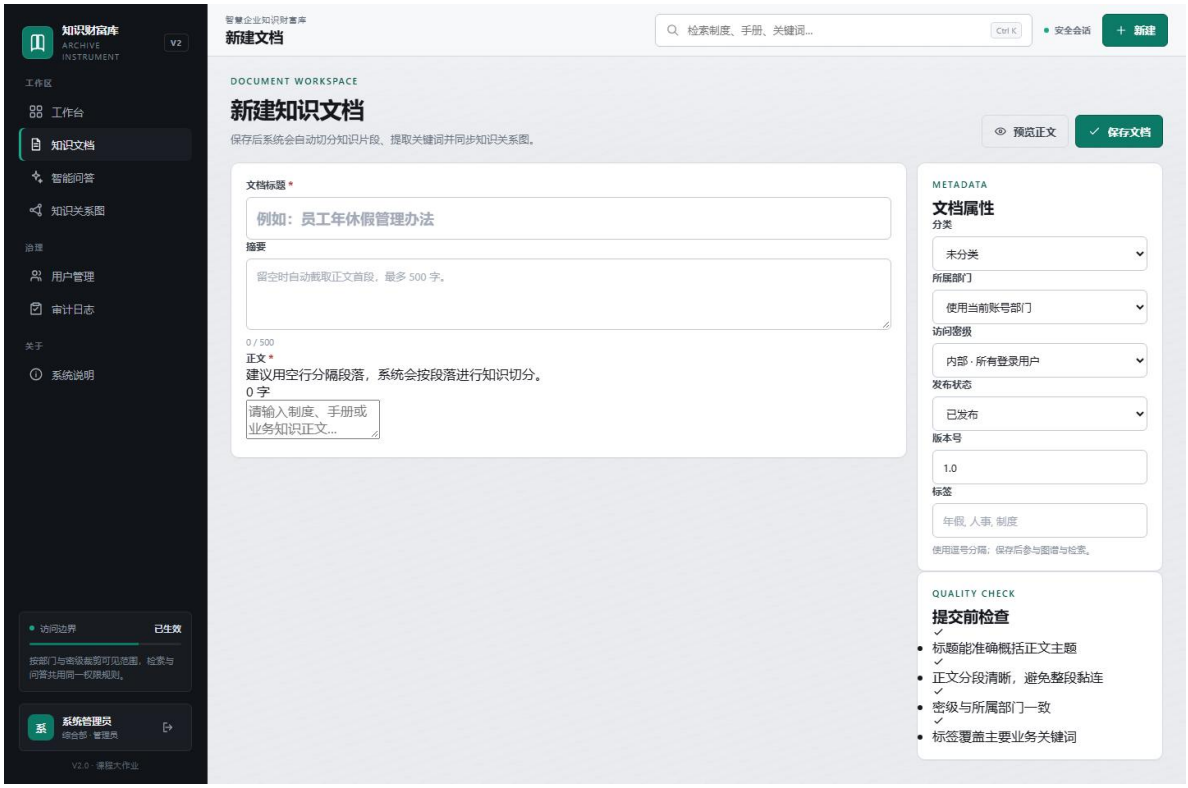


图 2-5 文档编辑页原型

项目	说明
对应文件	`docs/screenshots/05-document-editor.png`；实现：`frontend/src/views/DocumentEditorView.vue`
页面目标	新建或编辑文档，并以可视化预览降低录入错误
主要区域	标题、摘要、正文编辑区、字数统计、正文预览开关；右侧分类、部门、访问密级、发布状态、版本号、标签；提交前检查提示
关键交互	切换预览；保存前校验标题和正文；标签按中英文逗号拆分；保存后跳转详情；编辑模式加载原文档并检查 `can_edit`
数据/API	`GET /api/categories`；`POST /api/documents`；`PUT /api/documents/{id}`
权限/异常	新建所有登录用户可用；编辑仅作者或管理员；分类不存在/标题正文为空返回 400；保存后自动切分片段和同步图谱
需求/代码映射	UR-DOC-04/05；SR-DOC-005/006/007；`DocumentEditorView.vue`、`app/api.py::_apply_document_payload`、`_finalize_document`

2.2.6 智能问答页

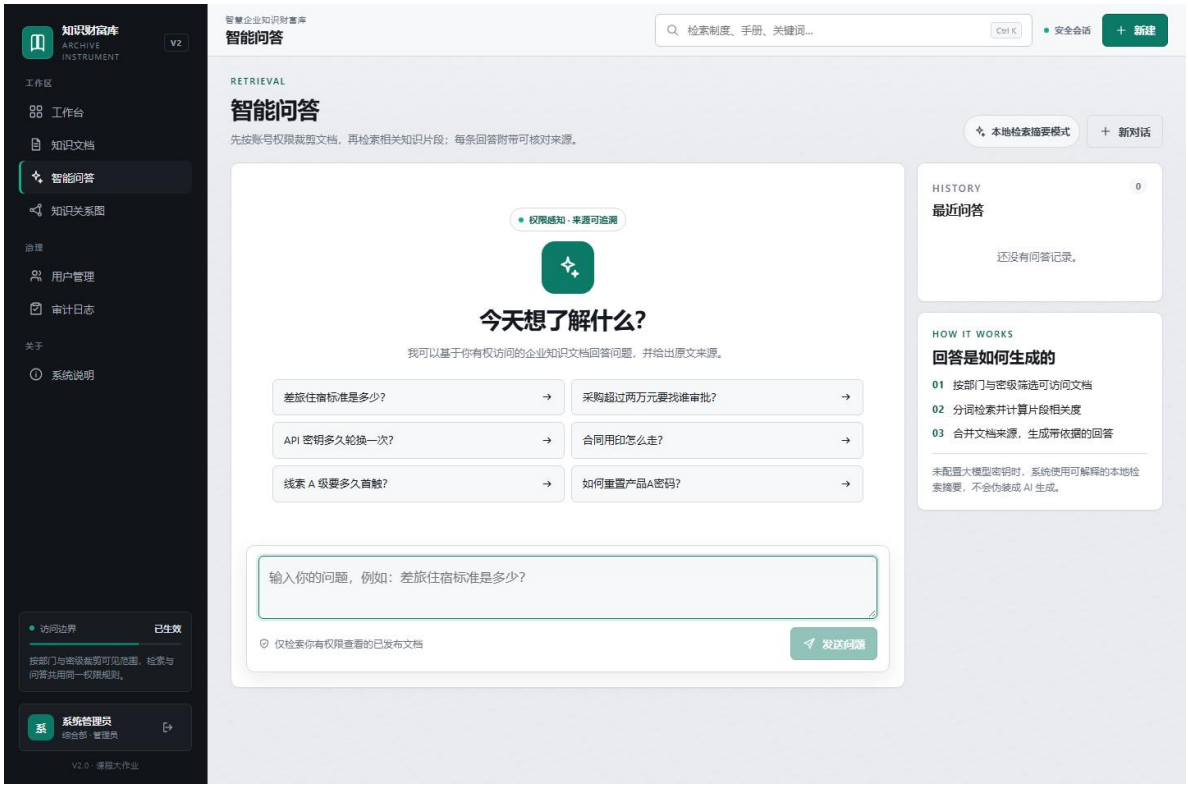


图 2-6 智能问答页原型

项目	说明
对应文件	docs/screenshots/06-qa.png；实现：frontend/src/views/QaView.vue
页面目标	用自然语言提问，展示带来源和片段的回答，并保留个人问答历史
主要区域	模式能力标签（本地检索摘要/大模型增强）；欢迎区与示例问题；对话区；问题输入框；回答来源卡与片段；右侧最近问答、回答生成说明、历史详情弹窗
关键交互	点击示例问题、提交问题、自动滚动到最新消息、打开历史详情；无 Key 时明确显示本地模式
数据/API	GET /api/qa 获取建议、历史、llm_enabled；POST /api/qa/ask 返回 answer/mode/mode_label/sources/fragments/history_id；GET /api/qa/history/{id} 查看来源
权限/异常	仅检索当前用户可访问的已发布片段；普通用户只读本人历史；问题为空 400；无命中显示可理解回答；大模型失败回退本地
需求/代码映射	UR-QA-01/02/03/04；SR-QA-001～009；QaView.vue、app/services/rag.py

2.2.7 知识关系图

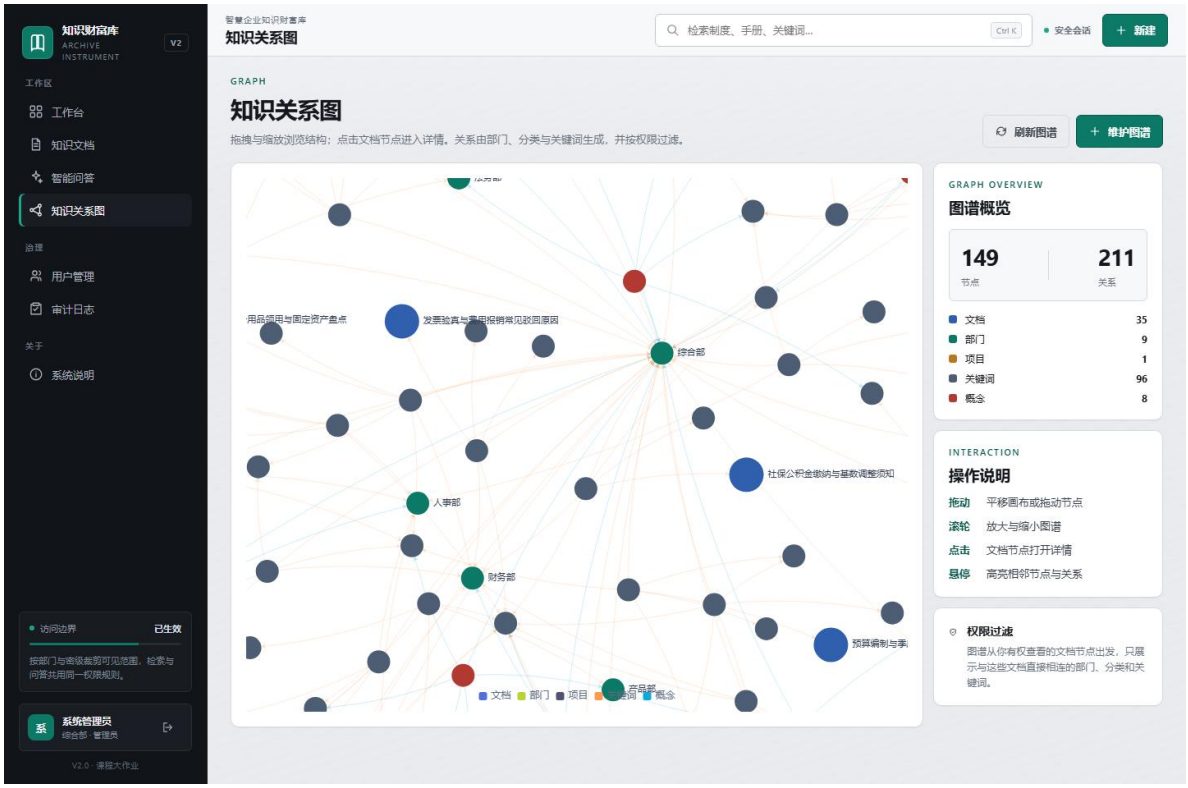


图 2-7 知识关系图原型

项目	说明
对应文件	docs/screenshots/07-graph.png；实现：frontend/src/views/GraphView.vue
页面目标	通过力导向图呈现文档、部门、关键词、概念之间的可交互关系
主要区域	650px 图谱画布；刷新图谱；管理员“维护图谱”；右侧节点/关系统计、类型颜色图例、交互说明、权限过滤提示；管理员维护弹窗
关键交互	拖动/平移、滚轮缩放、悬停高亮、点击文档节点跳详情；管理员新增节点或边；刷新重新加载
数据/API	GET /api/graph 返回 nodes/links/categories；GET /api/graph/manage；POST /api/graph/nodes；POST /api/graph/edges
权限/异常	图谱从可见文档节点出发裁剪；普通用户看不到仅由隐藏文档连接的节点；新增维护接口仅管理员，非管理员 403
需求/代码映射	UR-KG-01/02；SR-KG-001～005；GraphView.vue、app/services/graph.py

2.2.8 用户管理

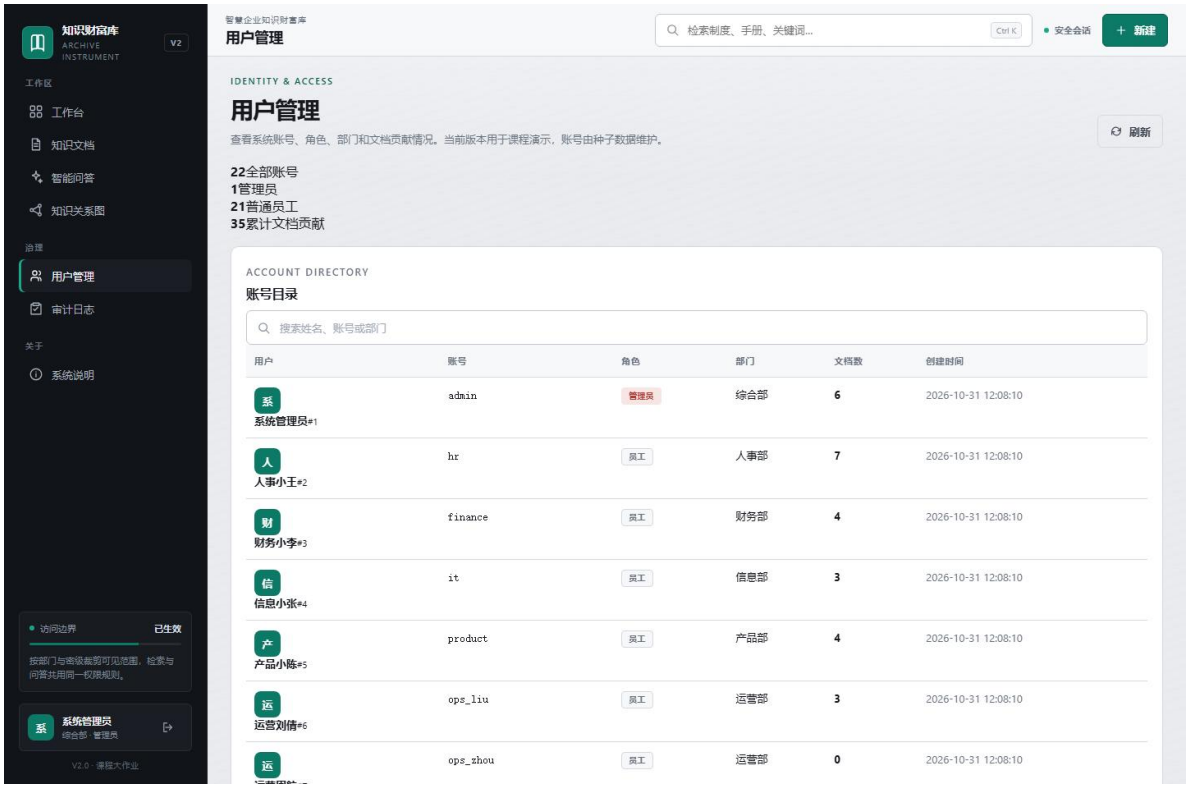


图 2-8 用户管理原型

项目	说明
对应文件	`docs/screenshots/08-users.png`；实现：`frontend/src/views/UsersView.vue`
页面目标	管理员查看演示账号、角色、部门和文档贡献
主要区域	账号数/管理员数/员工数/累计文档贡献统计；账号目录表；本地搜索框；用户、账号、角色、部门、文档数、创建时间
关键交互	刷新；按姓名、账号或部门即时过滤
数据/API	`GET /api/admin/users` 返回 `items` 与 `summary`
权限/异常	仅管理员；普通员工路由守卫返回工作台；当前版本不支持新增/删除账号，账号由种子数据维护
需求/代码映射	UR-AUTH-03；SR-AUTH-004；`UsersView.vue`、`app/api.py::admin_users`

2.2.9 审计日志

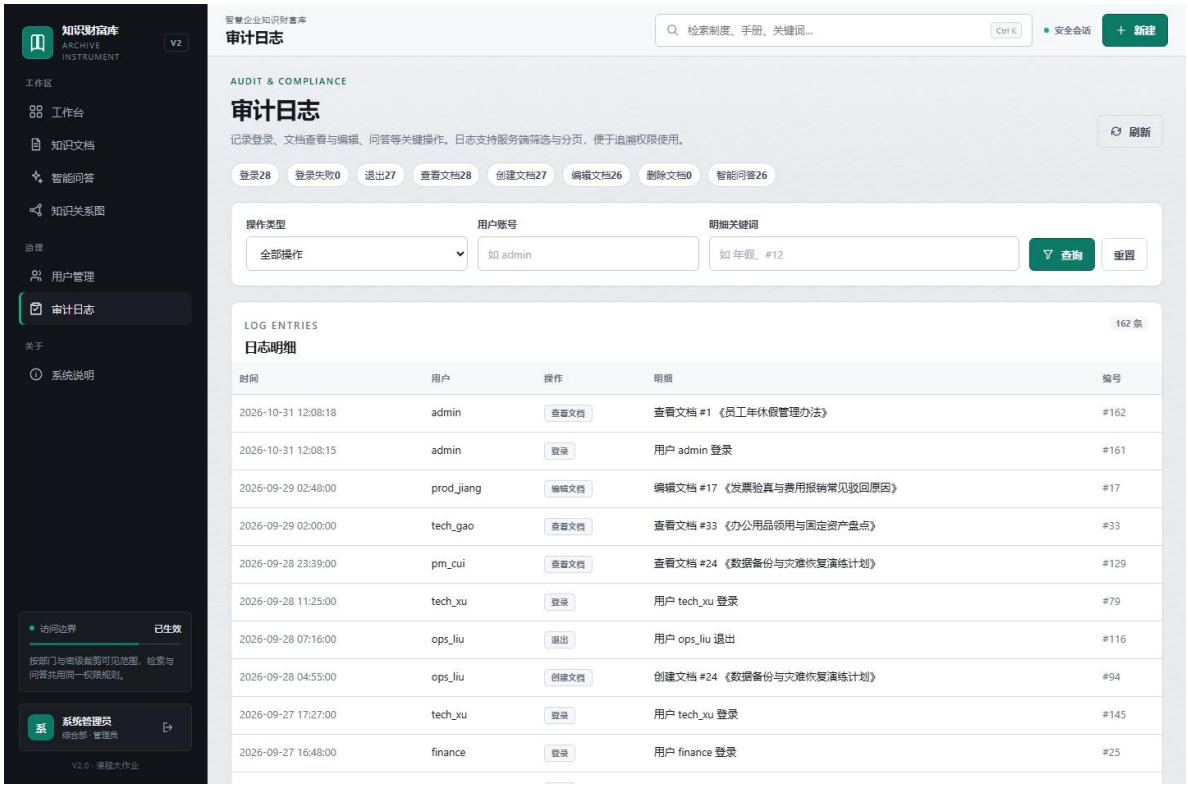


图 2-9 审计日志原型

项目	说明
对应文件	`docs/screenshots/09-audits.png`；实现：`frontend/src/views/AuditsView.vue`
页面目标	追溯登录、文档查看/编辑、问答等关键操作
主要区域	动作快捷筛选胶囊；用户、明细筛选；日志统计；日志明细表；上一页/下一页；动作中文标签
关键交互	按动作筛选；按用户名/明细模糊筛选；重置；翻页；刷新
数据/API	`GET /api/admin/audits`，参数 `action/user/detail/page`；后端固定每页 25 条并返回 `pagination/action_stats/actions`
权限/异常	仅管理员；非管理员 403；登录失败和未登录失败尝试也进入审计
需求/代码映射	UR-AUD-01；SR-AUD-001/002；`AuditsView.vue`、`app/api.py::admin_audits`

2.2.10 关于系统



图 2-10 关于系统原型

项目	说明
对应文件	`docs/screenshots/10-about.png`；实现：`frontend/src/views/AboutView.vue`
页面目标	说明项目定位、版本、技术栈、能力、典型场景和课程交付信息
主要区域	品牌主视觉；版本/课程/前后端分离徽标；可见文档、片段、节点、关系、本人问答统计；核心能力卡；技术架构流程；典型使用场景；课程交付说明
关键交互	页面加载 `GET /api/about`；文档与片段统计随当前权限变化，节点/边为结构统计，问答为本人统计
数据/API	`GET /api/about` 返回 `app`、`stats`、`scope`
权限/异常	仅已登录；未登录由路由守卫跳登录；统计数据不泄露机密规模
需求/代码映射	SR-OPS-003；`AboutView.vue`、`app/api.py::about`

2.3 页面原型与需求追踪

需求组	覆盖页面	关键验证点
认证与权限	登录、工作台、文档详情/编辑、用户、审计	登录会话、角色菜单、机密文档 403、管理员入口
文档管理	工作台、文档列表、详情、编辑	新建/查看/编辑/删除、分类/标签/密级/状态、片段数
RAG 问答	问答、工作台快捷提问、文档详情“围绕此主题提问”	来源可追溯、权限内检索、历史与模式提示
知识图谱	图谱、管理员维护弹窗	力导向交互、节点类型图例、权限裁剪
收藏与审计	文档列表/详情、工作台、审计	收藏切换、审计动作筛选与分页
运维体验	关于、健康检查、页面空状态	统计口径、版本信息、错误可读性

3. 用例实现顺序/时序图及说明

3.1 用例实现顺序总览

本项目选择“前后端分离”实现，所有业务页面通过 `frontend/src/api/client.js` 发出同源 `/api` 请求，Flask API 返回 JSON。实际实现顺序可以归纳为：

顺序	用户动作	前端处理	API/服务	数据变化
1	打开系统	路由守卫请求 `GET /api/meta`、`GET /api/auth/session`	应用元信息、会话判定	无
2	登录	提交登录表单	`POST /api/auth/login` → 限流 → 密码校验 → 会话	新增 login 或 login_failed 审计
3	浏览工作台	请求工作台摘要	`GET /api/dashboard` → 权限过滤文档	无
4	检索/查看文档	列表与详情请求	`GET /api/documents`、`GET /api/documents/{id}`	查看详情写 view_document 审计
5	新建/编辑文档	表单保存	`POST/PUT /api/documents` → 事务 → 片段 → 图谱 → 审计	documents、knowledge_chunks、graph_*、audit_logs
6	提问	聊天提交	`POST /api/qa/ask` → 权限过滤 → 检索 → 生成/摘要 → 历史 → 审计	qa_history、audit_logs
7	浏览图谱	加载图谱	`GET /api/graph` → 可见文档节点裁剪	无
8	管理员审计/用户	管理页面	`GET /api/admin/*`	无

3.2 登录用例时序图

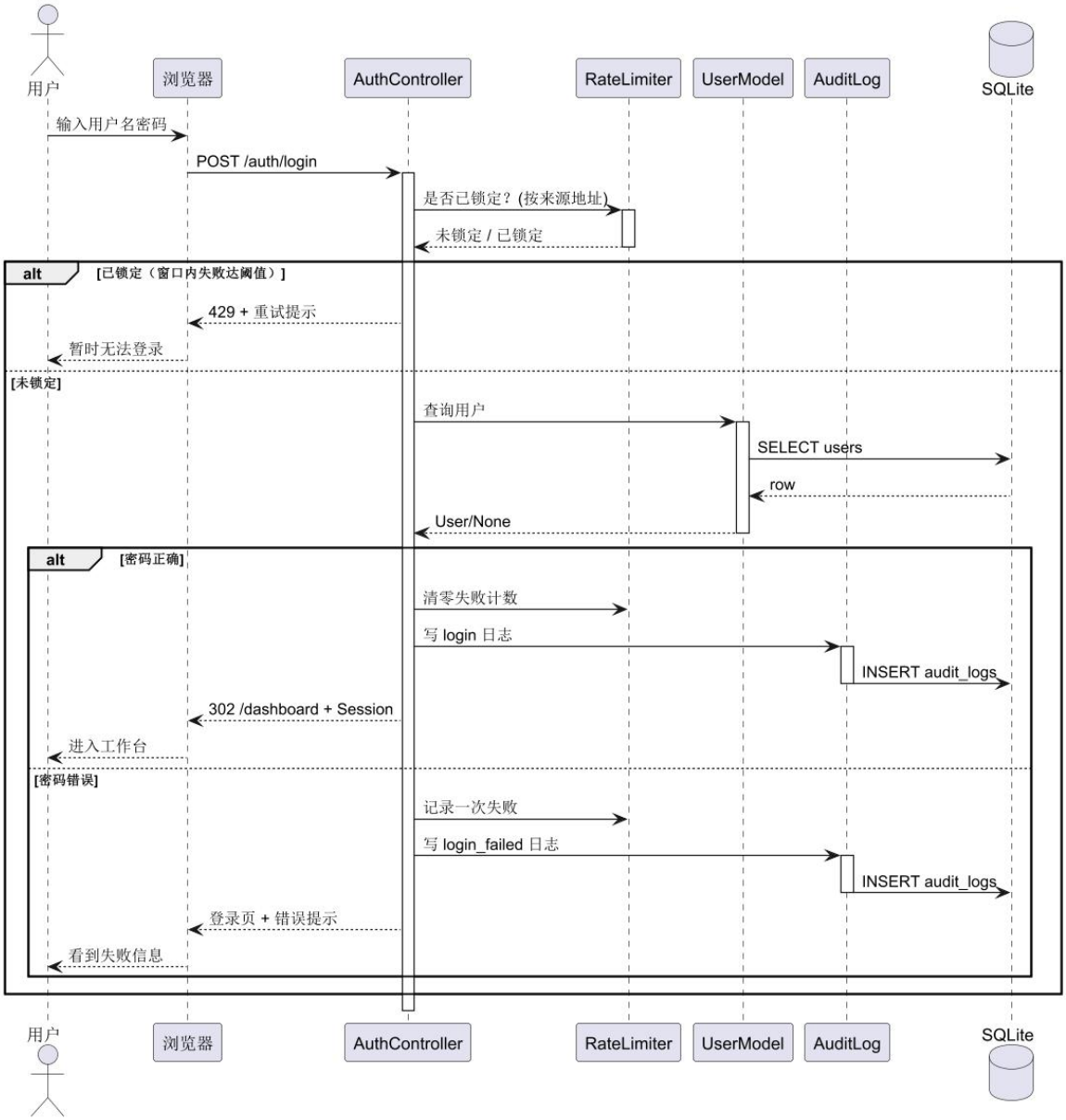


图 3-1 登录时序图

图源： `docs/uml/02-登录时序图.puml`

渲染图： `docs/uml/rendered/02-登录时序图.png`

图例说明：

元素	含义
参与者/对象	用户、浏览器、AuthController、RateLimiter、UserModel、AuditLog、SQLite
实线箭头	同步调用或数据库请求
虚线箭头	返回结果
垂直激活条	对象处于处理期间
`alt` 组合片段	互斥分支：已锁定/未锁定；密码正确/错误
`302 /dashboard + Session`	传统页面版登录回跳；V2.0 Vue 版对应 `200 + user + 会话 Cookie`，随后由前端路由跳转

关键元素解释：

427. **RateLimiter 在密码校验之前执行**。锁定期间即使密码正确也不放行，避免爆破者利用“正确密码”探测。

428. **失败与成功都写审计**。成功后写 `login`，失败后写 `login_failed`；未知用户名也记录用户名，便于发现爆破。

429. **服务端负责会话**。前端只保存用户状态到响应式 store；真正的登录态由 Flask-Login 的会话 Cookie 维持。

430. **V2.0 路由对照**：UML 图保留早期页面路由 `/auth/login` 的表述；当前 Vue 实现调用 `POST /api/auth/login`，但控制流、限流、密码校验和审计顺序一致，见 `app/api.py::login`。

实现对应表：

时序步骤	实现位置	说明
输入账号密码	`frontend/src/views/LoginView.vue`	表单校验和演示账号填充
发起登录	`frontend/src/stores/session.js`、`frontend/src/api/client.js`	`credentials: 'include'`，JSON 请求
锁定检查	`app/api.py::login`、`app/utils.py::RateLimiter`	按 `request.remote_addr` 的滑动窗口
查询用户/密码校验	`app/models.py::User.check_password`	Werkzeug 带盐慢哈希
写审计	`app/models.py::AuditLog`	`login`/`login_failed`
建立会话	`flask_login.login_user`	`remember` 可延长登录态
登录回跳	`frontend/src/router/index.js`	路由守卫与 `redirect` 查询参数

3.3 RAG 智能问答时序图

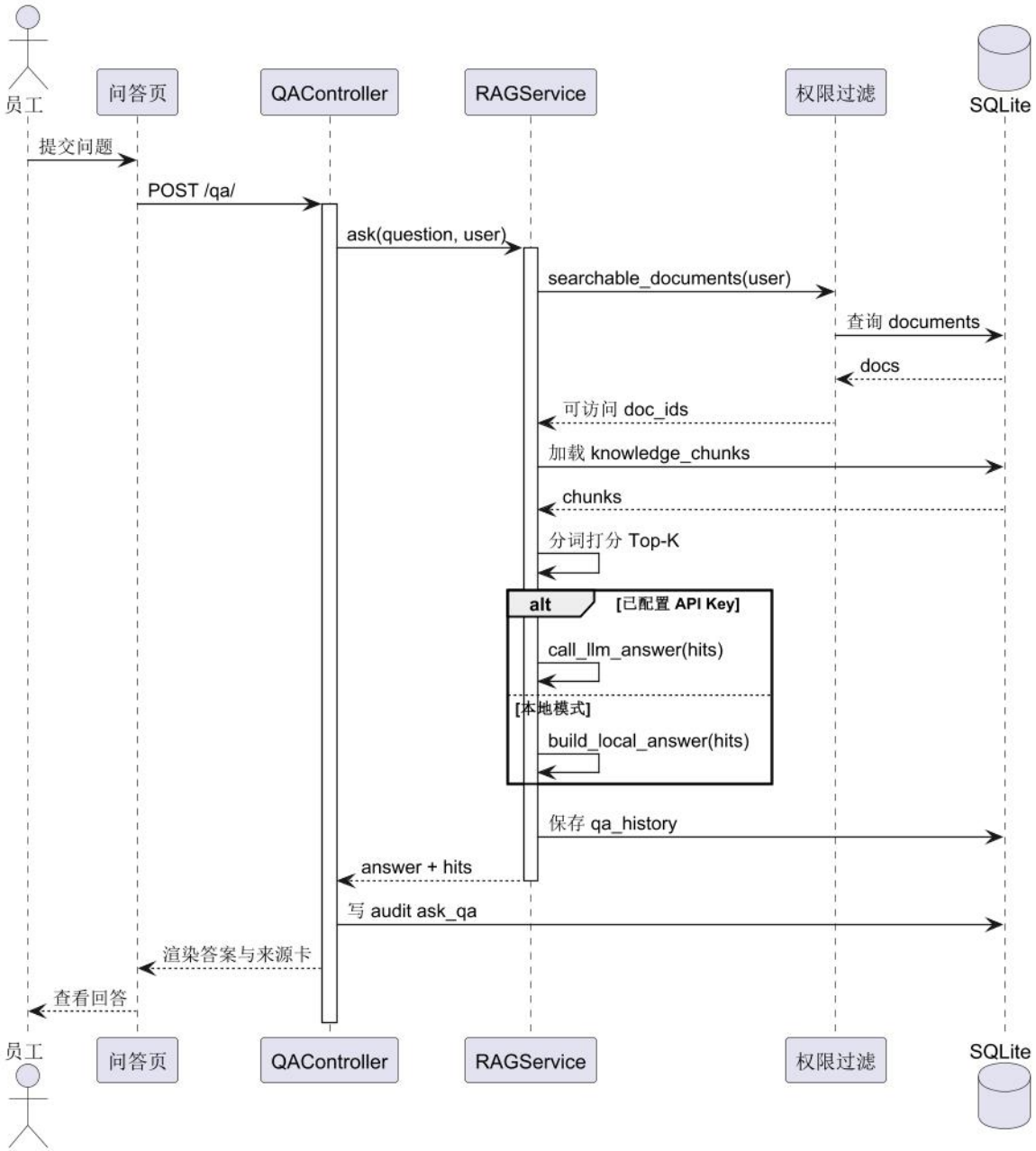


图 3-2 RAG 问答时序图

图源： `docs/uml/03-RAG 问答时序图.puml`

渲染图： `docs/uml/rendered/03-RAG 问答时序图.png`

图例说明：

元素	含义
员工	提交自然语言问题的已登录用户
问答页/QAController	Vue 问答页面与 Flask API 控制器
RAGService	权限过滤后的片段检索、打分、回答生成与历史保存
权限过滤	`searchable_documents()` / `can_view_document()`
SQLite	文档、片段、问答历史与审计持久化
`alt` 分支	有 API Key 时调用大模型；无 Key 时本地摘要
`Top-K`	按相关度排序后最多取配置数量片段，同文档最多 2 个片

元素	含义
	段

关键元素解释：

431. **先鉴权、后检索**。retrieve() 先计算当前用户可见文档 id 集合，再加载对应 knowledge_chunks，从源头上避免越权片段进入上下文。

432. **本地模式是默认可用路径**。build_local_answer() 将命中片段整理成摘要式回答，并明确说明“本地检索摘要模式”；没有 Key 不会冒充大模型。

433. **来源可追溯**。返回 sources（按文档合并）和 fragments（原始片段），每个片段带 document_id/title/department/score/fragment_no/fragment_total。

434. **问答历史持久化**。qa_history 保存问题、答案、来源 JSON、模式和时间；普通用户只能读取本人记录，管理员可读取全部。

435. **V2.0 路由对照**：UML 图保留早期 /qa/ 页面路由；当前 Vue 前端调用 POST /api/qa/ask，服务端处理流程与图中 QAController → RAGService → 权限过滤 → SQLite 一致。

实现对应表：

时序步骤	实现位置	说明
提交问题	frontend/src/views/QaView.vue	输入框/示例问题、loading 与错误提示
权限过滤	app/services/rag.py::searchable_documents	只取已发布且可见文档
加载片段	app/services/rag.py::retrieve	KnowledgeChunk.document_id.in_(allowed_ids)
分词与评分	_tokenize、score_chunk、rank_documents	jieba + 关键词 + 标题命中 + 短语包含
Top-K 去重	retrieve	同文档最多 2 个片段，默认 TOP_K=5
生成回答	build_local_answer / call_llm_answer	本地摘要或 OpenAI 兼容接口
保存历史	QAHistory、ask()	sources 保存来源 JSON
写审计	app/api.py::ask_question	ask_qa 动作，问题摘要最多 80 字
前端渲染	QaView.vue	对话气泡、来源卡、历史详情

3.4 文档发布活动图

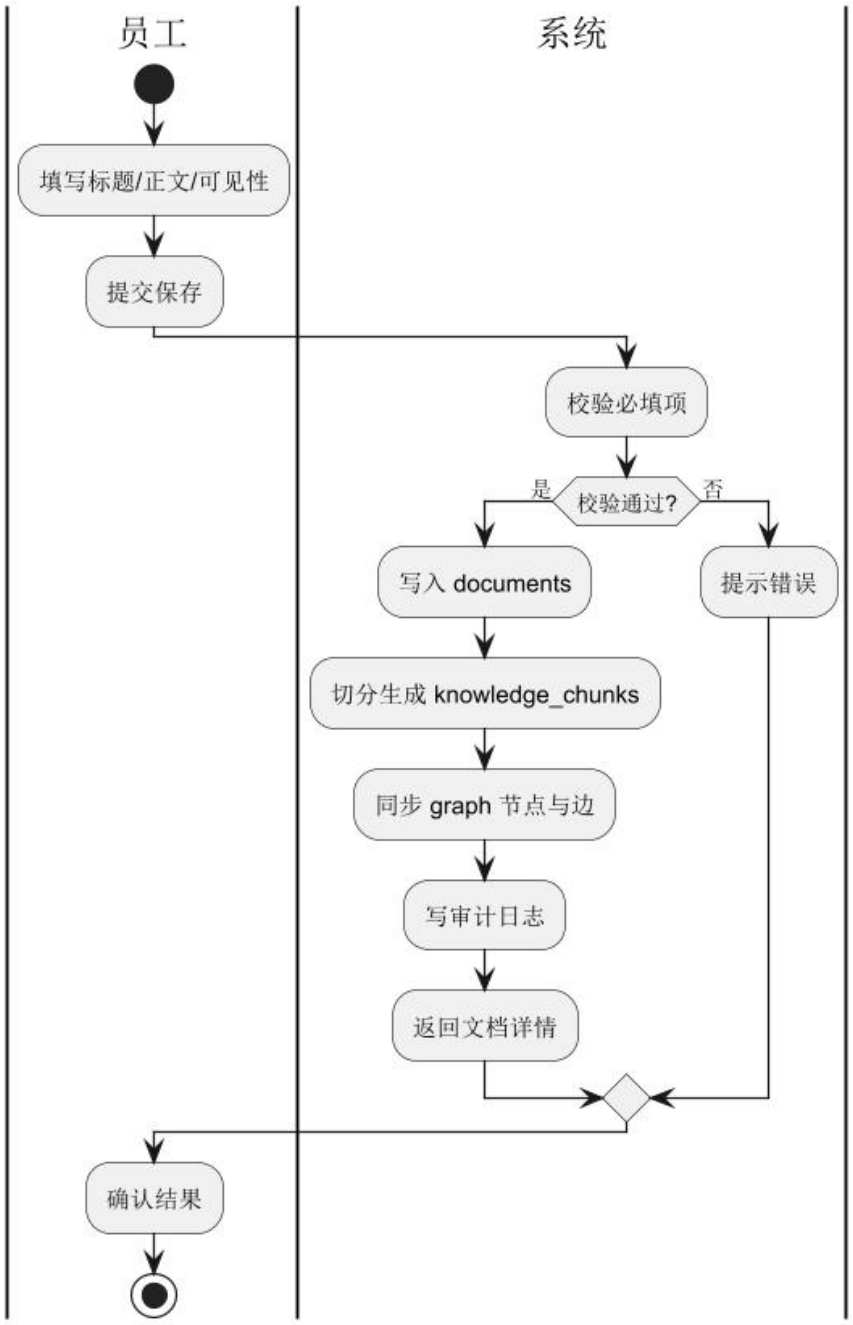


图 3-3 文档发布活动图

图源：`docs/uml/04-文档发布活动图.puml`

渲染图：`docs/uml/rendered/04-文档发布活动图.png`

图例说明：圆点表示开始/结束；圆角矩形表示活动；菱形表示校验分支；泳道区分“员工”和“系统”；箭头表示控制流。

说明：员工填写标题、正文、可见性并提交保存后，系统校验必填项；校验失败提示错误，校验通过则写入 `documents`，随后切分生成 `knowledge_chunks`、同步图谱节点与边、写入审计日志，最

后返回文档详情。该活动图对应 `app/api.py::_finalize_document()` 的组合流程，与 `app/services/rag.py::rebuild_chunks_for_document()`、`app/services/graph.py::sync_document_graph()` 可以直接对照。

3.5 文档状态图

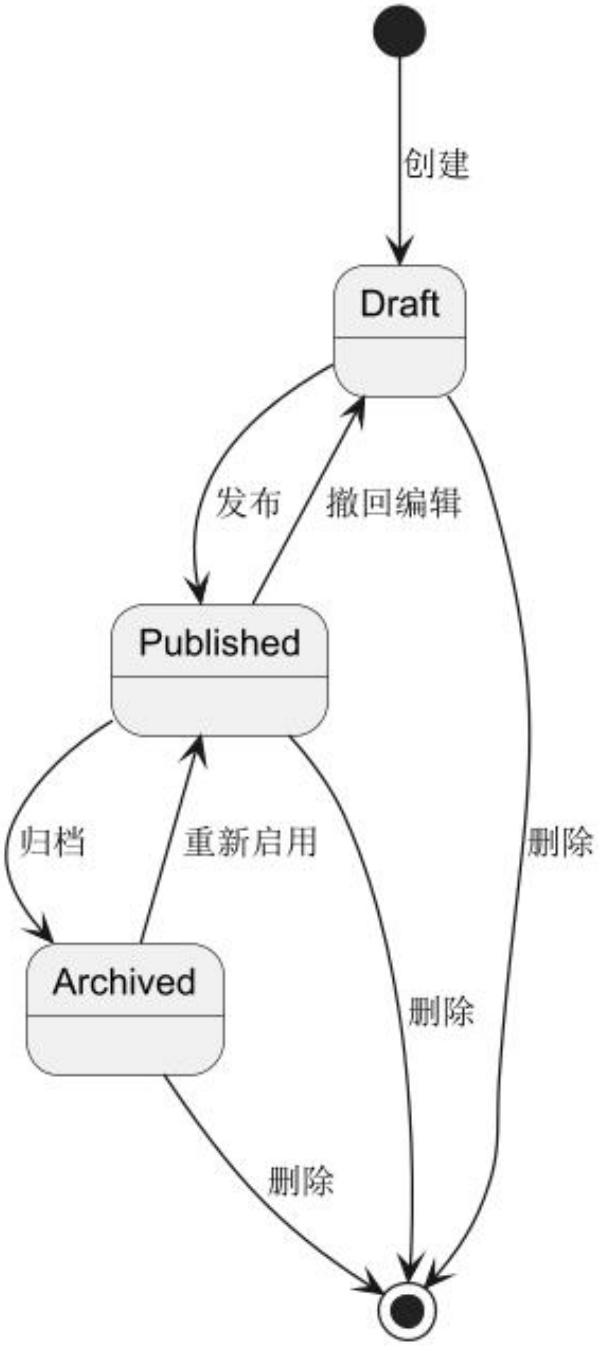


图 3-4 文档状态图

图源： `docs/uml/05-文档状态图.puml`

渲染图： `docs/uml/rendered/05-文档状态图.png`

图例说明：实心圆为初始状态；圆角矩形为 Draft/Published/Archived；箭头为发布、撤回编辑、归档、重新启用、删除等状态迁移；终止圆为删除或销毁。

说明：

- draft：草稿；列表默认不展示，作者/管理员可打开详情。
- published：已发布；进入普通检索和问答范围。
- archived：已归档；不再作为普通列表/问答知识源，作者/管理员仍可查看和维护。
- 当前 API 通过 PUT /api/documents/{id} 修改 status 字段完成状态迁移；DELETE /api/documents/{id} 删除记录并移除图谱节点/边。

3.6 时序/活动与代码、测试对应

用例	图	主要代码	测试关注点
登录	02-登录时序图	app/api.py::login、app/blueprints/auth.py、app/utils.py::RateLimiter	401、429、会话、失败审计、密码哈希
智能问答	03-RAG 问答时序图	app/api.py::ask_question、app/services/rag.py	权限过滤、Top-K、来源、模式、历史
管理文档	04-文档发布活动图、05-文档状态图	app/api.py::_apply_document_payload、_finalize_document	必填校验、片段重建、图谱同步、状态可见性
浏览图谱	03 时序图的权限过滤思想 + GET /api/graph	app/api.py::_visible_graph_payload、app/services/graph.py	不可见文档节点不泄露
管理/审计	02 时序图的审计分支 + 管理 API	app/api.py::admin_*、AuditLog	仅管理员、分页、动作筛选

4. 系统/模块类图及说明

4.1 领域类图

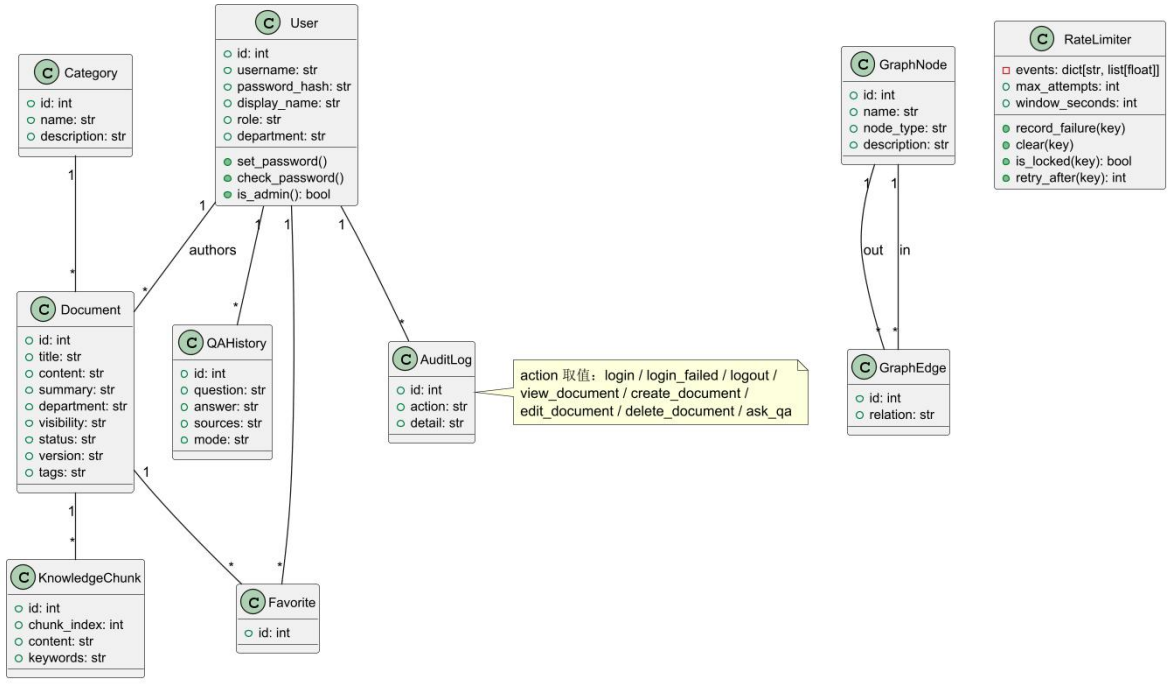


图 4-1 系统领域类图

图源： `docs/uml/06-类图.puml`

渲染图： `docs/uml/rendered/06-类图.png`

4.2 图例与关键元素

图元素	含义	示例
C 类框	类/ORM 实体/服务类	User、Document、QAHistory
分区	类名、属性、方法	Document 的标题、正文、密级等
+	公开属性/方法	set_password()、check_password()
-	私有属性	RateLimiter._events
实线	关联	User 1—* Document
数字/*	多重性	1 个用户可有多篇文档
注释框	约束说明	审计 action 取值
RateLimiter	安全基础类	进程内滑动窗口限流

4.3 类职责说明

类/模块	职责	关键字段/方法	代码路径
User	身份、角色	id/username/password_hash/display_name/role/department; set_password/check_password/is_admin	app/models.py

类/模块	职责	关键字段/方法	代码路径
	、部门、密码哈希、管理员判定		
Category	文档分类与说明	id/name/description	app/models.py
Document	文档主体、摘要、密级、状态、版本、标签、作者/分类关联	title/content/summary/department/visibility/status/version/tags/category_id/author_id	app/models.py
KnowledgeChunk	文档切分后的检索片段	document_id/chunk_index/content/keywords	app/models.py
GraphNode	图	name/node_type/description/document_id	app/models.py

类/模块	职责	关键字段/方法	代码路径
	谱节点（文档/部门/关键词/概念/项目）		
GraphEdge	节点之间的有向关系	source_id/target_id/relation	app/models.py
Favorite	用户收藏关系与唯一约束	user_id/document_id/created_at	app/models.py
AuditLog	关键操作审计	user_id/action/detail/created_at	app/models.py
QAHistory	问答历史与来源JSON	user_id/question/answer/sources/mode/created_at	app/models.py
RateLimiter	按来源IP	max_attempts/window_seconds; record_failure/clear/is_locked/retry_after	app/utils.py

类/模块	职责	关键字段/方法	代码路径
	的滑动窗口限流		
RAG 服务	切分、关键词、检索、打分、回答生成	chunk_text/extract_keywords/retrieve/ask	app/services/rag.py
图谱服务	节点复用、边去重、文档图谱同步、删除清理	sync_document_graph/ensure_edge/graph_payload	app/services/graph.py
API 蓝图	REST接口、JSON响应、权限装饰器	api_login_required/api_admin_required	app/api.py

4.4 主要关联与多重性

关联	多重性	约束/说明
User → Document	1 : 0..*	Document.author_id 可空；作者删除/未知时显示“未知作者”
Category → Document	1 : 0..*	Document.category_id 可空；空值表示未分类
Document → KnowledgeChunk	1 : 0..*	保存即重建片段，删除文档级联删除片段
User → Favorite	1 : 0..*	个人收藏
Document → Favorite	1 : 0..*	文档删除级联删除收藏
User → AuditLog	1 : 0..*	user_id 可空，匿名失败尝试可无用户
User → QAHistory	1 : 0..*	user_id 可空；普通用户仅访问本人记录
GraphNode → GraphEdge	1 : 0..*（出边）	source_id 外键
GraphNode → GraphEdge	1 : 0..*（入边）	target_id 外键
Document → GraphNode	1 : 0..*	document_id 可空；文档节点用于图谱权限裁剪

4.5 系统/模块类视图

为补充领域类图只展示核心实体、未展开前端页面和后端控制器的不足，系统模块关系可由以下两层图说明：

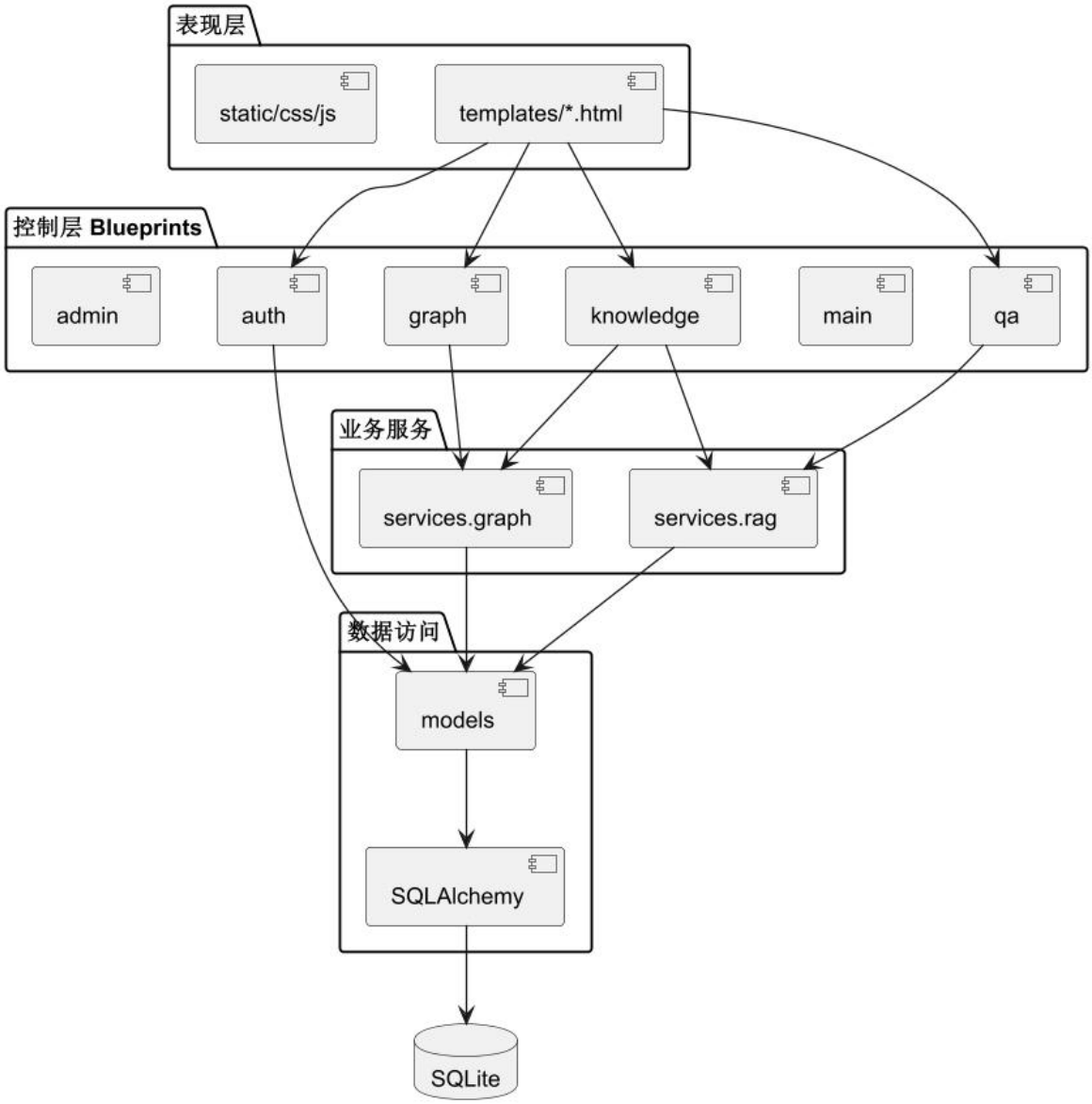

表现层
static/css/js
templates/*.html
控制层 Blueprints
admin
auth
graph
knowledge
main
qa
业务服务
services.graph
services.rag
数据访问
models
SQLAlchemy
SQLite

图 4-2 系统构件图

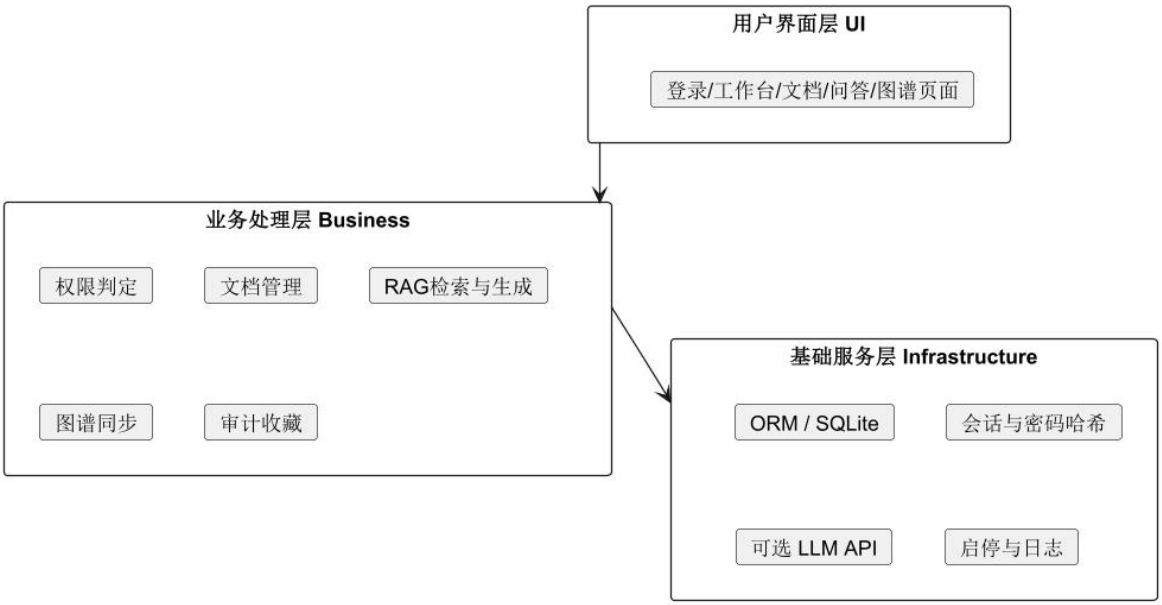


图 4-3 三层架构图

层次	模块/类	主要职责	对应实现
表现层	Vue Views、AppShell、PageHeader、BaseChart、EmptyState	页面路由、布局、图表、空状态、交互反馈	frontend/src/views/、frontend/src/components/
接口层	Flask api Blueprint	统一 /api、会话校验、管理员校验、JSON 序列化、错误码	app/api.py
业务服务层	rag.py、graph.py	切分/检索/问答、图谱同步/裁剪	app/services/
数据访问层	SQLAlchemy ORM 模型	表映射、关系、约束、查询	app/models.py
基础设施层	SQLite、Flask-Login、Werkzeug、jieba、ECharts	持久化、会话、密码哈希、分词、可视化	instance/knowledge.db、依赖库
安全横切	RateLimiter、audit_detail、can_view_document	限流、审计文案、密级判定	app/utils.py、app/services/rag.py

构件图图例：矩形构件表示可替换的软件单元，箭头表示依赖/调用方向；templates/static 与蓝图属于旧页面兼容层，V2.0 的主界面由 Vue 前端通过 REST API 调用同一业务服务。

三层架构图图例：UI 层负责展示，Business 层负责权限、文档、RAG、图谱、审计，Infrastructure 层提供 ORM/SQLite、会话、密码哈希、可选 LLM API 与启停日志。

4.6 类图与需求/代码对应

需求组	主要类/服务	关键行为	证据
认证与权限	User、RateLimiter、API 装饰器	登录、角色、密码哈希、限流、会话	app/models.py、app/utils.py、app/api.py
文档管理	Document、Category、KnowledgeChunk	CRUD、分类、片段重建	app/models.py、app/services/rag.py
智能问答	QAHistory、RAG 服务	检索、打分、生成、来源、历史	app/services/rag.py
知识图谱	GraphNode、GraphEdge、图谱服务	同步、去重、裁剪、维护	app/services/graph.py
收藏与审计	Favorite、AuditLog	唯一收藏、关键动作留痕	app/models.py、

需求组	主要类/服务	关键行为	证据
			app/api.py

说明：类图以“领域类 + 安全类”为主，是为了让课程评审快速看清业务实体和关系；系统级实现细节通过构件图、三层架构图和本章模块表补足，不把框架内部类全部画入领域类图，避免噪声。

5. 数据库实体类图及 E-R 图及说明

5.1 数据库实体类图（ORM 视角）

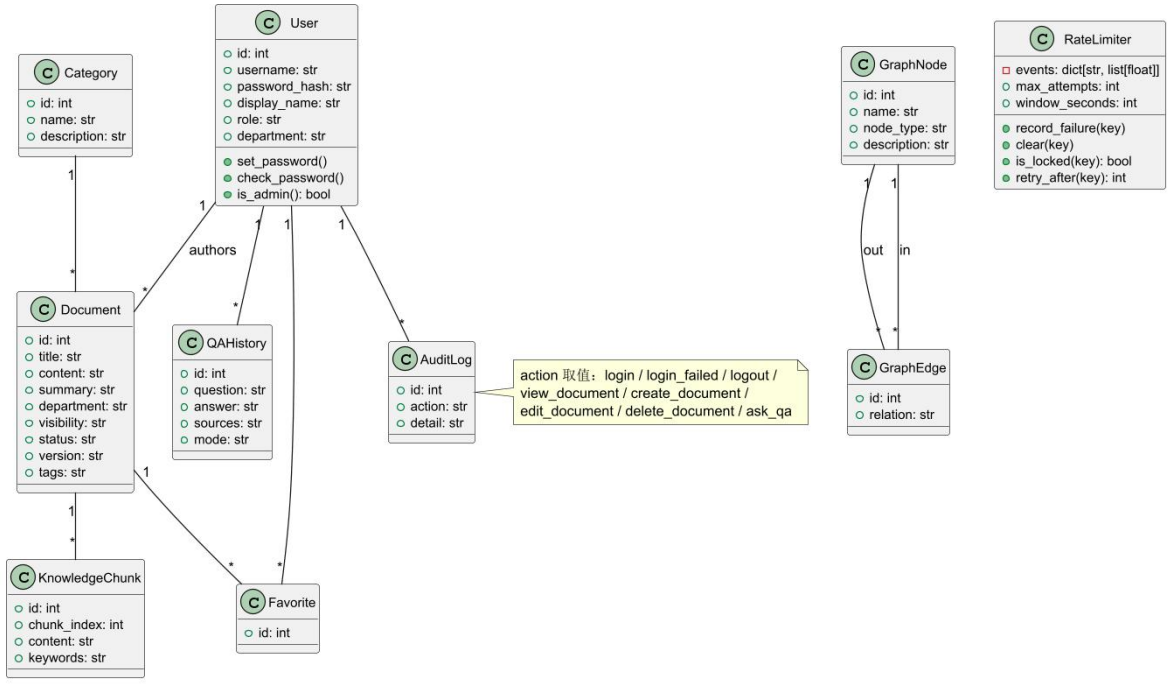


图 5-1 ORM 实体类图

ORM 实体类与图 4-1 相同，但这里从数据库映射角度阅读：User、Category、Document、KnowledgeChunk、GraphNode、GraphEdge、Favorite、AuditLog、QAHistory 对应 9 张 SQLite 表；RateLimiter 是内存安全类，不建表。主要映射定义在 app/models.py，通过 SQLAlchemy db.Model、ForeignKey、UniqueConstraint 建立约束。

5.2 E-R 图

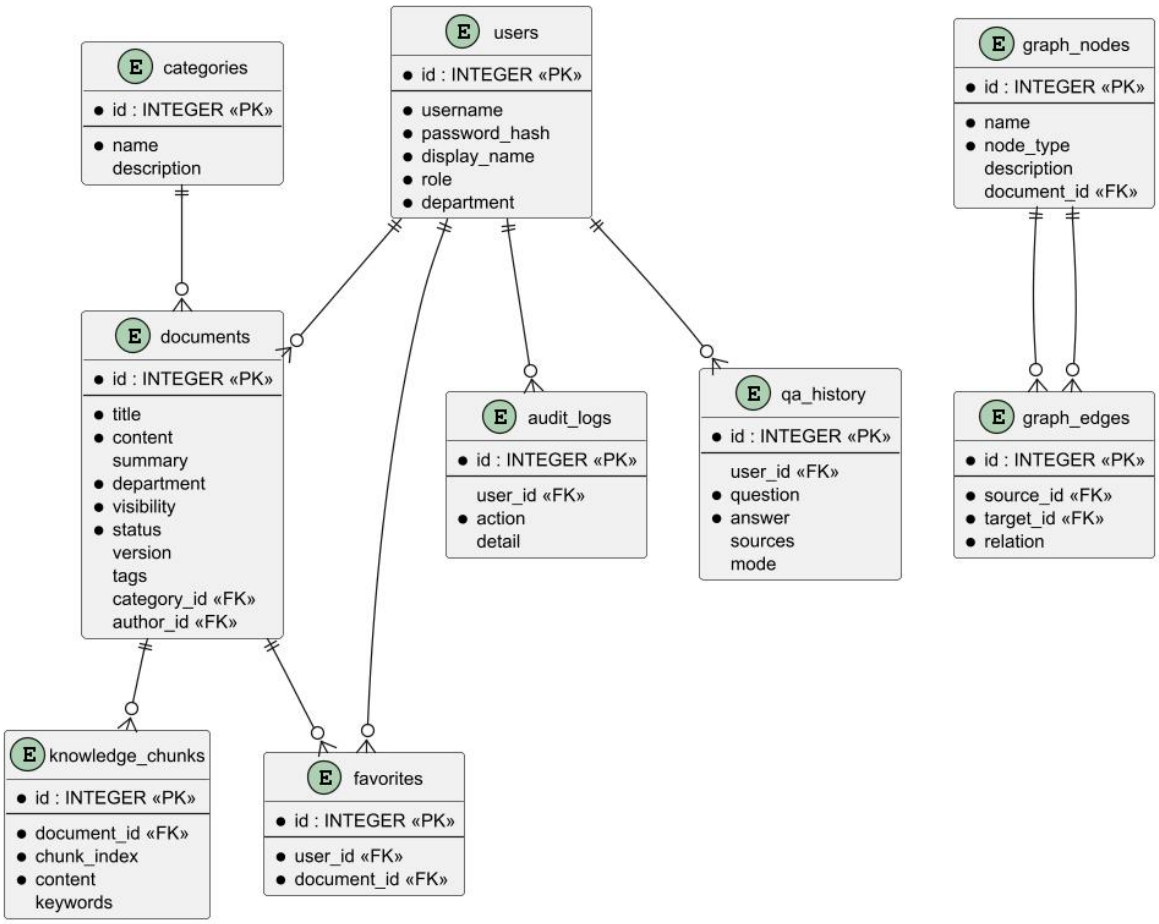


图 5-2 数据库 E-R 图

图源： `docs/uml/07-ER 图.puml`

渲染图： `docs/uml/rendered/07-ER 图.png`

图例说明：

元素	含义
E 实体框	数据库实体/表
PK	主键
FK	外键
普通字段	业务属性
鸟足形连线	一对多关系
竖线/圆圈	可选或必选参与
自关联（graph_nodes）	节点通过 graph_edges 连接其他节点

5.3 表清单与用途

表名	实体	用途	主键	关键约束
users	用户	账号、角色、部门、密码哈希	id	username 唯一、非空、索引
categories	分类	文档分类与说明	id	name 唯一、非空
documents	文档	业务知识正文与元数据	id	标题/正文/部门/密级/状态非空；作者、分类

表名	实体	用途	主键	关键约束
				外键
knowledge_chunks	知识片段	RAG 检索单元	id	document_id 非空、索引；文档删除级联
graph_nodes	图谱节点	文档/部门/关键词/概念/项目节点	id	name 唯一、非空；可选 document_id 外键
graph_edges	图谱边	节点之间的关系	id	source_id/target_id 外键、非空；同源同目标同关系避免重复
favorites	收藏	用户与文档的个人收藏关系	id	(user_id, document_id) 唯一
audit_logs	审计日志	关键操作留痕	id	action 非空；user_id 可空
qa_history	问答历史	问题、答案、来源、模式	id	question/answer 非空；user_id 可空

5.4 关系与基数说明

关系	基数	外键/实现	业务含义
users—documents	1 : 0..*	documents.author_id → users.id	一个用户可创建多篇文档；作者可空显示未知
categories—documents	1 : 0..*	documents.category_id → categories.id	一个分类可包含多篇文档；文档可为未分类
documents—knowledge_chunks	1 : 0..*	knowledge_chunks.document_id → documents.id	一篇文档切分为多个片段；级联删除
users—favorites	1 : 0..*	favorites.user_id → users.id	用户拥有多个收藏
documents—favorites	1 : 0..*	favorites.document_id → documents.id	文档可被多个用户收藏；级联删除
users—audit_logs	1 : 0..*	audit_logs.user_id → users.id，可空	用户的操作史；匿名失败也可记录
users—qa_history	1 : 0..*	qa_history.user_id → users.id，可空	用户的问答历史
graph_nodes—graph_edges（出）	1 : 0..*	graph_edges.source_id → graph_nodes.id	节点作为关系起点
graph_nodes—graph_edges（入）	1 : 0..*	graph_edges.target_id → graph_nodes.id	节点作为关系终点
documents—graph_nodes	1 : 0..*	graph_nodes.document_id → documents.id，可空	文档节点与业务文档关联，用于权限裁剪

5.5 数据字典

5.5.1 users

字段	类型	可空	默认/约束	说明
id	Integer	否	PK	用户编号
username	String(64)	否	唯一、索引	登录名
password_hash	String(255)	否	—	Werkzeug 带盐慢哈希，不保存明文
display_name	String(64)	否	—	展示姓名
role	String(20)	否	默认 employee	admin/employee
department	String(64)	否	默认 综合部	部门，决定机密文档同部门可见
created_at	DateTime	是	默认本地当前时间	创建时间

5.5.2 categories

字段	类型	可空	默认/约束	说明
id	Integer	否	PK	分类编号
name	String(64)	否	唯一	分类名称
description	String(255)	是	默认空串	分类说明

5.5.3 documents

字段	类型	可空	默认/约束	说明
id	Integer	否	PK	文档编号
title	String(200)	否	—	标题
content	Text	否	默认空串	正文
summary	String(500)	是	默认空串	摘要，可自动截取
department	String(64)	否	默认 综合部	所属部门
visibility	String(20)	否	默认 internal	public/internal/secret
status	String(20)	否	默认 published	draft/published/archived
version	String(20)	是	默认 1.0	版本号
filename	String(255)	是	默认空串	预留文件名字段
tags	String(255)	是	默认空串	逗号分隔标签
category_id	Integer	是	FK → categories.id	分类
author_id	Integer	是	FK → users.id	作者
created_at	DateTime	是	默认本地当前时间	创建时间
updated_at	DateTime	是	默认/更新为本地当前时间	更新时间

5.5.4 knowledge_chunks

字段	类型	可空	默认/约束	说明
id	Integer	否	PK	片段编号
document_id	Integer	否	FK → documents.id，索引	所属文档
chunk_index	Integer	否	默认 0	文档内片段序号
content	Text	否	—	片段正文
keywords	String(500)	是	默认空串	jieba 提取关键词

5.5.5 graph_nodes

字段	类型	可空	默认/约束	说明
id	Integer	否	PK	节点编号
name	String(100)	否	唯一	节点名称，如 文档:员工年休假管理办法
node_type	String(40)	否	默认 concept	document/department/project/keyword/concept
description	String(255)	是	默认空串	节点说明
document_id	Integer	是	FK → documents.id	文档节点关联业务文档

5.5.6 graph_edges

字段	类型	可空	默认/约束	说明
id	Integer	否	PK	边编号

字段	类型	可空	默认/约束	说明
source_id	Integer	否	FK → graph_nodes.id	起点节点
target_id	Integer	否	FK → graph_nodes.id	终点节点
relation	String(64)	否	默认 关联	关系名，如属于/分类为/含有

5.5.7 favorites

字段	类型	可空	默认/约束	说明
id	Integer	否	PK	收藏编号
user_id	Integer	否	FK → users.id	收藏用户
document_id	Integer	否	FK → documents.id	被收藏文档
created_at	DateTime	是	默认本地当前时间	收藏时间
唯一约束	—	—	uq_user_doc_fav(user_id, document_id)	防止同一用户重复收藏同一文档

5.5.8 audit_logs

字段	类型	可空	默认/约束	说明
id	Integer	否	PK	日志编号
user_id	Integer	是	FK → users.id	操作用户；未知登录名可为空
action	String(64)	否	—	动作代码
detail	String(500)	是	默认空串	统一中文明细
created_at	DateTime	是	默认本地当前时间	操作时间

动作代码：login、login_failed、logout、view_document、create_document、edit_document、delete_document、ask_qa。

5.5.9 qa_history

字段	类型	可空	默认/约束	说明
id	Integer	否	PK	问答编号
user_id	Integer	是	FK → users.id	提问用户
question	Text	否	—	问题
answer	Text	否	—	回答
sources	Text	是	默认空串	JSON 字符串，保存来源文档与分数
mode	String(20)	是	默认 local	local/llm
created_at	DateTime	是	默认本地当前时间	提问时间

5.6 数据库与代码/API 对应

数据库表	ORM 类	主要 API/服务	说明
users	User	/api/auth/*、/api/admin/users	登录、角色、用户列表
categories	Category	/api/categories、文档表单	分类维护与文档归类
documents	Document	/api/documents*	文档 CRUD 与权限过滤
knowledge_chunks	KnowledgeChunk	/api/qa/ask、	RAG 检索单元

数据库表	ORM 类	主要 API/服务	说明
		/api/documents 的片段数	
graph_nodes	GraphNode	/api/graph*	图谱节点与文档关联
graph_edges	GraphEdge	/api/graph*	图谱关系
favorites	Favorite	/api/documents/favorites、收藏切换	个人收藏
audit_logs	AuditLog	/api/admin/audits、各写操作	审计追溯
qa_history	QAHistory	/api/qa、/api/qa/ask、/api/qa/history/{id}	问答历史与来源

5.7 数据一致性与查询模式

436. **事务性写入**：文档保存时先 flush 获得文档 id，再重建片段、同步图谱，最后统一提交；避免前端看到半写入状态。

437. **删除清理**：删除文档前调用 remove_document_graph() 清理图谱节点与边；ORM 级联删除片段与收藏。

438. **权限查询**：列表、问答、图谱都通过 searchable_documents() 取可见文档集合，再在服务层进行过滤，避免只依赖前端隐藏。

439. **去重策略**：收藏表唯一约束防重复；图谱边按 (source_id, target_id, relation) 查询去重；节点按 name 复用。

440. **时间口径**：统一使用 now_naive() 的本地时间，API 输出格式为 YYYY-MM-DD HH:MM:SS，不携带时区后缀。

441. **JSON 文本字段**：qa_history.sources 是 JSON 字符串，读取失败时 API 回退为空数组，保证接口不因历史脏数据崩溃。

5.8 数据库设计需求追踪

需求	数据库支撑	代码证据
UR-AUTH-04/05/06	users、audit_logs；密码哈希与限流	User.password_hash、RateLimiter、AuditLog
UR-DOC-01～05	documents、categories、knowledge_chunks	Document、Category、KnowledgeChunk
UR-QA-01～04	knowledge_chunks、qa_history	KnowledgeChunk、QAHistory、RAG 服务
UR-KG-01/02	graph_nodes、graph_edges	GraphNode、GraphEdge、图谱服务
UR-FAV-01	favorites	Favorite 唯一约束
UR-AUD-01	audit_logs	AuditLog、admin_audits

6. 个人项目小结

6.1 项目完成情况自评

维度	完成内容	自评
需求与范围	完成竞品、用户需求、系统需求，明确 V2.0 范围与不做项	达到课程要求
架构与设计	完成 Vue + REST API + 服务层 + SQLAlchemy 的分层设计	达到课程要求
功能实现	认证、文档、收藏、分类、问答、图谱、用户、审计、关于、健康检查	主路径完整
数据与权限	密级、部门、作者、管理员、状态、收藏隔离、问答来源权限	重点完成
工程质量	120 个测试函数、API 契约、静态检查配置、启停脚本、UML 本地渲染	达到课程要求
文档完整性	10 张 UML、五部分考核材料、REST API 说明书、页面截图引用	基本完整
可演示性	本地启动、演示账号、示例问题、错误提示与空状态	可演示

6.2 主要收获

442. **从“能运行”提升到“可追溯”**：文档、片段、问答来源、图谱节点、审计记录之间建立了清晰链路，答辩时可以从页面一路追到数据库和代码。

443. **权限必须落在服务端**：前端隐藏按钮只能改善体验，真正的密级隔离必须由 `searchable_documents()`、`can_view_document()` 和 API 装饰器完成。

444. **单人项目更需要过程管理**：没有团队分工兜底，必须用需求编号、里程碑、测试清单和证据路径约束自己，避免范围膨胀。

445. **本地优先的工程选择**：默认本地摘要问答、SQLite、进程内限流、本地 UML 渲染，降低了外部服务失败对演示的影响。

446. **文档与图不是装饰**：用例图、时序图、类图和 E-R 图分别回答了“谁做什么”“如何调用”“类如何协作”“数据如何落库”，并与代码路径一一对应。

6.3 不足与改进方向

不足	影响	改进方向
登录限流为进程内实现	多进程/多机部署时计数不共享	迁移到 Redis 等共享存储
SQLite 适合演示	高并发写入与大规模检索能力有限	生产化可迁移 PostgreSQL，并引入向量检索
关键词检索而非向量语义检索	同义表达召回有限	引入 embedding/向量库，保留关键词混合检索
用户管理只读	管理员不能在线新增/停用账号	增加账号 CRUD、状态与密码重置
分类删除未开放	分类生命周期不完整	增加删除前引用检查/迁移策略
页面截图基线需持续维护	页面迭代后截图可能过期	固定 `docs/screenshots/01-...` 命名，并把截图更新纳入交付检查
前端以桌面端为主	移动端体验有限	增加小屏断点与触控交互专项测试

6.4 后续计划

447. 将 docs/screenshots/ 固定为 10 张截图基线，并在交付前逐张核对文件名与页面版本。

448. 增加一条端到端演示脚本，自动验证“登录 → 检索 → 问答 → 图谱 → 审计”。

449. 为 API 补充 OpenAPI 导出，与本文第 08 章保持同步。

450. 在保持 SQLite 演示能力的同时，把 RAG 检索抽象为可替换的检索接口。

451. 继续把用例编号、需求编号、测试编号和代码路径纳入变更检查，避免文档与实现漂移。

7. 考核材料与证据路径

7.1 个人分工与开发任务

开发/工程任务	本人承担内容	完成情况	证据路径
架构与数据库	Vue SPA + Flask REST API 分层；9 张表、外键、唯一约束、权限字段	完成	app/models.py、docs/uml/07-ER 图.puml、docs/course/03-软件设计规格说明书.md
认证与安全	登录/退出、Flask-Login 会话、密码哈希、IP 限流、失败审计、角色装饰器	完成	app/api.py、app/blueprints/auth.py、app/utils.py
前端壳层与路由	登录页、AppShell、路由守卫、会话状态、全局样式、错误/空状态	完成	frontend/src/App.vue、frontend/src/components/AppShell.vue、frontend/src/router/index.js
知识文档模块	列表、筛选、搜索、分页、详情、新建、编辑、删除、密级/状态控制	完成	app/api.py、frontend/src/views/DocumentsView.vue、DocumentDetailView.vue、DocumentEditorView.vue
RAG 问答模块	文档切分、jieba 关键词、检索评分、Top-K、本地摘要、可选 LLM、来源与历史	完成	app/services/rag.py、frontend/src/views/QaView.vue
知识图谱模块	自动同步文档/部门/分类/关键词节点与边、权限裁剪、ECharts 展示、管理员维护	完成	app/services/graph.py、frontend/src/views/GraphView.vue
收藏与分类	收藏切换、收藏列表、分类列表、管理员新增分类、唯一约束	完成	app/api.py、app/models.py
用户与审计管理	用户目录与文档贡献、审计筛选/分页/动作统计	完成	app/api.py、frontend/src/views/UsersView.vue、AuditsView.vue
关于与健康检查	关于页、/api/about、/api/health、兼容 /health、统计口径	完成	app/api.py、app/blueprints/main.py、frontend/src/views/AboutView.vue
测试与质量	API 契约、权限矩阵、RAG 算法、登录安全、系统回归；测试入口	完成测试资产	tests/test_*.py、run_tests.ps1、docs/05-测试报告.md
工程化与运维	启动/停止脚本、Vite	完成	start.ps1、stop.ps1、

开发/工程任务	本人承担内容	完成情况	证据路径
	代理、UML 本地渲染、健康检查、环境变量配置		frontend/vite.config.js、scripts/render_uml.py

7.2 文档任务

文档任务	内容	完成情况	证据路径
竞品调研	竞品对比、痛点、差异化定位、范围冻结	完成	docs/01-竞品调研报告.md
用户需求	用户角色、UR 编号、优先级	完成	docs/02-用户需求说明书.md
系统需求	SR 编号、权限规则、非功能需求、追踪	完成	docs/03-系统需求说明书.md
软件设计	架构、模块、数据库、API、安全、部署	完成	docs/04-软件设计说明书.md、docs/course/03-软件设计规格说明书.md
UML 图集	用例、时序、活动、状态、类、ER、部署、构件、三层架构及本地渲染	完成	docs/uml/*.puml、docs/uml/rendered/*.png
页面原型与截图	10 类业务页面实现与 01-login～10-about 截图基线	完成	frontend/src/views/、docs/screenshots/
测试文档	测试计划、测试用例、自动化测试与结果说明	完成	docs/05-测试报告.md、docs/course/04-项目测试计划.md、docs/course/05-测试用例说明书.md
项目管理	项目计划、里程碑、风险、质量保证、交付清单	完成	docs/06-项目管理.md、docs/course/01-项目开发计划.md、docs/course/06-项目总结.md
个人考核材料	5 部分个人材料、分工、完成情况、小结与证据	完成	docs/course/07-个人项目小结与考核材料.md
REST API 说明书	认证、响应/错误码、分页、27 个接口、权限与示例	完成	docs/course/08-REST-API接口设计说明书.md

7.3 完成情况汇总

交付维度	完成情况	核对方式
五部分考核材料	第 1～5 章全部覆盖，每章有图、图例、关键解释和代码追踪	对照本文目录与图片链接
可运行系统	Vue 3 前端 + Flask 3 REST API + SQLite 演示数据	start.ps1 启动后访问 /ui/
功能主路径	登录 → 检索 → 详情 → 新建/编辑 → 问答 → 图谱 → 审计	按演示账号手工验证
权限控制	角色、密级、部门、作者、管理员、问答历史归属	tests/test_security.py、tests/test_login_security.py
数据一致性	文档保存重建片段与图谱；删除清理图谱；收藏唯一约束	tests/test_api.py、tests/test_rag.py
自动化测试	5 个测试文件、120 个测试函数，独立临时库	.\run_tests.ps1
UML 与截图	10 张 UML 源/渲染图；10 张页面截图引用	docs/uml/、docs/screenshots/

交付维度	完成情况	核对方式
文档一致性	需求编号、接口字段、数据库字段和代码路径互相追踪	本文第 1～7 章与 08 文档

7.4 关键证据清单

材料	路径	说明
用例图源/渲染	docs/uml/01-用例图.puml、docs/uml/rendered/01-用例图.png	第 1 章
登录时序图源/渲染	docs/uml/02-登录时序图.puml、docs/uml/rendered/02-登录时序图.png	第 3 章
RAG 时序图源/渲染	docs/uml/03-RAG 问答时序图.puml、docs/uml/rendered/03-RAG 问答时序图.png	第 3 章
文档活动/状态图	docs/uml/04-文档发布活动图.puml、docs/uml/05-文档状态图.puml 及对应 PNG	第 3 章
类图源/渲染	docs/uml/06-类图.puml、docs/uml/rendered/06-类图.png	第 4、5 章
E-R 图源/渲染	docs/uml/07-ER 图.puml、docs/uml/rendered/07-ER 图.png	第 5 章
构件/架构图	docs/uml/09-构件图.puml、docs/uml/10-三层架构.puml 及对应 PNG	第 4 章补充
页面截图	docs/screenshots/01-login.png 至 docs/screenshots/10-about.png	第 2 章；如命名不同以页面关键词通配核对
API 实现	app/api.py	27 个主要 REST API 方法/路径
ORM 模型	app/models.py	9 张表与关系约束
RAG 服务	app/services/rag.py	切分、分词、检索、回答、来源
图谱服务	app/services/graph.py	节点、边、同步、裁剪
前端 API 客户端	frontend/src/api/client.js	同源 /api、JSON、credentials: include
自动化测试	tests/test_api.py、test_security.py、test_rag.py、test_login_security.py、test_system.py	120 个测试函数
启动与测试	start.ps1、stop.ps1、run_tests.ps1、run.py	可复现实验/演示
需求追踪	docs/02-用户需求说明书.md、docs/03-系统需求说明书.md	UR/SR 编号
项目管理	docs/06-项目管理.md	角色、时间盒、风险、质量

7.5 提交前检查清单

- [ ] 5 部分标题和顺序与学校要求一致（本文第 1～5 章）。
- [ ] 5 部分均有图引用：第 1 章 01-用例图；第 2 章 01-login～10-about；第 3 章 02/03/04/05；第 4 章 06/09/10；第 5 章 06/07。
- [ ] docs/screenshots/ 中 10 张截图可打开，文件命名与第 2 章一致或在文中保留通配说明。
- [ ] docs/uml/rendered/ 中所有 PNG 可打开，中文未出现方框乱码。

- [ ] `docs/course/08-REST-API 接口设计说明书.md` 与 `app/api.py` 无字段漂移。
- [ ] `python -m pytest` 或 `.\run_tests.ps1` 在独立测试库上执行通过。
- [ ] 演示账号可登录，主路径“检索 → 问答 → 图谱 → 审计”可复现。
- [ ] 不修改代码或其他文件，仅提交本文件、API 文档及已约定的截图/图集材料。

8. 结语

本项目虽然是单人独立完成，但按完整的软件工程过程进行了需求、设计、实现、测试、文档和项目管理闭环。V2.0 的实现重点不是堆叠页面，而是把 **文档权限、可追溯问答、可视化图谱、审计治理** 串成一条可验证的链路。本文给出的五部分材料、图引用、代码路径和测试证据，既用于课程考核，也作为后续维护和答辩说明的依据。

文档结束 • 2026-10-31 • V2.0

第 8 部分 REST API 接口设计说明书

1. 概述

1.1 设计目标

452. **前后端分离**：Vue 3 单页应用负责页面与交互，Flask 负责认证、权限、业务规则与数据持久化。

453. **统一资源命名**：以 `/api` 为前缀，按认证、工作台、文档、收藏、分类、问答、图谱、管理、关于/健康分组。

454. **服务端权威鉴权**：前端隐藏按钮只是体验优化，真正的角色与密级判断在 API/服务层完成。

455. **可追溯**：登录、文档查看/编辑、问答等关键动作写入 `audit_logs`；问答结果保存来源。

456. **可演示、可测试**：接口返回结构稳定，便于 Vue 前端、pytest 契约测试与课程答辩演示。

1.2 基础地址与传输

项目	约定
基础路径	`/api`
本地服务地址	`http://127.0.0.1:5000/api`
前端开发地址	`http://127.0.0.1:5173`，Vite 将 `/api` 代理到 `http://127.0.0.1:5000`
生产/演示入口	`start.ps1` 启动后访问 `http://127.0.0.1:5000/ui/`
协议	HTTP（本机演示）；公网部署应使用 HTTPS
请求编码	UTF-8
请求/响应格式	`application/json`；登录/写接口也兼容表单体，但 Vue 客户端统一发送 JSON
时间格式	`YYYY-MM-DD HH:MM:SS`，服务端本地时间，不带时区后缀
字符集	`app.json.ensure_ascii = False`，中文直接输出，不转义为 `\uXXXX`

1.3 同源、跨域与客户端约定

- 当前 Flask 未单独配置 CORS，Vue 生产构建作为同源静态资源提供服务；开发环境由 Vite 代理 `/api`。
- 前端客户端默认请求头：
- `Accept: application/json`
- 有请求体时：`Content-Type: application/json`
- `credentials: 'include'`

- 因认证依赖会话 Cookie，跨域调用必须同时配置 CORS 凭据与 `SameSite`/Secure Cookie，本项目当前不提供跨域 SDK。
- 所有需要登录的接口在未认证时返回 **401 JSON**，不会重定向到 HTML 登录页。

1.4 版本与兼容性

项目	说明
当前 API 版本	V2.0（与 `app/meta.py` 中 `APP_VERSION = "2.0"` 一致）
兼容页面	旧 Jinja 页面仍保留；V2.0 Vue 前端以 `/api` 为主边界
旧接口对照	UML 图中 `/auth/login`、`/qa/` 为早期页面路由；REST 对应为 `/api/auth/login`、`/api/qa/ask`
健康检查	主接口 `/api/health`；兼容入口 `/health`（返回结构略有差异）
版本演进	新增字段应保持向后兼容；破坏性变更需提升版本并同步本文与前端客户端

1.5 接口分组与端点总览

本系统 V2.0 共有 **27 个主要方法/路径组合**（`GET /api` 与 `GET /api/` 视为同一端点别名；兼容 `/health` 不计入 27 个 REST 端点）。

分组	方法	路径	用途	权限
系统	GET	`/api`	API 根信息	公开
系统	GET	`/api/health`	健康检查	公开
系统	GET	`/api/meta`	元信息、演示账号、枚举标签	公开
认证	POST	`/api/auth/login`	登录	公开
认证	GET	`/api/auth/session`	查询当前会话	公开（匿名返回 null）
认证	GET	`/api/auth/me`	当前用户资料	已登录
认证	POST	`/api/auth/logout`	退出	已登录
工作台	GET	`/api/dashboard`	工作台统计与摘要	已登录
文档	GET	`/api/documents`	文档列表/检索/筛选/分页	已登录
文档	GET	`/api/documents/favorites`	我的收藏	已登录
文档	GET	`/api/documents/{id}`	文档详情	已登录且可查看
文档	POST	`/api/documents`	新建文档	已登录
文档	PUT	`/api/documents/{id}`	编辑文档	作者或管理员
文档	DELETE	`/api/documents/{id}`	删除文档	作者或管理员
收藏	POST	`/api/documents/{id}/favorite`	收藏/取消收藏切换	已登录且可查看
分类	GET	`/api/categories`	分类列表	已登录
分类	POST	`/api/categories`	新增分类	管理员
问答	GET	`/api/qa`	问答页初始化、建议与历史	已登录
问答	POST	`/api/qa/ask`	提交问题并生成回答	已登录
问答	GET	`/api/qa/history/{id}`	问答历史详情	本人或管理员
图谱	GET	`/api/graph`	权限裁剪后的图谱数据	已登录
图谱	GET	`/api/graph/manage`	图谱维护面板数据	管理员
图谱	POST	`/api/graph/nodes`	新增/复用节点	管理员
图谱	POST	`/api/graph/edges`	新增关系	管理员

分组	方法	路径	用途	权限
管理	GET	/api/admin/users	用户列表与文档贡献	管理员
管理	GET	/api/admin/audits	审计日志列表	管理员
关于	GET	/api/about	关于页数据与可见范围统计	已登录

2. 认证方式

2.1 会话认证

系统使用 **Flask-Login 服务端会话**：

457. 客户端调用 `POST /api/auth/login` 提交用户名和密码。
458. 校验通过后，Flask-Login 在响应中设置会话 Cookie。
459. 浏览器后续请求自动携带 Cookie；前端 `fetch` 使用 `credentials: 'include'`。
460. 受保护接口通过 `api_login_required` 检查 `current_user.is_authenticated`。
461. 管理员接口再通过 `api_admin_required` 检查 `current_user.is_admin`。
462. 退出调用 `POST /api/auth/logout`，清除当前会话并写审计。

认证不是 Bearer Token：V2.0 未提供 JWT/OAuth Access Token，也不从 `Authorization` 头读取凭证。课程演示依赖同源 Cookie 会话。

2.2 登录请求与安全约束

`POST /api/auth/login` 请求体：

字段	类型	必填	说明
username	string	是	用户名，首尾空白会被去除
password	string	是	密码，不能为空
remember	boolean	否	是否启用 Flask-Login 的 remember 机制；缺省为 false

安全约束：

- 密码使用 Werkzeug 带盐慢哈希存储，数据库中不保存明文（`User.password_hash`）。
- 同一来源 IP 在默认 300 秒窗口内失败达到 8 次后，后续登录请求返回 429 和 `retry_after`；成功登录清零计数。
- 失败登录写入 `audit_logs(action="login_failed")`，成功登录写入 `action="login"`。
- 会话 Cookie 配置为 `HttpOnly=True`、`SameSite=Lax`；生产配置可设置 `SESSION_COOKIE_SECURE`。

- 当前版本未引入独立 CSRF Token；同源部署与 `SameSite=Lax` 是现有边界，若改为跨域或高安全场景应补充 CSRF 防护。

2.3 认证相关响应

场景	HTTP	响应
登录成功	200	`{"user": UserPayload, "message": "登录成功"}`
用户名或密码错误	401	`{"error": "用户名或密码错误", "code": "INVALID_CREDENTIALS"}`
登录锁定	429	`{"error": "登录失败次数过多，请 N 秒后再试", "retry_after": N}`
未登录访问受保护接口	401	`{"error": "请先登录后再访问", "code": "AUTH_REQUIRED"}`
非管理员访问管理接口	403	`{"error": "需要管理员权限", "code": "FORBIDDEN"}`
会话查询（匿名）	200	`{"user": null}`

3. 统一响应与错误码

3.1 成功响应风格

API 不使用统一的 `{code, data}` 外层，而是按资源返回有语义的对象，例如：

- `{"items": [...], "pagination": {...}}`
- `{"document": {...}, "related": [...], "can_edit": true}`
- `{"answer": "...", "sources": [...], "fragments": [...]}`
- `{"message": "..."}`

这样做的目的是让前端直接读取资源字段；失败时统一使用 `error` 与 `code`（部分限流响应额外包含 `retry_after`）。

3.2 错误结构

常规业务错误：

```
{
  "error": "人类可读错误信息",
  "code": "ERROR_CODE"
}
```

字段校验错误可附加 `fields`：

```
{
  "error": "参数校验失败",
  "code": "VALIDATION_ERROR",
  "fields": {
    "title": "不能为空"
  }
}
```

3.3 错误码表

code	HTTP	触发条件	典型接口
AUTH_REQUIRED	401	未登录访问受保护接口	/api/dashboard、/api/documents、/api/about
INVALID_CREDENTIALS	401	用户名不存在或密码错误	POST /api/auth/login
FORBIDDEN	403	已登录但无角色/数据权限	管理接口、隐藏文档、他人文档编辑
NOT_FOUND	404	文档/问答记录/资源不存在	文档详情、问答历史
VALIDATION_ERROR	400	必填项缺失、分类不存在、分类重名等	登录之外的写接口
无 code + retry_after	429	登录失败限流锁定	POST /api/auth/login

3.4 HTTP 状态码约定

状态码	含义	本系统用法
200	OK	查询成功、登录成功、更新成功、收藏切换成功
201	Created	新建文档、新建分类、新增图谱节点/边
400	Bad Request	参数/业务校验失败
401	Unauthorized	未登录或凭据错误
403	Forbidden	角色不足或文档/问答越权
404	Not Found	资源不存在
429	Too Many Requests	登录窗口内失败过多
500	Internal Server Error	未预期异常；当前全局错误页主要服务于旧页面，业务 API 正常路径不返回裸堆栈

说明：未命中路由时 Flask 的全局 404 处理器可能返回旧的 HTML 错误页，这不属于本文定义的业务 API 错误契约；调用已定义接口时，业务错误按上表返回 JSON。

3.5 错误示例

未登录

```
GET /api/documents
```

```
{
  "error": "请先登录后再访问",
  "code": "AUTH_REQUIRED"
}
```

无权查看机密文档

```
GET /api/documents/42
```

```
{
  "error": "无权查看该文档",
```

```
  "code": "FORBIDDEN"
}
```

4. 分页与筛选约定

4.1 文档分页

GET /api/documents：

参数	类型	默认	约束	说明
page	integer	1	最小 1；超过总页数时钳制到最后页	页码
per_page	integer	9	1～50	每页数量
q	string	空	—	标题/摘要/正文/标签关键词
category_id	integer	空	必须是有效分类才参与过滤	分类
department	string	空	与文档部门精确匹配	部门
visibility	string	空	public/internal/secret	密级
sort	string	updated	updated/title/department	排序；存在 q 时按相关度排序，sort 被忽略

pagination 对象：

```
{
  "page": 1,
  "pages": 3,
  "total": 22,
  "per_page": 9
}
```

约定：

- 即使总数为 0，pages 也返回 1（后端使用 max(..., 1)）；
- page 超出范围时自动回退到最后一页；
- 列表只返回当前用户可见的 **已发布** 文档；
- 有关键词时，rank_documents() 按标题、标签、摘要、正文和分词重叠加权排序。

4.2 审计分页

GET /api/admin/audits 固定每页 25 条，不提供 per_page 参数：

参数	类型	说明
action	string	仅接受合法动作代码；非法值忽略
user	string	按用户名模糊匹配
detail	string	按明细模糊匹配
page	integer	最小 1，超出时钳制到最后页

4.3 非分页列表

以下接口返回完整或固定上限列表，不使用 `pagination`：

- `GET /api/documents/favorites`：当前用户全部可见收藏；
- `GET /api/categories`：全部分类；
- `GET /api/admin/users`：全部用户；
- `GET /api/qa`：最近 20 条本人问答；
- `GET /api/graph/manage`：最近 60 个节点和最近 60 条边；
- `GET /api/graph`：权限裁剪后的完整图谱。

5. 公共数据结构

5.1 UserPayload

字段	类型	说明
id	integer	用户编号
username	string	登录名
display_name	string	展示姓名
role	string	admin 或 employee
role_label	string	中文角色名
department	string	所属部门
is_admin	boolean	是否管理员
created_at	string	创建时间

注意：响应不包含 `password_hash`。

5.2 DocumentPayload

字段	类型	说明
id	integer	文档编号
title	string	标题
summary	string	摘要；为空时由正文自动截取
department	string	所属部门
visibility	string	public/internal/secret
visibility_label	string	中文密级
status	string	draft/published/archived
status_label	string	中文状态
version	string	版本号
tags	string[]	标签数组
category_id	integer/null	分类编号
category	string	分类名；无分类为“未分类”
author_id	integer/null	作者编号
author	string	作者展示名；未知为“未知作者”
created_at	string	创建时间
updated_at	string	更新时间
char_count	integer	正文字符数
chunk_count	integer	知识片段数
is_favorite	boolean	当前用户是否已收藏

字段	类型	说明
content	string	**仅详情/创建/更新响应包含**，正文

5.3 QAItemPayload

字段	类型	说明
id	integer	问答历史编号
question	string	问题
answer	string	回答
mode	string	local 或 llm
mode_label	string	中文模式名
created_at	string	提问时间
sources	array	仅历史详情接口包含，解析后的来源数组；解析失败为空数组

5.4 AuditPayload

字段	类型	说明
id	integer	审计编号
user_id	integer/null	用户编号
username	string	用户名；未知为“匿名/未知”
action	string	动作代码
action_label	string	中文动作名
detail	string	统一明细
created_at	string	操作时间

5.5 GraphPayload

普通图谱 `GET /api/graph`

字段	类型	说明
nodes	array	节点数组
nodes[].id	integer	节点编号
nodes[].name	string	节点名
nodes[].category	string	节点类型
nodes[].symbolSize	number	ECharts 节点大小
nodes[].itemStyle	object	{"color": "#..."}
nodes[].document_id	integer/null	关联文档 id；非文档节点为 null
links	array	边数组
links[].source	integer	起点节点 id
links[].target	integer	终点节点 id
links[].relation	string	关系名
categories	array	[{"name":"document"}, ...]

管理图谱 `GET /api/graph/manage`

- nodes：id/name/node_type/description；
- edges：id/source/target/relation，其中 source、target 为节点名称；
- node_types：["document","department","project","keyword","concept"]。

5.6 PaginationPayload

字段	类型	说明
page	integer	当前页
pages	integer	总页数，至少 1
total	integer	总记录数
per_page	integer	每页条数

6. 系统、认证与工作台接口

6.1 系统接口

6.1.1 GET /api（别名 /api/）

项目	说明
用途	返回 API 根信息与健康检查入口
权限	公开
请求参数	无
成功响应	name、version、description、health
错误	正常无业务错误

响应示例

```
{
  "name": "智慧企业知识财富库",
  "version": "2.0",
  "description": "企业知识管理、检索问答与关系图 REST API",
  "health": "/api/health"
}
```

6.1.2 GET /api/health

项目	说明
用途	检查 Flask 应用与 SQLite 连通性
权限	公开
请求参数	无
成功响应	status（ok/degraded）、database（boolean）、version
状态码	始终按当前实现返回 200；数据库失败时 status="degraded"、database=false
错误	不抛出业务错误

响应示例

```
{
  "status": "ok",
  "database": true,
  "version": "2.0"
}
```

6.1.3 GET /api/meta

项目	说明
用途	前端启动时读取系统名称、版本、技术栈、演示账号与枚举标签
权限	公开
请求参数	无
成功响应字段	name、name_en、version、tagline、tech_stack、features、scenarios、demo_accounts、departments、visibility_labels、status_labels、role_labels
错误	正常无业务错误

主要字段结构

字段	类型	说明
demo_accounts	array	{username,password,label,hint}，用于登录页演示账号快捷填充
departments	string[]	九个部门
visibility_labels	object	public/internal/secret 到中文
status_labels	object	draft/published/archived 到中文
role_labels	object	admin/employee 到中文

6.1.4 兼容健康检查 GET /health

项目	说明
用途	旧页面/启动脚本兼容的健康检查
权限	公开
成功响应	status、app、version、database
与 /api/health 差异	多返回 app 字段；两者都执行 SELECT 1

```
{
  "status": "ok",
  "app": "智慧企业知识财富库",
  "version": "2.0",
  "database": true
}
```

6.2 认证接口

6.2.1 POST /api/auth/login

项目	说明
用途	登录并建立服务端会话
权限	公开
请求体	username（必填）、password（必填）、remember（可选 boolean）
成功响应	200：user（UserPayload）、message
失败响应	401 INVALID_CREDENTIALS；429 带 retry_after
审计	成功写 login，失败写 login_failed
限流	默认同 IP 300 秒内 8 次失败后锁定，成功清零

请求示例

```
{
  "username": "admin",
  "password": "admin123",
  "remember": false
}
```

成功响应示例

```
{
  "user": {
    "id": 1,
    "username": "admin",
    "display_name": "系统管理员",
    "role": "admin",
    "role_label": "管理员",
    "department": "综合部",
    "is_admin": true,
    "created_at": "2026-09-15 10:00:00"
  },
  "message": "登录成功"
}
```

失败响应示例

```
{
  "error": "用户名或密码错误",
  "code": "INVALID_CREDENTIALS"
}
```

锁定响应示例

```
{
  "error": "登录失败次数过多，请 183 秒后再试",
  "retry_after": 183
}
```

6.2.2 GET /api/auth/session

项目	说明
用途	页面启动时查询当前登录用户；匿名不是错误
权限	公开
请求参数	无
成功响应	`{"user": UserPayload}` 或 `{"user": null}`
错误	正常无业务错误

6.2.3 GET /api/auth/me

项目	说明
用途	获取当前登录用户资料
权限	已登录
请求参数	无
成功响应	`{"user": UserPayload}`
错误	401 `AUTH_REQUIRED`

6.2.4 POST /api/auth/logout

项目	说明
用途	写退出审计、清除当前会话
权限	已登录
请求体	无
成功响应	{"message": "已退出登录"}
错误	401 AUTH_REQUIRED
副作用	新增 logout 审计

6.3 工作台接口

6.3.1 GET /api/dashboard

项目	说明
用途	返回当前用户工作台统计、图表、最近文档、最近问答、快捷问题和管理员审计摘要
权限	已登录
请求参数	无
数据范围	文档/收藏/问答/图表按当前用户权限；图谱节点/边为结构总量；审计摘要仅管理员
错误	401 AUTH_REQUIRED

响应结构

字段	类型	说明
stats.visible_documents	integer	当前用户可见且已发布的文档数
stats.favorites	integer	当前用户收藏数（数据库收藏总数）
stats.qa_total	integer	当前用户问答总数
stats.qa_week	integer	当前用户近 7 天问答数
stats.nodes	integer	图谱节点总数
stats.edges	integer	图谱边总数
charts.departments	array	[{"name":"人事部","value":3}]，按可见文档统计
charts.categories	array	[{"name":"人事制度","value":3}]，最多 8 类
recent_documents	array	最近 6 篇可见文档（DocumentPayload）
recent_qa	array	当前用户最近 6 条问答（不含 sources）
recent_logs	array	管理员最近 8 条审计；普通员工为空数组
quick_questions	string[]	4 个快捷问题

响应示例

```
{
  "stats": {
    "visible_documents": 35,
    "favorites": 4,
    "qa_total": 46,
    "qa_week": 0,
    "nodes": 154,
    "edges": 222
  },
  "charts": {
```

```
    "departments": [
      {"name": "人事部", "value": 4},
      {"name": "财务部", "value": 3}
    ],
    "categories": [
      {"name": "人事制度", "value": 4}
    ]
  },
  "recent_documents": [],
  "recent_qa": [],
  "recent_logs": [],
  "quick_questions": [
    "员工年假有几天？",
    "差旅住宿标准是多少？",
    "加班怎么补偿？",
    "采购超过两万元要找谁审批？"
  ]
}
```

7. 文档接口

7.1 权限规则总表

操作	普通员工	管理员	数据/状态限制
列表/检索	可	可	只返回已发布且可见文档
查看详情	可	可	密级权限；草稿/归档仅作者或管理员
新建	可	可	标题和正文必填
编辑	仅本人文档	全部文档	标题和正文必填
删除	仅本人文档	全部文档	删除后不可恢复，并清理图谱
收藏	可	可	只能收藏通过 `can_view_document()` 密级判定的文档；接口不额外校验发布状态

密级规则：

- `public`：所有已登录用户可查看；
- `internal`：所有已登录用户可查看；
- `secret`：仅管理员、同部门用户或文档作者可查看；
- 列表与问答只使用 `published` 文档；
- 详情允许作者/管理员查看草稿或归档，但必须先通过密级判断。

7.2 GET /api/documents

项目	说明
用途	文档列表、关键词检索、筛选、排序与分页
权限	已登录
查询参数	`q`、`category_id`、`department`、`visibility`、`sort`、`page`、`per_page`
成功响应	`items`、`categories`、`pagination`、`filters`、

项目	说明
	departments
失败	401 AUTH_REQUIRED

查询参数

参数	类型	默认	说明
q	string	空	关键词；使用 jieba 与加权规则排序
category_id	integer	空	分类过滤
department	string	空	部门精确过滤
visibility	string	空	public/internal/secret
sort	string	updated	updated/title/department；有 q 时忽略
page	integer	1	页码，最小 1
per_page	integer	9	1～50

响应字段

字段	类型	说明
items	DocumentPayload[]	当前页文档，不含正文
categories	array	全部分类：id/name/description
pagination	PaginationPayload	分页信息
filters	object	回显 q/category_id/department/visibility/sort
departments	string[]	九个部门常量

响应示例


```
{
  "items": [
    {
      "id": 12,
      "title": "员工年休假管理办法",
      "summary": "员工依法享有年休假……",
      "department": "人事部",
      "visibility": "internal",
      "visibility_label": "内部",
      "status": "published",
      "status_label": "已发布",
      "version": "1.0",
      "tags": ["年假", "人事", "制度"],
      "category_id": 2,
      "category": "人事制度",
      "author_id": 2,
      "author": "人事专员",
      "created_at": "2026-09-15 10:00:00",
      "updated_at": "2026-09-20 15:30:00",
      "char_count": 1280,
      "chunk_count": 4,
      "is_favorite": false
    }
  ],
  "categories": [
    {"id": 2, "name": "人事制度", "description": "员工关系与假期"}
  ],
  "pagination": {"page": 1, "pages": 1, "total": 1, "per_page": 9},
  "filters": {"q": "年假", "category_id": null, "department": "", "visibility": "", "sort":
"updated"},
  "departments": ["综合部", "人事部", "财务部", "信息部", "产品部", "运营部", "市场部", "法务部", "技
术部"]
}
```

7.3 GET /api/documents/favorites

项目	说明
用途	返回当前用户收藏的、且密级判定仍可查看的文档
权限	已登录
请求参数	无
成功响应	`items`：DocumentPayload[]，`is_favorite=true`；按收藏时间倒序
分页	不分页
失败	401 `AUTH_REQUIRED`

说明：如果文档后来变为不可见或作者/管理员删除，收藏记录可能由 ORM 级联清理；接口还会用 `can_view_document()` 二次过滤，避免返回当前已无权查看的文档。收藏列表当前**不额外过滤** `draft/archived` 状态：若用户已收藏某草稿/归档文档，它仍可能出现在收藏列表中。

7.4 GET /api/documents/{id}

项目	说明
用途	获取文档详情、正文、相关文档和编辑权限标记
权限	已登录；密级判定通过，且文档已发布或当前用户为作者/管理员
路径参数	`id`：integer 文档编号
成功响应	`document`（DocumentPayload + `content`）、`related`、`can_edit`
失败	401；403 `FORBIDDEN`；404 `NOT_FOUND`
副作用	首次/2 分钟内未记录时写入 `view_document` 审计（相同用户、同一文档 2 分钟内去重）

响应字段

字段	类型	说明
`document`	object	文档详情，包含 `content` 与 `is_favorite`
`related`	DocumentPayload[]	最多 4 篇相关文档，按同分类/同部门/标签重叠评分
`can_edit`	boolean	当前用户是否作者或管理员

错误顺序：先判断文档是否存在（404），再判断密级可见性（403），最后判断草稿/归档状态（403）。

7.5 POST /api/documents

项目	说明
用途	新建文档，并自动建立知识片段与图谱关系
权限	已登录
请求体	JSON（也兼容表单）
成功响应	201：`document`（含 content）、`message="文档已创建"`
失败	400 `VALIDATION_ERROR`；401 `AUTH_REQUIRED`

请求字段

字段	类型	必填	默认/约束	说明
title	string	是	非空、最长 200	标题
content	string	是	非空	正文
summary	string	否	空则自动截取，最多 500	摘要
category_id	integer/null	否	必须存在	分类
department	string	否	必须是九部门之一，否则使用当前账号部门	所属部门
visibility	string	否	默认 internal；非法值回退	密级
status	string	否	默认 published；非法值回退	状态
version	string	否	默认 1.0	版本
tags	string[] 或 string	否	数组或逗号分隔字符串	标签

请求示例

```
{
  "title": "API 自动化测试文档",
  "content": "这是通过 REST API 创建的测试正文。\n\n第二段用于验证知识切分。",
  "summary": "API 测试摘要",
  "category_id": 1,
  "department": "综合部",
  "visibility": "internal",
  "status": "published",
  "version": "1.0",
  "tags": ["API", "测试"]
}
```

后置处理顺序：

463. 写入 documents；
464. rebuild_chunks_for_document() 重建 knowledge_chunks；
465. sync_document_graph() 创建/更新文档节点、部门节点、分类节点、关键词节点与边；
466. 写入 create_document 审计；
467. 返回带正文的文档对象。

7.6 PUT /api/documents/{id}

项目	说明
用途	编辑文档；保存后重建片段与图谱
权限	作者或管理员
路径参数	id：文档编号
请求体	与新建相同；title、content 必填
成功响应	200：document（含 content）、message="文档已更新"
失败	401；403 FORBIDDEN；404 NOT_FOUND；400 VALIDATION_ERROR
审计	edit_document

说明：

- 本接口为**全量更新语义**：title、content 必须重新提交，未提交的密级、状态等字段按服务端默认规则处理；Vue 编辑器会提交完整表单。
- 非作者且非管理员返回 403“只能编辑自己创建的文档”；
- 字段未提供时，部门使用原值/当前账号部门，密级/状态非法值回退；
- 标签支持数组或逗号字符串；数组会被拼接为逗号分隔存储；
- 更新后 updated_at 由 ORM 自动刷新；
- 片段重建先删除旧片段，再生成新片段。

7.7 DELETE /api/documents/{id}

项目	说明
用途	删除文档及关联图谱节点/边
权限	作者或管理员
路径参数	id：文档编号
请求体	无
成功响应	{"message": "文档已删除"}
失败	401；403 FORBIDDEN；404 NOT_FOUND
审计	delete_document

说明：删除前调用 remove_document_graph(doc) 清理文档节点及连接边；SQLAlchemy 关系级联删除知识片段和收藏。操作不可恢复。

7.8 POST /api/documents/{id}/favorite

项目	说明
用途	切换收藏状态
权限	已登录且通过密级判定（can_view_document）
路径参数	id：文档编号
请求体	无
成功响应	{"is_favorite": true/false, "message": "已收藏"/"已取消收藏"}
失败	401；403 FORBIDDEN；404 NOT_FOUND
约束	(user_id, document_id) 唯一，防止重复收藏

响应示例

```
{
  "is_favorite": true,
  "message": "已收藏"
}
```

7.9 收藏接口汇总

接口	方法	权限	请求	响应
/api/documents/favorites	GET	已登录	无	{"items": DocumentPayload[]}，按收藏时间倒序，仅返

接口	方法	权限	请求	响应
				回 can_view_document() 为真的文档；不额外过滤状态
/api/documents/{id}/favorite	POST	已登录且通过密级判定	无	{"is_favorite": boolean, "message": string}，切换收藏状态；不额外校验状态

收藏以当前用户为隔离边界；管理员也不能代替其他用户收藏。表 favorites 对 (user_id, document_id) 有唯一约束。

8. 分类接口

8.1 GET /api/categories

项目	说明
用途	获取分类列表，供文档筛选和编辑表单使用
权限	已登录
请求参数	无
成功响应	items：id、name、description、document_count
失败	401 AUTH_REQUIRED

统计口径：document_count 按 documents.category_id 全库计数，包含草稿/归档和当前用户不可见文档；它用于分类管理语境，不等同于工作台的“可见文档”统计。前端若不需要该口径，应只展示分类名称。

响应示例

```
{
  "items": [
    {
      "id": 1,
      "name": "人事制度",
      "description": "考勤、假期、入离职",
      "document_count": 5
    }
  ]
}
```

8.2 POST /api/categories

项目	说明
用途	新增文档分类
权限	管理员
请求体	name（必填，唯一）、description（可选）
成功响应	201：id、name、message="分类已添加"
失败	400 VALIDATION_ERROR（名称为空/重名）；401；403 FORBIDDEN

请求示例

```
{
  "name": "客户服务",
  "description": "客服话术与服务标准"
}
```

响应示例

```
{
  "id": 7,
  "name": "客户服务",
  "message": "分类已添加"
}
```

当前 API 未提供分类删除/改名端点；文档的 `category_id` 可为空表示“未分类”。

9. 智能问答接口

9.1 问答数据流

468. 前端 `POST /api/qa/ask` 提交问题；
469. 服务端通过 `searchable_documents(current_user)` 取可见且已发布的文档；
470. 只加载这些文档的 `knowledge_chunks`；
471. jieba 分词 + 关键词 + 标题/短语评分，取 Top-K；同一文档最多 2 个片段；
472. 无 API Key 时 `build_local_answer()` 生成本地摘要；有 Key 时 `call_llm_answer()` 调用 OpenAI 兼容 Chat Completions；
473. 保存 `qa_history`，写入 `audit_logs(action="ask_qa")`；
474. 返回 `answer`、`mode`、`sources`、`fragments`、`history_id`。

9.2 GET /api/qa

项目	说明
用途	问答页初始化：建议问题、快捷问题、LLM 模式标记、最近历史
权限	已登录
请求参数	无
成功响应	`suggestions`、`quick_questions`、`llm_enabled`、`history`
失败	401 `AUTH_REQUIRED`
历史数量	当前用户最近 20 条

响应字段

字段	类型	说明
`suggestions`	`string[]`	12 个建议问题
`quick_questions`	`string[]`	4 个快捷问题

字段	类型	说明
llm_enabled	boolean	是否配置 OPENAI_API_KEY
history	QAItemPayload[]	不含 sources，用于侧栏历史列表

9.3 POST /api/qa/ask

项目	说明
用途	提交问题并生成带来源的回答
权限	已登录；检索范围由当前用户权限决定
请求体	question（必填，非空）
成功响应	200：answer、mode、mode_label、history_id、sources、fragments
失败	400 VALIDATION_ERROR“问题不能为空”；401 AUTH_REQUIRED
副作用	新增 qa_history；新增 ask_qa 审计

请求示例

```
{
  "question": "员工年假有几天？"
}
```

响应结构

字段	类型	说明
answer	string	回答正文
mode	string	local 或 llm
mode_label	string	“本地检索”/“大模型生成”
history_id	integer	新增问答历史编号
sources	array	按文档合并的来源
fragments	array	原始命中片段

`sources[]` 结构

字段	类型	说明
document_id	integer	来源文档编号
title	string	文档标题
department	string	部门
score	number	本文档最高相关度
fragments	array	本文件命中的片段对象

`fragments[]` 结构

字段	类型	说明
score	number	片段相关度
chunk_id	integer	片段编号
document_id	integer	文档编号
title	string	文档标题
content	string	片段正文摘要/片段原文
department	string	部门
fragment_no	integer	在结果中的第几个片段
fragment_total	integer	该文档命中片段总数

响应示例


```
{
  "answer": "根据企业知识库检索，针对「员工年假有几天？」整理如下：……",
  "mode": "local",
  "mode_label": "本地检索",
  "history_id": 15,
  "sources": [
    {
      "document_id": 12,
      "title": "员工年休假管理办法",
      "department": "人事部",
      "score": 18.6,
      "fragments": [
        {
          "score": 18.6,
          "chunk_id": 44,
          "document_id": 12,
          "title": "员工年休假管理办法",
          "content": "工作满一年不满十年的员工，年休假为 5 天……",
          "department": "人事部",
          "fragment_no": 1,
          "fragment_total": 1
        }
      ]
    }
  ],
  "fragments": [
    {
      "score": 18.6,
      "chunk_id": 44,
      "document_id": 12,
      "title": "员工年休假管理办法",
      "content": "工作满一年不满十年的员工，年休假为 5 天……",
      "department": "人事部",
      "fragment_no": 1,
      "fragment_total": 1
    }
  ]
}
```


示例为展示结构，实际 `fragments` 与 `sources[].fragments` 均包含命中片段。若没有命中，`sources` 与 `fragments` 为空数组，`answer` 会明确说明未检索到相关内容。

9.4 GET /api/qa/history/{id}

项目	说明
用途	查看单条问答历史详情及来源
权限	记录本人或管理员
路径参数	`id`：问答历史编号
成功响应	`item`：QAItemPayload，包含解析后的 `sources`
失败	401；403 `FORBIDDEN`“无权查看该问答记录”；404 `NOT_FOUND`
来源结构	`qa_history.sources` 保存的是 `[{document_id,title,score}]`：历史详情只返回这些字段，不返回当时片段全文

响应示例


```
{
  "item": {
    "id": 15,
```

```
    "question": "员工年假有几天？",
    "answer": "根据企业知识库检索……",
    "mode": "local",
    "mode_label": "本地检索",
    "created_at": "2026-10-31 10:20:00",
    "sources": [
      {"document_id": 12, "title": "员工年休假管理办法", "score": 18.6}
    ]
  }
}
```

实时问答响应（POST /api/qa/ask）和历史详情（GET /api/qa/history/{id}）的 sources 结构不同：前者包含 department 与 fragments，后者是持久化的精简来源。

10. 知识图谱接口

10.1 图谱权限与裁剪规则

- 普通图谱从当前用户可见文档节点出发；
- 只把与这些文档直接相连的节点/边纳入结果；
- 不展示仅由当前用户不可见文档连接的概念/关键词节点；
- 管理员维护接口不受普通图谱裁剪限制，可查看最近 60 个节点/边；
- 文档新增/更新时由 sync_document_graph() 自动同步；删除时由 remove_document_graph() 清理。

10.2 GET /api/graph

项目	说明
用途	普通用户浏览权限裁剪后的 ECharts 力导向图数据
权限	已登录
请求参数	无
成功响应	nodes、links、categories
失败	401 AUTH_REQUIRED
节点类型	document、department、project、keyword、concept

节点/边结构：见 5.5 GraphPayload。links.source 与 links.target 是节点 id，不是名称。

10.3 GET /api/graph/manage

项目	说明
用途	管理员打开“维护图谱”弹窗，读取最近节点、边和可选节点类型
权限	管理员
请求参数	无
成功响应	nodes（最近 60）、edges（最近 60）、node_types
失败	401；403 FORBIDDEN“需要管理员权限”

响应示例

```
{
  "nodes": [
    {"id": 1, "name": "文档:员工年休假管理办法", "node_type": "document", "description": "员工休假制度"}
  ],
  "edges": [
    {"id": 1, "source": "文档:员工年休假管理办法", "target": "人事部", "relation": "属于"}
  ],
  "node_types": ["document", "department", "project", "keyword", "concept"]
}
```

10.4 POST /api/graph/nodes

项目	说明
用途	新增或复用概念/项目等节点
权限	管理员
请求体	name（必填）、node_type（可选，默认 concept）、description（可选）
成功响应	201：id、name、message="节点已添加"
失败	400 VALIDATION_ERROR“节点名称不能为空”；401；403
去重	按节点名称复用，已存在时返回已有节点 id，不新增重复名称

请求示例

```
{
  "name": "数字化转型",
  "node_type": "concept",
  "description": "企业数字化相关概念"
}
```

响应示例

```
{
  "id": 22,
  "name": "数字化转型",
  "message": "节点已添加"
}
```

10.5 POST /api/graph/edges

项目	说明
用途	新增节点关系；若起点/终点不存在则按 concept 类型自动创建
权限	管理员
请求体	source_name（必填）、target_name（必填）、relation（可选，默认“关联”）
成功响应	201：{"message": "关系已添加"}
失败	400 VALIDATION_ERROR“起点和终点名称不能为空”；401；403
去重	同起点、终点、关系名的边不重复插入

请求示例

```
{
  "source_name": "数字化转型",
  "target_name": "信息部",
  "relation": "由部门推进"
}
```

响应示例

```
{
  "message": "关系已添加"
}
```

当前 API 未提供图谱节点/边的删除与编辑端点；管理员可新增，自动同步负责文档相关节点和边。

11. 管理接口

11.1 GET /api/admin/users

项目	说明
用途	管理员查看全部账号、角色、部门、创建时间与文档贡献
权限	管理员
请求参数	无
成功响应	`items`、`summary`
失败	401 `AUTH_REQUIRED`；403 `FORBIDDEN`“需要管理员权限”

`items[]` 字段

字段	类型	说明
`id`	integer	用户编号
`username`	string	登录名
`display_name`	string	展示姓名
`role`	string	`admin`/`employee`
`role_label`	string	中文角色
`department`	string	部门
`is_admin`	boolean	是否管理员
`created_at`	string	创建时间
`document_count`	integer	该用户作为作者的文档总数（全库口径）

`summary` 字段

字段	类型	说明
`total`	integer	全部账号数
`admins`	integer	管理员数
`employees`	integer	普通员工数

响应示例

```
{
  "items": [
    {
```

```
      "id": 1,
      "username": "admin",
      "display_name": "系统管理员",
      "role": "admin",
      "role_label": "管理员",
      "department": "综合部",
      "is_admin": true,
      "created_at": "2026-09-15 10:00:00",
      "document_count": 7
    }
  ],
  "summary": {"total": 22, "admins": 1, "employees": 21}
}
```

11.2 GET /api/admin/audits

项目	说明
用途	管理员按动作/用户/明细筛选审计日志，按时间倒序分页
权限	管理员
查询参数	action、user、detail、page
成功响应	items、pagination、action_stats、actions
失败	401 AUTH_REQUIRED；403 FORBIDDEN“需要管理员权限”
每页	固定 25 条

查询参数

参数	类型	说明
action	string	仅合法动作代码参与过滤；非法值忽略
user	string	用户名模糊匹配，联表 users
detail	string	明细模糊匹配
page	integer	最小 1；超出时钳制到最后页

响应字段

字段	类型	说明
items	AuditPayload[]	当前页日志
pagination	PaginationPayload	per_page 固定 25
action_stats	object	全库按动作代码计数，不受当前筛选影响
actions	array	[{value,label}]，合法动作筛选项

动作代码与中文

action	中文
login	登录
login_failed	登录失败
logout	退出
view_document	查看文档
create_document	创建文档
edit_document	编辑文档
delete_document	删除文档
ask_qa	智能问答

响应示例

```
{
  "items": [
    {
      "id": 88,
      "user_id": 3,
      "username": "hr",
      "action": "view_document",
      "action_label": "查看文档",
      "detail": "查看文档 #12 《员工年休假管理办法》",
      "created_at": "2026-10-31 10:30:00"
    }
  ],
  "pagination": {"page": 1, "pages": 4, "total": 88, "per_page": 25},
  "action_stats": {"login": 20, "login_failed": 2, "view_document": 45, "ask_qa": 21},
  "actions": [
    {"value": "login", "label": "登录"},
    {"value": "login_failed", "label": "登录失败"}
  ]
}
```


`action_stats` 是管理页顶部的全量统计，不会随当前筛选条件改变；分页列表本身才受筛选影响。

12. 关于与健康接口表

12.1 GET /api/about

项目	说明
用途	关于页展示应用元信息、技术栈、核心能力、典型场景和统计
权限	已登录
请求参数	无
成功响应	`app`、`stats`、`scope`
失败	401 `AUTH_REQUIRED`
统计口径	文档/片段为当前用户可见范围；节点/边为结构全量；问答为本人

`app` 字段

字段	类型	说明
`name`	string	系统中文名
`name_en`	string	英文名
`version`	string	V2.0
`tagline`	string	一句话定位
`tech_stack`	string	技术栈文本
`features`	string[]	核心能力列表
`scenarios`	string[]	典型场景列表

`stats` 字段

字段	类型	说明
`documents`	integer	当前用户可见已发布文档数
`chunks`	integer	可见文档对应的片段数
`nodes`	integer	全量图谱节点数
`edges`	integer	全量图谱边数
`qa`	integer	当前用户问答总数

响应示例

```
{
  "app": {
    "name": "智慧企业知识财富库",
    "name_en": "Enterprise Knowledge Wealth Base",
    "version": "2.0",
    "tagline": "企业知识管理 · 检索问答 · 关系图",
    "tech_stack": "Vue 3 · Vite · Flask REST API · SQLAlchemy · SQLite · ECharts · jieba",
    "features": ["按部门与密级管控的制度/手册归档"],
    "scenarios": ["人事：查年假天数、加班补偿、入职首周事项"]
  },
  "stats": {
    "documents": 35,
    "chunks": 38,
    "nodes": 154,
    "edges": 222,
    "qa": 46
  },
  "scope": "本人可见范围"
}
```

12.2 关于/健康接口速查表

接口	方法	权限	主要响应	说明
/api/about	GET	已登录	app/stats/scope	关于页数据，统计口径随权限
/api/health	GET	公开	status/database/version	REST 健康检查
/health	GET	公开	status/app/version/database	兼容旧页面/启动脚本

12.3 健康检查语义

status	database	含义
ok	true	应用可响应，数据库 SELECT 1 成功
degraded	false	应用可响应，但数据库检查失败

> 当前实现无论数据库是否成功都返回 HTTP 200，以响应体区分 ok/degraded。监控系统应读取 database 字段，而不是只看 HTTP 状态码。

13. 权限矩阵

13.1 角色级权限

能力	匿名	普通员工	管理员
查看元信息/健康	可	可	可
登录/查询会话	可	可	可
退出	不可	可	可
工作台	不可	可	可
文档列表/检索	不可	可	可

能力	匿名	普通员工	管理员
文档详情	不可	可见文档	全部文档
新建文档	不可	可	可
编辑/删除文档	不可	仅本人	全部
收藏/取消收藏	不可	可（通过密级判定）	可（通过密级判定）
分类列表	不可	可	可
新增分类	不可	不可	可
问答	不可	可	可
问答历史	不可	仅本人	全部
浏览图谱	不可	可（裁剪）	可（裁剪）
维护图谱	不可	不可	可
用户列表	不可	不可	可
审计日志	不可	不可	可
关于页	不可	可	可

13.2 文档数据级权限

文档密级/状态	普通员工	管理员	说明
`public + published`	可查看	可查看	所有登录用户
`internal + published`	可查看	可查看	所有登录用户
`secret + published`	同部门或作者可查看	可查看	部门隔离
`draft`	仅作者	可查看	列表不返回，详情需作者
`archived`	仅作者	可查看	不进入普通检索/问答

13.3 关键权限实现位置

权限点	实现
登录校验	`app/api.py::api_login_required`
管理员校验	`app/api.py::api_admin_required`
密级/部门判断	`app/services/rag.py::can_view_document`
可见已发布文档集合	`app/services/rag.py::searchable_documents`
文档编辑/删除所有权	`app/api.py::update_document、delete_document`
问答历史归属	`app/api.py::qa_history_detail`
图谱裁剪	`app/api.py::_visible_graph_payload`

> 本文 JSON 示例中的 id、计数、时间、用户名等为便于阅读的示意值，实际值以运行中的数据库和当前账号权限为准；字段名、类型、嵌套结构以本文与 `app/api.py` 为准。

14. 调用流程与示例

14.1 浏览器会话流程

```
1. GET  /api/meta                获取版本/演示账号/枚举
2. GET  /api/auth/session        匿名返回 {"user": null}
3. POST /api/auth/login          建立会话，返回 user
4. GET  /api/dashboard           加载工作台
5. GET  /api/documents?q=年假     检索文档
6. GET  /api/documents/12        读取详情（写查看审计）
7. POST /api/qa/ask              提问并保存历史
8. GET  /api/graph               读取权限裁剪图谱
```

```
9. POST /api/auth/logout          退出并写审计
```

14.2 cURL 示例

登录并保存 Cookie

```
curl -c cookies.txt -H "Content-Type: application/json" \
  -d '{"username":"admin","password":"admin123"}' \
  http://127.0.0.1:5000/api/auth/login
```

携带 Cookie 查询文档

```
curl -b cookies.txt "http://127.0.0.1:5000/api/documents?q=年假&page=1&per_page=9"
```

提问

```
curl -b cookies.txt -H "Content-Type: application/json" \
  -d '{"question":"员工年假有几天？"}' \
  http://127.0.0.1:5000/api/qa/ask
```

14.3 PowerShell 示例

```
$session = New-Object Microsoft.PowerShell.Commands.WebRequestSession
Invoke-RestMethod -WebSession $session -Method Post `
  -Uri 'http://127.0.0.1:5000/api/auth/login' `
  -ContentType 'application/json' `
  -Body '{"username":"admin","password":"admin123"}'

Invoke-RestMethod -WebSession $session `
  -Uri 'http://127.0.0.1:5000/api/documents?q=年假'
```

15. 接口—需求—测试追踪

接口组	主要需求	主要测试文件	重点验证
/api/auth/*	UR-AUTH-01/02/05/06/07；SR-AUTH-001～009	tests/test_api.py、tests/test_login_security.py	登录/退出、限流、失败审计、密码哈希
/api/dashboard	SR-OPS-001	tests/test_api.py、tests/test_security.py	统计范围与结构
/api/documents*	UR-DOC-01～05；SR-DOC-001～007	tests/test_api.py、tests/test_security.py	CRUD、检索、分页、密级、片段重建
/api/documents/favorites、收藏切换	UR-FAV-01；SR-FAV-001～003	tests/test_api.py	收藏切换与唯一性
/api/categories	UR-DOC-06；SR-DOC-008	tests/test_api.py、tests/test_security.py	管理员新增、重名、列表
/api/qa*	UR-QA-01～04；SR-QA-001～009	tests/test_api.py、tests/test_rag.py	来源、权限、Top-K、模式、历史
/api/graph*	UR-KG-01/02；SR-KG-001～005	tests/test_api.py、tests/test_security.py	裁剪、维护权限、节点/边
/api/admin/*	UR-AUD-01；SR-AUD-001/002	tests/test_api.py、tests/test_login_security.py	管理员权限、分页、审计

接口组	主要需求	主要测试文件	重点验证
/api/about、/api/health	SR-OPS-002/003	tests/test_system.py、tests/test_api.py	统计口径、健康响应

16. 实现边界与维护约定

16.1 当前边界

475. **认证**：仅会话 Cookie，不提供 JWT/OAuth、API Key 或开放平台鉴权。

476. **跨域**：未配置 CORS；Vue 开发环境依赖 Vite 代理，生产环境依赖同源部署。

477. **CSRF**：未实现独立 CSRF Token；当前依赖 SameSite=Lax 与同源调用，跨域/高安全部署需补充。

478. **限流**：登录限流为单进程内存滑动窗口，多进程部署需 Redis 等共享存储。

479. **文档体**：文档写接口接收 JSON 正文，不提供 multipart 文件上传端点。

480. **删除**：分类、用户、图谱节点/边没有删除 API；文档删除会联动清理图谱。

481. **分页**：仅文档列表和审计列表分页；收藏、分类、用户、问答历史、图谱管理列表使用固定上限或全量返回。\n8. **收藏状态**：收藏切换和收藏列表按 can_view_document() 密级判定过滤，当前未额外检查 status；若产品要求收藏列表只含已发布文档，应补充状态条件与测试。

16.2 变更维护规则

- 修改 app/api.py 的字段或状态码时，必须同步更新本文第 5～13 章和前端 frontend/src/api/client.js 的调用；
- 修改数据库字段时，必须同步更新 app/models.py、docs/uml/07-ER 图.puml 并重新渲染；
- 修改权限规则时，必须同步更新 docs/03-系统需求说明书.md 与安全测试；
- 新增 API 时，应补充端点总览、请求/响应字段、权限、错误码和测试追踪；
- 提交前建议执行：
- .\run_tests.ps1
- .\.venv\Scripts\python.exe -m ruff check app tests
- 手工验证“登录 → 文档检索 → 问答 → 图谱 → 审计”主路径。

文档结束 • 2026-10-31 • V2.0